MÓDULO 6. ANÁLISIS DE COMPORTAMIENTO Y METODOLOGÍAS OSINT – UNIDAD 1

MÁSTER EN *ANÁLISIS DE MALWARE Y REVERSING*



Campus Internacional CIBERSEGURIDAD
ENIIT INNOVA IT BUSINESS SCHOOL
UCAM UNIVERSIDAD CATÓLICA DE MURCIA

Título: Análisis de comportamientos y metodologías OSINT
Autor: Iván Portillo

Idioma: Español
Edición: 2026



Este trabajo está sujeto bajo la licencia **Reconocimiento-No Comercial- Compartir Igual 4.0 Internacional** (CC-BY-NC-ND 4.0) de Creative Commons:

https://creativecommons.org/licenses/by-nc-nd/4.0/

Usted es libre de:

- Compartir - copiar y redistribuir el material en cualquier medio o formato.

El licenciante no puede revocar estas libertades siempre y cuando usted siga los términos de la licencia.



Atribución —Debe reconocer adecuadamente la autoría, proporcionar un enlace a la licencia e indicar si se han realizado cambios. Puede hacerlo de cualquier manera razonable, pero no de una manera que sugiera que tiene el apoyo del licenciador o lo recibe por el uso que hace.



NoComercial —Usted no puede hacer uso del material con fines comerciales.



NoDerivados — Si remezcla, transforma o crea a partir del material, no puede distribuir el material modificado.

Sobre el autor

Iván Portillo es responsable de Inteligencia en Vodafone Business.

Coordinador de uno de los grupos de trabajo del foro contra las Campañas de Desinformación del Departamento de Seguridad Nacional (DSN).

Además, es docente tutor en el presente Máster y en el Máster en Ciberinteligencia del Campus Internacional de Ciberseguridad, docente titular en el Máster en Análisis de la Inteligencia y Ciberinteligencia y en el grado de Ciberdelincuencia y Ciencias Forenses de la Universidad Nebrija y docente en el Máster de Ciberseguridad y Seguridad de la Información de la UCLM. Dentro de su educación destaca el título de Graduado en Sistemas de Información por la UAH, adicionalmente cuenta con un postgrado en Análisis de Inteligencia y otro postgrado en Seguridad Informática.

Acumula más de 14 años de experiencia en proyectos sobre ciberseguridad, estando especializado en el análisis de amenazas (Cyber Threat Intelligence) desde una perspectiva táctica/operativa y en la generación de Inteligencia obtenida a través de procesos de crawling, análisis y correlación de datos masivos. Cuenta con un perfil multidisciplinar con conocimientos sobre análisis forense, análisis de datos, lenguajes de programación e Inteligencia.

Ponente habitual en congresos de ciberseguridad como Jornadas STIC del CCN-CERT, SANS Cyber Threat Intelligence Summit, RootedCON, C1b3rWall, Cybersecurity Summer Bootcamp de INCIBE, IntelCon, Hc0n, etc.

ivanportillomorales

@ivanPorMor

ivan.portillo@protonmail.com

@p0rt7

MÓDULO 6. ANÁLISIS DE COMPORTAMIENTO Y METODOLOGÍAS OSINT 1

1. TÉCNICAS DE INVESTIGACIÓN EN FUENTES ABIERTAS 6

1.1. KIT DE HERRAMIENTAS 6

1.1.1. REGISTRO REGIONAL DE INTERNET 6
1.1.2. HUNTER 8
1.1.3. HAVEIBEENPWNED 12
1.1.4. DEHASHED 14
1.1.5. PASTEBIN 15
1.1.6. VIRUSTOTAL 16
1.1.7. HYBRID ANALYSIS 21
1.1.8. ANY RUN 23
1.1.9. THREATMINER 26
1.1.10. ALIENVAULT OTX 28
1.1.11. WHOIS 31
1.1.12. HACKER TARGET 36
1.1.13. FEODO TRACKER 38
1.1.14. IP BLACKLIST CHECK 41
1.1.15. BLACKLIST - MXTOOLBOX 42
1.1.16. ABUSEIPDB 43
1.1.17. WEBMII 44
1.1.18. INTELLIGENCEX 46
1.1.19. THEHARVESTER 48
1.1.20. CROSSLINKED 49
1.1.21. MALTEGO 51
1.1.22. INSTALOADER 57
1.1.23. NAMECHK 59
1.1.24. OSRFRAMEWORK 60
1.1.25. 67
1.1.26. SOCIAL SEARCHER 67
1.1.27. SOCIAL BEARING 69
1.1.28. EMAIL PERMUTATOR 73

1.2. PROCEDIMIENTO DE INVESTIGACIÓN DE NOMBRES DE USUARIO 74

1.3. PROCEDIMIENTO DE INVESTIGACIÓN DE NOMBRES DE PERSONAS 76

1.4. PROCEDIMIENTO DE INVESTIGACIÓN DE DOMINIOS 79

1.5. PROCEDIMIENTO DE INVESTIGACIÓN DE CORREOS ELECTRÓNICOS 83

1.6. PROCEDIMIENTO DE INVESTIGACIÓN DE DIRECCIONES IP 86

2. TÉCNICAS DE INVESTIGACIÓN EN TOR PARTIENDO DE FUENTES ABIERTAS 90

2.1. BUSCADORES DE HIDDEN SERVICES DE TOR EN FUENTES ABIERTAS 90

2.1.1. DANIEL HOSTING 90
2.1.2. AHMIA 94
2.1.3. ONIONLAND 99
2.1.4. DARKFEED 101
2.1.5. STEALTHMOLE 103

2.2. BUSCADORES DE HIDDEN SERVICES DENTRO DE TOR 108

2.2.1. THE HIDDEN WIKI 108
2.2.2. TORCH 109
2.2.3. DEEP SEARCH 111
2.2.4. THE DEEP SEARCHES 113

3. INTRODUCCIÓN AL CYBER THREAT INTELLIGENCE (CTI) 116
3.1. INDICADORES DE COMPROMISO 125
3.2. ACTORES DE AMENAZA 127
3.3. TÁCTICAS, TÉCNICAS Y PROCEDIMIENTOS 132
3.4. LA PIRÁMIDE DEL DOLOR 137
3.5. MODELANDO LA AMENAZA MEDIANTE STIX 143
3.6. PLATAFORMAS DE THREAT INTELLIGENCE 152
3.6.1. MISP 153
3.6.2. INSTALACIÓN DE MISP 156
3.6.3. CONFIGURACIÓN MISP 158
4. CASO PRÁCTICO DE INVESTIGACIÓN DE UNA AMENAZA 165
4.1. INVESTIGACIÓN DEL GRUPO CRIMINAL SILVERTERRIER 165
4.1.1. OPERACIONES DE SILVERTERRIER 166
4.1.2. INDICADORES DE COMPROMISO ASOCIADOS 170
4.1.3. MALWARE ASOCIADO 171
4.1.4. TTPs ASOCIADOS 171
4.1.5. INVESTIGACIÓN DE LAS DIRECCIONES IP DETECTADAS 172
4.1.6. INVESTIGACIÓN DE LOS DOMINIOS DETECTADOS 177
5. BIBLIOGRAFÍA 198
6. VIDEOS SOBRE LA MATERIA 201

1. TÉCNICAS DE INVESTIGACIÓN EN FUENTES ABIERTAS

La labor del analista va más allá de la mera ejecución de diversas herramientas, sino entender el motivo por el cual utilizamos una u otra herramienta en determinadas circunstancias u operaciones a la que nos enfrentemos. En este punto gana importancia el método y el procedimiento para obtener información más que ejecutar una serie de herramientas sin ningún tipo de control. A lo largo de este tema se va a presentar un inventario de herramientas útiles para generar Inteligencia por medio de las fuentes abiertas, entender los resultados de cada una de ellas y sobre todo a tener un procedimiento para saber que guía seguir ante una investigación sobre un dominio, dirección IP , nombre de persona, correo electrónico o nombre de usuario.

1.1. KIT DE HERRAMIENTAS

En este subapartado se presentan una serie de herramientas útiles para una investigación sobre amenazas utilizando herramientas que obtengan los datos de las fuentes abiertas.

1.1.1. REGISTRO REGIONAL DE INTERNET

El **Registro Regional de Internet (RIR**) es el encargado de supervisar y registrar los recursos de Internet**,** permitiendo identificar los rangos de IP (IPv4 y IPv6) y Números de Sistemas Autónomos (ASN) asignados a una determinada región geográfica. Existen 5 regiones divididos a nivel mundial, los cuales pueden verse distribuidos geográficamente en la Imagen 1.



Imagen 1. RIR divididos por regiones geográficas

A continuación, se enumeran las 5 regiones:

- RIPE. Es el RIR encargado de asignar las direcciones IP a las regiones de Europa, Oriente Medio y Asia Central. Desde su página oficial se dispone de un recurso web que permite consultar información sobre cualquier registro. Dicho recurso es el siguiente: RIPE Database Query (https://apps.db.ripe.net/db-web-ui/query).

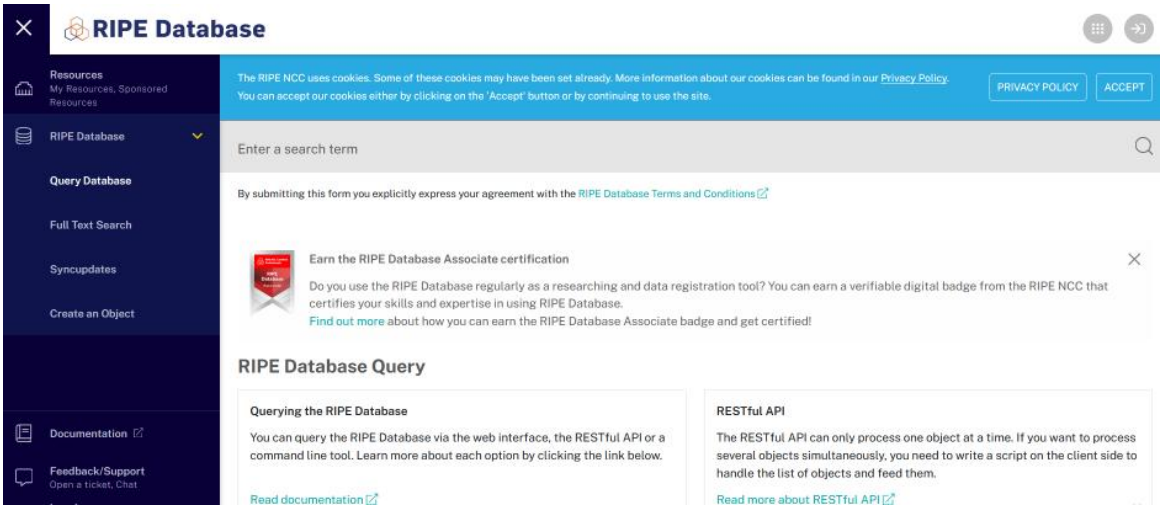


Imagen 2. Sitio oficial de RIPE Database Query

Entre los datos que recopila tenemos: rango IP, nombre del registrador, descripción del registrador, país, administrador, registrador técnico, estado, fecha de creación, fecha de modificación. Proporcionan toda la fuente de datos en abierto con actualizaciones constantes en el siguiente enlace: https://ftp.ripe.net/ripe/dbase/ripe.db.gz.

- AFRINIC. Es el RIR encargado de asignar las direcciones IP para el continente africano. Proporcionan toda la fuente de datos en abierto con actualizaciones constantes en el siguiente enlace: https://ftp.afrinic.net/pub/dbase/afrinic.db.gz.

- ARIN. Es el RIR encargado de asignar las direcciones IP a las regiones de Norteamérica, Canadá, Estados Unidos y parte del Caribe. Proporcionan toda la fuente de datos en abierto con actualizaciones constantes en el siguiente enlace: https://ftp.arin.net/pub/rr/arin.db.gz.

- LACNIC. Es el RIR encargado de asignar las direcciones IP a las regiones de Latinoamérica y la parte del Caribe que no cubre ARIN. Proporcionan toda la fuente de datos en abierto con actualizaciones constantes en el siguiente enlace: https://ftp.lacnic.net/pub/stats/lacnic/delegated-lacnic-extended-latest.

- APNIC. Es el RIR encargado de asignar las direcciones IP a las regiones de Asia y la costa del Pacífico. Proporcionan toda la fuente de datos en abierto con actualizaciones constantes en el siguiente enlace: https://ftp.apnic.net/apnic/whois/.

1.1.2. HUNTER

Hunter es un servicio online que nos permite obtener información sobre correos electrónicos. La herramienta es de pago pero permite disponer de una cuenta gratuita más limitada, logueandose con credenciales de Google. El enlace de acceso a dicho servicio es el siguiente: https://hunter.io.

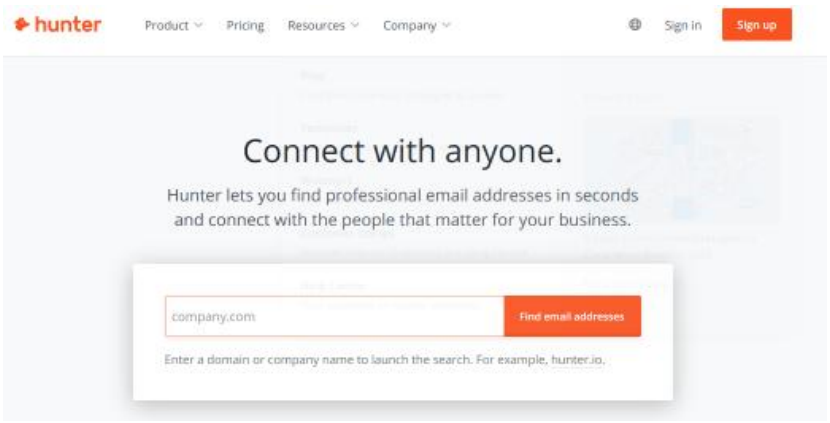


Imagen 3. Sitio principal de hunter

Hunter dispone de una serie de herramientas que permiten obtener información a partir de un dato concreto, por ejemplo, un dominio, un nombre de persona o correo electrónico. Las herramientas mencionadas son las siguientes:

- **Domain Search**. Mediante esta herramienta es posible detectar correos electrónicos y nombres de personas, entre otros datos (ver Imagen 4), a partir de un dominio dado.

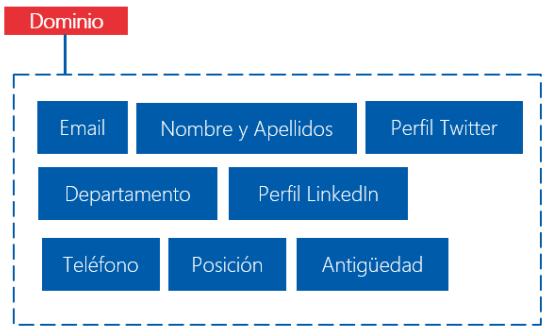


Imagen 4. Ejemplo de datos recolectados por Hunter a partir de un dominio

En este caso vamos a realizar una búsqueda de un objetivo para detectar correos electrónicos asociados. En la Imagen 5 se puede comprobar el resultado de nuestra búsqueda, recibiendo un listado de correos electrónicos, nombres de

persona y perfil social asociados, junto con la fiabilidad de coincidencia de que dicho correo puede ser verídico o no. Por otro lado, en la parte de la derecha podemos observar el presunto formato que puede estar utilizando el servidor de correo del objetivo para crear cada uno de los correos electrónicos.

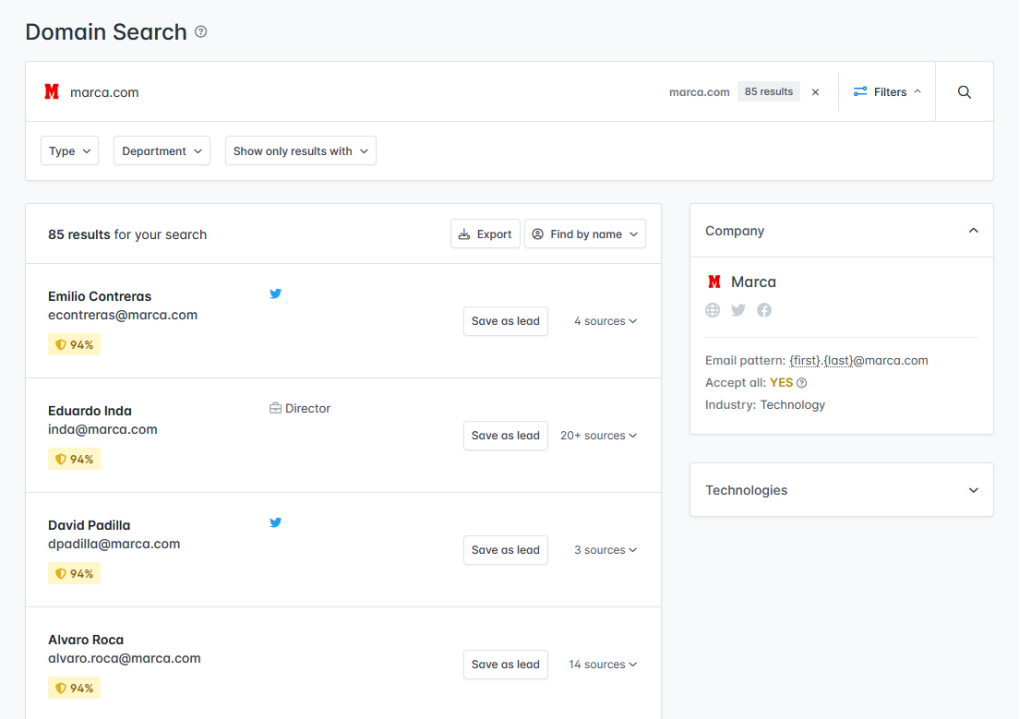


Imagen 5. Resultados generados por Domain Search de Hunter

Si hacemos zoom al primer resultado podemos ver las fuentes donde Hunter lo ha encontrado junto con la fecha asociada (ver Imagen 6).

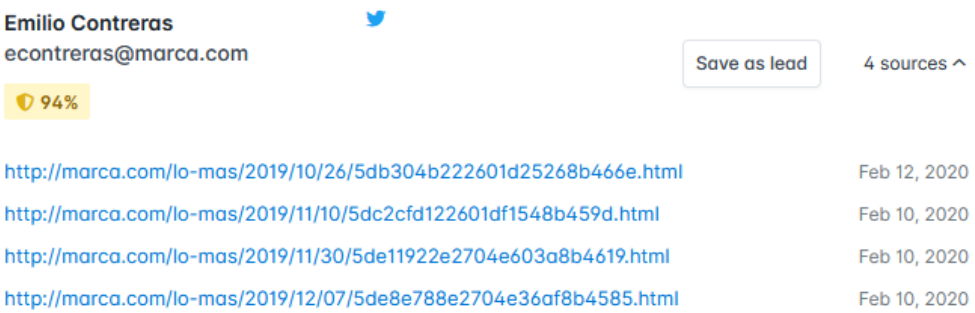


Imagen 6. Resultado individual con Domain Search

- **Email Finder**. Mediante esta herramienta es posible buscar un correo electrónico partiendo del nombre de la persona y de un dominio dado. En la Imagen 7 se puede observar cómo partiendo de un nombre de persona junto con el dominio se puede detectar el correo asociado, además de las fuentes donde lo ha localizado.

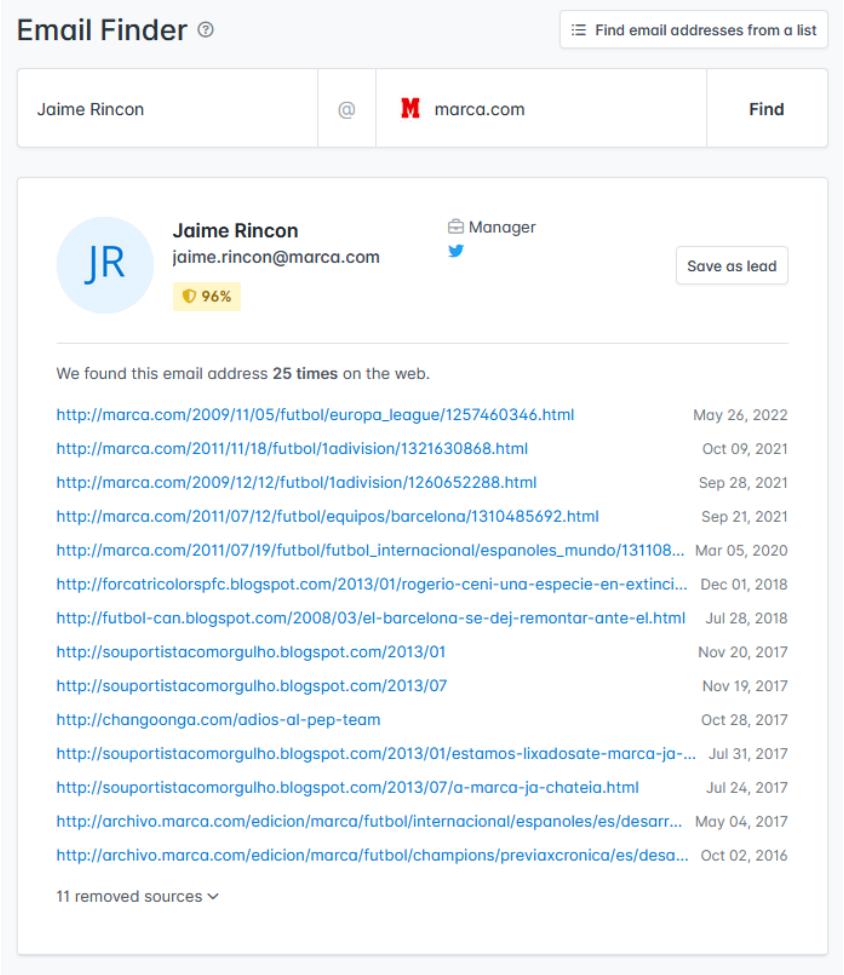


Imagen 7. Resultados de Email Finder de Hunter

- **Email Verifier**. Mediante esta herramienta es posible verificar si un correo electrónico existe dentro del dominio asociado. En la Imagen 8 se puede observar el resultado de esta herramienta partiendo de un correo electrónico dado, indicando las fuentes donde lo ha localizado y realizando una serie de

comprobaciones por medio del formato, el estado del servidor de correo, estado del correo y el tipo.

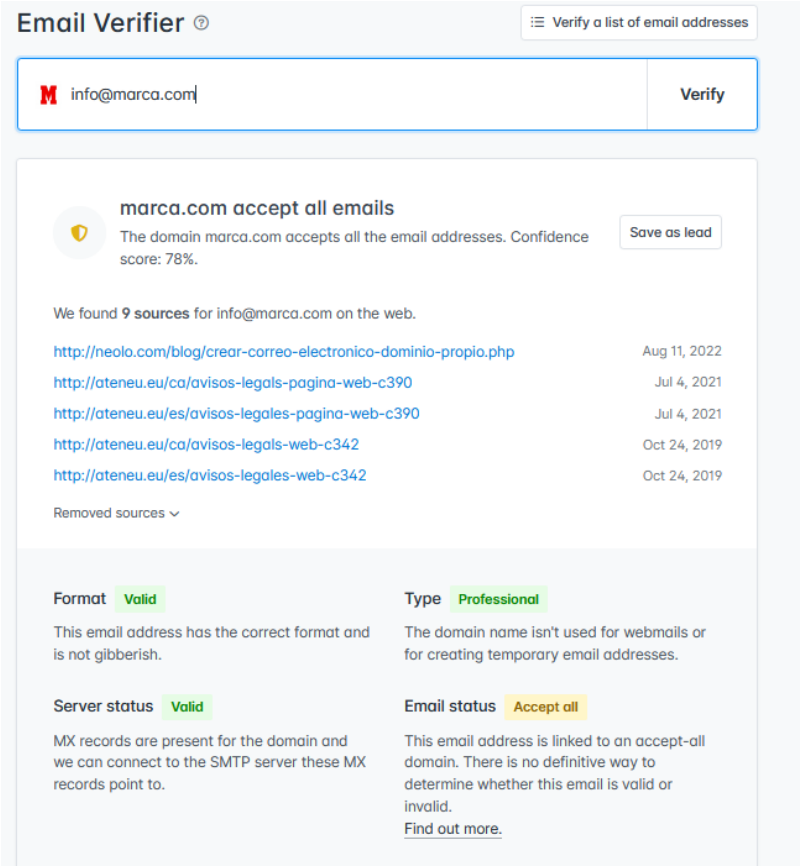


Imagen 8. Resultado de Email Verifier de Hunter

1.1.3. HAVEIBEENPWNED

HaveIbeenPwned es una herramienta web que permite comprobar si un email o un número de teléfono se encuentra presente en alguna fuga de información. La herramienta dispone actualmente con un total de 663 sitios web comprometidos y más de 12.484 millones de cuentas recopiladas (ver Imagen 9). El enlace de acceso a dicho servicio es el siguiente: https://haveibeenpwned.com.

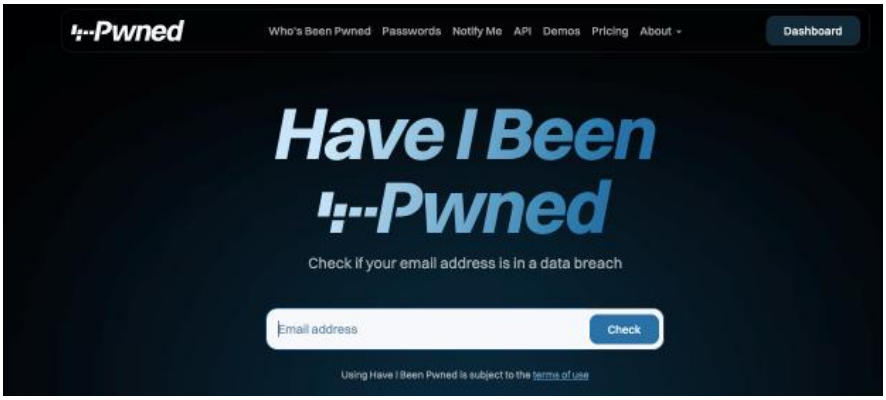


Imagen 9. Sitio web de HaveIbeenPwned

Si realizamos una búsqueda de un correo electrónico o un número de teléfono nos indicara si está presente en alguna fuga de información o no. En el caso de que exista una coincidencia podrá conocerse en que Data Leak se ha producido, descripción de la fuga y que tipo de datos se han filtrado (ver Imagen 10).

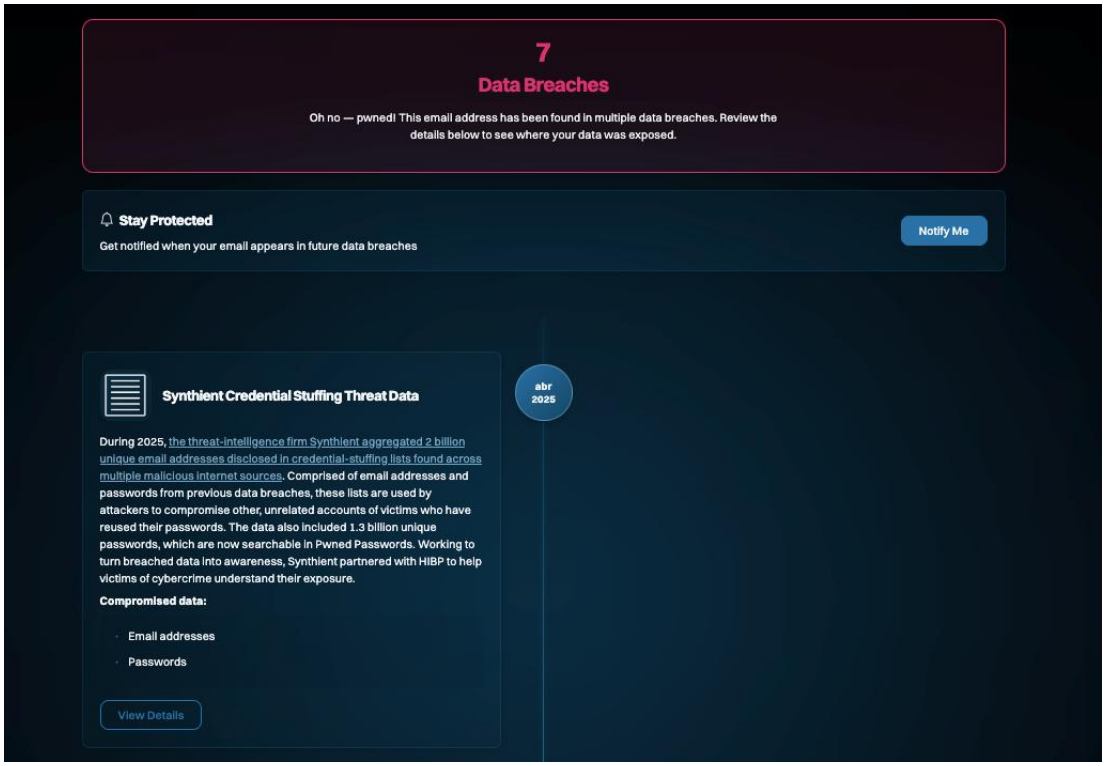


Imagen 10. Resultados de HaveIbeenPwned

Además, HaveIbeenPwned cuenta con una sección con información sobre todos los Data Leaks que se han producido. El enlace del recurso es el siguiente: https://haveibeenpwned.com/PwnedWebsites.

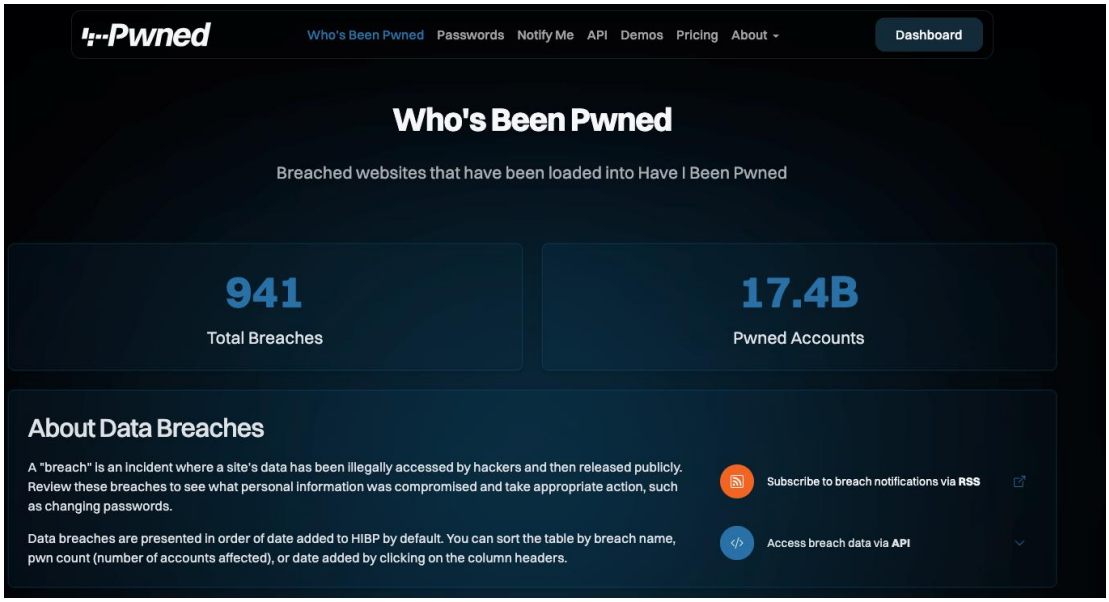


Imagen 11. Listado de Data Leaks filtrados

1.1.4. DEHASHED

Dehashed es un servicio que nos permite obtener información sobre fugas de información a partir de un dominio, username, correo electrónico, dirección IP, número de teléfono y dirección postal como punto de partida. En la Imagen 12 puede verse el sitio web de Dehashed, junto con el número total de activos comprometidos: *14.453 millones de registros*. El enlace de acceso es el siguiente: https://dehashed.com.

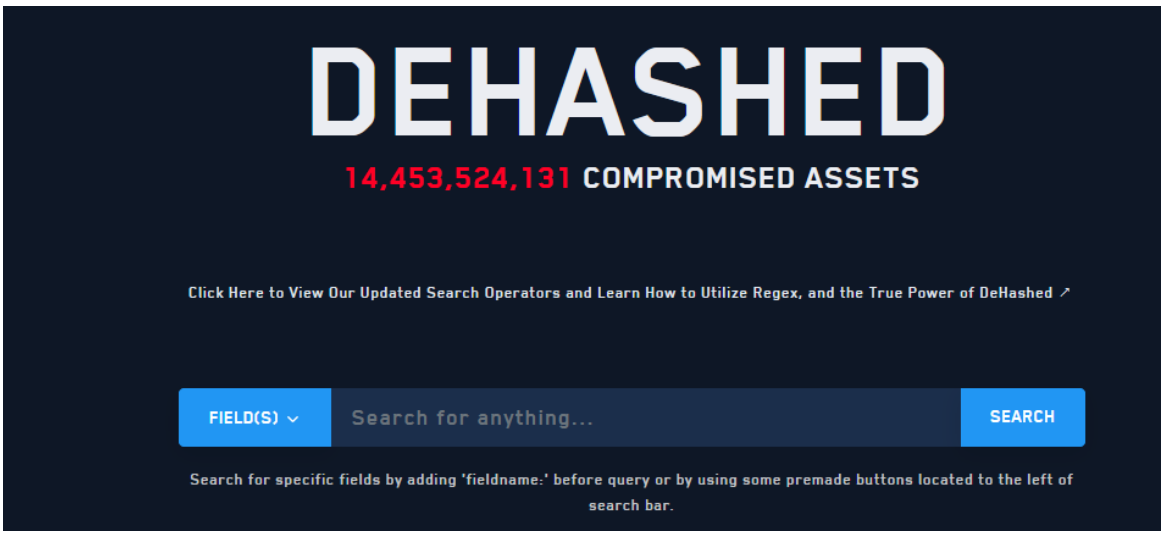


Imagen 12. Sitio web oficial de Dehashed

Es un servicio algo diferente a HaveIbeenPwned, ya que ofrece información de todos los datos de un objetivo que hayan sido filtrados en cada Data Leaks en donde esté presente. Dehashed se trata de un servicio de pago, pero que permite loguearse con una cuenta gratuita y realizar búsquedas en su plataforma. En la Imagen 13 se realiza una búsqueda del dominio de Microsoft, obteniéndose que hay *565.150 resultados* en total. En la parte inferior de la propia imagen, disponemos de diferentes bloques donde aparece información relativa a cada colección de Data Leak detectada y asociada a nuestro objetivo. En el caso de que dispongamos de una cuenta gratuita, veremos exactamente lo mismo que en la Imagen 13 pero no podremos acceder a cada bloque con la información.

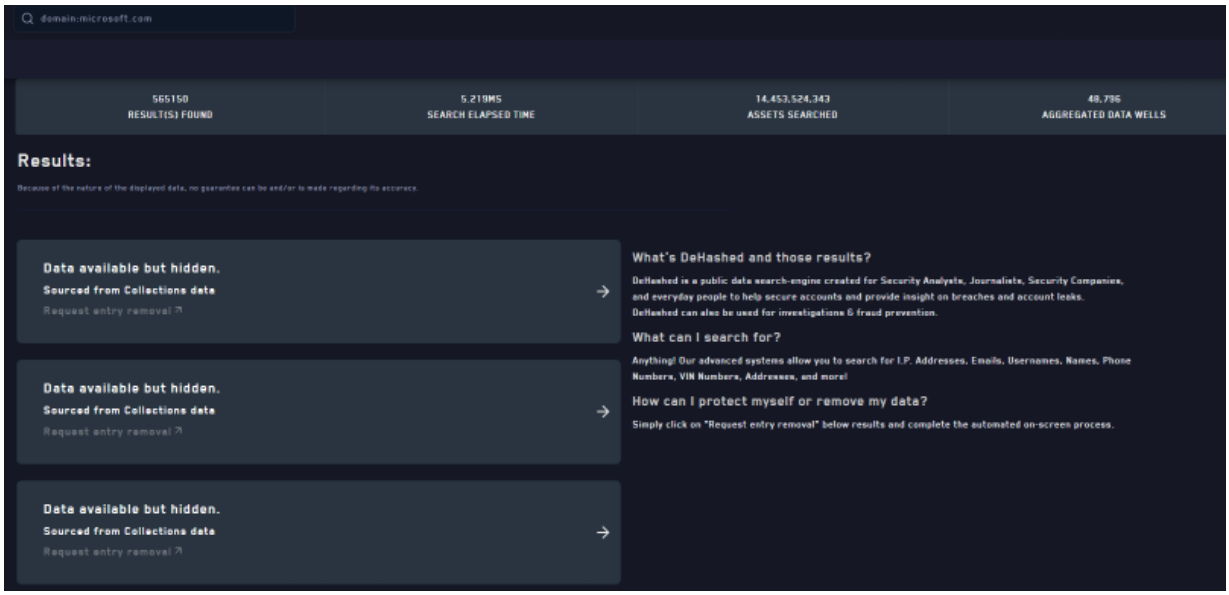


Imagen 13. Resultados de búsqueda con Dehashed

1.1.5. PASTEBIN

Pastebin es un sitio web que permite compartir fácilmente cualquier tipo de mensaje de texto de manera anónima. Actualmente es utilizado para filtrar información de cualquier tipo de dato, los más frecuentes la difusión de pastes sobre Data Leaks o sobre operaciones relacionados con temas de Hacktivismo. La información que es difundida por esta plataforma es bastante volátil, ya que en muchos casos los pastes duran minutos.

En la Imagen 14 pueden verse los últimos pastes publicados en Pastebin.

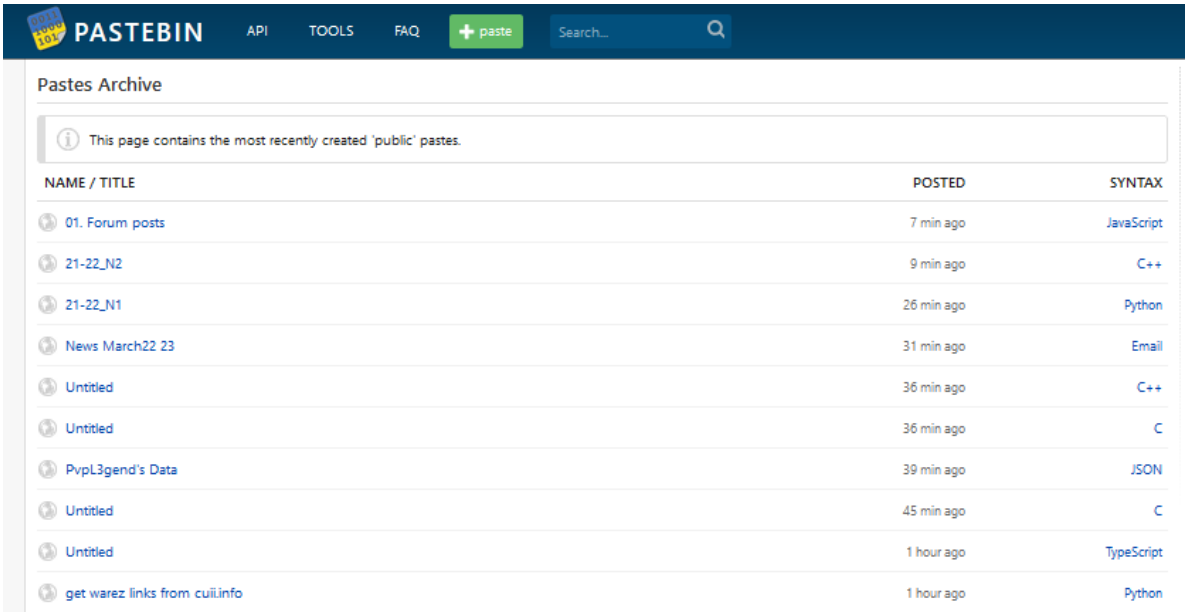


Imagen 14. Sitio web de Pastebin

Jorge Coronado en el blog de Quantika14 escribió un artículo donde explicaba como scrapear y como ir descargando los últimos pastes publicados mediante Python. El script utilizado puede encontrarse en la siguiente ruta: https://github.com/JWScr33d/crawler-downloader-pastebin.

A continuación, se facilitan los enlaces a la herramienta online:

- Buscador de Pastebin: https://pastebin.com/search?q=keyword
- Últimos pastes subidos a Pastebin: https://pastebin.com/archive.

1.1.6. VIRUSTOTAL

VirusTotal es ampliamente conocido por poseer uno de los repositorios de malware más grandes del mundo y ser una de las herramientas de Threat Intelligence más importantes. VirusTotal tiene un módulo de Inteligencia (de pago) en el que cuenta con una comunidad donde consultar cualquier tipo de dato a analizar a modo fuente. A través de esta comunidad de Inteligencia es posible realizar operaciones añadidas con respecto a la versión gratuita, siendo las siguientes:

- Búsqueda de cualquier patrón coincidente con la keyword introducida. En la Imagen 15 puede verse un extracto de 157 resultados de ficheros coincidentes con una palabra clave en particular.
- Descarga de muestras de cualquier tipo de archivo (EXE, APK, DEX, HTML, PDF, PPT, etc).
- Previsualización del contenido del fichero.
- Visualización de los strings asociados al fichero.
- Estadísticas sobre cuando fue subida la muestra o realizado el análisis.

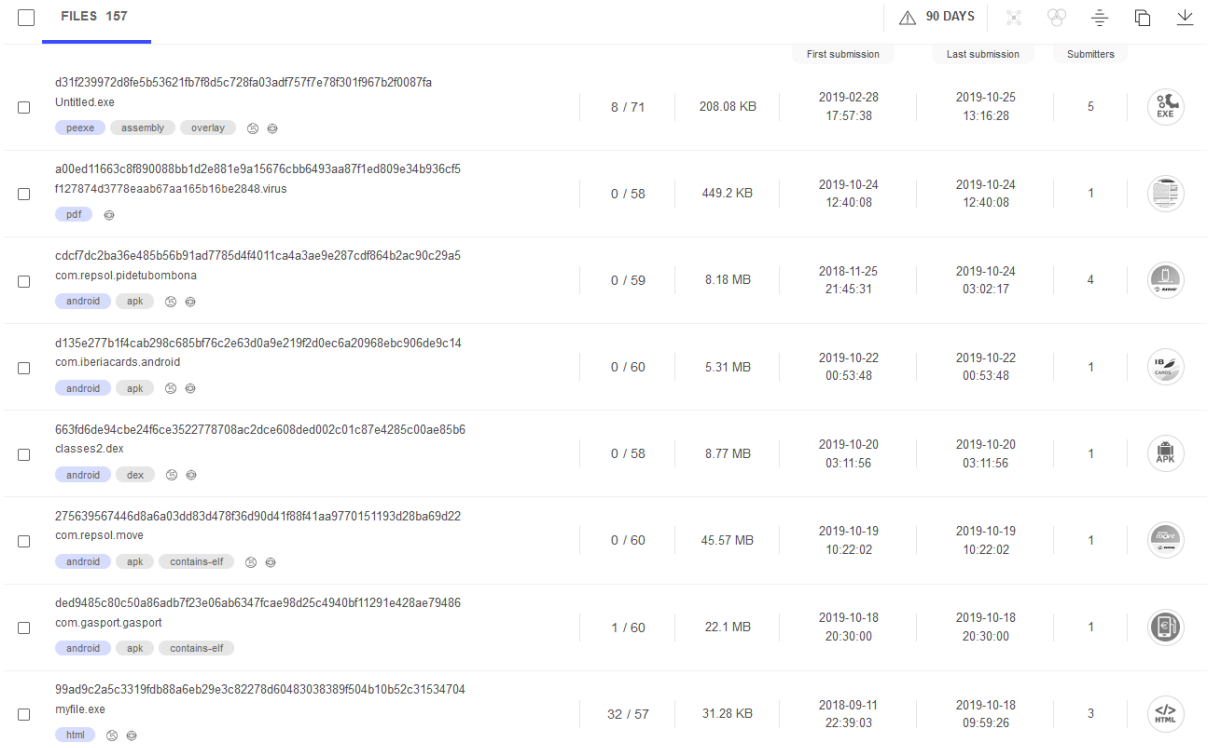


Imagen 15. Resultados de la búsqueda por keyword en VT Intelligence

Acabamos de descubrir lo que ofrece VirusTotal como fuente, pero es posible obtener diferentes tipos de datos más allá del malware. En la Imagen 16 puede verse un diagrama de cómo utilizar VirusTotal para buscar información sobre un dominio. A partir de dicho dominio es posible recopilar datos como la reputación web, el score de seguridad, la dirección IP, subdominios y certificados asociados, URL relacionadas con malware o

muestras representadas mediante un hash. Además, es posible seguir recopilando más datos mediante el descubrimiento de la dirección IP detectada anteriormente, consiguiendo datos como por ejemplo: dominios que resuelvan a la misma dirección IP, ASN, país donde fue registrada la IP, Rango IP, URL relacionadas con malware, muestras de malware (representadas mediante un hash) que evidencien una comunicación con la dirección IP.

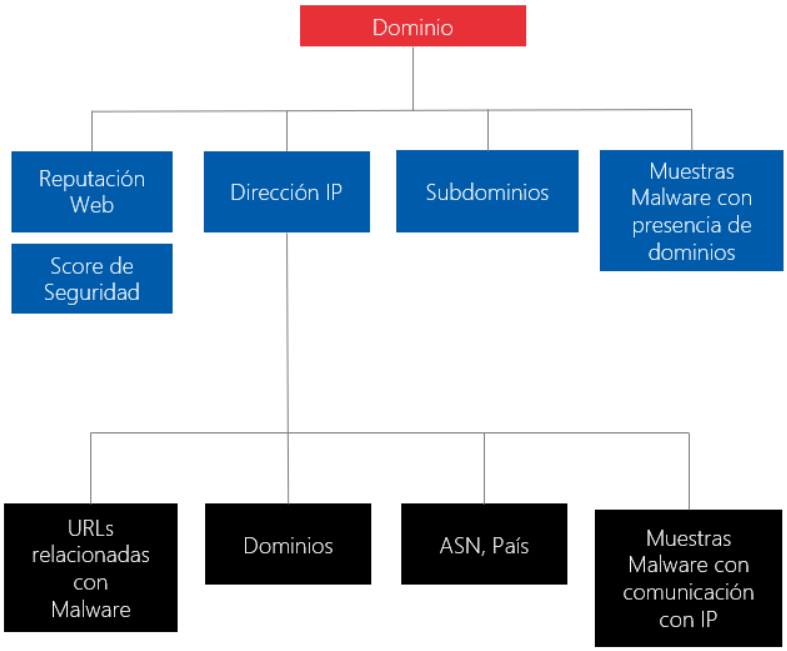


Imagen 16. Datos que pueden ser obtenidos por VT

Con VirusTotal es posible realizar búsquedas sobre un dominio, dirección IP, Hash o URL mediante la cuenta gratuita. Además, permite subir ficheros para ser analizados en busca de malware. Con esto último, hay que tener mucho cuidado y no compartir ficheros confidenciales porque dentro de la base de datos de conocimiento de la que dispone VirusTotal es posible obtener los metadatos, descargar o visualizar el propio documento.

En la Imagen 17 puede verse un ejemplo de los resultados generados por VirusTotal al realizar una búsqueda por un dominio.

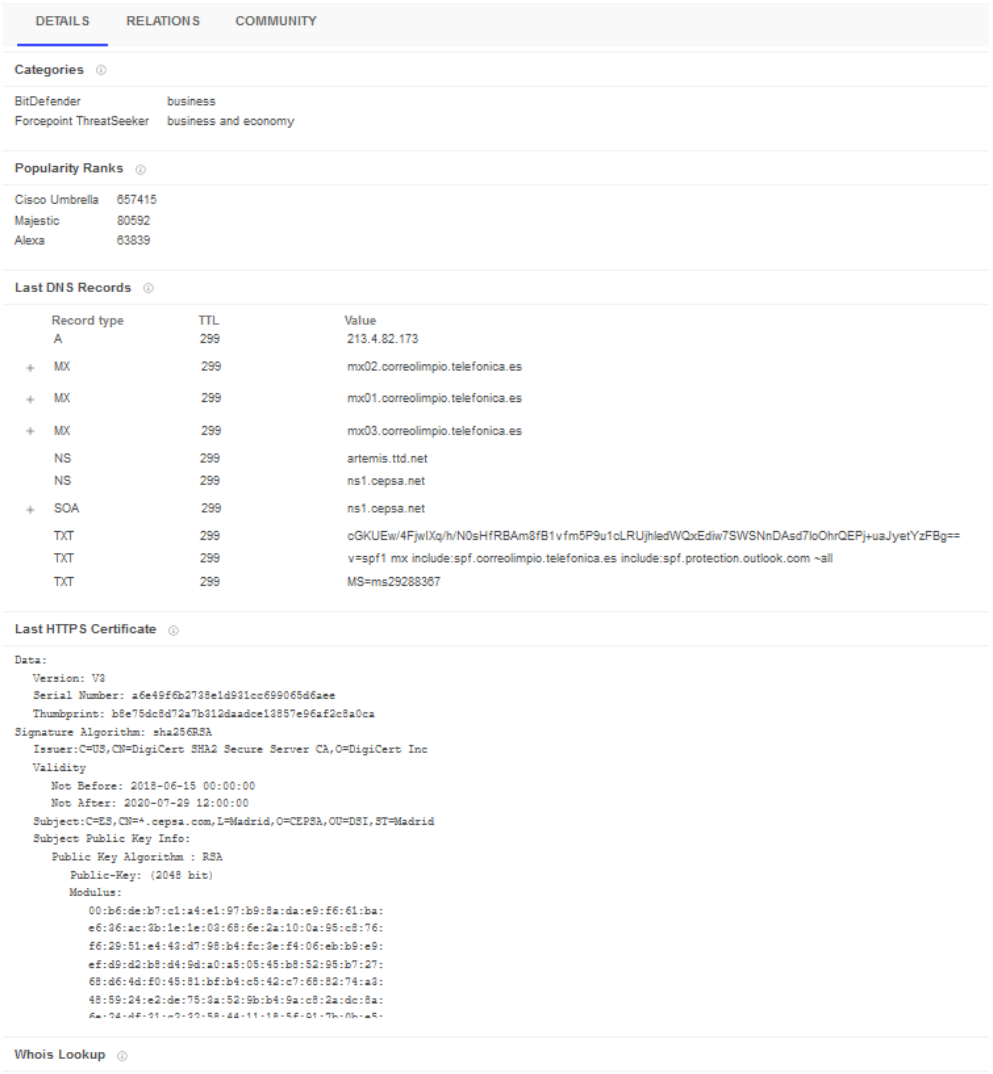


Imagen 17. Ejemplo de resultados de VT al buscar un dominio

En la Imagen 18 ha sido utilizado el módulo Graph de VirusTotal para sacar de manera visual todas las relaciones que puede tener asociado un dominio buscado.

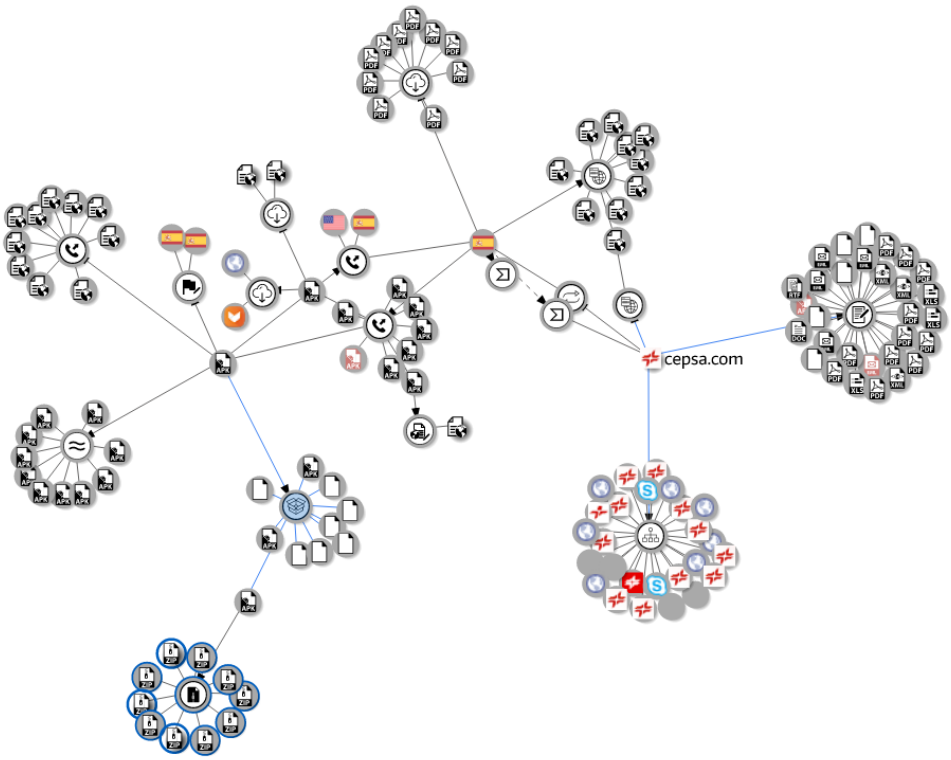


Imagen 18. Analizando un dominio con VT Graph

A continuación, se facilitan los enlaces a la herramienta online:

- Buscador de VT: https://www.virustotal.com/gui/home/search.
- Documentación de la API: https://developers.virustotal.com/reference
- Módulo VT Hunting (únicamente con subscripción de pago): https://www.virustotal.com/gui/hunting
- Modulo VT Graph: https://www.virustotal.com/graph/

1.1.7. HYBRID ANALYSIS

Hybrid Analysis es una herramienta gratuita online enfocada al análisis de Malware. En el año 2017 fue comprada por CrowdStrike[1], lo que le permite contar con una base de conocimiento sobre amenazas bastante grande. Las funcionalidades con las que cuenta Hybrid Analysis son las que pueden visualizarse en el menú de la Imagen 19. Permite subir uno o varios ficheros para su análisis, dispone de un buscador donde realizar consultas sobre dominios, direcciones IP, hashes o URLs para ver si tienen relación con algún tipo de malware. Además, permite realizar búsquedas mediante reglas YARA o strings en hexadecimal / ASCII.

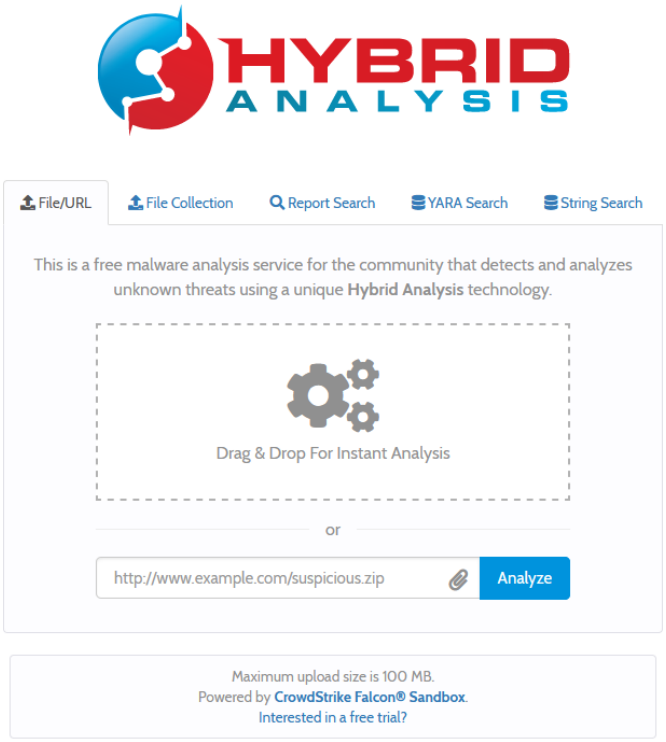


Imagen 19. Sitio web de Hybrid Analysis

En la Imagen 20 puede verse un ejemplo de reglas YARA que pueden ser definidas con Hybrid Analysis, siendo en este caso reglas relacionadas con el grupo Lazarus.

[1] CrowdStrike es una de las protecciones para Endpoint más importantes del mercado, el cual integra antivirus, detección y respuesta junto a Threat Hunting. Contiene una de las bases de datos sobre TTP y amenazas bastante importantes.

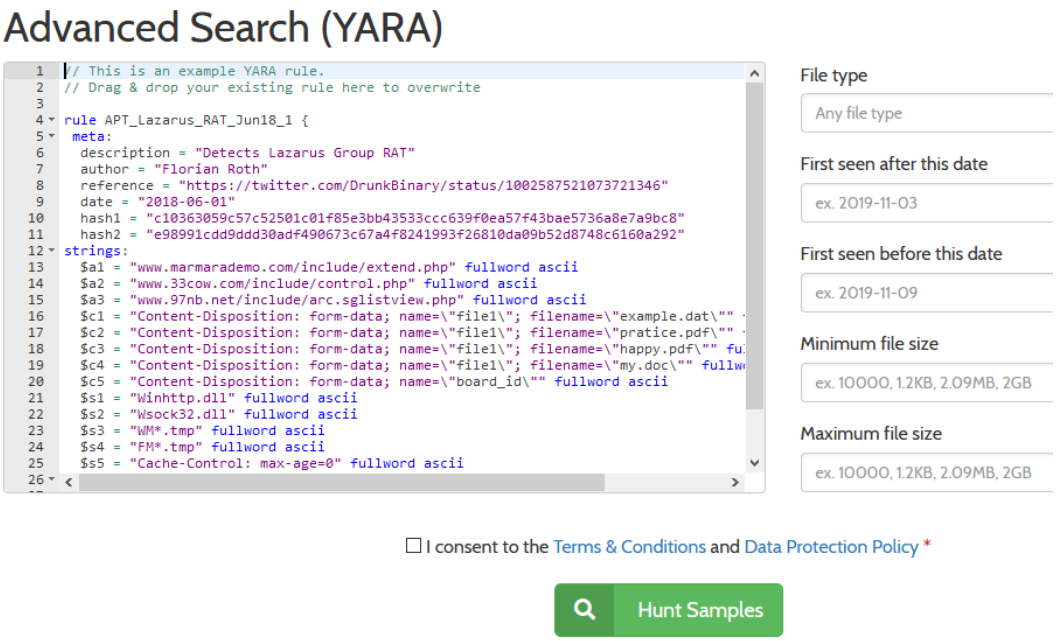


Imagen 20. Definición de reglas YARA en Hybrid Analysis

En la Imagen 21 pueden verse los resultados generados por la regla YARA definida en la Imagen 138.

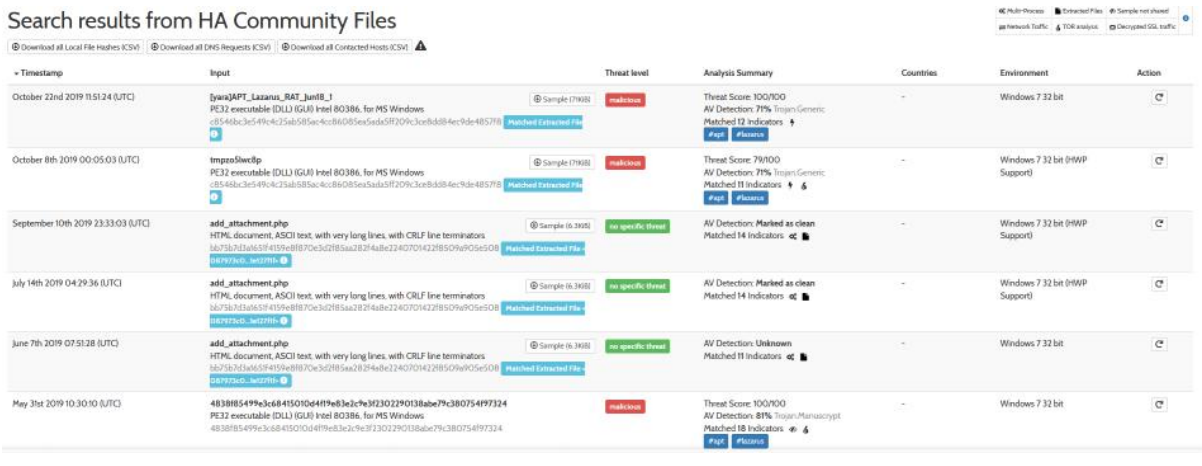


Imagen 21. Resultados generados por la definición de las reglas YARA de la Imagen 20

A continuación, se facilitan los enlaces a la herramienta online:

- Sitio Oficial de Hybrid Analysis: https://hybrid-analysis.com/.
- Buscador con reglas YARA: https://hybrid-analysis.com/yara-search.

- Colección de últimas muestras analizadas: https://hybrid-analysis.com/file-collections.
- Últimas URL enviadas al Sandbox: https://hybrid-analysis.com/submissions/sandbox/urls.
- Últimos ficheros enviados: https://hybrid-analysis.com/submissions/sandbox/files.
- Documentación de la API: https://hybrid-analysis.com/docs/api/v2.

1.1.8. ANY RUN

ANY RUN es una herramienta para analizar muestras de malware mediante análisis dinámico. Dispone de una versión gratuita que permite subir una muestra, elegir el sistema operativo donde cargar esta, detectar que procesos son ejecutados y descubrir que conexiones entrantes/salientes son establecidas.

En la versión gratuita es posible interactuar con el sistema operativo donde se haya subido la muestra durante 60 segundos más otros 4 minutos adicionales y el tamaño máximo permitido para la muestra es de 16 MB. La versión gratuita no permite interactuar con la API pero en la versión de pago si, incluso exportar los resultados en JSON y en formato legible para MISP.

A continuación, se facilitan los enlaces a la herramienta online:

- Sitio Oficial de ANY RUN: https://any.run.
- Herramienta ANY RUN (Ver imagen 22): https://app.any.run/.
- Últimas muestras públicas enviadas (Ver Imagen 23): https://app.any.run/submissions.
- Documentación de la API: https://any.run/api-documentation/.



Imagen 22. Sitio oficial de ANY RUN



Imagen 23. Últimas muestras públicas enviadas

En la Imagen 24 puede verse un ejemplo de una muestra analizada. En la parte central puede visualizarse un video mostrando cómo se comporta el sistema una vez se ha ejecutado la muestra. En la parte inferior pueden apreciarse las peticiones HTTP, conexiones establecidas, peticiones DNS y amenazas detectadas dentro de la muestra. En la parte derecha se ven todos los procesos ejecutados.

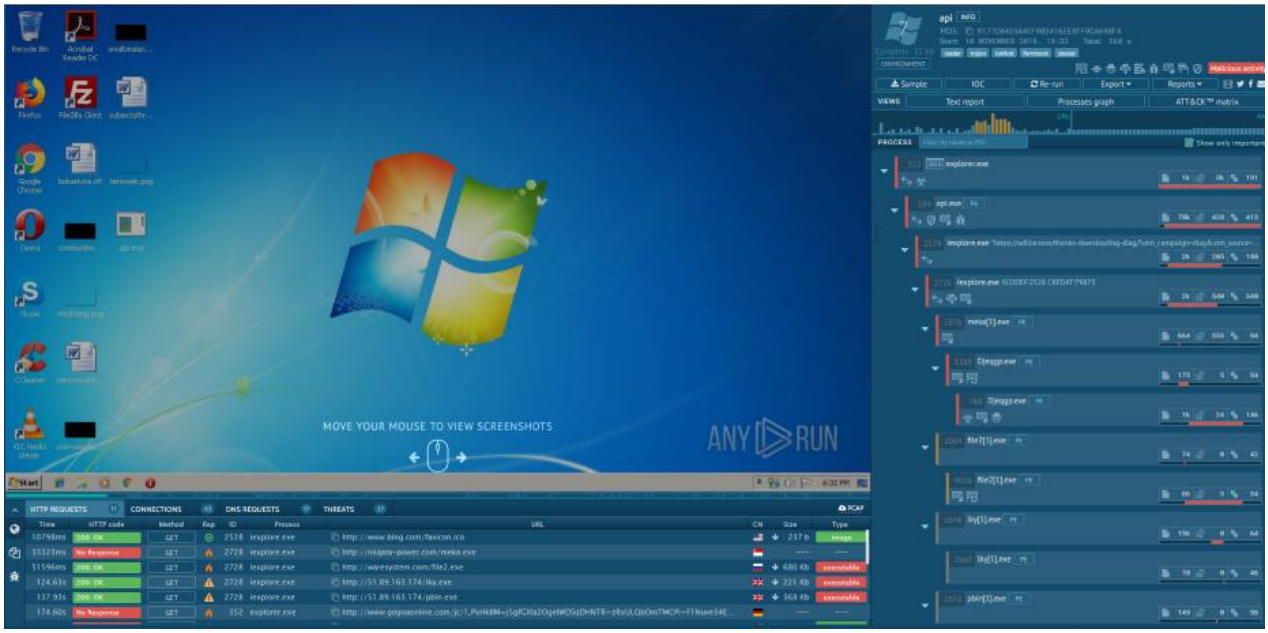


Imagen 24. Ejecución de una muestra de malware

Si accedemos a la opción de ATT&CK podremos ver los TTPs obtenidos de MITRE y que están relacionados con la muestra (ver Imagen 25). En el caso de que accedamos a la opción IOC, podremos ver un listado de IoC detectados en la muestra (ver Imagen 26).

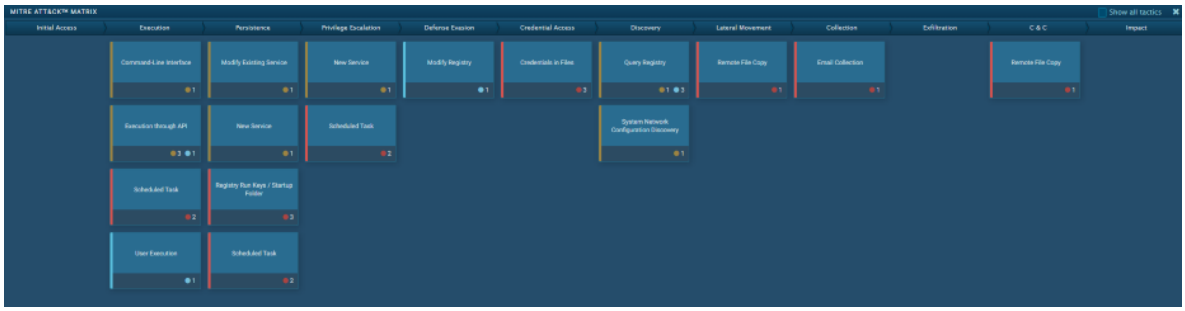


Imagen 25. TTPs relacionados con la muestra

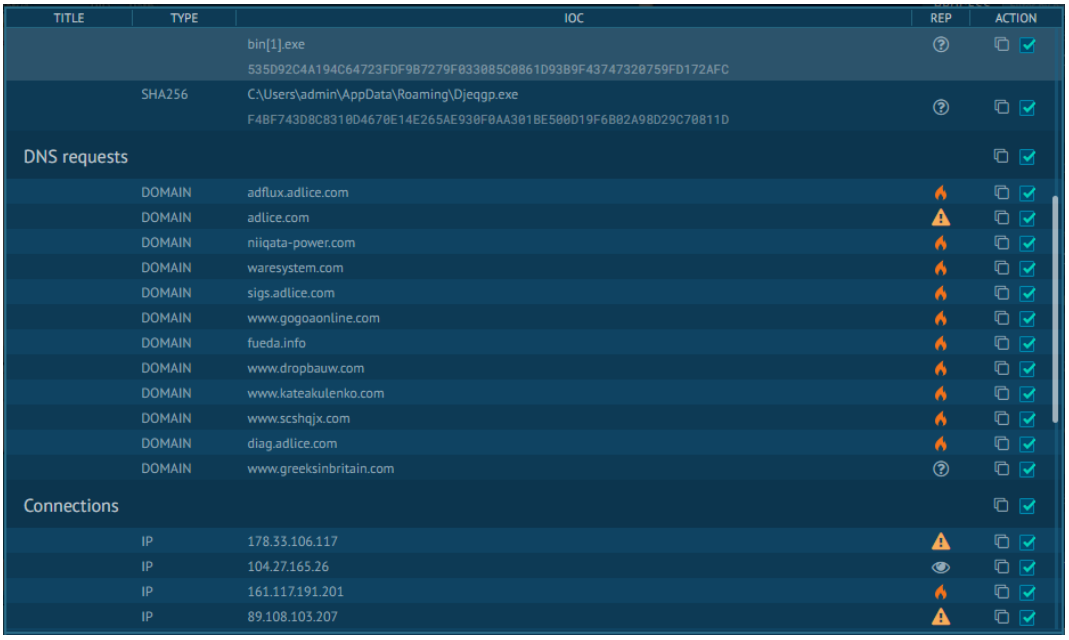


Imagen 26. Direcciones IP, dominios y subdominios detectados en la muestra

1.1.9. THREATMINER

ThreatMiner es una plataforma online que recopila diferentes IoCs de otras herramientas con el fin de disponer de una única interfaz para realizar las investigaciones sobre amenazas. ThreatMiner enriquece su base de datos sobre amenazas mediante fuentes externas, siendo las siguientes: CIRCL, VirusTotal, Hybrid Analysis, AlienVault OTX, Ipinfo, Robtex, VirusShare o Maltego.

Además, dispone también de la integración de las herramientas de código abierto APTNotes e IOCParser. Tal como puede verse en la Imagen 27 tras acceder a la web oficial (https://www.threatminer.org), cuenta con 25 millones de muestras, 50 millones de dominios, 48 millones de hosts, 978 informes de APTNotes.



Imagen 27. Sitio oficial de ThreatMiner

La herramienta permite realizar búsquedas sobre dominios, direcciones IP, URL, hashes, emails, notas recopiladas con APTNotes, SSL, User-Agent, familias de antivirus, registro, strings. A continuación son mostradas algunas de las opciones mencionadas:

- Buscar términos por APTNotes: https://www.threatminer.org/reports.php?q=lazarus
- Buscar por dominio: https://www.threatminer.org/domain.php?q=google.com
- Buscar por IP: https://www.threatminer.org/host.php?q=216.58.213.110
- Buscar por hash: https://www.threatminer.org/sample.php?q=e6ff1bf0821f00384cdd25efb9b1cc09
- Buscar por email: https://www.threatminer.org/email.php?q=***@***
- Buscar por AV: https://www.threatminer.org/av.php?q=Trojan.Enfal
- Buscar por mutex string: https://www.threatminer.org/mutex.php?q=UVhVXmJpX2Ax
- Buscar por User-Agent: https://www.threatminer.org/ua.php?q=Python-urllib
- Resto de queries: https://www.threatminer.org/features.php

Dispone de una API (puede consultarse en el siguiente enlace: https://www.threatminer.org/api.php) que permite la integración con otras plataformas para analizar amenazas como MISP, Splunk (SIEM), Rapid7 InsightConnect, IBM Resilient (Plataforma de gestión de incidentes).

1.1.10. ALIENVAULT OTX

OTX proporciona acceso gratuitamente a una comunidad global sobre amenazas, donde cualquier profesional pueda investigar y compartir activamente los últimos datos, tendencias y técnicas sobre las amenazas emergentes a nivel mundial. En la actualidad OTX cuenta con un total de 250.000 pulsos, que son un conjunto de colecciones de información sobre amenazas.

Características básicas:

- Dispone en la actualidad de 53 millones de registros sobre diversos IoCs (CIDR, CVE, Dominio, Email, IPv4, IPv6, FileHash MD5, FileHash SHA1, FileHash SHA-256, Hostname, Mutex, URL, reglas YARA, FilePath).
- Dispone de información sobre un total de 346 adversarios.
- Permite buscar información sobre amenazas relacionadas en un total de 19 industrias.
- Dispone de un repositorio sobre familias de malware, contando en la actualidad con 27.000.
- Permite la integración con agentes de AlienVault OSSIM, AlienVault USM, Bro, Suricata.
- Dispone de una API que permite la comunicación mediante Java, Python, Goland y TAXII.
- OTX permite crear y compartir resúmenes sobre amenazas que denominan Pulse. Dentro de estos es posible encontrar indicadores de compromisos relacionados, una vista del software objetivo y otros detalles relacionado con la amenaza en cuestión.
- OTX permite subir archivos para ser analizados estática y dinámicamente por el sandbox interno de AlienVault con el fin de detectar la presencia de alguna

amenaza. Además, a través de OTX es posible enviar una URLs para comprobar si tiene artefactos relacionados con otra amenaza.

- Los tipos de ficheros permitidos para su análisis son: cualquier ejecutable de Windows PE (exe, dll, sys), ejecutables de Linux (ELF), archivos ofimáticos (doc, docx, ppt, ppt, pps, pptx, ppsx, xls, xlsx, rtf, pub, pdf), paquetes de Microsoft Installer (MSI), JAR, ZIP, HTA), Windows Shortcut (lnk), Windows Script File (wsf), JavaScript, Visual Basic (vbs, vbe), Shockwave Flash (swf), batch file (bat), shell script (sh), PowerShell (ps), Scalable Vector Graphics (svg), MIME RFC 822 (eml), Python (py) y Perl (pl).
- Posibilidad de categorizar cada fichero o URL enviada con el TLP deseado, por defecto es catalogado como White.

A continuación, se facilitan enlaces relacionados con AlienVault OTX:

- Sitio Oficial: https://otx.alienvault.com.
- Documentación API: https://otx.alienvault.com/api.
- Repositorio para conexión con Bro: https://github.com/AlienVault-OTX/OTX-Apps-Bro-IDS.
- Repositorio para conexión con TAXII: https://github.com/AlienVault-OTX/OTX-Apps-TAXII.
- Repositorio para conexión con Suricata: https://github.com/AlienVault-OTX/OTX-Suricata.

  Repositorio para conexión mediante Java SDK: https://github.com/AlienVault-OTX/OTX-Java-SDK.
- Repositorio para conexión mediante Python SDK: https://github.com/AlienVault-OTX/OTX-Python-SDK.
- Repositorio para conexión mediante Golang: https://github.com/AlienVault-OTX/OTX-Go-SDK.

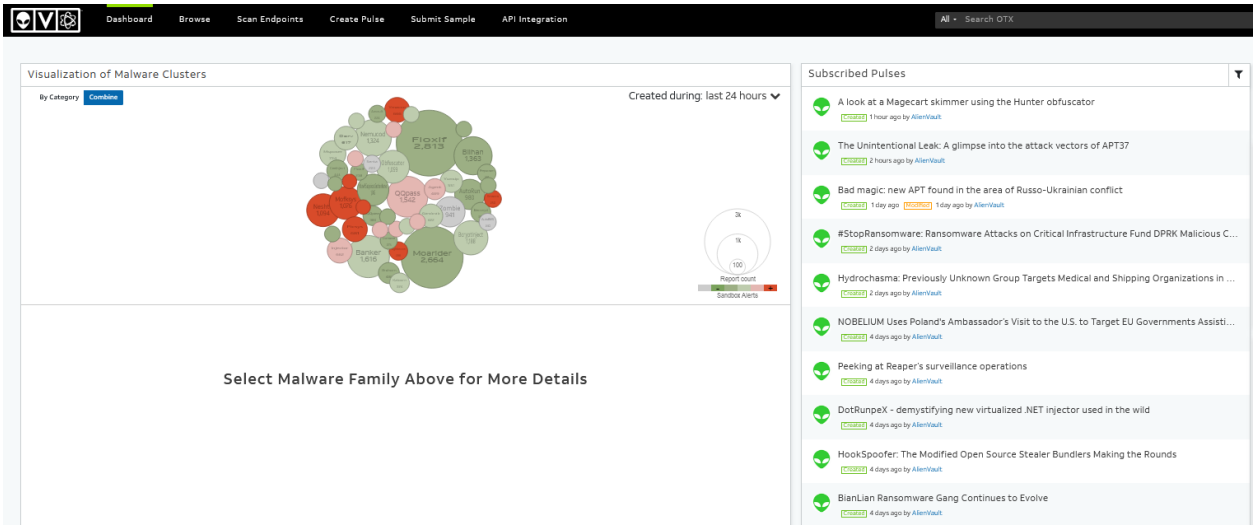


Imagen 28. Sitio oficial de AlienVault OTX

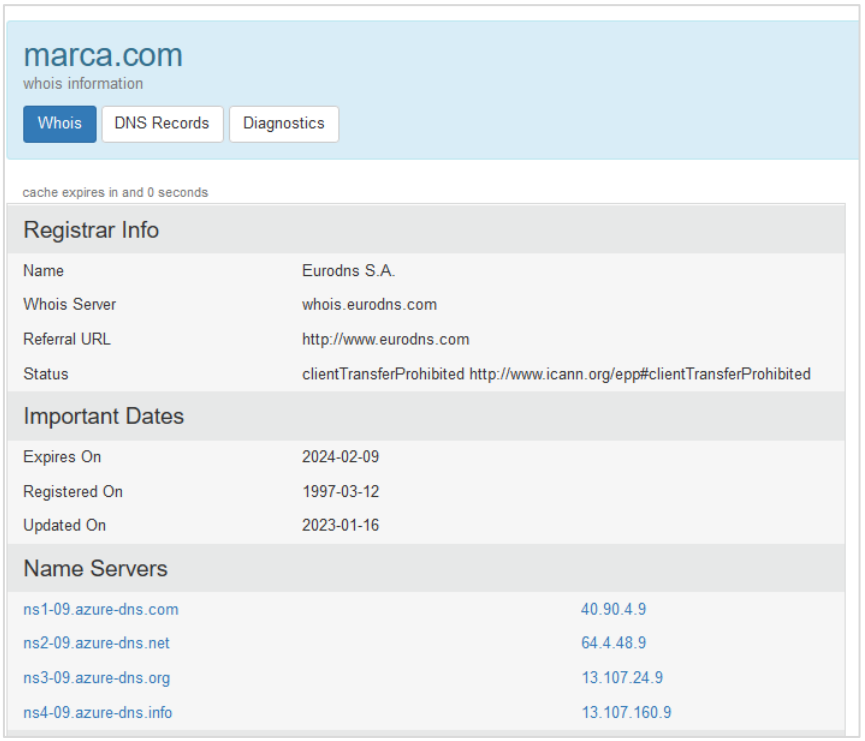
1.1.11. WHOIS

WHOIS permite buscar el nombre y la información de contacto de quien opere un dominio, aunque la información que podamos obtener a grandes rasgos es bastante limitada debido al RGPD. El WHOIS está formado por la siguiente información:

- **Información del registrador**: nombre, referencia por URL, estado
- **Datos sobre fechas asociados**: fecha de registro, expiración y actualización)
- Servidores NS (Registros NS)
- **Información de contacto del registrante**: nombre organización, dirección postal, ciudad, país, teléfono y correo electrónico
- **Información de contacto del administrador**: nombre organización, dirección postal, ciudad, país, teléfono y correo electrónico
- **Información de contacto técnico**: nombre organización, dirección postal, ciudad, país, teléfono y correo electrónico

Existen varias plataformas web que ofrecen información relativa al whois, siendo las más importantes las siguientes:

- **who.is**. Se trata de un sitio web que ofrece servicio dando información relativa a dominios o direcciones IP. Cuenta con una versión gratuita, aunque si se desea hay disponible una versión de pago que permite realizar un seguimiento de los dominios objetivos. El enlace de acceso es el siguiente: https://who.is/. En las imágenes 30 y 31 se realiza una búsqueda de "marca.com" con el objetivo de obtener el Whois asociado al mismo. Entre los datos que se recopilan están: el nombre del registrador, fechas de registro, actualización y expiración, registros NS e información de contacto del administrador, técnico y registrante.



marca.com

whois information

Whois | DNS Records | Diagnostics

cache expires in and 0 seconds

Registrar Info

Name	Eurodns S.A.
Whois Server	whois.eurodns.com
Referral URL	http://www.eurodns.com
Status	clientTransferProhibited http://www.icann.org/epp#clientTransferProhibited

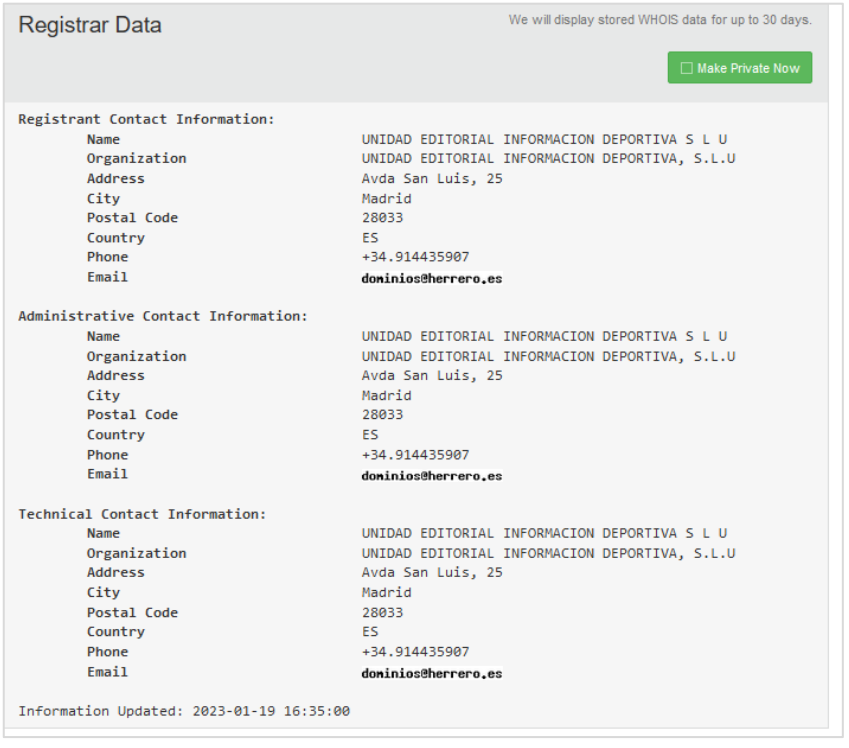
Important Dates

Expires On	2024-02-09
Registered On	1997-03-12
Updated On	2023-01-16

Name Servers

ns1-09.azure-dns.com	40.90.4.9
ns2-09.azure-dns.net	64.4.48.9
ns3-09.azure-dns.org	13.107.24.9
ns4-09.azure-dns.info	13.107.160.9

Imagen 29. Resultados del Whois del objetivo - parte 1



Registrar Data

We will display stored WHOIS data for up to 30 days.

Make Private Now

```
Registrant Contact Information:
        Name                    UNIDAD EDITORIAL INFORMACION DEPORTIVA S L U
        Organization            UNIDAD EDITORIAL INFORMACION DEPORTIVA, S.L.U
        Address                 Avda San Luis, 25
        City                    Madrid
        Postal Code             28033
        Country                 ES
        Phone                   +34.914435907
        Email                   dominios@herrero.es

Administrative Contact Information:
        Name                    UNIDAD EDITORIAL INFORMACION DEPORTIVA S L U
        Organization            UNIDAD EDITORIAL INFORMACION DEPORTIVA, S.L.U
        Address                 Avda San Luis, 25
        City                    Madrid
        Postal Code             28033
        Country                 ES
        Phone                   +34.914435907
        Email                   dominios@herrero.es

Technical Contact Information:
        Name                    UNIDAD EDITORIAL INFORMACION DEPORTIVA S L U
        Organization            UNIDAD EDITORIAL INFORMACION DEPORTIVA, S.L.U
        Address                 Avda San Luis, 25
        City                    Madrid
        Postal Code             28033
        Country                 ES
        Phone                   +34.914435907
        Email                   dominios@herrero.es

Information Updated: 2023-01-19 16:35:00
```

Imagen 30. Resultados del Whois del objetivo - parte 2

- **DomainTools**. Se trata de una herramienta comercial que ofrece servicio sobre información de dominios y direcciones IP y aunque sea de pago permite realizar algunas peticiones de manera gratuita. El enlace de acceso es el siguiente: https://whois.domaintools.com/.

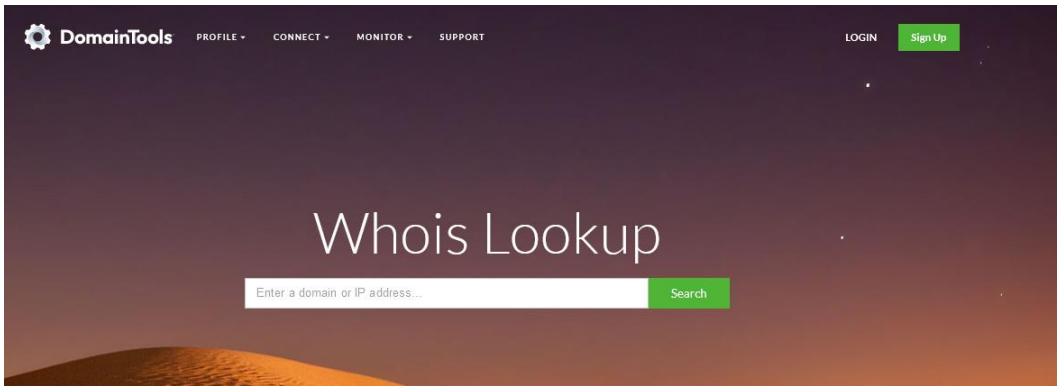


Imagen 31. Sitio web oficial de DomainTools

A continuación, se realiza una búsqueda del dominio "marca.es" para obtener información relativa al dominio mediante DomainTools. En la Imagen 33 puede consultarse los registros NS asociados al dominio, la dirección IP, el ASN y un screenshot del sitio web. Al tratarse de un dominio .es, la información que se puede recuperar por este tipo de herramientas es mínima.

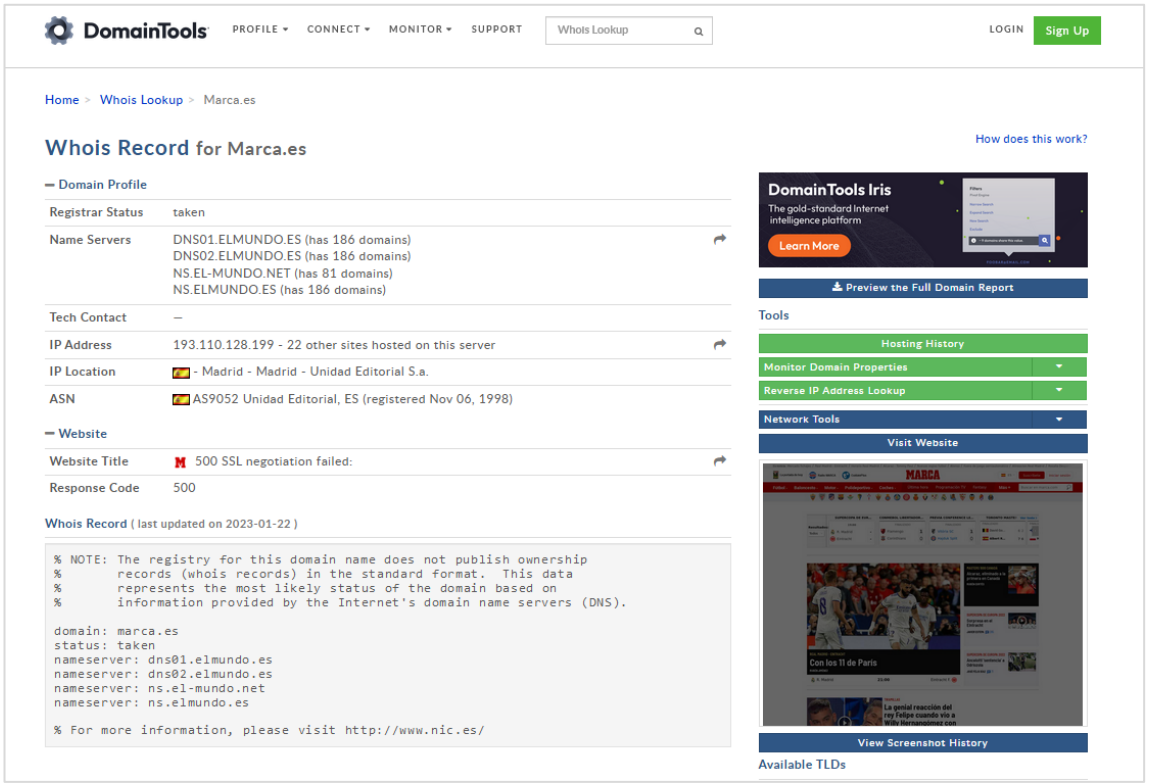


Imagen 32. Resultados del objetivo con DomainTools

- **Dominios .es**. Se trata de la unidad responsable de la gestión del registro de nombres de dominio de Internet bajo el código de país ".es" y están integrados en la Entidad Pública Empresarial de Red.es del Gobierno de España. El propio "dominios.es" dispone de un buscador gratuito donde poder consultar información sobre dominios españoles bajo el TLD ".es". El enlace de acceso es el siguiente: https://www.dominios.es/es.

Accediendo al sitio web oficial, se realiza una búsqueda del dominio de "marca.es", tal como se puede apreciar en la Imagen 34. Acto seguido "dominio.es" indica los dominios que están registrados, detectando que nuestro dominio objetivo (marca.es) está ocupado (ver Imagen 35).



Imagen 33. Búsqueda del dominio objetivo en dominios.es



Imagen 34. Resultados de la búsqueda del dominio objetivo

Si se accede a consultar los datos asociados del dominio objetivo (marca.es) podremos obtener información asociada al propio dominio, como el titular de este, el agente registrador, fechas de alta y expiración, servidores NS con su dirección IP asociada y los contactos administrativo y técnico. En la Imagen 36 se puede ver lo comentado.



Información de Dominio

Volver

Los datos de contacto de este dominio están ocultos. Si desea comunicarse con el Titular y el PCA pulse aquí

DATOS DEL TITULAR

Nombre del Dominio	marca.es
Estado	Activado
Identificador	UEID2-ESNIC-F4
Titular	UNIDAD EDITORIAL INFORMACIÓN DEPORTIVA,S.L.U
Fecha de Alta	20-07-2001
Fecha de Caducidad	20-07-2023
Agente Registrador	EURODNS S.A.

PERSONA DE CONTACTO ADMINISTRATIVO

Identificador	F95A19-ESNIC-F5
Nombre	PATRICIA DOMINGO

PERSONA DE CONTACTO TECNICO

Identificador	F95A18-ESNIC-F5
Nombre	ALEX PALOMO

PERSONA DE CONTACTO DE FACTURACION

SERVIDORES DNS

Nombre Servidor	IP
dns01.elmundo.es	193.110.128.50 2001:67c:2294:1000::f050
dns02.elmundo.es	193.110.128.51
ns.elmundo.es	193.110.128.51 2001:67c:2294:1000::f051
ns.el-mundo.net	

Imagen 35. Resultados asociados al dominio objetivo con dominios.es

1.1.12. HACKER TARGET

Hacker Target está compuesto por un conjunto de servicios en forma de herramientas de diversa índole con el objetivo de ofrecer un descubrimiento de la superficie de ataque y las vulnerabilidades que pueda estar asociado a un cliente. Hacker Target ofrece servicios tanto de pago como una parte gratuita de sus herramientas. El enlace del sitio oficial es el siguiente: https://hackertarget.com/.

Antes de comenzar a enumerar las herramientas, es necesario conocer que tipos de registros DNS pueden estar asociados a un dominio. Dichos registros son los que se pueden ver a continuación:

Registro A	Tipo de registro DNS. Vinculan un nombre de host (dominio) a una dirección IP. Ej.: ftp.dominio.com. A 156.25.89.36
Registro NS	Tipo de registro DNS. Son los servidores DNS Autorizados para un dominio/subdominio y quien informará de cualquier petición solicitada al dominio. Ej.: dominio.com. NS ns1.dominio.com.
Registro MX	Tipo de registro DNS. Indica el servidor de correo responsable de distribuir y gestionar los correos relacionados con el dominio. Ej.: dominio.com. MX 10 mx01.dominio.com.
Registro CNAME	Tipo de registro DNS. Especifica las redirecciones desde los subdominios de un dominio hacia otros dominios/subdominios. Ej.: ftp.dominio.com. CNAME dominio.com.
DNS Reverse	Utiliza registro DNS PTR. Resuelve dirección IP hacia un nombre de host (dominio). Similar a Registro A pero a la inversa. Ej.: 44.33.22.11.in-addr.arpa PTR dominio.com.

Hacker Target posee una serie de herramientas muy interesantes relacionados con dominios y direcciones IP, siendo las siguientes:

- **DNS Lookup**. Con esta herramienta se pueden obtener todos los registros DNS asociados a un dominio objetivo. El enlace de acceso es el siguiente: https://hackertarget.com/dns-lookup/. En la Imagen 37 pueden verse los resultados sobre registros DNS asociados a un dominio objetivo (marca.es).

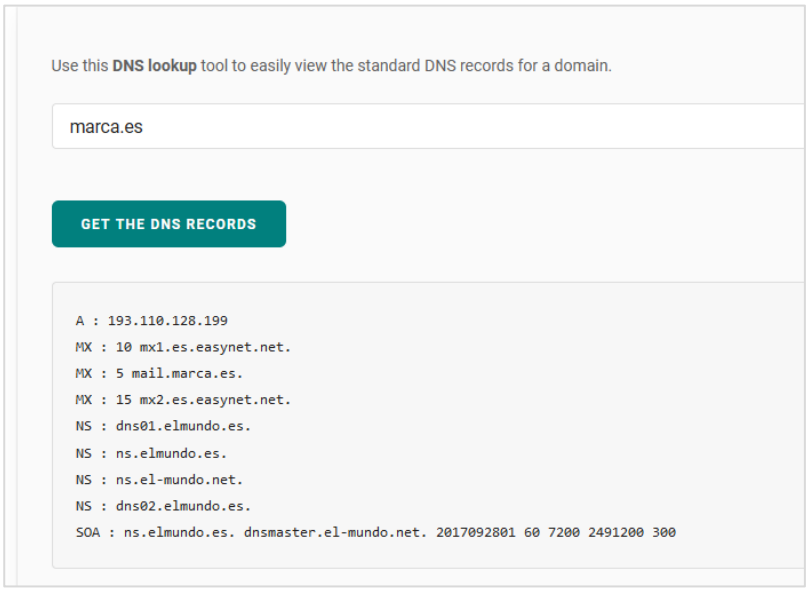


Imagen 36. Resultados de DNS Lookup

- **Reverse IP Lookup**. Con esta herramienta se pueden obtener todos los dominios

que estén apuntando a una dirección IP objetivo. El enlace de acceso es el siguiente: https://hackertarget.com/reverse-ip-lookup/.

En la Imagen 38 pueden consultarse todos los dominios que apuntan a la dirección IP detrás de nuestro dominio objetivo (marca.es).

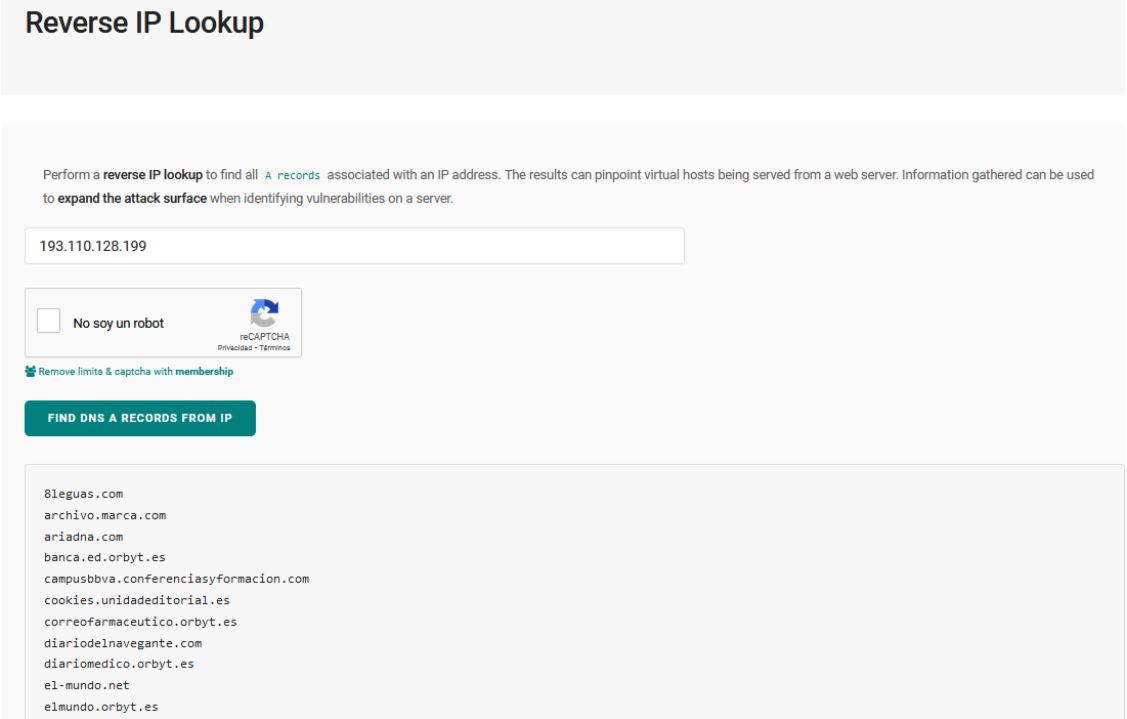


Imagen 37. Listado de dominios obtenidos mediante Reverse IP Lookup

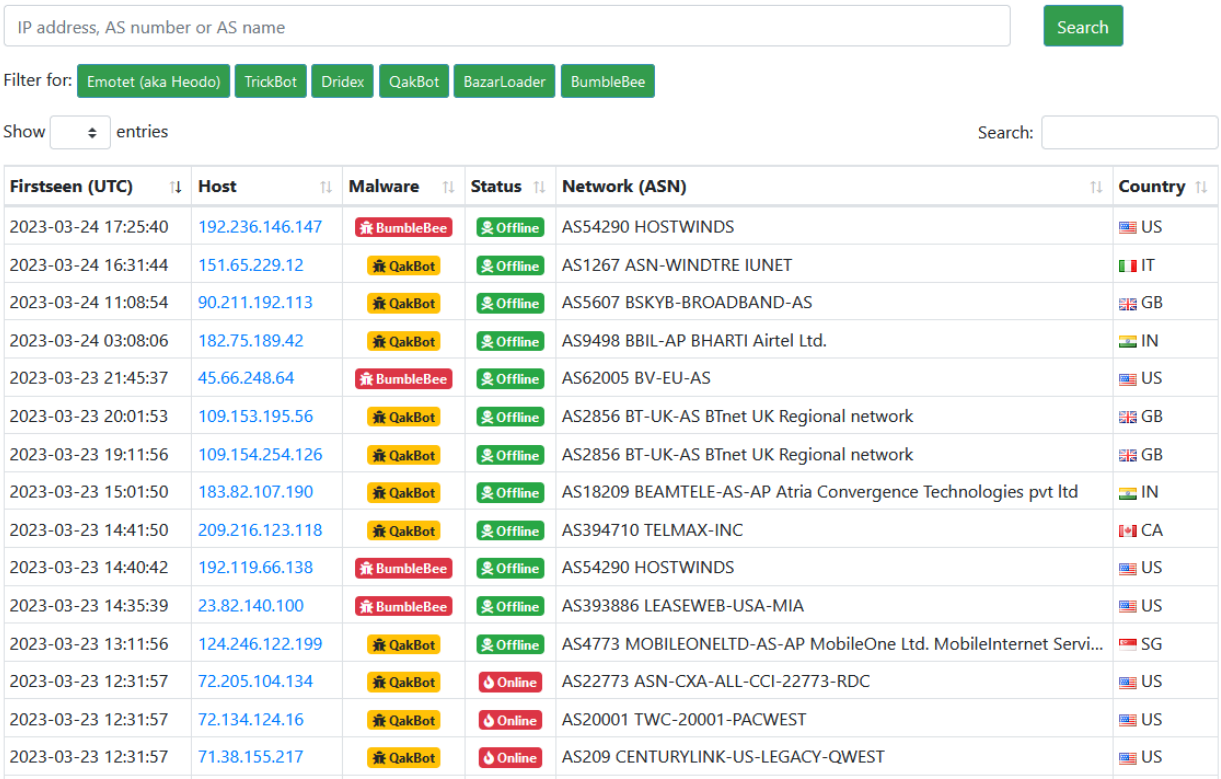
1.1.13. FEODO TRACKER

Feodo Tracker es un Proyecto de abuse.ch con el objetivo de compartir información sobre servidores de Comando y Control (C&C) de botnets asociadas con Dridex, Emotet, TrickBot, QuakBot y BazarLoader. Feodo Tracker rastrea y monitoriza diferentes familias relacionadas con las botnets mencionadas anteriormente con el propósito de identificar nuevas familias consideradas como una variante del malware Feodo. Dicho malware era

un troyano bancario que se utilizaba en diferentes tipos de fraude online hacia el sector bancario, en el que desde el 2010 varias familias de malware evolucionaron de él.

Feodo Tracker dispone de un buscador que permite realizar consultas sobre direcciones IP, ASN o AS, el cual está activo desde el 2010. En enlace de dicho buscador está disponible aquí: https://feodotracker.abuse.ch/browse/.

En la Imagen 39 puede verse el propio buscador donde clasifica la información en cuanto a la fecha de detección de la primera aparición, dirección IP, el tipo de malware, el estado (activo o inactivo), ASN y el país origen de la dirección IP.


IP address, AS number or AS name

Search

Filter for: Emotet (aka Heodo) | TrickBot | Dridex | QakBot | BazarLoader | BumbleBee

Show entries

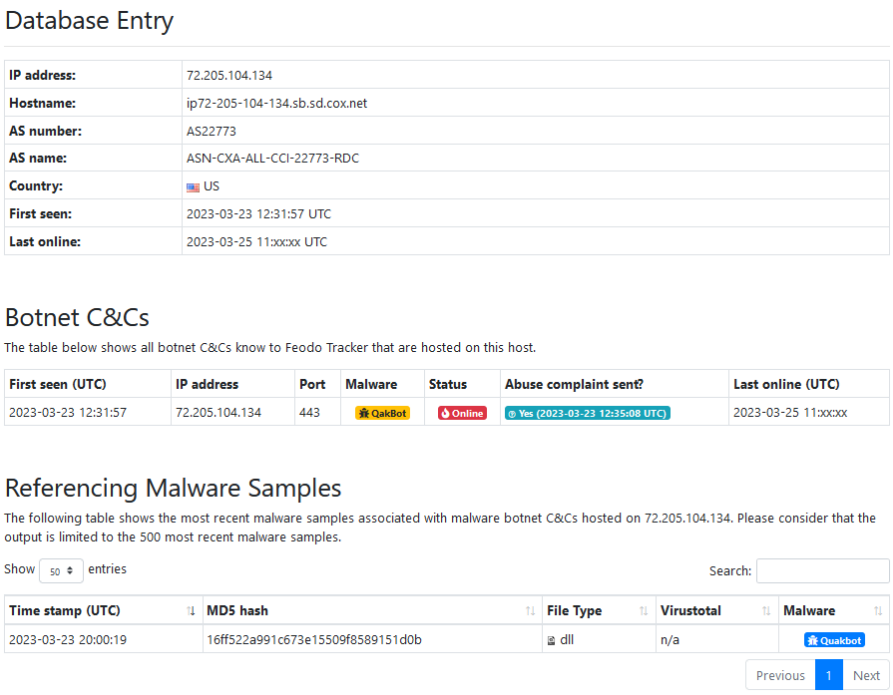
Search:

Firstseen (UTC)	Host	Malware	Status	Network (ASN)	Country
2023-03-24 17:25:40	192.236.146.147	BumbleBee	Offline	AS54290 HOSTWINDS	US
2023-03-24 16:31:44	151.65.229.12	QakBot	Offline	AS1267 ASN-WINDTRE IUNET	IT
2023-03-24 11:08:54	90.211.192.113	QakBot	Offline	AS5607 BSKYB-BROADBAND-AS	GB
2023-03-24 03:08:06	182.75.189.42	QakBot	Offline	AS9498 BBIL-AP BHARTI Airtel Ltd.	IN
2023-03-23 21:45:37	45.66.248.64	BumbleBee	Offline	AS62005 BV-EU-AS	US
2023-03-23 20:01:53	109.153.195.56	QakBot	Offline	AS2856 BT-UK-AS BTnet UK Regional network	GB
2023-03-23 19:11:56	109.154.254.126	QakBot	Offline	AS2856 BT-UK-AS BTnet UK Regional network	GB
2023-03-23 15:01:50	183.82.107.190	QakBot	Offline	AS18209 BEAMTELE-AS-AP Atria Convergence Technologies pvt ltd	IN
2023-03-23 14:41:50	209.216.123.118	QakBot	Offline	AS394710 TELMAX-INC	CA
2023-03-23 14:40:42	192.119.66.138	BumbleBee	Offline	AS54290 HOSTWINDS	US
2023-03-23 14:35:39	23.82.140.100	BumbleBee	Offline	AS393886 LEASEWEB-USA-MIA	US
2023-03-23 13:11:56	124.246.122.199	QakBot	Offline	AS4773 MOBILEONELTD-AS-AP MobileOne Ltd. MobileInternet Servi...	SG
2023-03-23 12:31:57	72.205.104.134	QakBot	Online	AS22773 ASN-CXA-ALL-CCI-22773-RDC	US
2023-03-23 12:31:57	72.134.124.16	QakBot	Online	AS20001 TWC-20001-PACWEST	US
2023-03-23 12:31:57	71.38.155.217	QakBot	Online	AS209 CENTURYLINK-US-LEGACY-QWEST	US

Imagen 38. Buscador de Feodo Tracker

Si accedemos a una de las direcciones IP nos podemos encontrar con diferentes tipos de información, como puede ser el hostname relacionado, el ASN, AS, país, fecha de primera y última vez de detección, familia de malware asociado y hash de un muestra, la cual,

podríamos investigar más a fondo con otras herramientas. En la Imagen 39 puede verse lo comentado.



Database Entry

IP address:	72.205.104.134
Hostname:	ip72-205-104-134.sb.sd.cox.net
AS number:	AS22773
AS name:	ASN-CXA-ALL-CCI-22773-RDC
Country:	US
First seen:	2023-03-23 12:31:57 UTC
Last online:	2023-03-25 11:xx:xx UTC

Botnet C&Cs

The table below shows all botnet C&Cs know to Feodo Tracker that are hosted on this host.

First seen (UTC)	IP address	Port	Malware	Status	Abuse complaint sent?	Last online (UTC)
2023-03-23 12:31:57	72.205.104.134	443	QakBot	Online	Yes (2023-03-23 12:35:08 UTC)	2023-03-25 11:xx:xx

Referencing Malware Samples

The following table shows the most recent malware samples associated with malware botnet C&Cs hosted on 72.205.104.134. Please consider that the output is limited to the 500 most recent malware samples.

Show 50 entries Search:

Time stamp (UTC)	MD5 hash	File Type	Virustotal	Malware
2023-03-23 20:00:19	16ff522a991c673e15509f8589151d0b	dll	n/a	Quakbot

Previous 1 Next

Imagen 39. Información de un C&C concreto en Feodo Tracker

Por otro lado, Feodo Tracker cuenta con listas de bloqueo (blocklist) que pueden ser utilizadas para bloquear cualquier acceso de dichos C&C con nuestra infraestructura corporativa. En la Imagen 40 puede verse que Feodo Tracker comparte una serie de blocklist de direcciones IP, IoC y reglas para Suricata asociadas a C2 de botnets. El enlace está disponible aquí: https://feodotracker.abuse.ch/blocklist/.

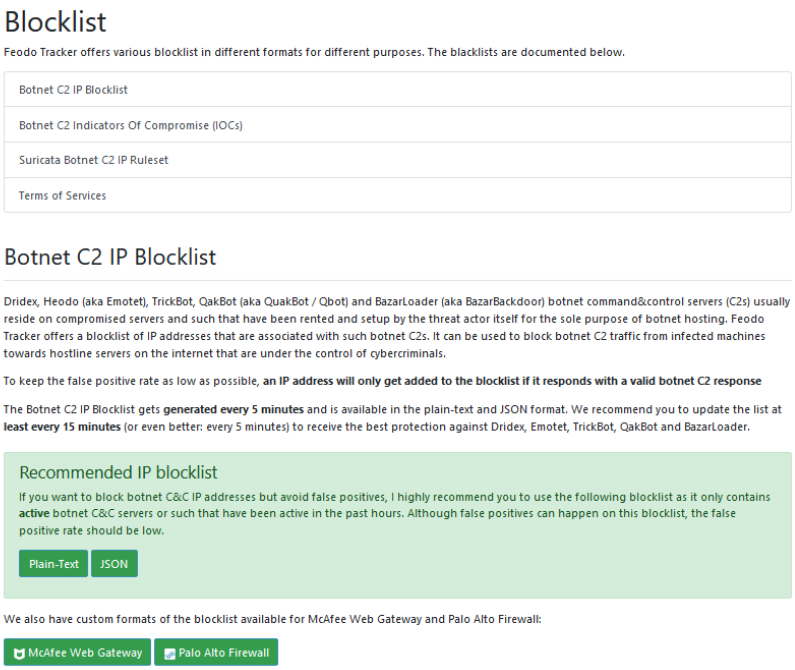


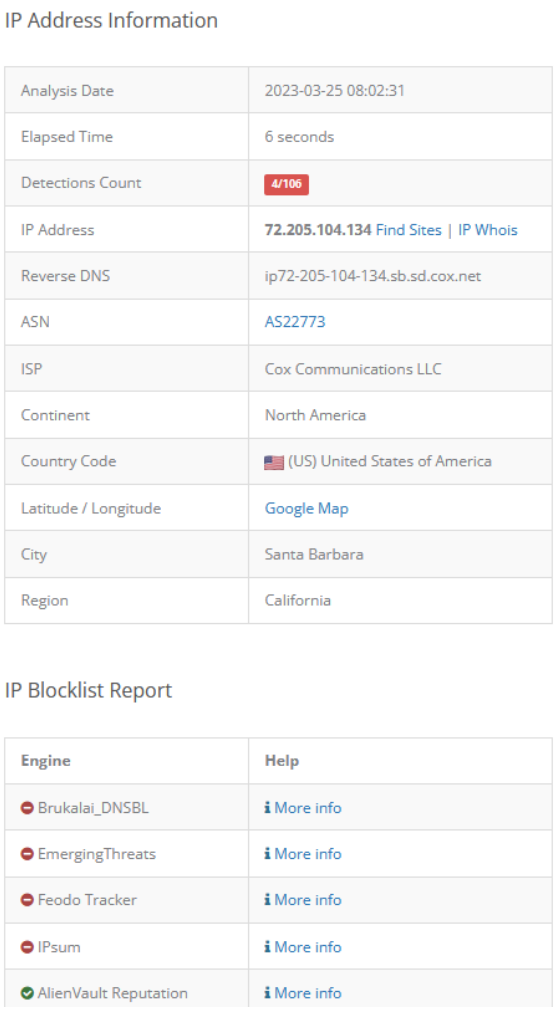
Imagen 40. Blocklist ofrecidas por Feodo Tracker

1.1.14. IP BLACKLIST CHECK

IP Blacklist Check es una herramienta ofrecida por el servicio online IPVOID que permite comprobar si una dirección IP está involucrada en incidentes de malware o actividades de spam. Para cumplir con su objetivo realiza diferentes peticiones hacia distintas DNSBL[2] y servicios de reputación de IP. El enlace de acceso es el siguiente: https://www.ipvoid.com/ip-blacklist-check/.

En la Imagen 41 vemos una consulta realizada a la dirección IP vista en la Imagen 39 relacionada con la botnet QuakBot, donde obtenemos información sobre el ASN, geolocalización, ISP y un conteo de coincidencias con servicios online de blocklist, entre ellos el de Feodo Tracker visto anteriormente.

[2] DNSBL: Lista negra basada en DNS relacionadas con campañas de SPAM



IP Address Information

Analysis Date	2023-03-25 08:02:31
Elapsed Time	6 seconds
Detections Count	4/106
IP Address	**72.205.104.134** Find Sites | IP Whois
Reverse DNS	ip72-205-104-134.sb.sd.cox.net
ASN	AS22773
ISP	Cox Communications LLC
Continent	North America
Country Code	(US) United States of America
Latitude / Longitude	Google Map
City	Santa Barbara
Region	California

IP Blocklist Report

Engine	Help
Brukalai_DNSBL	More info
EmergingThreats	More info
Feodo Tracker	More info
IPsum	More info
AlienVault Reputation	More info

Imagen 41. Información sobre una IP relacionada con un C2 consultado desde IP Blacklist Check

1.1.15. BLACKLIST - MXTOOLBOX

Blacklist es una herramienta ofrecida por el servicio online MXToolbox que permite analizar si una dirección IP está relacionada con campañas de spam, consultando un total de 100 blacklist sobre DNSBL. El enlace de acceso es el siguiente: https://mxtoolbox.com/blacklists.aspx

En la Imagen 42 vemos una consulta realizada a la dirección IP 71.38.155[.]217, donde únicamente localizamos en la blacklist donde está presente, siendo en este caso SORBS y Spamhaus.

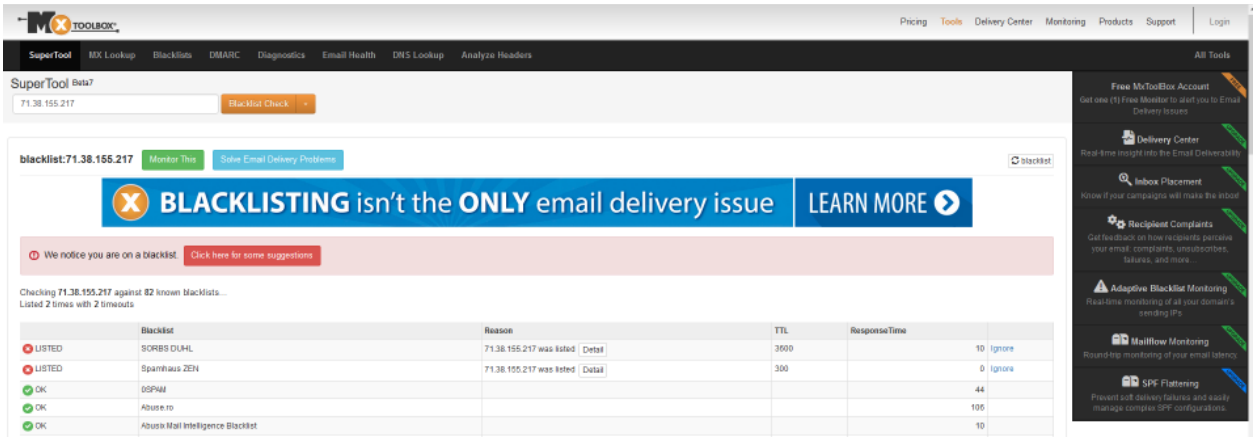


Imagen 42. Resultados de búsqueda de una IP en Blacklist de MXToolbox

1.1.16. ABUSEIPDB

AbuseIPDB es un servicio gratuito que permite comprobar si una dirección IP está relacionada con algún tipo de actividad maliciosa con el objetivo de añadirla en listas de bloqueo. El enlace de acceso es el siguiente: https://www.abuseipdb.com.

En la Imagen 43 vemos una consulta realizada a la dirección IP vista en la Imagen 39 relacionada con la botnet QuakBot, donde obtenemos el porcentaje de aparición dentro de la base de datos de AbuseIPDB (siendo un 3%), el ISP, país y ciudad asociados a la IP, hostname y una coincidencia con un informe adjunto donde se añade un comentario indicando que la dirección IP ha sido añadida dentro de la base de datos de ThreatFox IOC de Abuse.ch. Esto último hace referencia a una base de datos pública sobre Indicadores de Compromiso que podéis encontrar aquí: https://threatfox.abuse.ch/browse/.

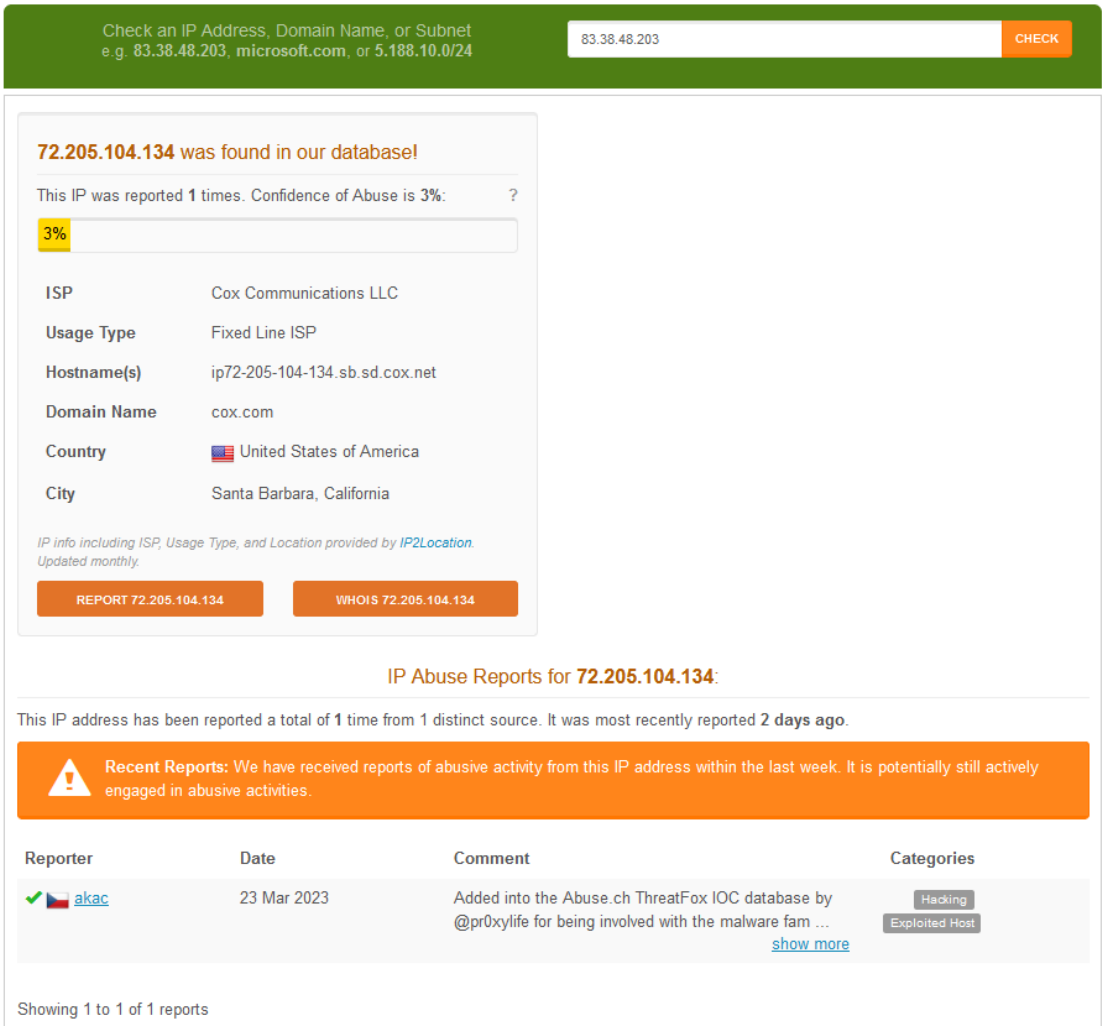


Imagen 43. Resultados de búsqueda sobre una dirección IP maliciosa en AbuseIPDB

1.1.17. WEBMII

Webmii es una herramienta online que permite realizar una búsqueda sobre un nombre de persona a partir del nombre y los apellidos, permitiendo así obtener información relacionada con redes sociales o la presencia del objetivo en cualquier foro, prensa digital, blog, etc. El enlace de acceso es el siguiente: https://webmii.com.

En la Imagen 44 puede verse el sitio oficial de Webmii y en la Imagen 45 los resultados sobre un objetivo marcado (en este caso mi nombre y apellidos), facilitando además un score de la cuenta.



Imagen 44. Sitio web oficial de Webmii

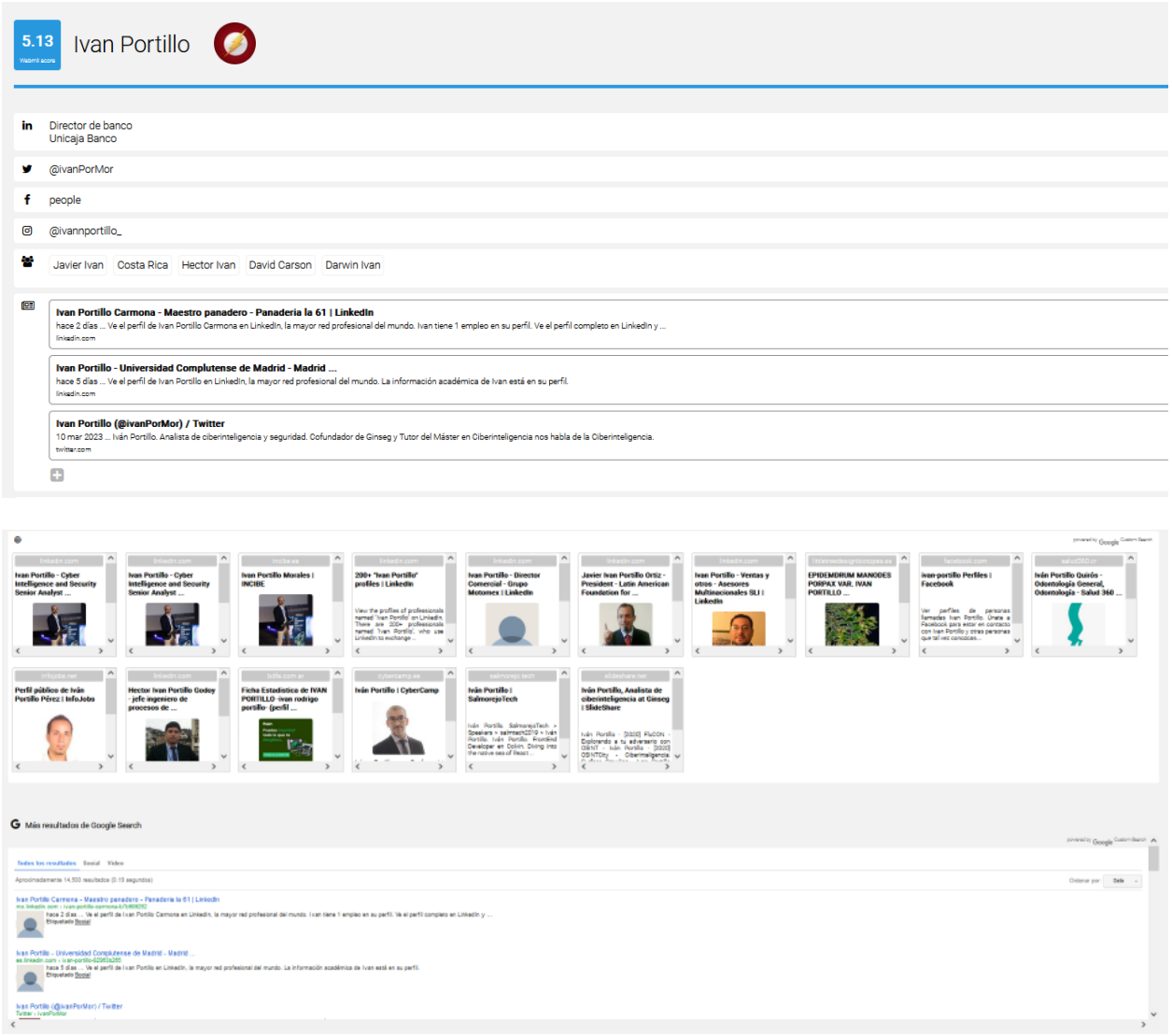


Imagen 45. Resultados de un objetivo con Webmii

1.1.18. INTELLIGENCEX

IntelligenceX ofrece un repositorio donde consultar datos relacionados sobre fugas de información, dominios, correos electrónicos, direcciones IP, usernames, VINs, hashes, números de teléfono, perfiles sociales, etc. Se trata de una herramienta de pago pero que permite acceder de manera gratuita a parte de su contenido. El enlace de acceso es el siguiente: https://intelx.io/

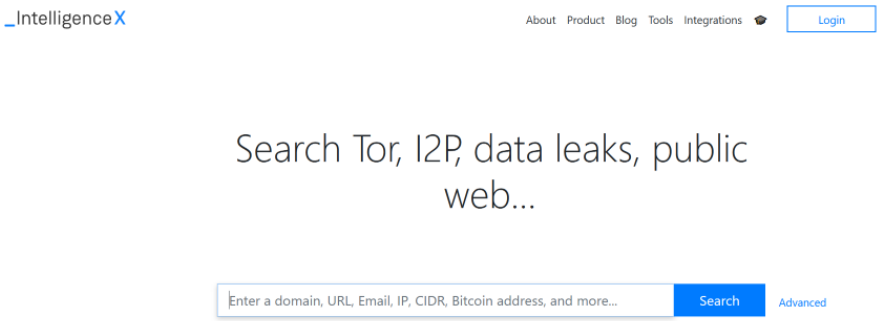


Imagen 46. Sitio web oficial de IntelligenceX

IntelligenceX permite realizar las búsquedas mediante buckets que son conjuntos de datos que tienen una categoría común, siendo posible ejecutar aquellas según necesidad. Estos buckets engloban todo tipo de colecciones, desde sitios pastes y enlaces ".onion" hasta whois de un dominio. En la Imagen 47 puede verse el resto de buckets que permite buscar la herramienta.

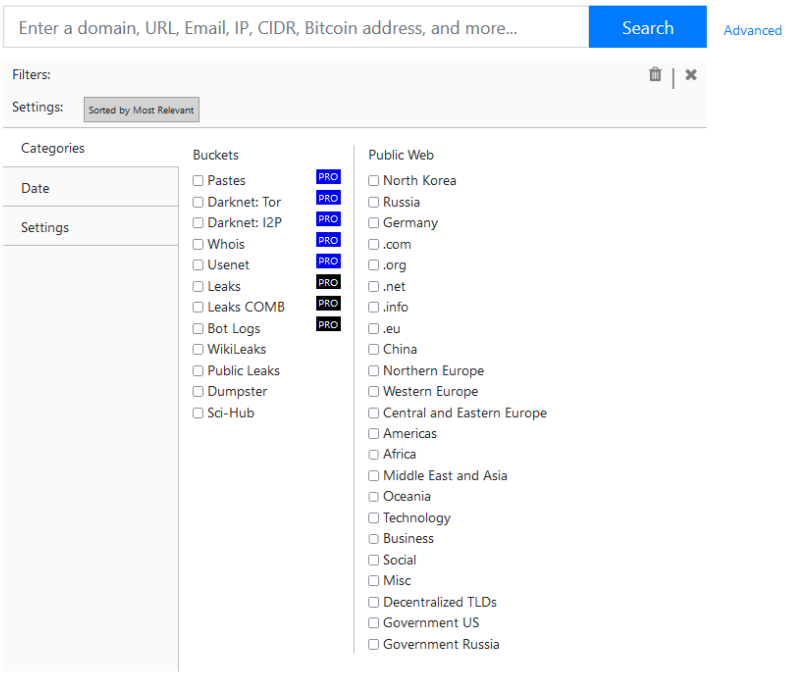


Imagen 47. Filtros de búsqueda de IntelligenceX

Realizando una búsqueda del dominio objetivo (marca.com) obtenemos la volumetría de datos que puede verse en la Imagen 48.

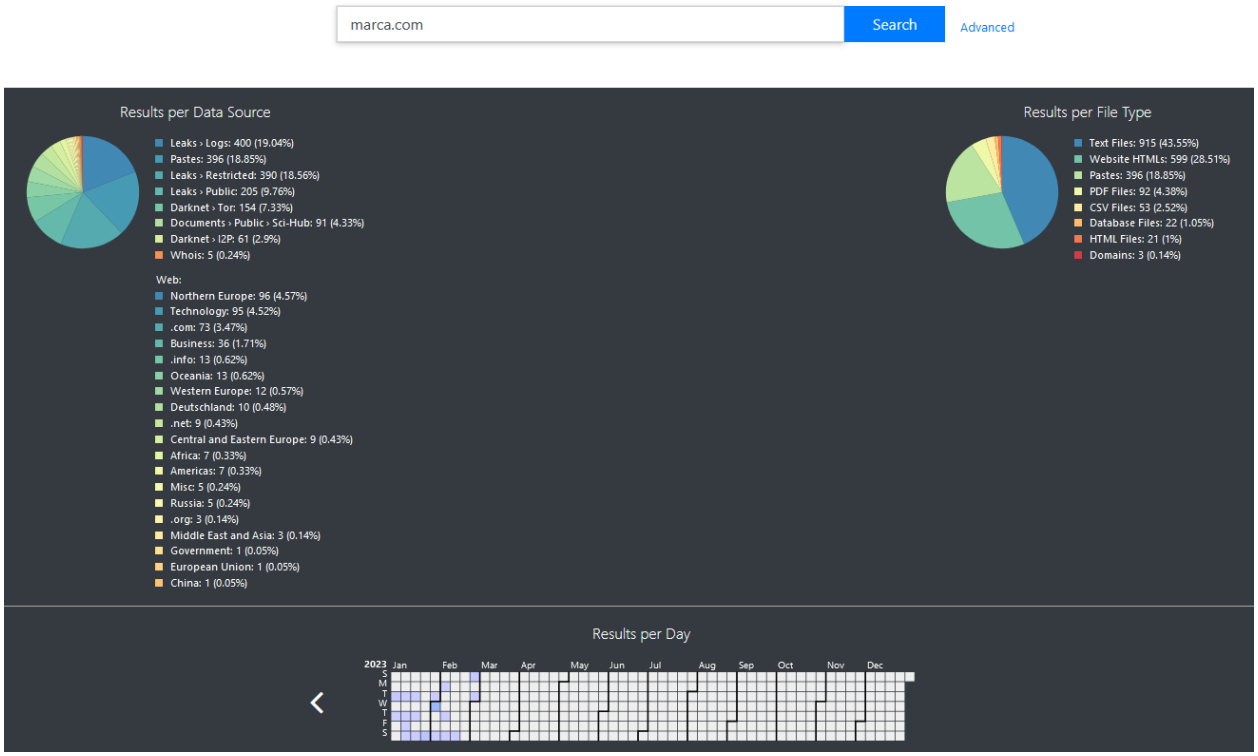


Imagen 48. Volumetría de datos obtenidos del dominio objetivo

1.1.19. THEHARVESTER

TheHarvester es una herramienta de línea de comando que permite recopilar información sobre un objetivo de manera pasiva, usando los motores de búsquedas de Bing, Google, Yahoo, Baidu y Shodan, entre otros. Se pueden obtener correos electrónicos, subdominios, IPs, nombre de perfiles de usuario en redes sociales, URLs de Trello, etc. En la Imagen 49 pueden verse todas las opciones de configuración para la ejecución de la herramienta.

Instalación:
git clone https://github.com/laramies/theHarvester
cd theHarvester
pip3 install -r requirements/base.txt

Ejecución:
python3 theHarvester.py -d marca.com -l 300 -b all



Imagen 49. Opciones de ejecución de TheHarvester

Realizando una búsqueda del dominio objetivo (marca.com) obtenemos diferentes tipos de datos como por ejemplo direcciones IP, dominios, correos electrónicos, hosts, etc. Un ejemplo de ello puede verse en la Imagen 50.

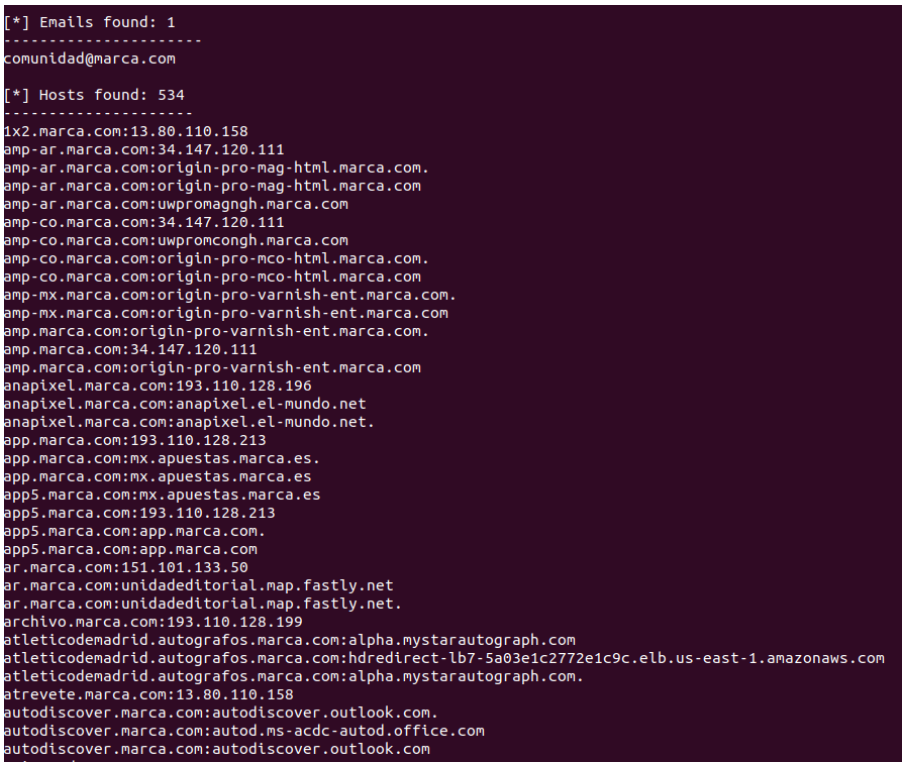


Imagen 50. Resultados de TheHarvester

1.1.20. CROSSLINKED

Crosslinked es una herramienta de línea de comando que permite obtener un listado de correos electrónicos localizados mediante fuentes públicas a partir de un formato de correo electrónico asociado a un dominio.

Instalación:
git clone https://github.com/m8r0wn/crosslinked
cd crosslinked
pip3 install -r requirements.txt

Ejecución:
python3 crosslinked.py -f '{first}.{last}@marca.com' marca

Realizando una búsqueda del dominio objetivo (marca.com) obtenemos un listado de correos electrónicos asociados al dominio. En la Imagen 51 puede verse lo mencionado.

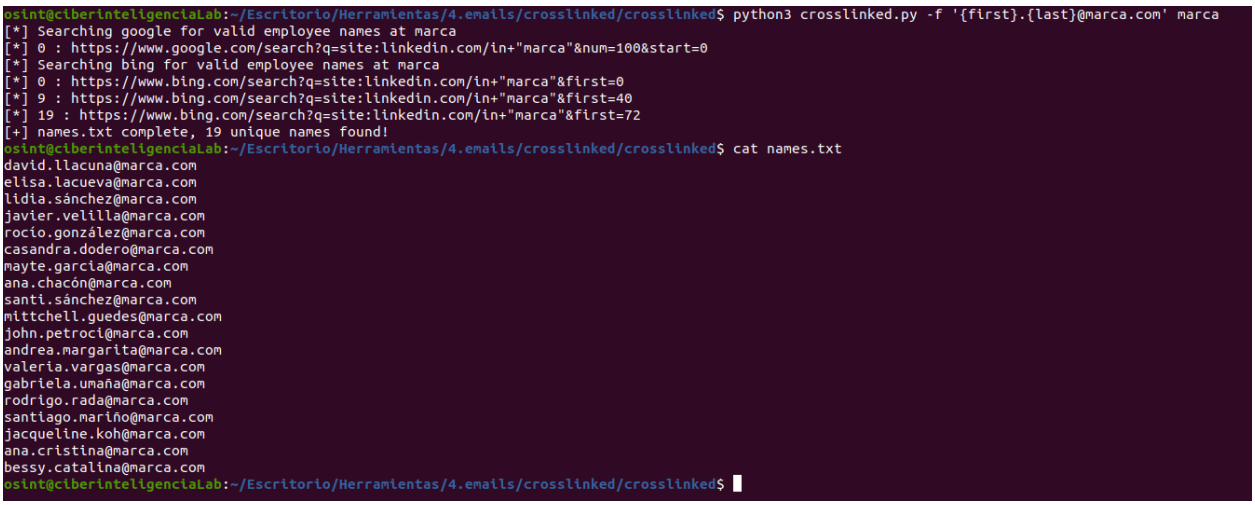


Imagen 51. Resultados de crosslinked

1.1.21. MALTEGO

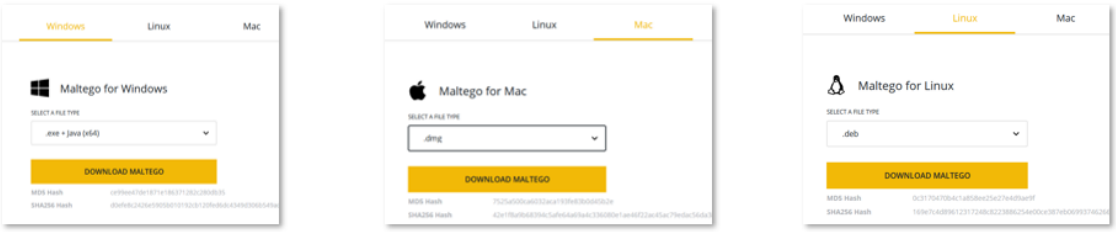
Maltego es una herramienta que recopila información a partir de diferentes fuentes, tanto gratuitas como de pago, mostrándolas en forma de grafos, siendo de gran ayuda en el análisis posterior por los equipos de Inteligencia y forense.

Contiene una serie de módulos de aplicaciones externas que complementan su potencial, además de una sencilla integración con APIs de distintas fuentes de información.



La vista en grafos permite abstraerse de la propia recopilación de la información independientemente de la fuente de donde se busque. Maltego nos ayudará a analizar la información mediante nodos con identidad única y las relaciones existentes con otros nodos de datos.

Maltego está disponible para las plataformas de Windows, Linux y Mac. En cada una de ellas es necesario tener instalado Java. Para la versión de Windows se dispone de una opción para descargar e instalar Maltego y Java juntos. Para Linux habría que descargarlo y ejecutar sudo dpkg -i Maltego.v4.x.deb.



Para poder utilizar la versión gratuita es necesario registrarse en Maltego Community Edition (CE) por medio del siguiente enlace: https://login.maltego.com/registration.

La primera vez que se ejecute Maltego preguntará que versión se desea utilizar, en nuestro caso Maltego CE. Posteriormente, se deberá utilizar la cuenta recién creada y loguearse con la misma.

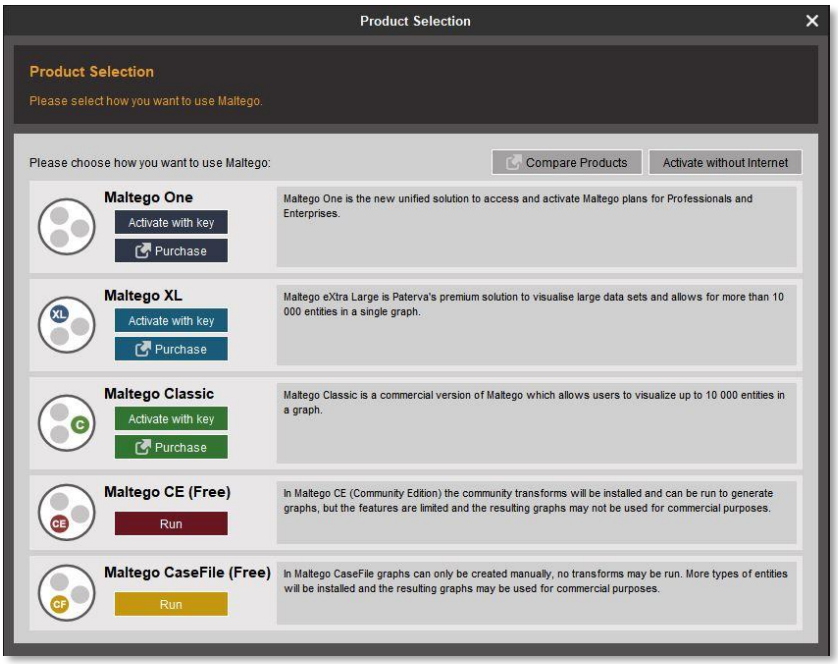
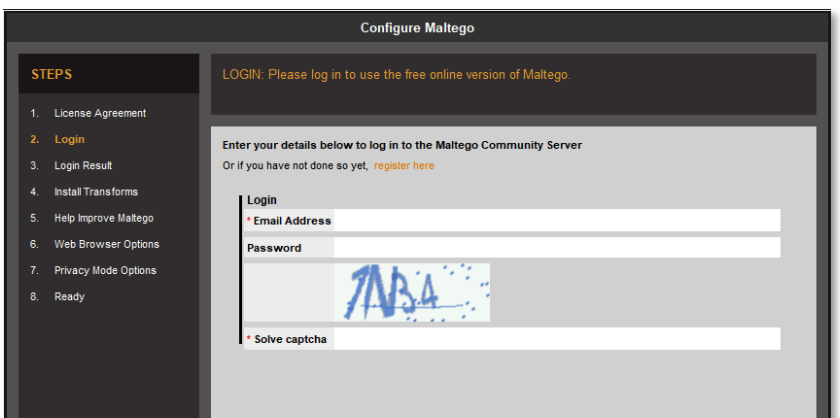


Imagen 53. Elección del producto de Maltego a utilizar



Maltego tiene una serie de transformadas que hacen referencia a un conjunto de operaciones que permiten realizar cualquier tipo de acción con una entidad, consultando diversas fuentes conectadas al propio Maltego. En la Imagen 54 se pueden ver algunas de las fuentes que Maltego tiene preconfiguradas para su uso.

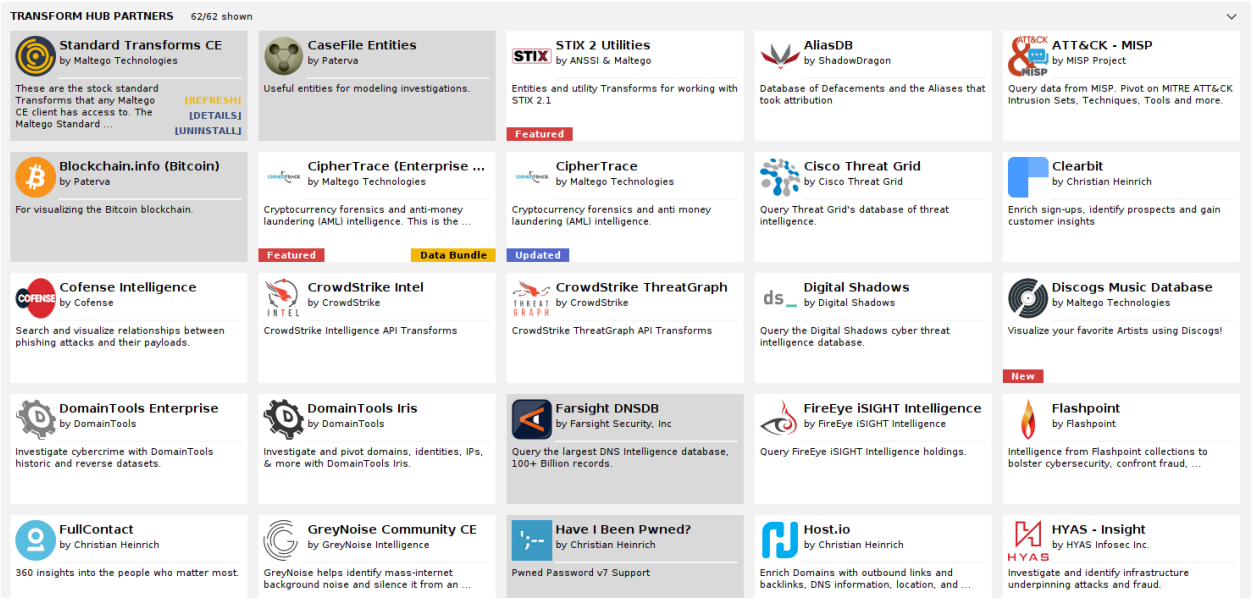


Imagen 54. Transformadas de Maltego

Para poder trabajar con cada fuente será necesario disponer de una API, donde podremos integrarla fácilmente dentro de Maltego para poder consumir los datos recibidos de cada fuente. En la Imagen 55 se puede observar el asistente típico de Maltego para integrar las fuentes, en este caso de Shodan. Por medio de esta integración seremos capaces de acceder a Shodan para consultar diversos datos por medio de sus transformadas.

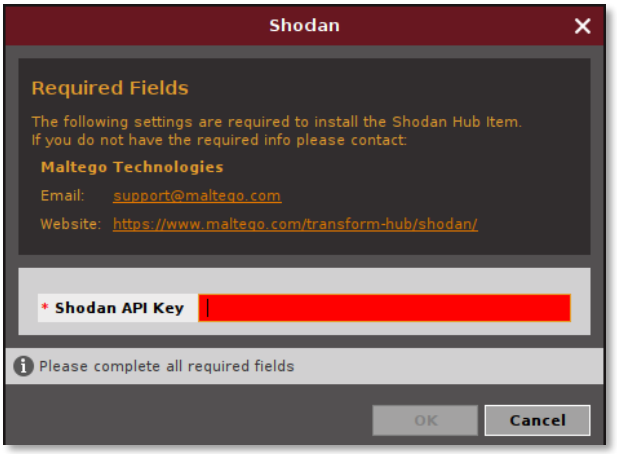


Imagen 55. Integración de Shodan con Maltego mediante su API

La ejecución de las transformadas tiene tres niveles, siendo los siguientes:

- **Nivel superior de transformadas**. En dicho nivel es donde se listan los diferentes elementos instalados dentro del *Transform Hub* a nivel general cuando desplegamos el menú de transformadas. En la Imagen 56 puede verse un resumen de que es cada elemento.

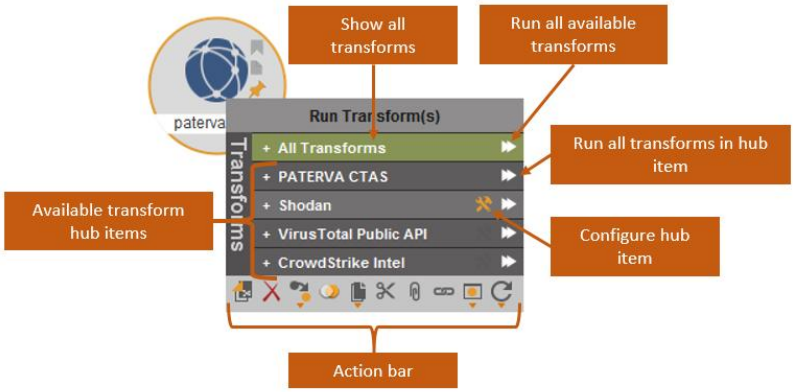


Imagen 56. Nivel superior de transformadas

- **Segundo nivel de transformadas**. Haciendo clic con el botón izquierdo del ratón en un elemento del *Transform Hub* se accede al nivel del conjunto. Dentro de este nivel disponemos de las transformadas a nivel general y agrupadas por categorías de transformadas que realicen tareas similares. En la Imagen 57 puede verse un resumen de que es cada elemento.

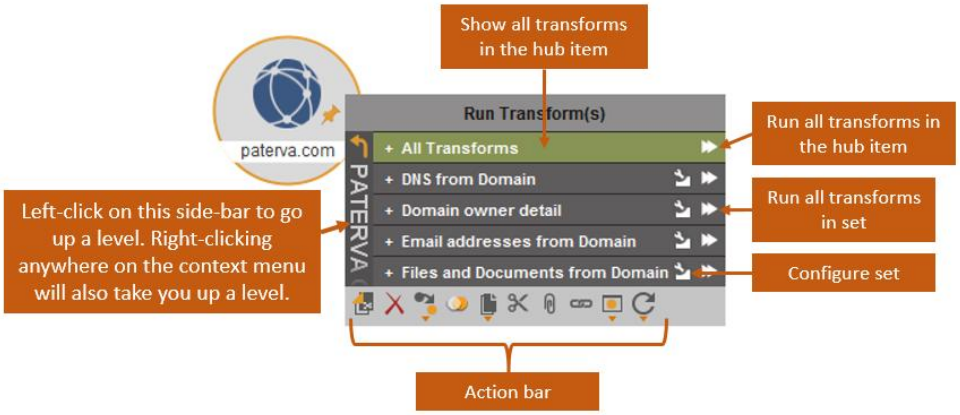


Imagen 57. Segundo nivel de transformadas

- **Último nivel de transformadas**. En este nivel finalmente es donde se ejecutan las transformadas a un nivel mucho más individual utilizando una fuente o una tarea concreta. En la Imagen 58 puede verse un resumen de que es cada elemento.

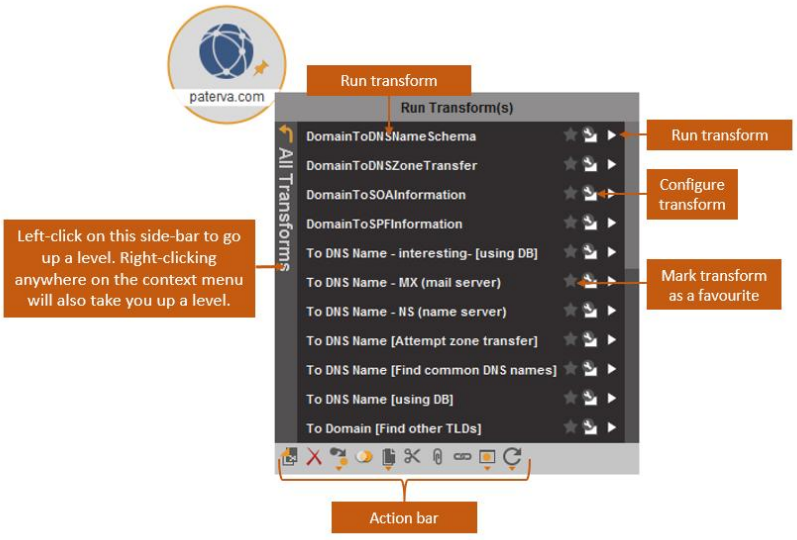


Imagen 58. Último nivel de transformadas

Maltego nos permite investigar diferentes tipos de datos y sus relaciones, las más importantes son las siguientes:

- Criptomonedas (Bitcoins y Ethereum)

- Dispositivos
- Eventos (conversaciones por correo electrónico o teléfono, línea de tiempo, incidente, reuniones)
- Grupos (criminales, instituciones educativas, grupos online o religiosos, organizaciones, movimientos políticos)
- Infraestructura (direcciones IP, rango IP, AS, banners, dominios, ISP, URL, sitios web, certificados SSL)
- Localizaciones (aeropuertos, estaciones de tren, iglesias, ciudad, país, región, escenas de crímenes, prisiones, punto GPS, tiendas)
- Malware (Hashes)
- Personas (correo electrónico, username, documentos, imágenes, nombre de persona, teléfono, etc)
- Redes Sociales (tweet o hashtag, afiliación a Facebook o LinkedIn)
- Tracking (cuenta bancaria, número de vuelo, DNI, número de pasaporte, vehículos)

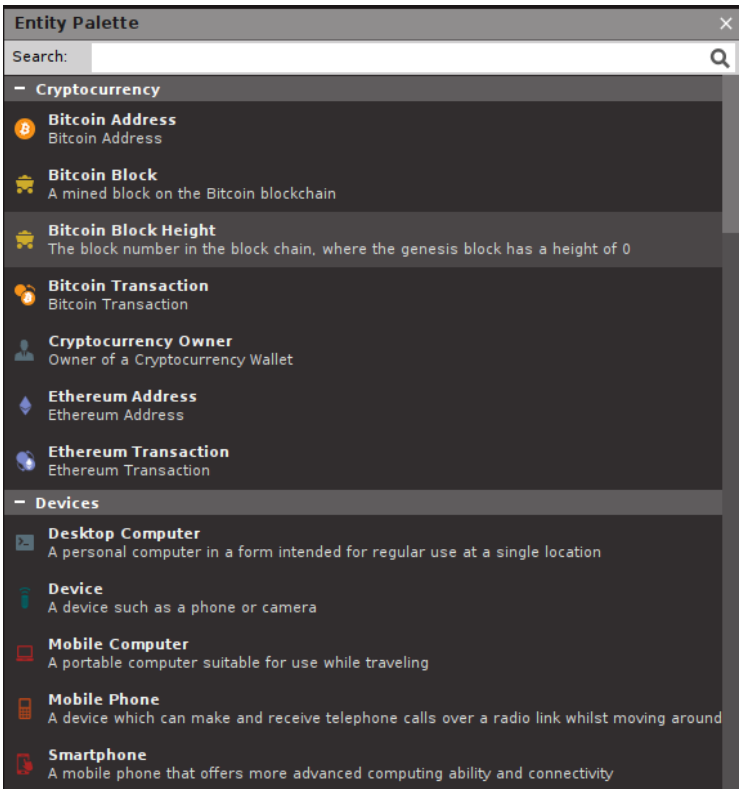


Imagen 59. Paleta de diferentes entidades para poder investigar en Maltego

En la Imagen 60 puede verse un ejemplo generado con Maltego. Además, parte de la investigación realizada en la sección 6.1.5 fue realizada con Maltego.

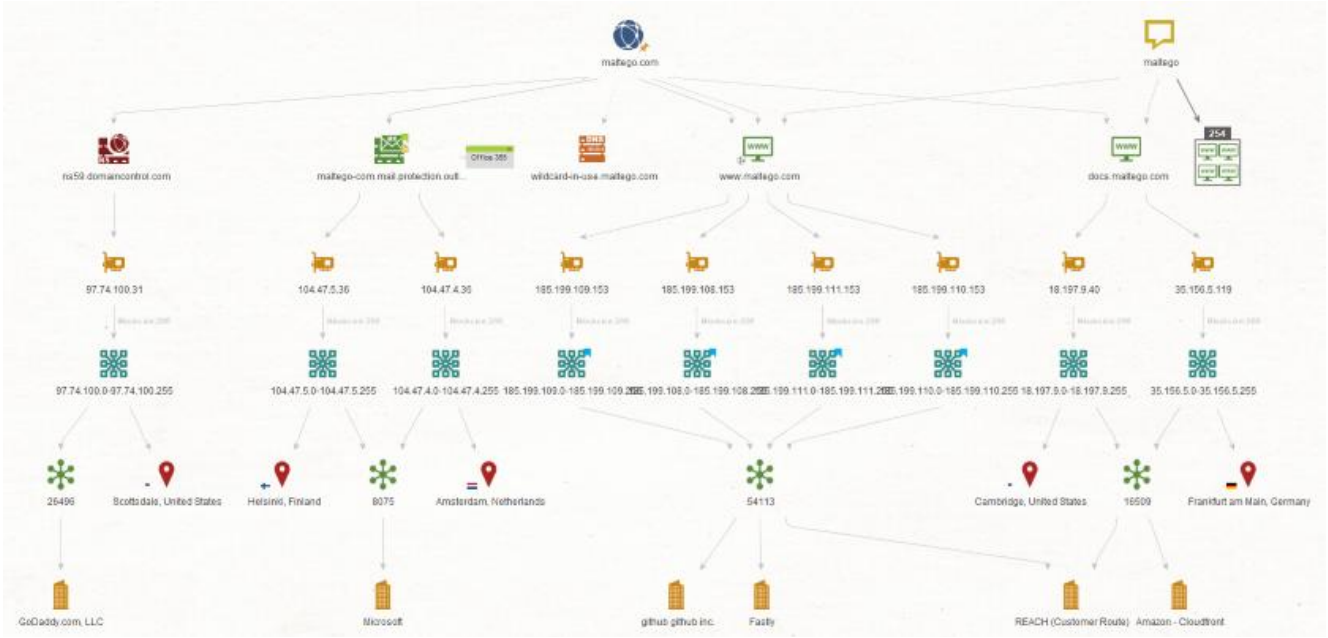


Imagen 60. Representación gráfica de resultados con Maltego

En el siguiente enlace se dispone de toda la documentación oficial de Maltego: https://docs.maltego.com/support/solutions/articles/15000008703.

1.1.22. INSTALOADER

Instaloader es una herramienta de línea de comando que permite recopilar datos asociados a un perfil público de Instagram como por ejemplo imágenes publicadas, mensajes, hashtags, stories, etc.

Instalación:
pip3 install instaloader

Ejecución:
• instaloader "#osint" → Descargar todas las coincidencias con #osint
• instaloader username → Descargar todas las imágenes e información asociada del perfil especificado.
• Instaloader @username → Descargar información sobre los perfiles seguidos por el perfil especificado.

En la Imagen 61 se ejecuta la herramienta para recolectar información sobre el hashtag osint.

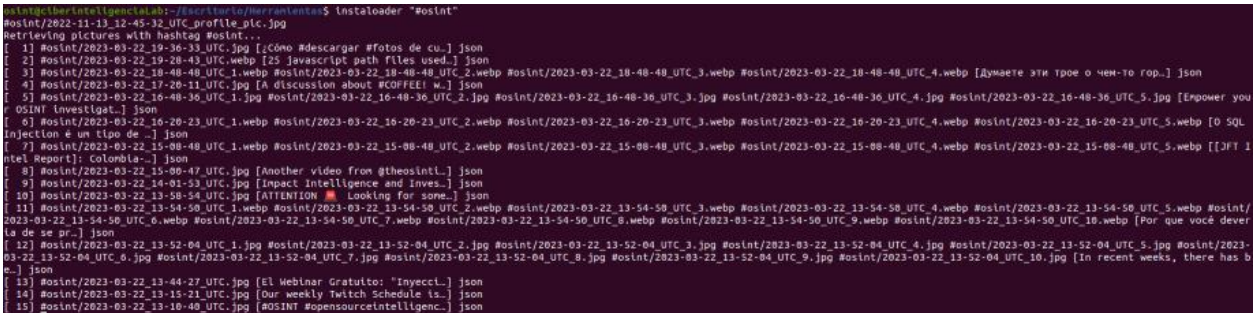


Imagen 61. Ejecución de instaloader

La herramienta descargará una copia de la imagen asociado al mensaje, el texto extraído del mensaje y el JSON original del mensaje, tal como puede observarse en la Imagen 62.

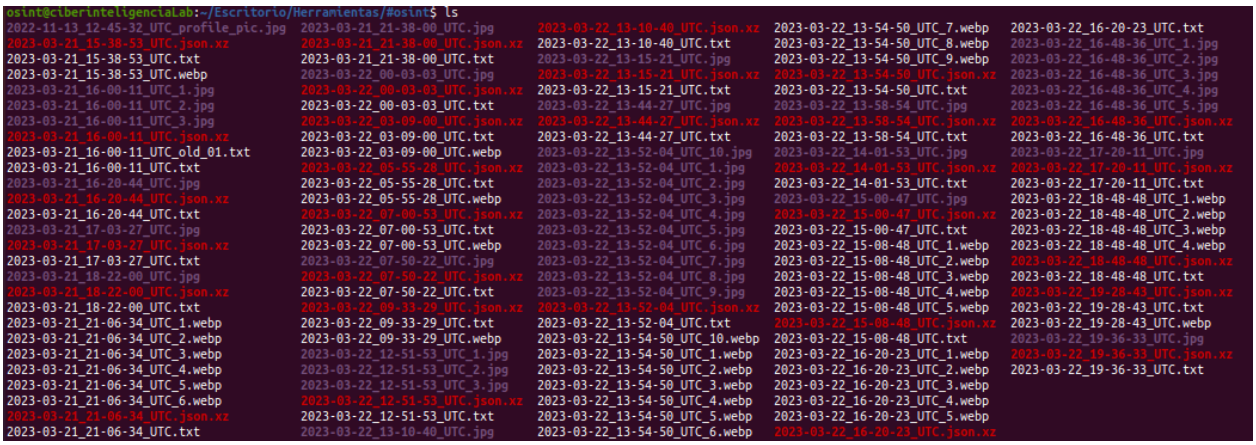


Imagen 62. Directorio de ficheros generados por instaloader

Si deseamos leer el contenido del fichero JSON, tan solo tendremos que descomprimirlo y filtrarlo con el comando "**jq**" para darle un formato legible (ver Imagen 63).



Imagen 63. Visualización de uno de los JSON generado por Instaloader

1.1.23. NAMECHK

Herramienta online que permite realizar búsquedas de un nombre de usuario en todas las redes sociales y comprobar si existen coincidencias. El enlace de acceso a la herramienta es la siguiente: https://namechk.com.

Tal como se puede ver en la Imagen 64, podemos detectar coincidencias de si el usuario ya cuenta con un perfil social en alguna red. Aquellas losetas que estén sombreadas indican que ya existe un perfil social con dicho nombre de usuario, por el contrario las de color verde indican que no existe coincidencia.

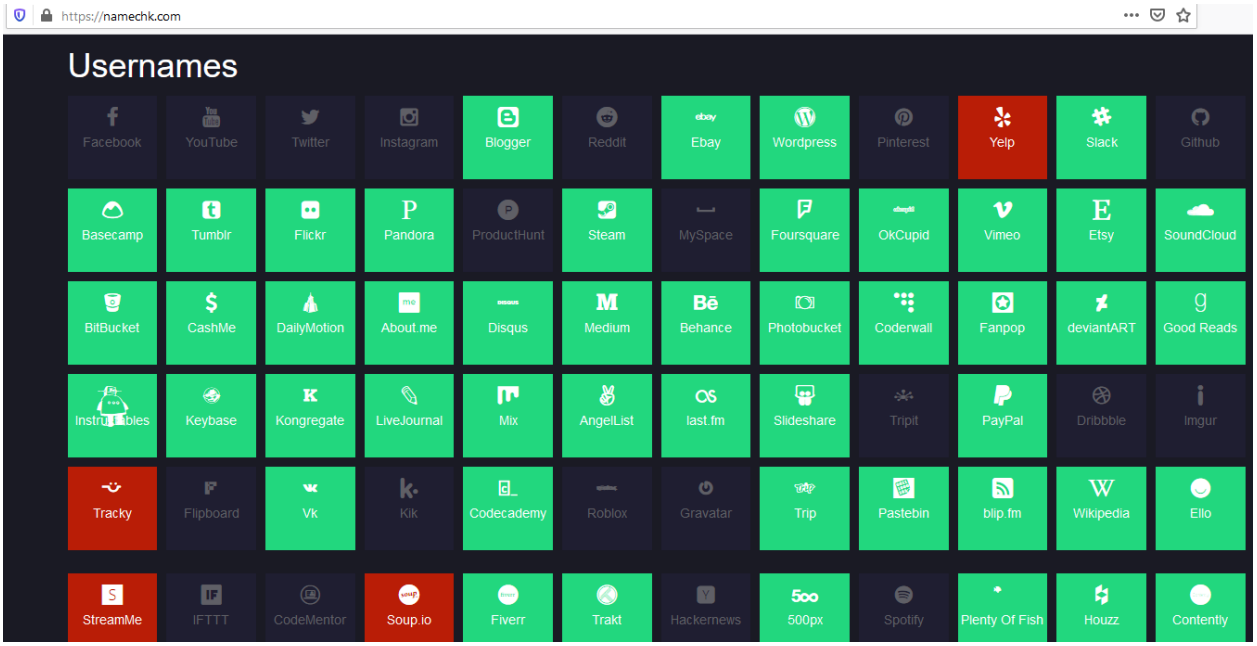


Imagen 64. Resultados ofrecidos por Namechk

1.1.24. OSRFRAMEWORK

Herramienta por línea de comando que permite obtener resultados sobre posibles perfiles sociales según una búsqueda a partir de un username, correo electrónico o nombre de persona. El enlace de acceso es el siguiente: www.github.com/i3visio/osrframework.

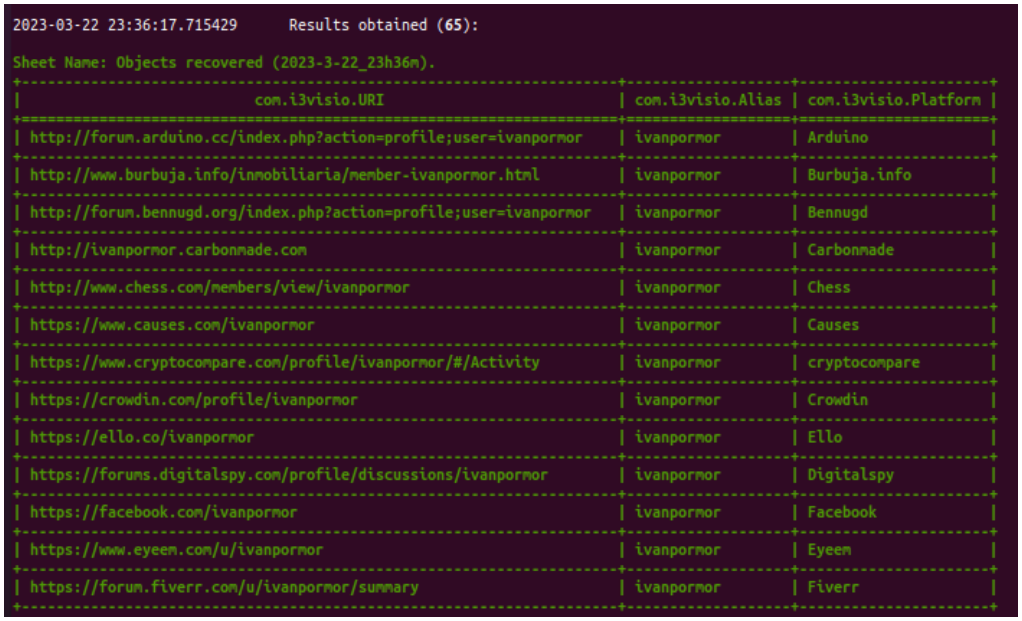
Instalación:
pip3 install osrframework

OSRFramework está compuesto por un conjunto de herramientas siendo las siguientes:

- **Usufy**. Permite verificar la existencia de un username en un total de 306 plataformas.

Comando: usufy -n "username" -p all

En la Imagen 65 pueden visualizarse los resultados generados por la ejecución de la herramienta, donde se ha partido del nombre de usuario "ivanpormor" con el objetivo de detectar la existencia del mismo usuario en otras plataformas sociales.



2023-03-22 23:36:17.715429 Results obtained (65):

Sheet Name: Objects recovered (2023-3-22_23h36m).

com.i3visio.URI	com.i3visio.Alias	com.i3visio.Platform
http://forum.arduino.cc/index.php?action=profile;user=ivanpormor	ivanpormor	Arduino
http://www.burbuja.info/inmobiliaria/member-ivanpormor.html	ivanpormor	Burbuja.info
http://forum.bennugd.org/index.php?action=profile;user=ivanpormor	ivanpormor	Bennugd
http://ivanpormor.carbonmade.com	ivanpormor	Carbonmade
http://www.chess.com/members/view/ivanpormor	ivanpormor	Chess
https://www.causes.com/ivanpormor	ivanpormor	Causes
https://www.cryptocompare.com/profile/ivanpormor/#/Activity	ivanpormor	cryptocompare
https://crowdin.com/profile/ivanpormor	ivanpormor	Crowdin
https://ello.co/ivanpormor	ivanpormor	Ello
https://forums.digitalspy.com/profile/discussions/ivanpormor	ivanpormor	Digitalspy
https://facebook.com/ivanpormor	ivanpormor	Facebook
https://www.eyeem.com/u/ivanpormor	ivanpormor	Eyeem
https://forum.fiverr.com/u/ivanpormor/summary	ivanpormor	Fiverr

Imagen 65. Resultados de usufy

- **Mailfy**. Permite verificar si un correo electrónico está siendo utilizado en las siguientes 5 plataformas sociales (Infojobs, Instagram, Twitter, KeyServerUbuntu y OkCupid) y comprobará si el mismo está presente en alguna fuga de información o exposición en alguna fuente compartida.

Comando: mailfy -m correo

Además, la herramienta permite utilizar un nombre de usuario, realizar una combinatoria con diferentes servidores de correo electrónico y comprobar si existe alguna coincidencia de este en alguna fuga de información o exposición en alguna fuente compartida.

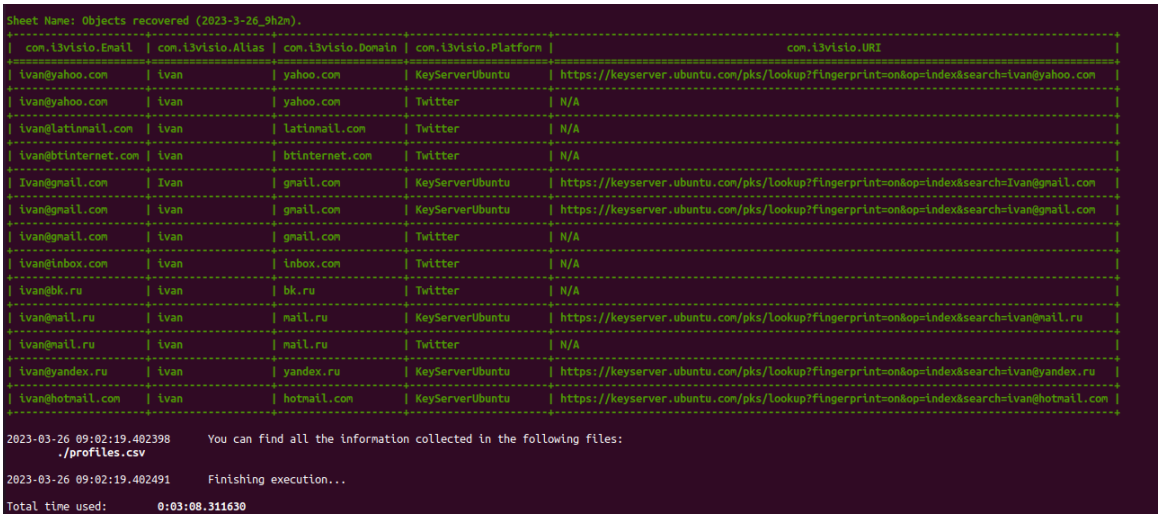
Comando: mailfy -n username -d all

En la Imagen 66 puede verse como la herramienta va realizando combinaciones entre el username facilitado (ivan) y un listado de proveedores de correo, acto seguido comprobará si el correo electrónico existe o no.



Imagen 66. Ejecución de la herramienta mailfy

En la Imagen 67 puede visualizarse el resultado de la ejecución lanzada en la Imagen 69, en el cual, se obtiene un listado de correos electrónicos, la red social donde está asociado el mismo y en algunos casos una URL de referencia.



Sheet Name: Objects recovered (2023-3-26_9h2m).

com.i3visio.Email	com.i3visio.Alias	com.i3visio.Domain	com.i3visio.Platform	com.i3visio.URI
ivan@yahoo.com	ivan	yahoo.com	KeyServerUbuntu	https://keyserver.ubuntu.com/pks/lookup?fingerprint=on&op=index&search=ivan@yahoo.com
ivan@yahoo.com	ivan	yahoo.com	Twitter	N/A
ivan@latinmail.com	ivan	latinmail.com	Twitter	N/A
ivan@btinternet.com	ivan	btinternet.com	Twitter	N/A
Ivan@gmail.com	Ivan	gmail.com	KeyServerUbuntu	https://keyserver.ubuntu.com/pks/lookup?fingerprint=on&op=index&search=Ivan@gmail.com
ivan@gmail.com	ivan	gmail.com	KeyServerUbuntu	https://keyserver.ubuntu.com/pks/lookup?fingerprint=on&op=index&search=ivan@gmail.com
ivan@gmail.com	ivan	gmail.com	Twitter	N/A
ivan@inbox.com	ivan	inbox.com	Twitter	N/A
ivan@bk.ru	ivan	bk.ru	Twitter	N/A
ivan@mail.ru	ivan	mail.ru	KeyServerUbuntu	https://keyserver.ubuntu.com/pks/lookup?fingerprint=on&op=index&search=ivan@mail.ru
ivan@mail.ru	ivan	mail.ru	Twitter	N/A
ivan@yandex.ru	ivan	yandex.ru	KeyServerUbuntu	https://keyserver.ubuntu.com/pks/lookup?fingerprint=on&op=index&search=ivan@yandex.ru
ivan@hotmail.com	ivan	hotmail.com	KeyServerUbuntu	https://keyserver.ubuntu.com/pks/lookup?fingerprint=on&op=index&search=ivan@hotmail.com

2023-03-26 09:02:19.402398 You can find all the information collected in the following files:
./profiles.csv

2023-03-26 09:02:19.402491 Finishing execution...

Total time used: 0:03:08.311630

Imagen 67. Resultados de la herramienta mailfy

- **Searchfy**. Permite verificar la existencia de perfiles en redes sociales a través del nombre completo de una persona.

Comando: searchfy -q “nombre persona”

En la Imagen 68 pueden visualizarse los resultados generados por la ejecución de la herramienta, donde se ha partido del nombre de persona “ivan portillo” con el objetivo de detectar si dicho nombre completo está presente en alguna red social.

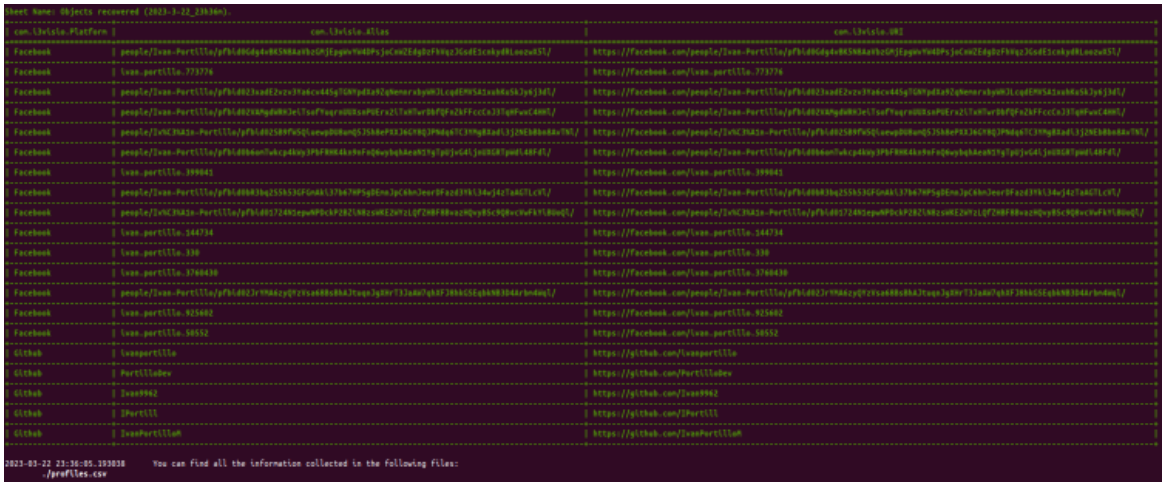


Imagen 68. Resultado de searchfy

- **alias_generator**. Permite generar un listado de posibles nombres de usuario partiendo de una serie de datos que solicita la herramienta.

Comando: alias_generator

En la Imagen 69 puede visualizarse la ejecución de la herramienta, donde nos solicita información sobre el nombre, apellidos, un año de lo que deseemos, ciudad y país.

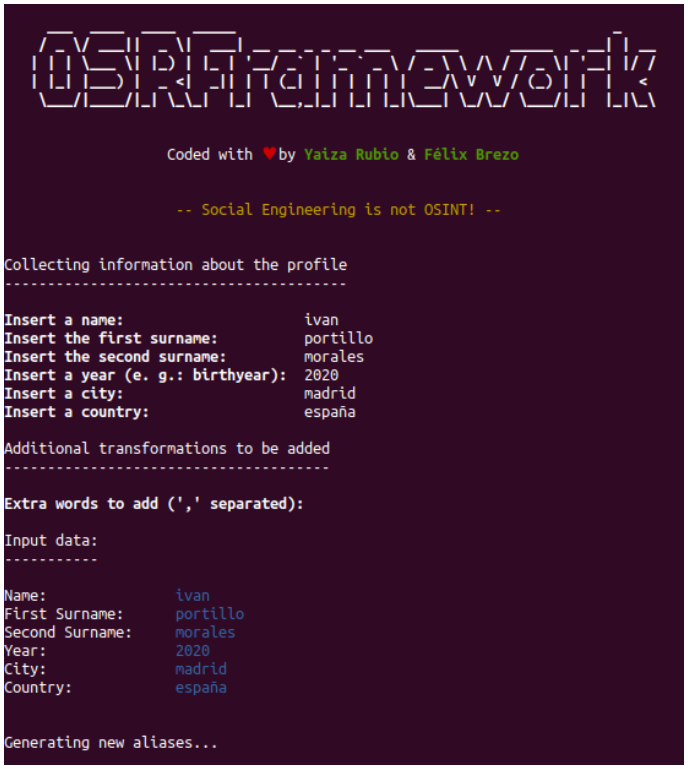


Imagen 69. Ejecución de la herramienta alias_generator

En la Imagen 70 puede verse el listado con un total de 381 nombre de usuarios generados, utilizando una combinatoria entre los datos solicitados.



Imagen 70. Resultados sobre un listado de posibles nombres de usuarios del objetivo con alias_generator

1.1.25.

1.1.26. SOCIAL SEARCHER

Social Searcher es una herramienta online que permite extraer información a partir de un hashtag, menciones, un nombre de usuario o una tendencia de redes sociales, el cual, se nutre de las siguientes fuentes: Twitter, Facebook, Instagram, Reddit, YouTube, VK, Tumblr, Vimeo, Flickr, Daylymotion y sitios web. Se trata de una herramienta de pago pero dispone de una versión gratuita más limitada. El enlace de acceso a Social Searcher es el siguiente: https://www.social-searcher.com/.

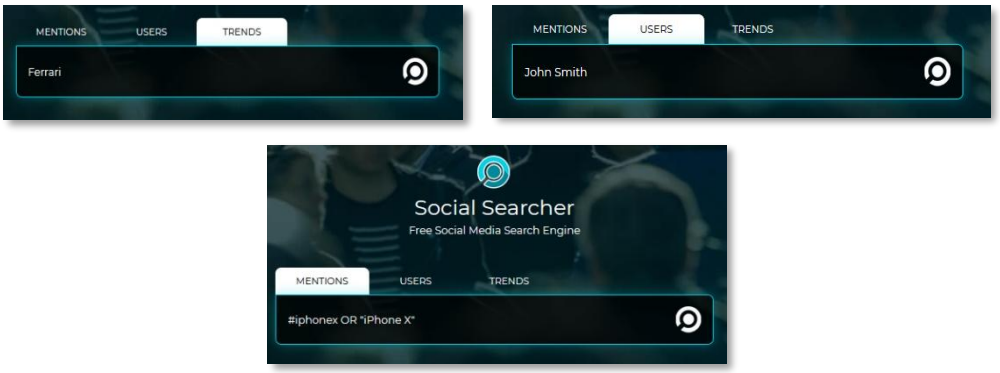


Imagen 71. Sitio oficial de Social Searcher

Realizando una monitorización del hashtag "#ransomware" detectamos las estadísticas que pueden visualizarse en las Imágenes 72, 73 y 74, relacionados con el número total de mensajes por cada red social, hashtags más utilizados, enlaces compartidos y usuarios más populares.



Imagen 72. Resultados de post publicados relacionados con la palabra clave objetivo con Social Searcher

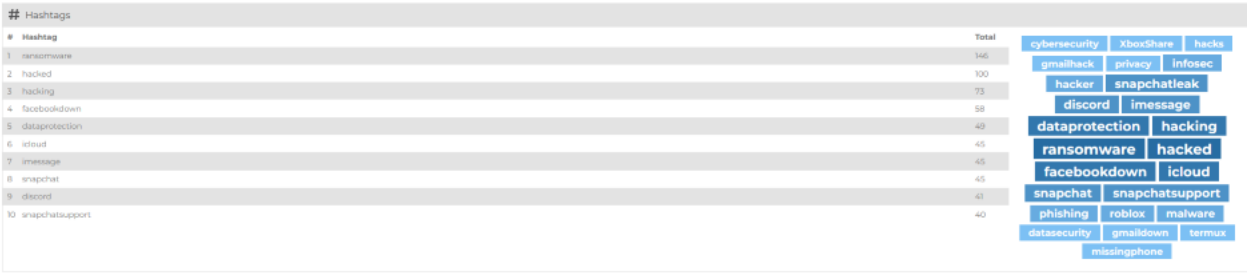


Imagen 73. Resultados de los hashtags detectados en los post sobre la palabra clave objetivo con Social Searcher

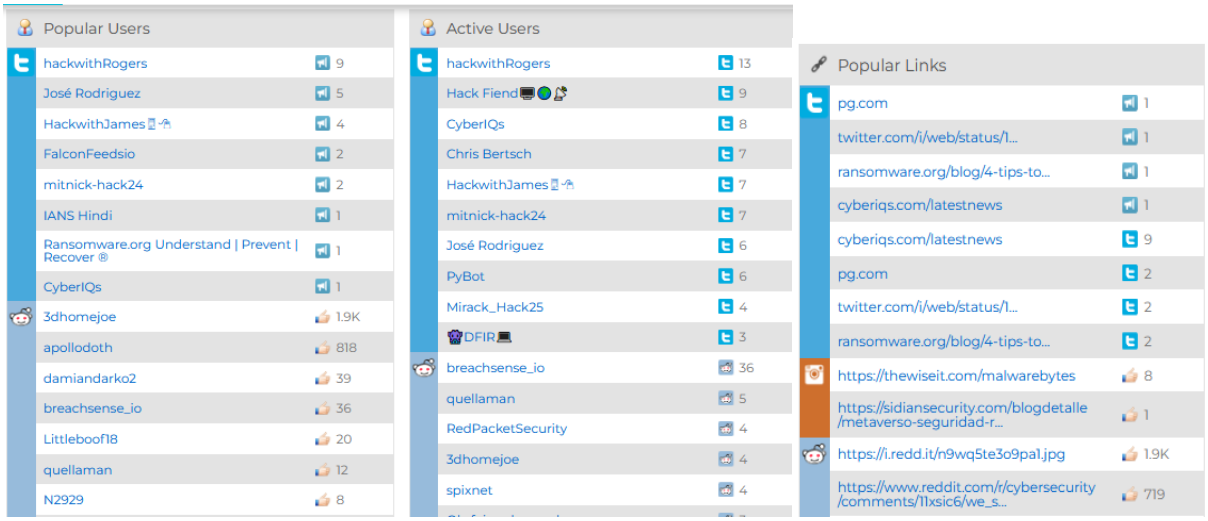


Imagen 74. Links y usuarios más destacados en la monitorización de la palabra clave objetivo con Social Searcher

En la Imagen 75 es posible visualizar cada uno de los mensajes de las distintas redes sociales, pudiendo descargar su contenido con una exportación en CSV por medio del botón “MORE” de la esquina superior derecha.

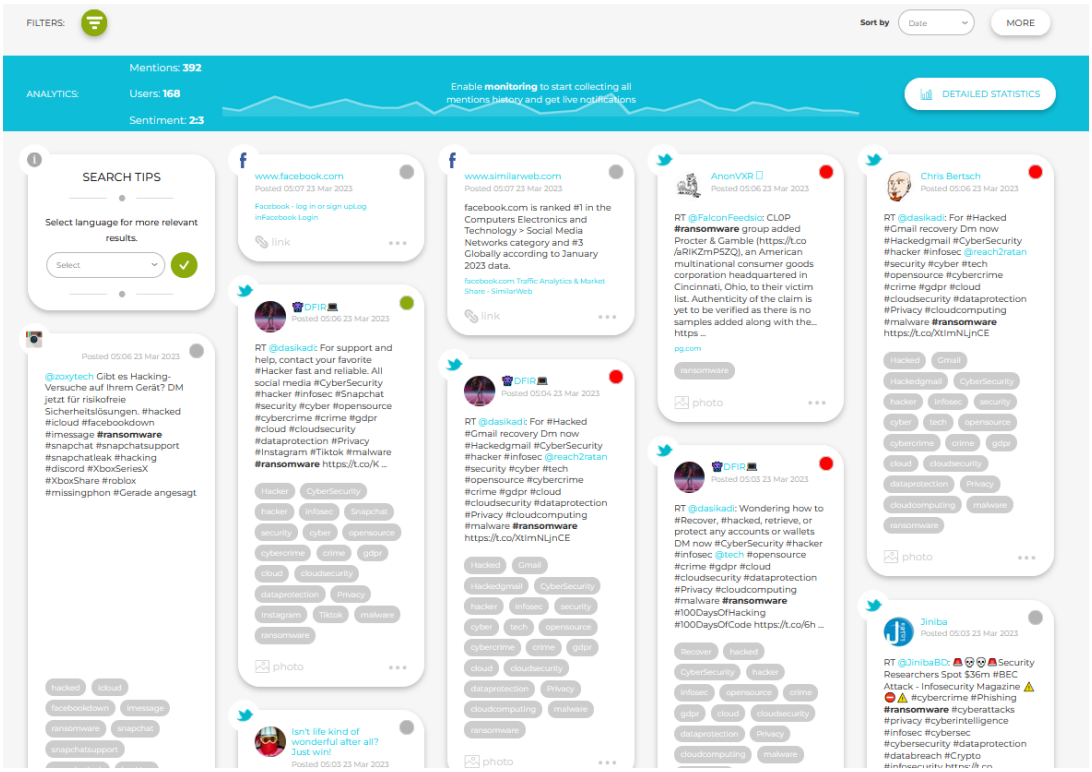


Imagen 75. Vista general de resultados

1.1.27. SOCIAL BEARING

Social Bearing es una herramienta online que permite extraer información de Twitter, partiendo de una palabra clave, un hashtag, un nombre de usuario, una geolocalización, seguidores y seguidos de un perfil en concreto. Se trata de una herramienta gratuita que necesita permiso para acceder a una cuenta de Twitter para poder descargar la información. El enlace de acceso a Social Searcher es el siguiente: https://socialbearing.com/.

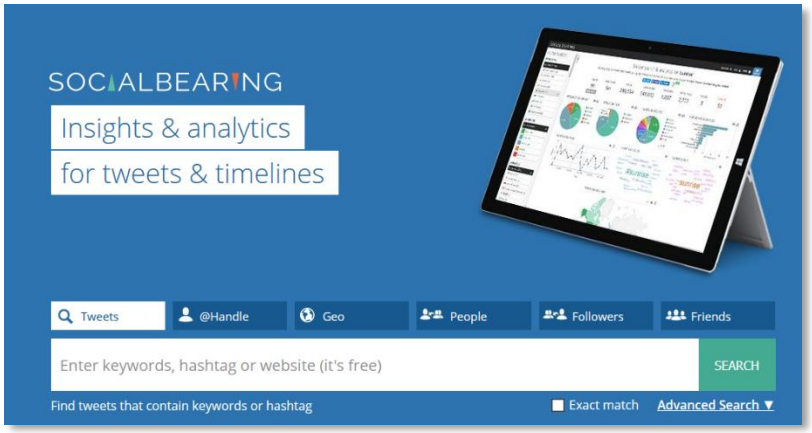
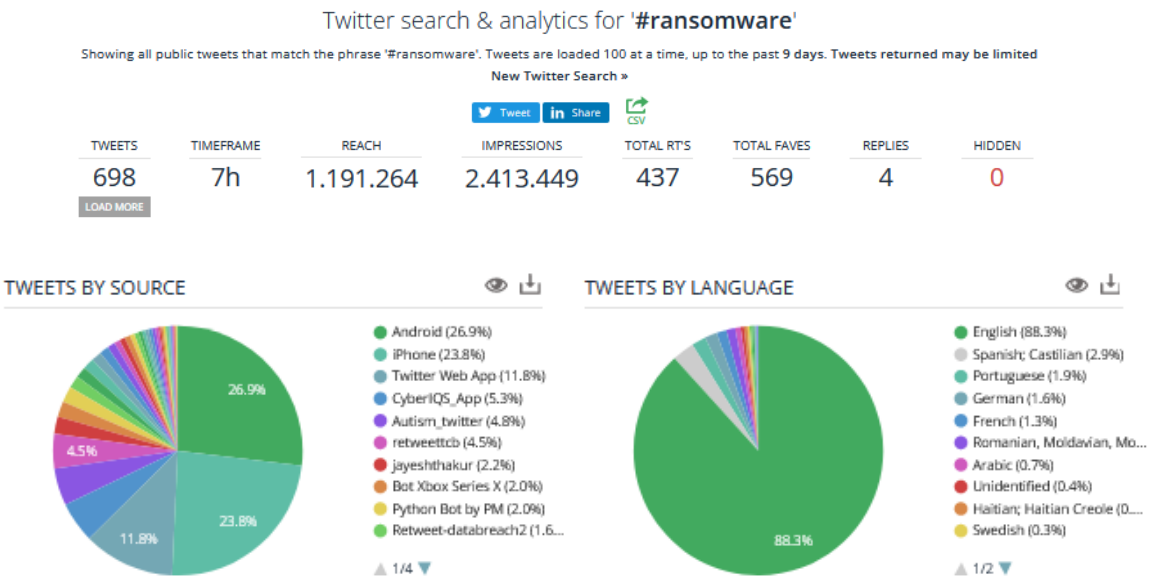


Imagen 76. Sitio oficial de Social Bearing

Realizando una monitorización del hashtag "#ransomware" y extrayendo un total de 698 tweets, detectamos las estadísticas que pueden visualizarse en la Imagen 77, donde es posible obtener los tipos de tweets, el sentimiento, idioma del tweet, top 10 de dominios compartidos, timeline de tweets y nube de palabras a destacar.



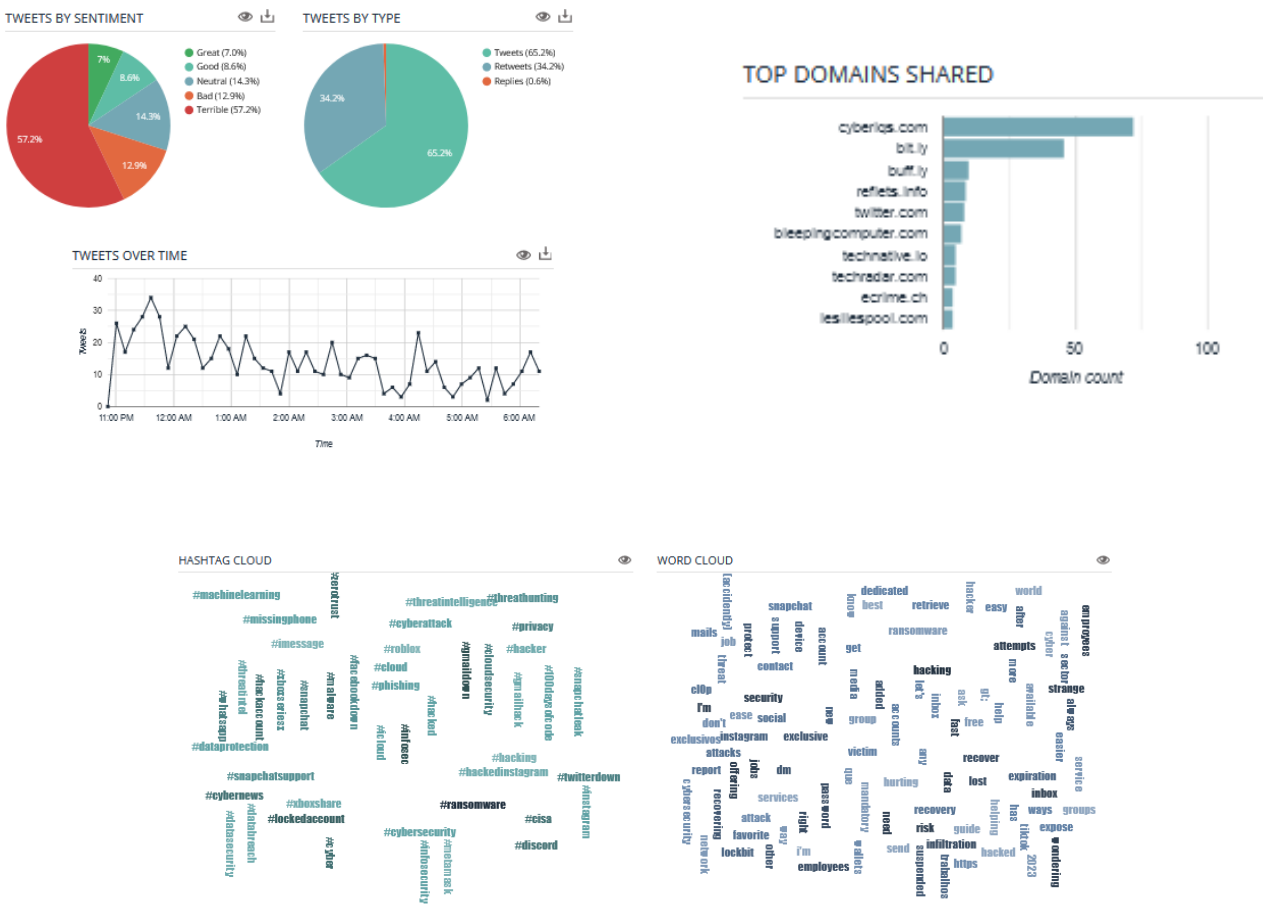


Imagen 77. Resumen a modo estadísticas de los datos recolectados por Social Bearing

En la Imagen 78 puede visualizarse una serie de filtros que pueden ser utilizados para ir al detalle en la monitorización, como por ejemplo filtrar por tipo de tweet (videos, enlaces, menciones, retweets, geolocalización, etc), sentimiento, idioma, top influencers o top contribuidores.

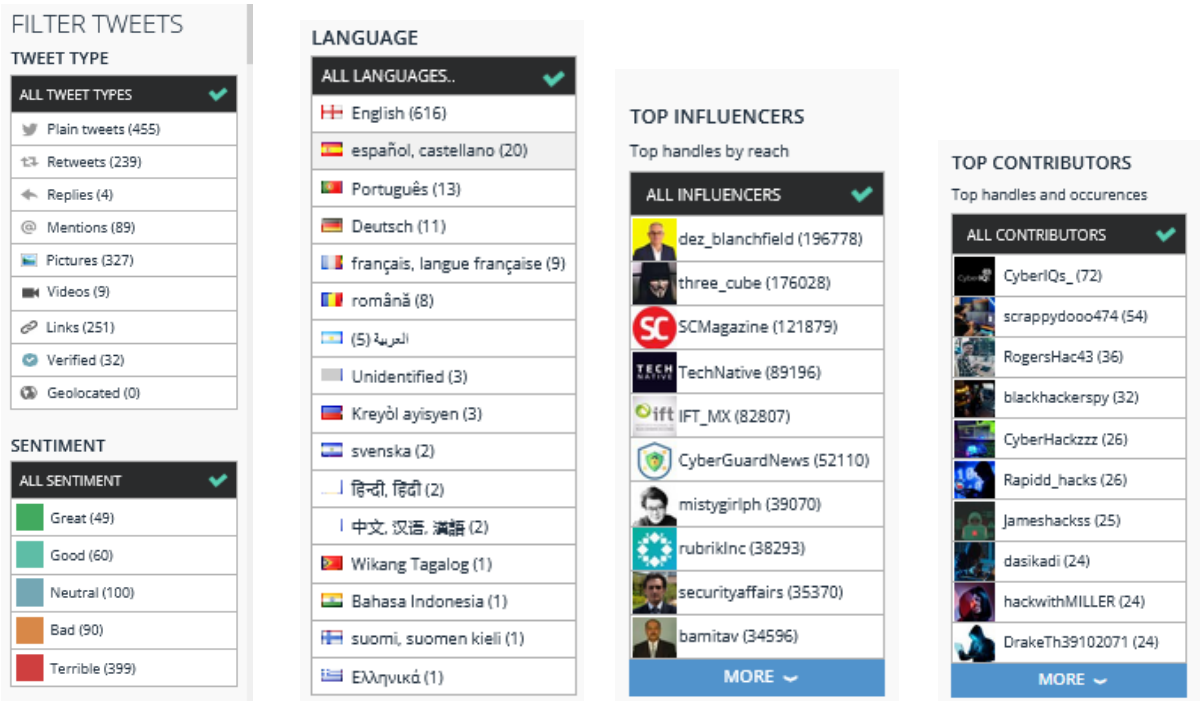


Imagen 78. Diferentes filtros disponibles con Social Bearing sobre una monitorización concreta

En la Imagen 79 es posible visualizar cada uno de los tweets detectados, pudiendo descargar su contenido con una exportación en CSV si se desea.

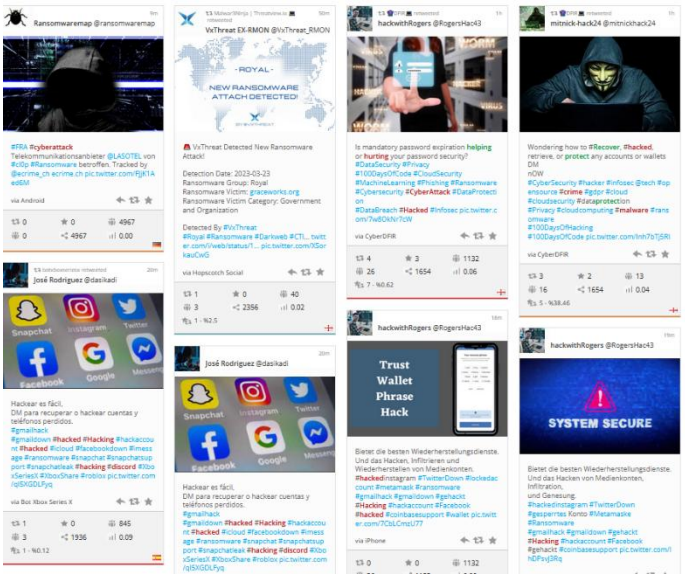


Imagen 79. Vista general de tweets detectados con Social Bearing

1.1.28. EMAIL PERMUTATOR

Email Permutator es una herramienta online que permite realizar una combinatoria entre el nombre, apellidos, username y diferentes proveedores de correos electrónico para obtener un listado de posibles correos electrónicos. El acceso a Email Permutator es el siguiente enlace: http://metricsparrow.com/toolkit/email-permutator/#

En la Imagen 80 puede verse una ejecución de la herramienta, obteniendo un total de 138 correos electrónicos basados en una combinatoria de los parámetros de entrada.

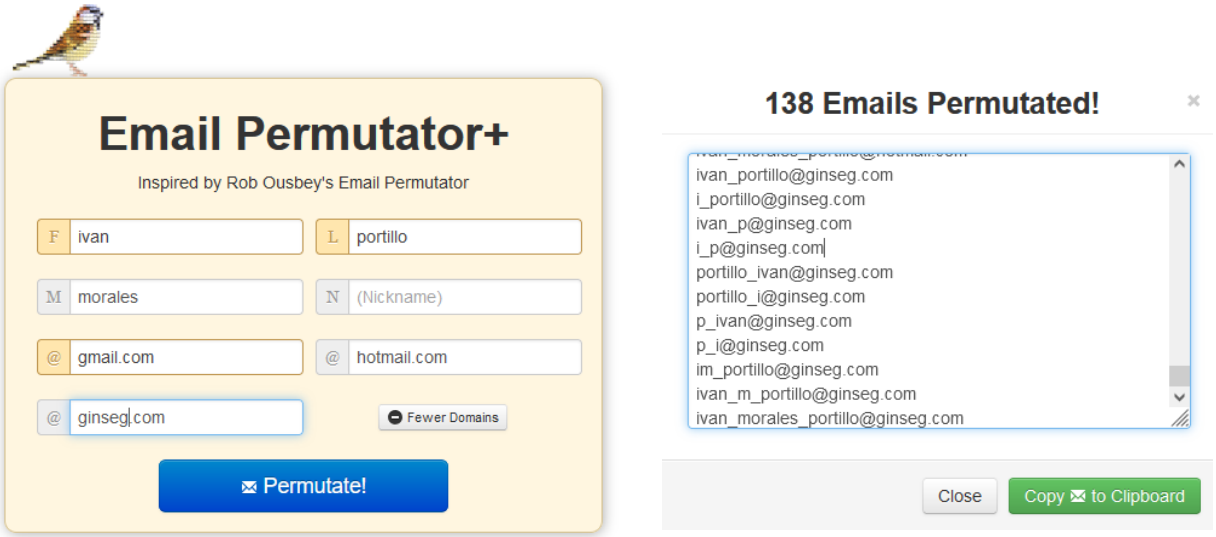


Imagen 80. Listado de correos electrónicos obtenidos con Email Permutator

1.2. PROCEDIMIENTO DE INVESTIGACIÓN DE NOMBRES DE USUARIO

Tal como hemos comentado al principio de este tema es bastante importante contar con una metodología para obtener de una manera guiada toda la información sobre nuestro objetivo. En la Imagen 81 se puede ver en líneas generales un procedimiento para investigar un nombre de usuario o username. En este caso partiendo de un nombre de usuario podríamos realizar las siguiente acciones:

- Comprobar si el nombre de usuario existe en las diversas redes sociales
- Comprobar si utilizando el username junto con proveedores de correo electrónico somos capaces de identificar un correo válido
- Realizar peticiones a los diferentes buscadores mediante dorks para detectar cualquier tipo de información relacionada
- Construir URLs de redes sociales utilizando el username
- Comprobar si el nombre de usuario está presente en alguna fuga de información

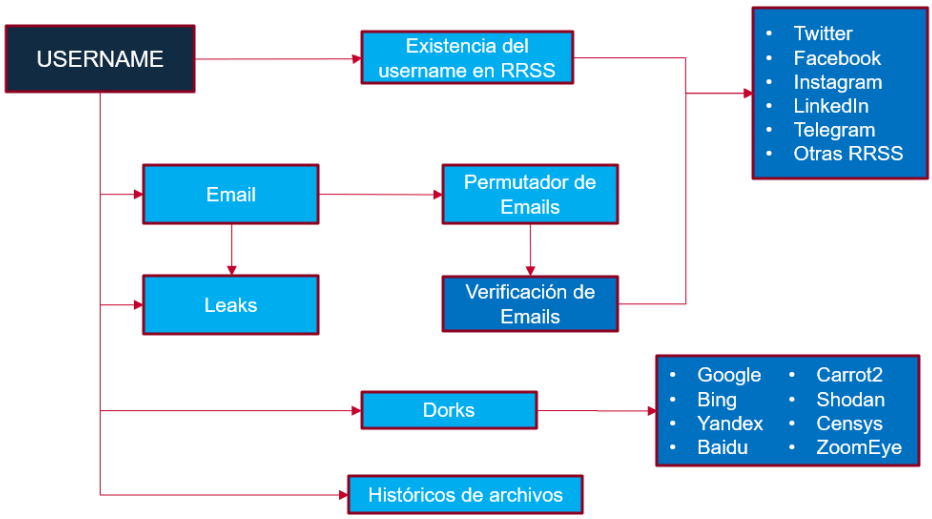


Imagen 81. Diagrama general del procedimiento de investigación de un nombre de usuario

Si hacemos un poco de zoom ahora, podemos comprobar cómo somos capaces de verificar la existencia de un nombre de usuario con herramientas específicas, utilizando para ello recursos para detectarlo tanto de manera individual con cada red social y a nivel

más generalista con multiplataformas sociales. Todo lo comentado puede ser visualizado más gráficamente en la Imagen 82.

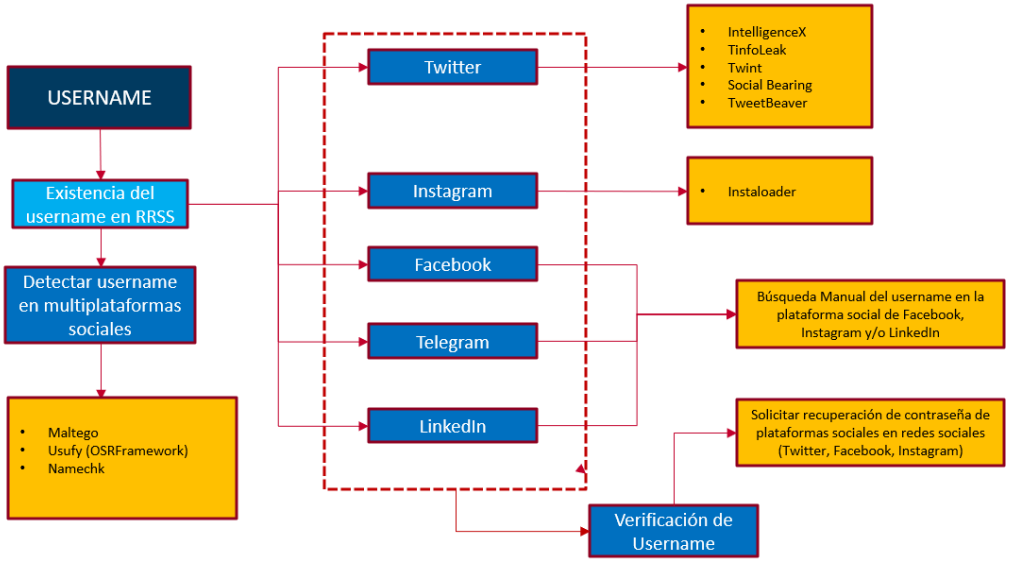


Imagen 82. Procedimiento de investigación de username en detalle 1

En el caso que se quiera utilizar la técnica de recuperación de contraseña (en algunas ocasiones puede permitir detectar algún digito del número de teléfono y del correo electrónico asociados al perfil social), hay que tener presente que en algunas redes sociales es posible que se envíe una notificación sobre que se está solicitando un cambio de contraseña. Esto supondría un riesgo para la investigación ya que le estaríamos dando pistas al objetivo de que le estamos investigando. Una recomendación con este tipo de técnicas (y a nivel general) es ejecutar siempre primero todas las técnicas (ya sea de manera manual o con automatizaciones) con perfiles sociales que estén bajo nuestro poder, de esta forma podremos comprobar si existe algún tipo de riesgo o no. Ahora mismo con la única red social que tenemos altas garantías que eso no ocurra es con Twitter.

Si hacemos otro zoom por otra vía de investigación, podemos realizar una combinatoria del username con diferentes proveedores de correo electrónico o bien con el dominio de nuestro objetivo. En este caso obtendríamos un listado de correos electrónicos sin validar, cosa que sería lo siguiente a realizar: una verificación de estos. En el momento que

tengamos una lista validada de correos electrónicos podríamos investigar si están presentes en algún Data Leak o bien comprobar si el nombre de usuario ha sido filtrado en alguno. Por otro lado, sería posible realizar diferentes consultas en los distintos buscadores para intentar localizar información relevante, al igual que buscar en históricos de archivos web como se ha comentado anteriormente. En la Imagen 83 puede verse lo comentado.

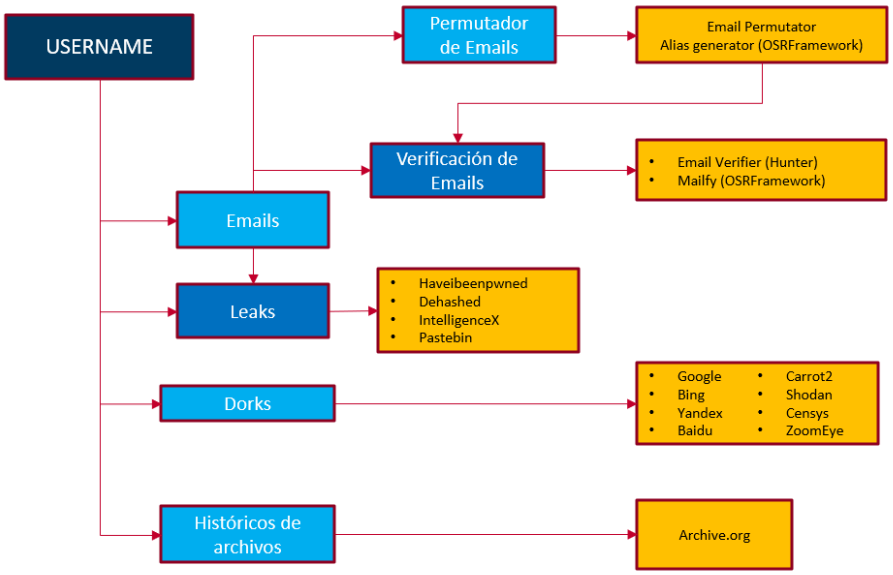


Imagen 83. Procedimiento de investigación de username en detalle 2

1.3. PROCEDIMIENTO DE INVESTIGACIÓN DE NOMBRES DE PERSONAS

Tal como hemos visto en el procedimiento de un nombre de usuario, podemos realizar la misma operativa con un nombre de persona. Dicho procedimiento tiene bastantes similitudes con el procedimiento del nombre de usuario. En la Imagen 84 se puede ver en líneas generales dicho procedimiento, donde en este caso partiremos de un nombre completo para efectuar la investigación. Las diferentes acciones que podemos ejecutar son las siguientes:

- Comprobar si el nombre y apellidos de la persona objetivo están relacionados con un perfil de alguna red social
- Comprobar si realizando una combinatoria del nombre y apellidos junto con proveedores de correo electrónico somos capaces de identificar un correo válido
- Realizar peticiones a los diferentes buscadores mediante dorks para detectar cualquier tipo de información relacionada
- Comprobar si el nombre y apellidos de la persona están presentes en alguna fuga de información

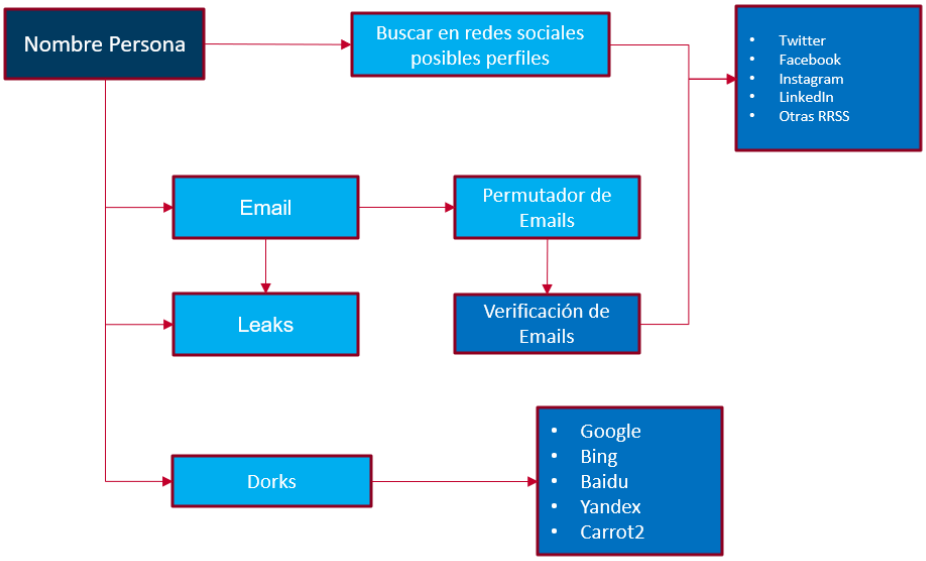


Imagen 84. Procedimiento de investigación de un nombre de persona

Si hacemos un poco de zoom ahora, podemos comprobar cómo somos capaces de verificar la existencia de un nombre de persona con herramientas específicas, utilizando para ello recursos para detectarlo tanto de manera individual con cada red social y a nivel más generalista con multiplataformas sociales. Todo lo comentado puede ser visualizado más gráficamente en la Imagen 85.

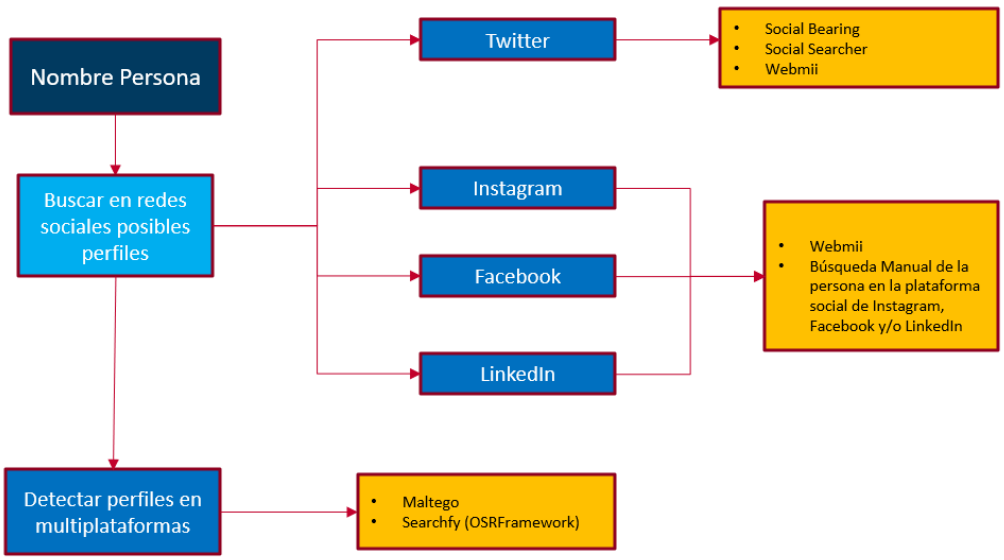


Imagen 85. Procedimiento de investigación de nombre de persona en detalle 1

Si hacemos otro zoom por otra vía de investigación, podemos realizar una combinatoria del nombre de persona con el nombre y apellidos con diferentes proveedores de correo electrónico o bien con el dominio de nuestro objetivo. En este caso obtendríamos un listado de correos electrónicos sin validar, cosa que sería lo siguiente a realizar: una verificación de estos. En el momento que tengamos una lista validada de correos electrónicos podríamos investigar si están presentes en algún Data Leak o bien comprobar si el nombre y apellidos han sido filtrados en alguno. Por otro lado sería posible realizar diferentes consultas en los distintos buscadores para intentar localizar información relevante, al igual que buscar en históricos de archivos como se ha comentado anteriormente. En la Imagen 86 puede verse lo comentado.

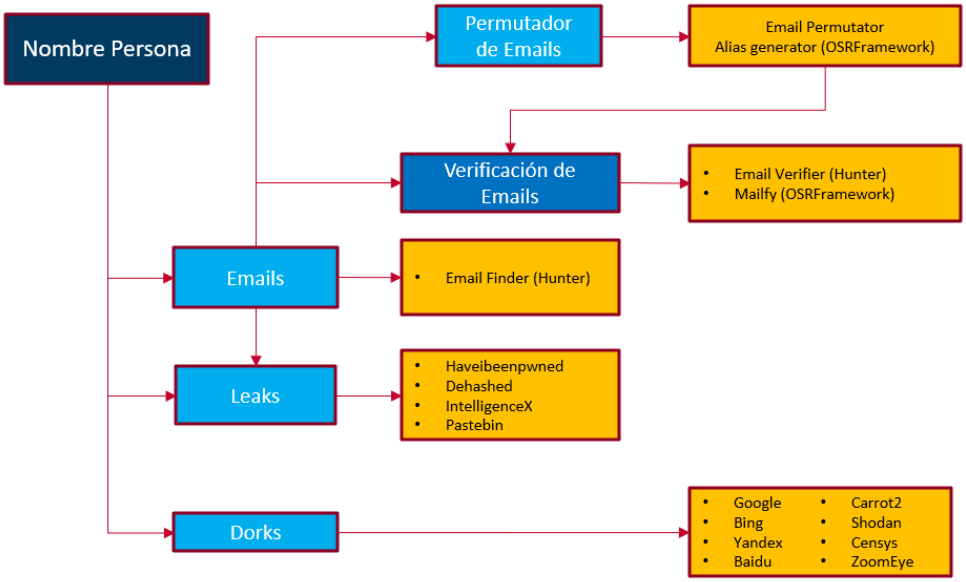


Imagen 86. Procedimiento de investigación de nombre de persona en detalle 2

1.4. PROCEDIMIENTO DE INVESTIGACIÓN DE DOMINIOS

Tal como hemos visto en los procedimientos anteriores, podemos realizar la misma operativa con un dominio. En la Imagen 87 se puede ver en líneas generales dicho procedimiento, donde en este caso partiremos de un dominio para efectuar la investigación. Las diferentes acciones que podemos ejecutar son las siguientes:

- Comprobar la dirección IP detrás del dominio objetivo
- Obtener registros DNS asociados al dominio objetivo
- Obtener el whois del dominio objetivo
- Realizar peticiones a los diferentes buscadores tanto genéricos como especializados mediante dorks para detectar cualquier tipo de información relacionada
- Comprobar si el dominio objetivo tiene muestras o URLs maliciosas asociadas
- Obtener históricos webs del dominio objetivo
- Obtener correos electrónicos relacionados con el dominio objetivo
- Comprobar si el dominio ha sido filtrado en alguna fuga de información

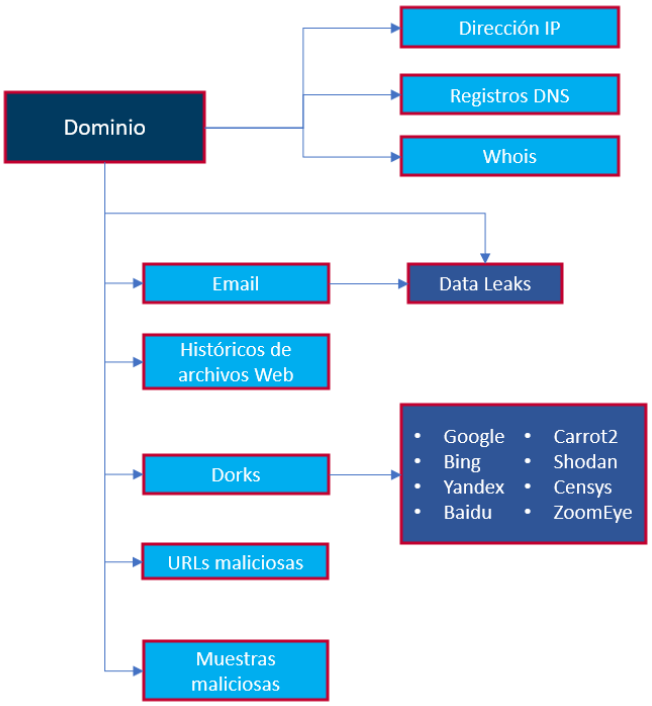


Imagen 87. Procedimiento de investigación de un dominio

Podemos aplicar distintas técnicas para recopilar información relacionados con la dirección IP, los registros DNS, el whois o muestras maliciosas que estén asociados con el dominio objetivo, utilizando para ello herramientas específicas. Todo lo comentado puede ser visualizado más gráficamente en la Imagen 88.

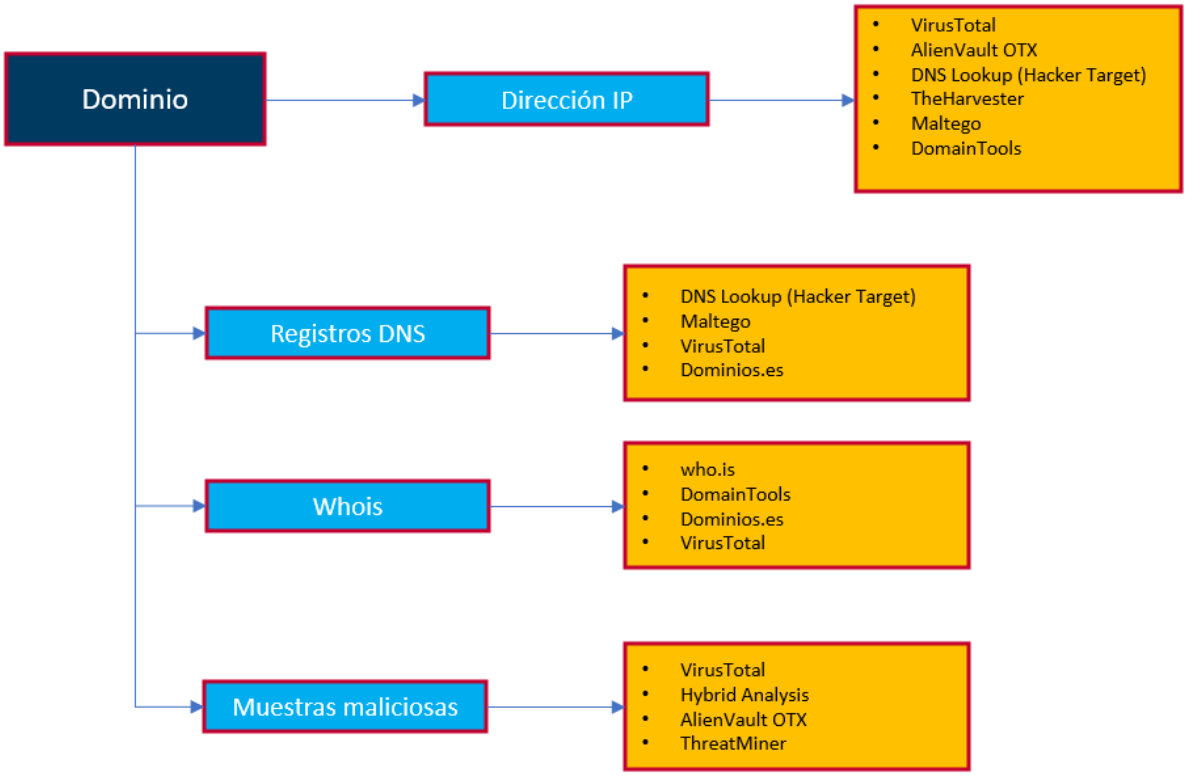


Imagen 88. Procedimiento de investigación de un dominio en detalle 1

Si hacemos otro zoom por el resto de vías de investigación, podemos descubrir que somos capaces de obtener más información partiendo de un dominio, como por ejemplo consultando en buscadores genéricos y/o especializados, obtener diferentes screenshot del dominio en distintos instantes de tiempo, localizar correos electrónicos filtrados en alguna fuente publica o bien en data leaks de cualquier tipo y por último detectar URLs maliciosas empleando herramientas enfocadas en Inteligencia de amenazas. En la Imagen 89 puede verse gráficamente lo comentado.

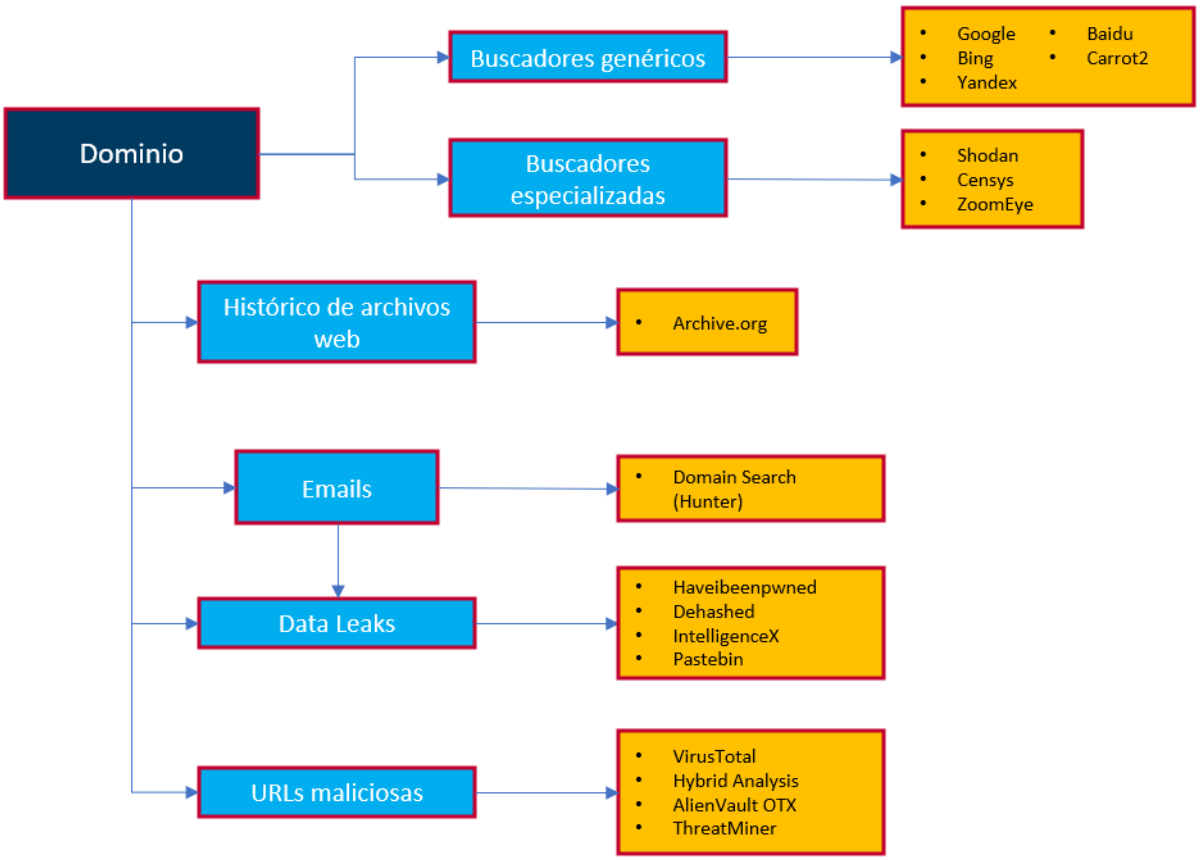


Imagen 89. Procedimiento de investigación de un dominio en detalle 2

1.5. PROCEDIMIENTO DE INVESTIGACIÓN DE CORREOS ELECTRÓNICOS

Tal como hemos visto en los procedimientos anteriores, podemos realizar la misma operativa con un correo electrónico. En la Imagen 90 se puede ver en líneas generales dicho procedimiento, donde en este caso partiremos de un correo electrónico para efectuar la investigación. Las diferentes acciones que podemos ejecutar son las siguientes:

- Comprobar si el correo electrónico está presente en alguna fuga de información
- Obtener el nombre de usuario de alguna red social que este asociado al correo electrónico
- Obtener el nombre de persona con nombre y apellidos asociados al correo electrónico
- Verificar si el correo electrónico es válido

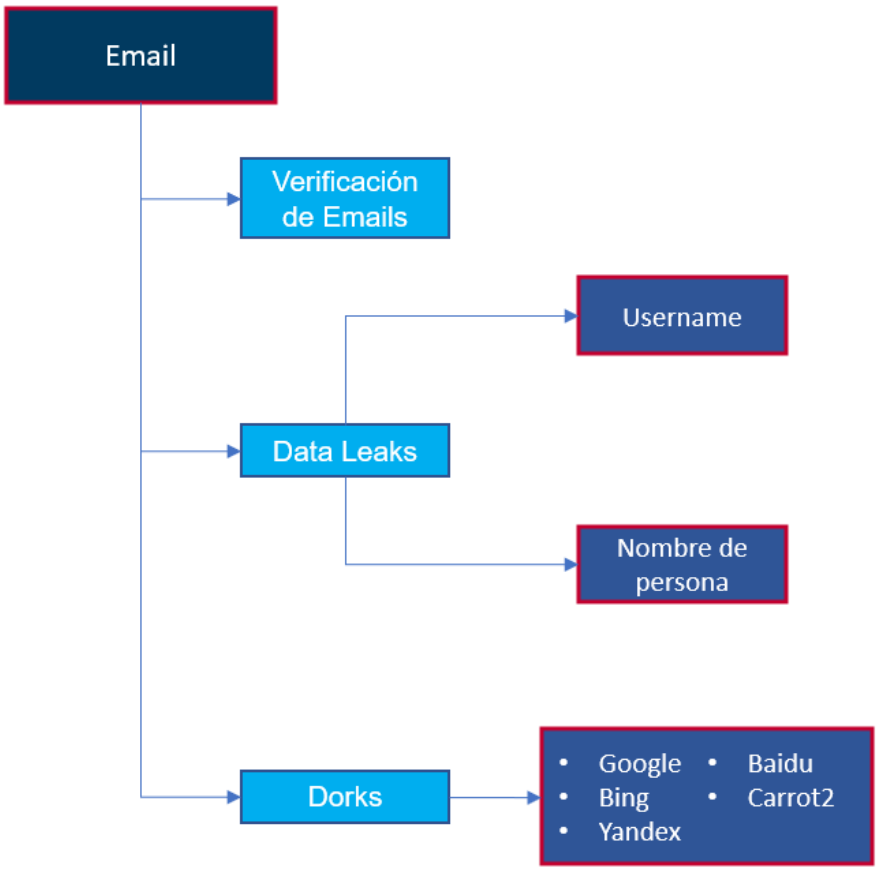


Imagen 90. Procedimiento de investigación de un correo electrónico

Para obtener información relacionado a un correo electrónico disponemos de algunas técnicas para ello, como por ejemplo la validación del propio correo electrónico, realizar consultas en buscadores genéricos, comprobar si hay coincidencias con alguna fuga de información y realizar búsquedas en dichas fugas con el fin de detectar posibles nombres de usuario o de nombres y apellidos. Por último, comprobar si el correo electrónico está relacionado con alguna amenaza consultando herramientas específicas para ello. Todo lo comentado puede ser visualizado más gráficamente en la Imagen 91.

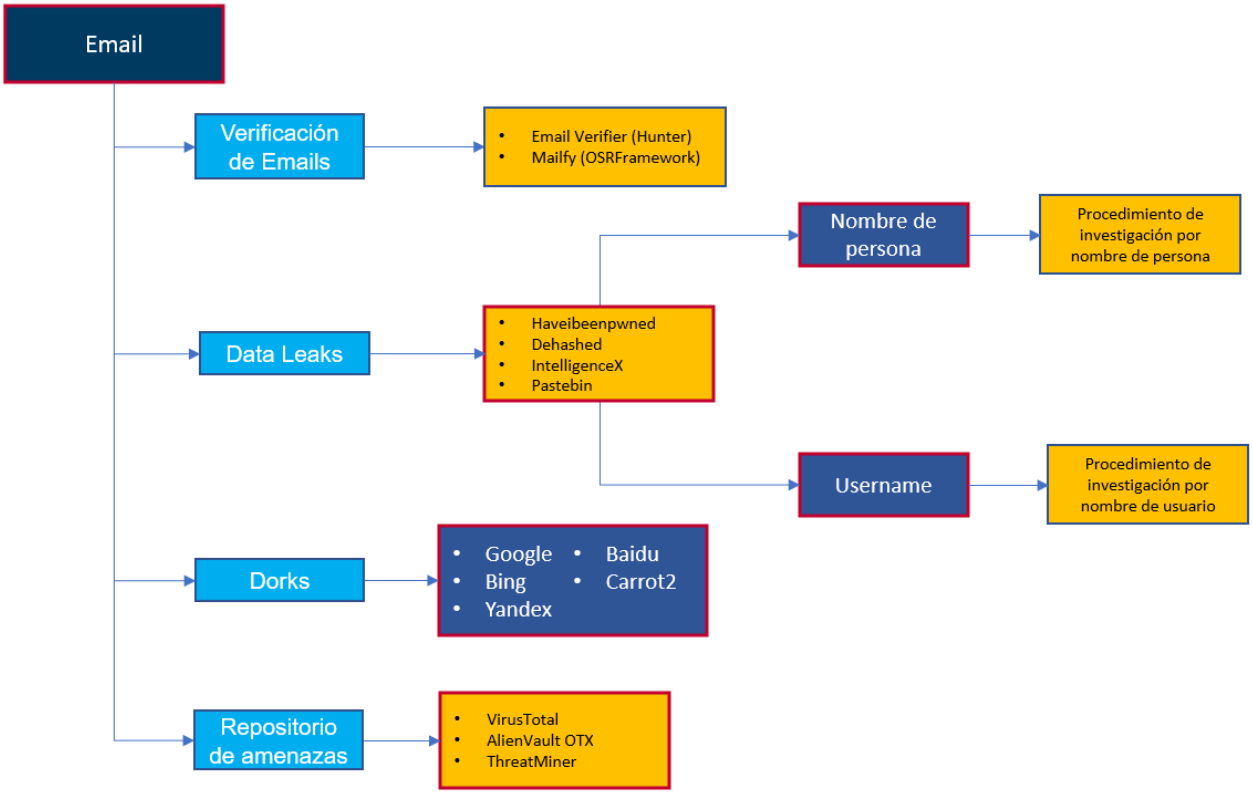


Imagen 91. Procedimiento de investigación de un correo electrónico al detalle

1.6. PROCEDIMIENTO DE INVESTIGACIÓN DE DIRECCIONES IP

Tal como hemos visto en los procedimientos anteriores, podemos realizar la misma operativa con una dirección IP. En la Imagen 92 se puede ver en líneas generales dicho procedimiento, donde en este caso partiremos de una dirección IP para efectuar la investigación. Las diferentes acciones que podemos ejecutar son las siguientes:

- Comprobar los dominios que están apuntando a la dirección IP objetivo
- Obtener el whois de la dirección IP objetivo
- Obtener el Rango IP al que pertenece la dirección IP objetivo
- Realizar peticiones a los diferentes buscadores tanto genéricos como especializados mediante dorks para detectar cualquier tipo de información relacionada
- Comprobar si la dirección IP objetivo tiene muestras maliciosas asociadas o está presente en alguna blacklist
- Comprobar si la dirección IP ha sido filtrada en alguna fuga de información

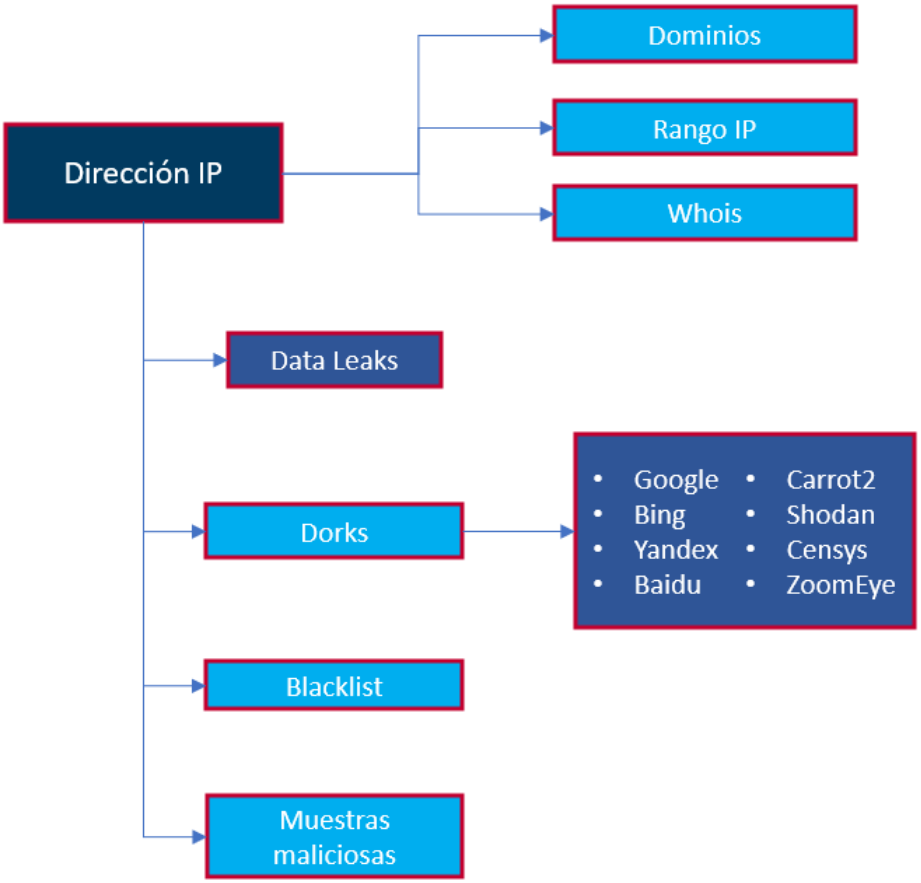


Imagen 92. Procedimiento de investigación de una dirección IP

Para obtener información relacionada a una dirección IP disponemos de una serie de técnicas para ello, como por ejemplo la recolección de dominios que están apuntando a la misma dirección IP objetivo, comprobar a que rango IP pertenece la IP, el whois asociado con los contactos pertinentes y conocer si la dirección IP esta o ha estado relacionada con alguna muestra maliciosa. Todo lo comentado puede ser visualizado más gráficamente en la Imagen 93 con las herramientas específicas para cada tarea.

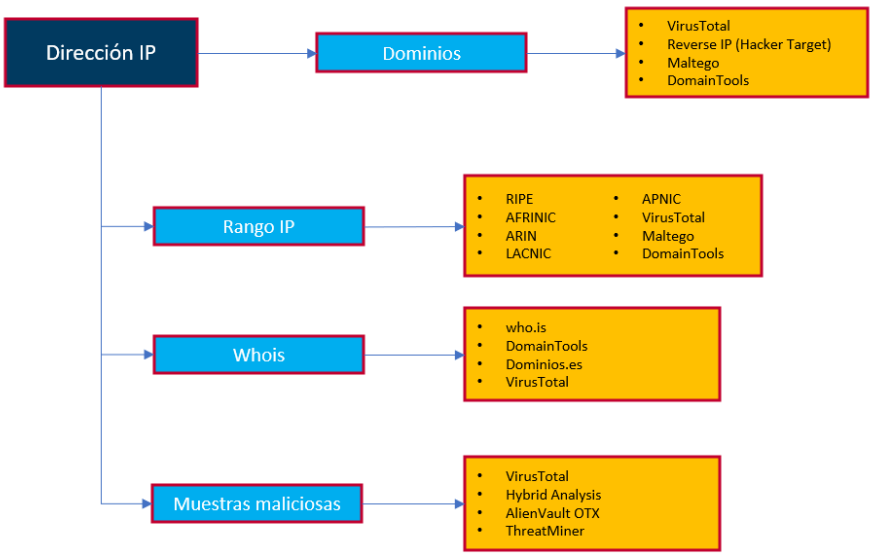


Imagen 93. Procedimiento de investigación de una dirección IP en detalle 1

Si hacemos otro zoom por el resto de vías de investigación, podemos descubrir que somos capaces de obtener más información partiendo de nuestro objetivo, como por ejemplo consultando en buscadores genéricos y/o especializados con el fin de detectar posibles protocolos, puertos, servicios, certificados y un largo etcétera de tecnología asociada a la dirección IP. A parte, es posible comprobar si la propia dirección IP está presente en fugas de información o bien dentro de alguna blocklist relacionada con amenazas concretas. En la Imagen 94 puede verse gráficamente lo comentado.

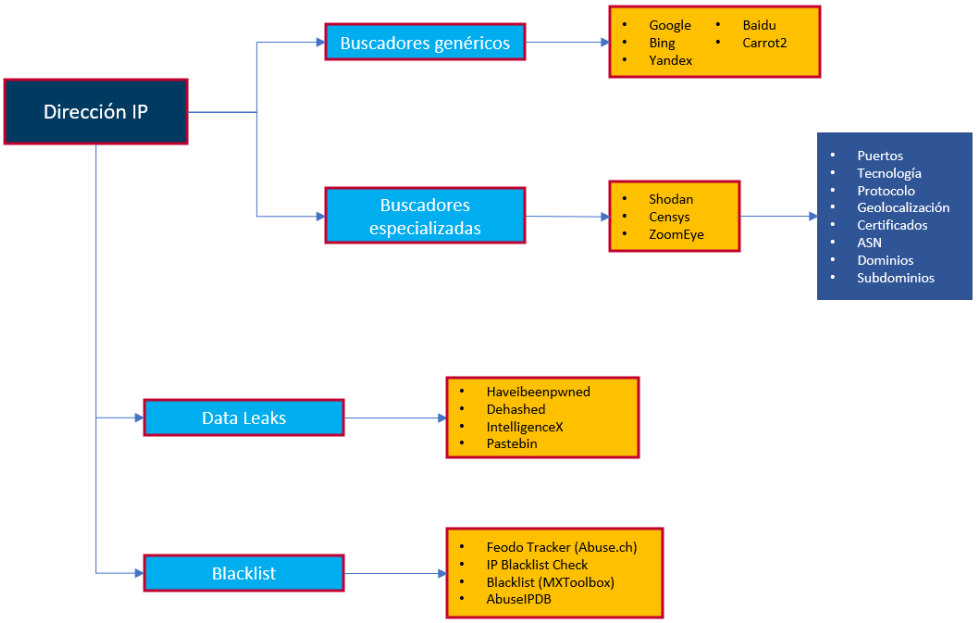


Imagen 94. Procedimiento de investigación de una dirección IP en detalle 2

2. Técnicas DE INVESTIGACIÓN EN TOR PARTIENDO DE FUENTES ABIERTAS

Las mismas técnicas vistas en el tema anterior pueden ser extrapoladas a la investigación de amenazas dentro de Tor, tan solo variarán las fuentes que consultemos y la forma de acceso a este tipo de Darknet. Por este hecho, en la presente sección veremos una serie de fuentes que podremos utilizar dentro de la Surface Web para localizar dominios .onion y luego posteriormente consultar otras fuentes más ocultas dentro de la propia red Tor.

2.1. BUSCADORES DE HIDDEN SERVICES DE TOR EN FUENTES ABIERTAS

En este apartado se pueden encontrar una serie de buscadores que van a permitir localizar enlaces de dominios .onion, realizando consultas desde la Surface Web utilizando palabras clave concretas.

2.1.1. DANIEL HOSTING

Daniel Hosting era uno de los ISP más conocidos sobre Hidden Services en Internet, pero debido a un ataque en 2020 donde filtraron toda la BBDD en Internet, Daniel Winzen (creador de Daniel Hosting) decidió no continuar como proveedor de alojamiento de dominios .onion (ver Imagen 95). Se dispone de más información en el siguiente enlace: https://www.infobae.com/america/tecno/2020/06/03/se-filtro-la-base-de-datos-de-uno-de-los-servicios-de-hosting-mas-grandes-de-la-dark-web/.

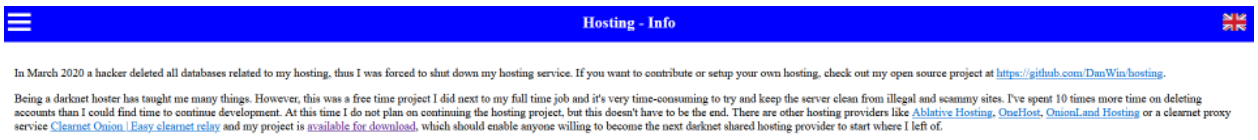


Imagen 95. Sitio web de Daniel Hosting indicando que ya no ofrece servicios de hosting en Tor

Daniel Hosting permite el acceso a su sitio web por dos vías:

- Surface Web: https://danwin1210.de.
- Tor: http://danielas3rtn54uwmofdo3x2bsdifr47huasnmbgqzfrec5ubupvtpid.onion/

Daniel Hosting ofrece los siguientes recursos dentro de su sitio web:

- Un verificador de si un Hidden Service de Tor está activo o no. En la Imagen 96 se puede ver una prueba con el dominio .onion de Daniel Hosting. El acceso está disponible en el siguiente enlace: https://onions.danwin1210.de/test.php.

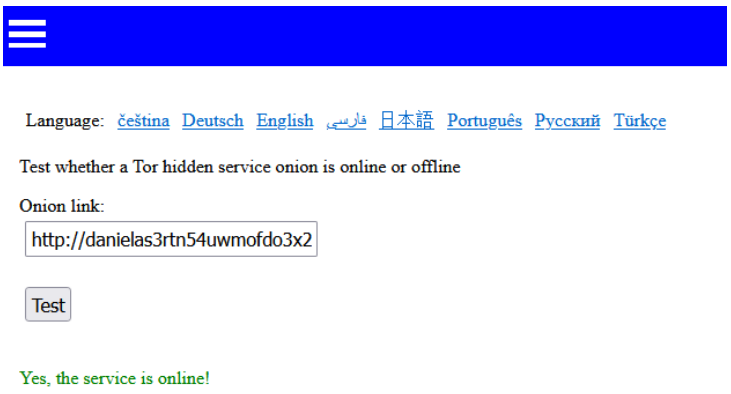


Imagen 96. Verificador de dominios .onion con Daniel Hosting

- Un buscador para realizar diferentes consultas para localizar dominios de Tor. En la Imagen 97 se puede ver lo comentado. El acceso está disponible en el siguiente enlace: https://onions.danwin1210.de/.

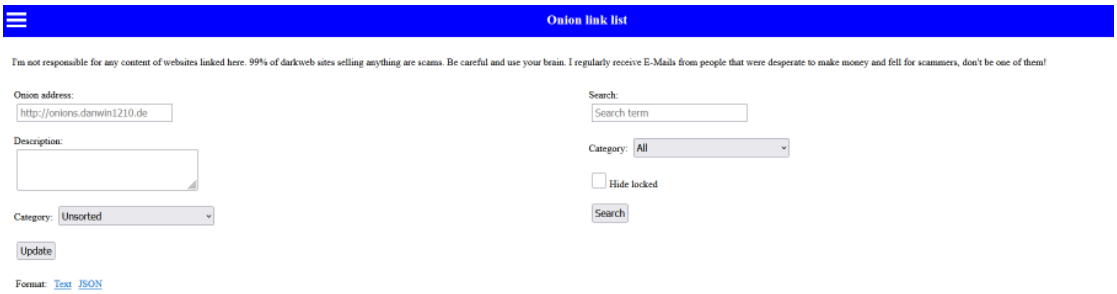


Imagen 97. Buscador de dominio .onion de Daniel Hosting

Ahora, procedemos a realizar una consulta de la palabra clave "ransomware" dentro del buscador, el cual nos devuelve un único resultado relacionado con un dominio .onion en el que su descripción hace mención a un sitio web relacionado con sitios de grupos de ransomware. Lo mencionado puede verse en la Imagen 98.

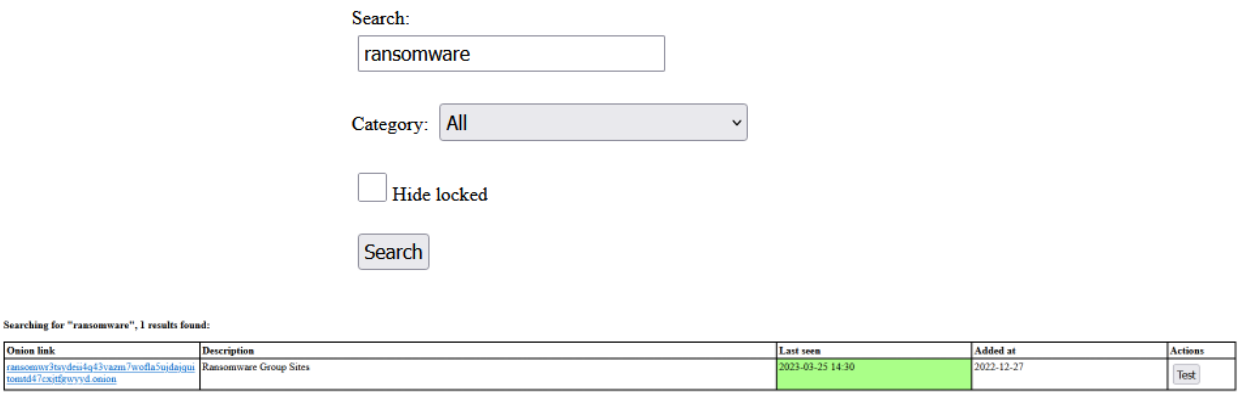
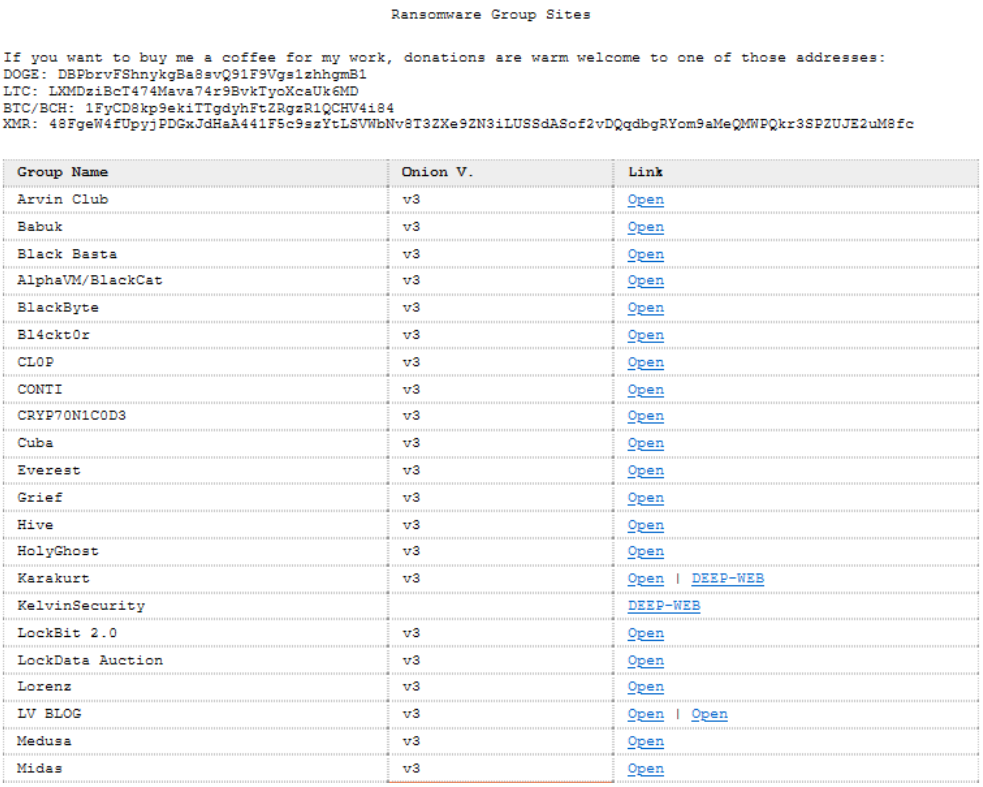


Imagen 98. Búsqueda de la palabra clave "ransomware" dentro de Daniel Hosting

Si ahora abrimos nuestro Tor Browser y accedemos al dominio .onion recolectado, podremos ver su contenido relacionado y valoraremos si el mismo puede llegar a ser interesante como fuente o no. Dicho contenido puede verse en la Imagen 99, siendo un inventario de grupos de ransomware con su respectivo enlace .onion.



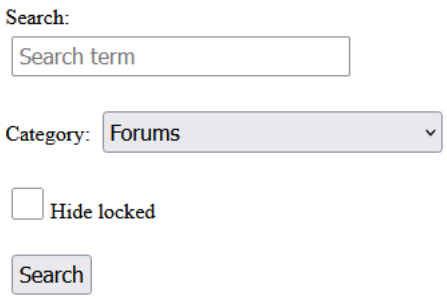
Ransomware Group Sites

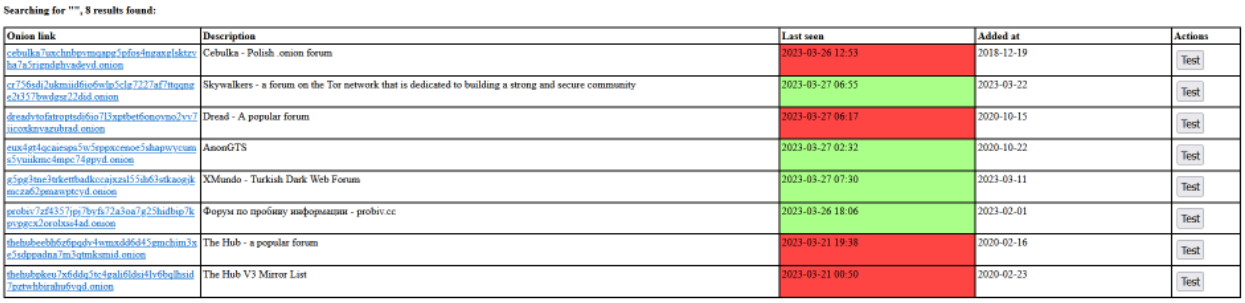
If you want to buy me a coffee for my work, donations are warm welcome to one of those addresses:
DOGE: DBPbrvFShnykgBa8svQ91F9Vgs1zhhgmB1
LTC: LXMDziBcT474Mava74r9BvkTyoXcaUk6MD
BTC/BCH: 1FyCD8kp9ekiTTgdyhFtZRgzR1QCHV4i84
XMR: 48FgeW4fUpyjPDGxJdHaA441F5c9szYtLSVWbNv8T3ZXe9ZN3iLUSSdASof2vDQqdbgRYom9aMeQMWPQkr3SPZUJE2uM8fc

Group Name	Onion V.	Link
Arvin Club	v3	Open
Babuk	v3	Open
Black Basta	v3	Open
AlphaVM/BlackCat	v3	Open
BlackByte	v3	Open
Bl4ckt0r	v3	Open
CL0P	v3	Open
CONTI	v3	Open
CRYP70N1C0D3	v3	Open
Cuba	v3	Open
Everest	v3	Open
Grief	v3	Open
Hive	v3	Open
HolyGhost	v3	Open
Karakurt	v3	Open | DEEP-WEB
KelvinSecurity		DEEP-WEB
LockBit 2.0	v3	Open
LockData Auction	v3	Open
Lorenz	v3	Open
LV BLOG	v3	Open | Open
Medusa	v3	Open
Midas	v3	Open

Imagen 99. Enlace del dominio .onion recolectado mediante Daniel Hosting

Ahora realizaremos otra consulta filtrando por la categoría de foros y sin utilizar ninguna palabra clave. En la Imagen 100 pueden verse los enlaces .onion recolectados, indicando cuales están operativos o inoperativos.





Searching for "", 8 results found:

Onion link	Description	Last seen	Added at	Actions
cebulka7uxchnbpvmqapg5pfos4ngaxglsktzzbu7a5rignqdhyadeyd.onion	Cebulka - Polish .onion forum	2023-03-26 12:53	2018-12-19	Test
cr756sdi2ukmiid6io6wlp5cla7227af7ttqqnqe2t357bwdgsr22did.onion	Skywalkers - a forum on the Tor network that is dedicated to building a strong and secure community	2023-03-27 06:55	2023-03-22	Test
dreadytofatroptsdj6io7l3xptbet6onoyno2yv7jicoxknyazubrad.onion	Dread - A popular forum	2023-03-27 06:17	2020-10-15	Test
eux4gt4qcairsqs5w5eppxcesoe5shapwycuaie5yuukmc4mpc74pqyd.onion	AnonGTS	2023-03-27 02:32	2020-10-22	Test
g5pg3tne3trkettbadkccajxzsl55ih63stkaogjkuczu62pmawptcyd.onion	XMundo - Turkish Dark Web Forum	2023-03-27 07:30	2023-03-11	Test
probsv7zf4357jpi7bvfk72a3oa7g25hidbsp7kpvpqcx2orolxss4ad.onion	Форум по пробиву информации - probiv.cc	2023-03-26 18:06	2023-02-01	Test
thehubeebbfzfpqdv4wmxdd6d45gmchjm3se5sdppadna7m3qtmksmid.onion	The Hub - a popular forum	2023-03-21 19:38	2020-02-16	Test
thehubpkeu7x6ddq5tc4rali6ldsj4ly6bqlhsid7prtvhbsrahu6vqd.onion	The Hub V3 Mirror List	2023-03-21 00:50	2020-02-23	Test

Imagen 100. Resultados de dominios .onion relacionados con foros

2.1.2. AHMIA

AHMIA es un buscador accesible desde la Surface Web, el cual, permite realizar consultas mediante palabras clave para detectar dominios .onion. AHMIA utiliza una serie de crawlers que van detectando nuevos dominios .onion, almacenándolas dentro de su base de datos.

AHMIA permite el acceso a su sitio web por dos vías:

- Surface Web: https://ahmia.fi/.
- Tor: http://juhanurmihxlp77nkq76byazcldy2hlmovfu2epvl5ankdibsot4csyd.onion/

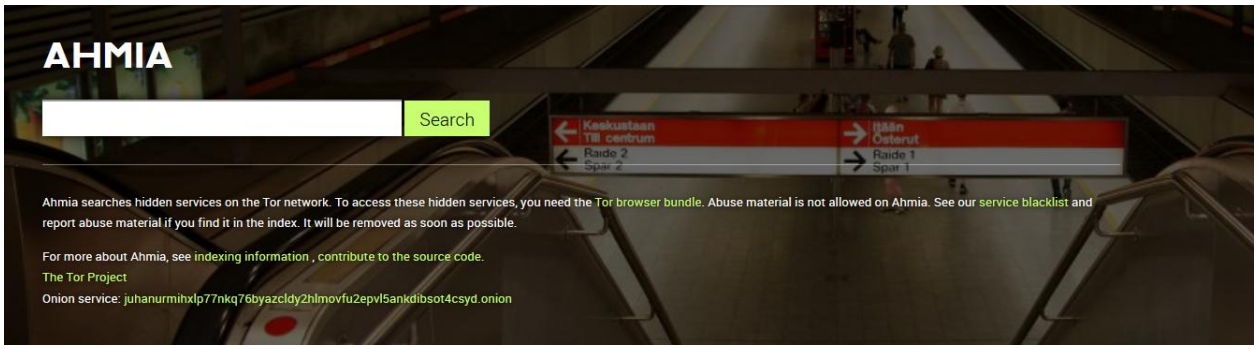


Imagen 101. Sitio web oficial de AMHIA

AHMIA ofrece los siguientes recursos dentro de su sitio web:

- Permite visualizar estadísticas tanto de manera visual mediante grafos (Imagen 103) o por gráfica de barras (Imagen 104). El acceso está disponible en el siguiente enlace: https://ahmia.fi/stats/.

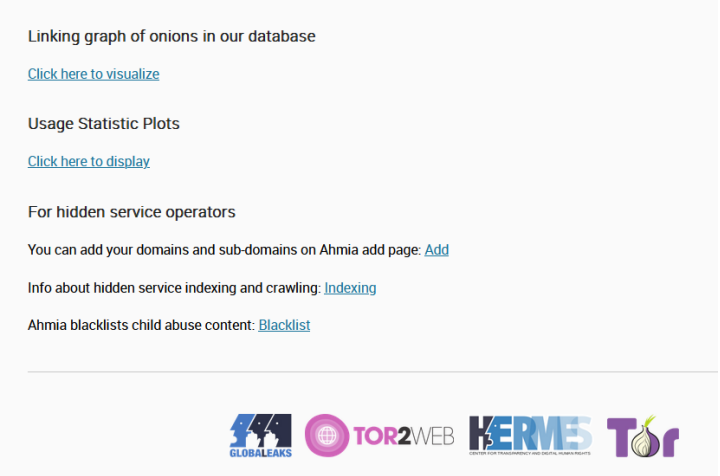


Imagen 102. Diferentes opciones de visualización de estadísticas sobre dominios .onion

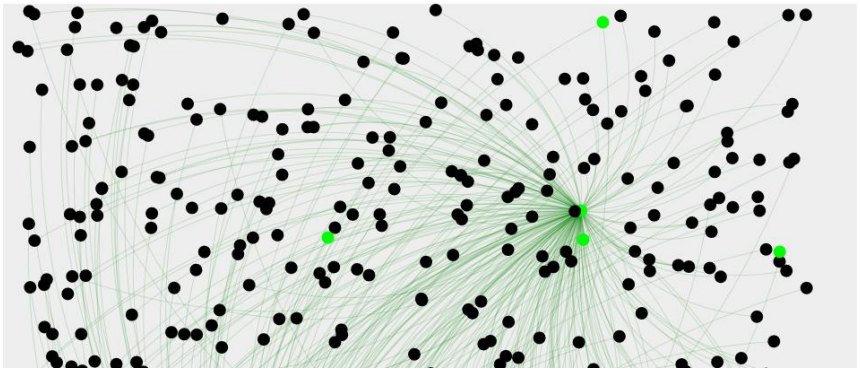


Imagen 103. Estadísticas de dominios .onion representados mediante grafos

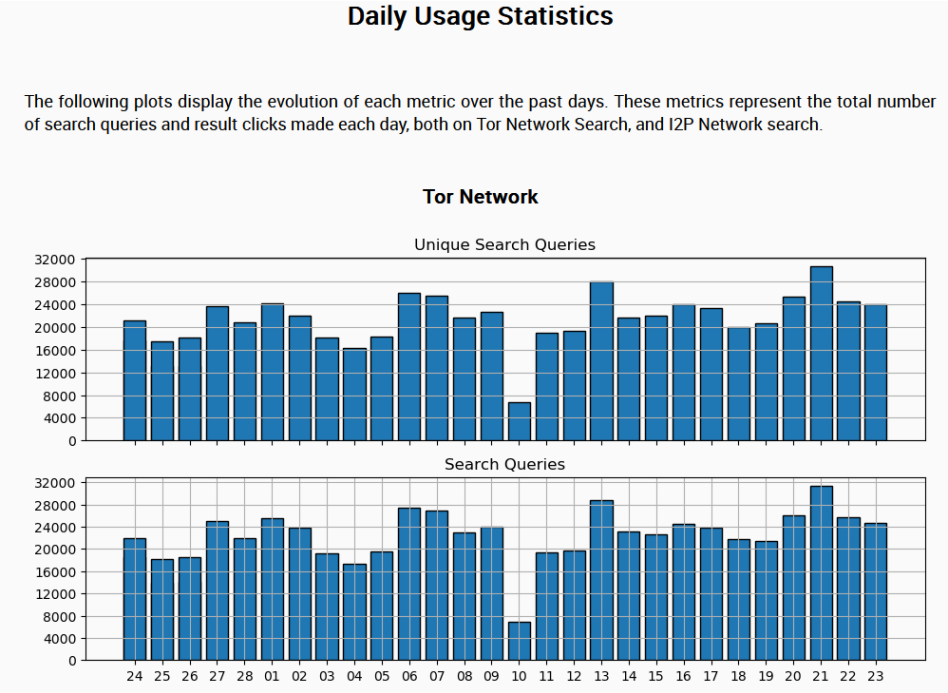


Imagen 104. Estadísticas de uso diario de dominio .onion

- Permite consultar un listado de dominios .onion que AHMIA tiene indexados en su base de datos interna. El acceso está disponible directamente en el siguiente enlace: https://ahmia.fi/onions/. En la Imagen 105 puede verse un extracto del listado.

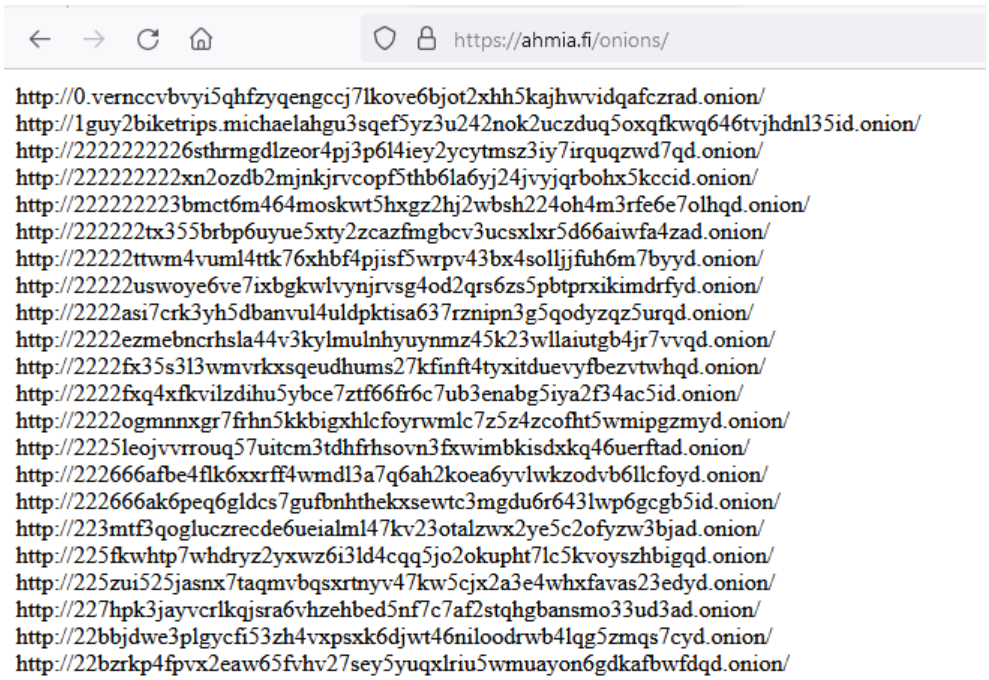


Imagen 105. Listado de dominios .onion indexados por AHMIA

- Un buscador para realizar diferentes consultas para localizar dominios .onion. En la Imagen 106 se puede ver lo comentado. El acceso está disponible directamente desde el sitio web principal: https://ahmia.fi/.

Ahora, procedemos a realizar la consulta de la palabra clave “ransomware” dentro de AHMIA, el cual nos devuelve 236 resultados relacionados con dominios .onion. Lo mencionado puede verse en la Imagen 106.

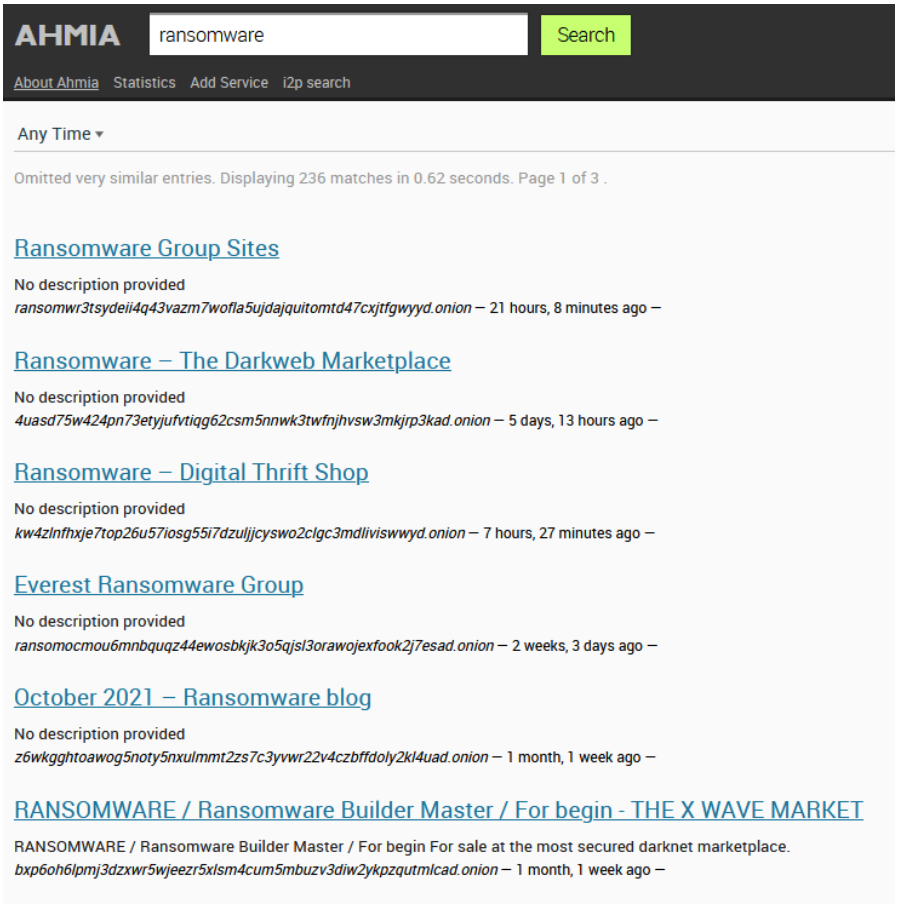


Imagen 106. Resultado de la palabra clave "ransomware" en AHMIA

2.1.3. ONIONLAND

OnionLand es un buscador accesible desde la Surface Web, el cual, tal como ocurre con AHMIA permite realizar consultas mediante palabras clave para detectar dominios .onion. OnionLand utiliza una serie de crawlers que van detectando nuevos dominios .onion, almacenándolas dentro de su base de datos.

OnionLand permite el acceso a su sitio web por dos vías:

- Surface Web: https://onionlandsearchengine.com/.
- Tor: http://3bbad7fauom4d6sgppalyqddsqbf5u5p56b5k5uk2zxsy3d6ey2jobad.onion/

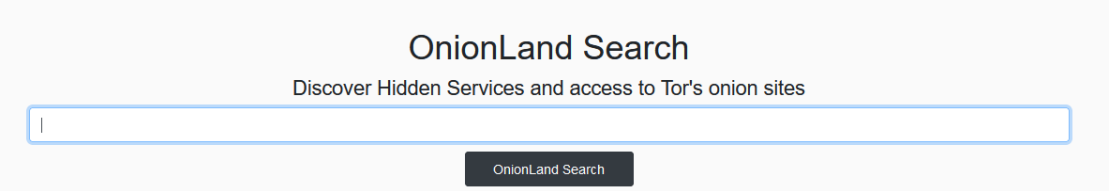


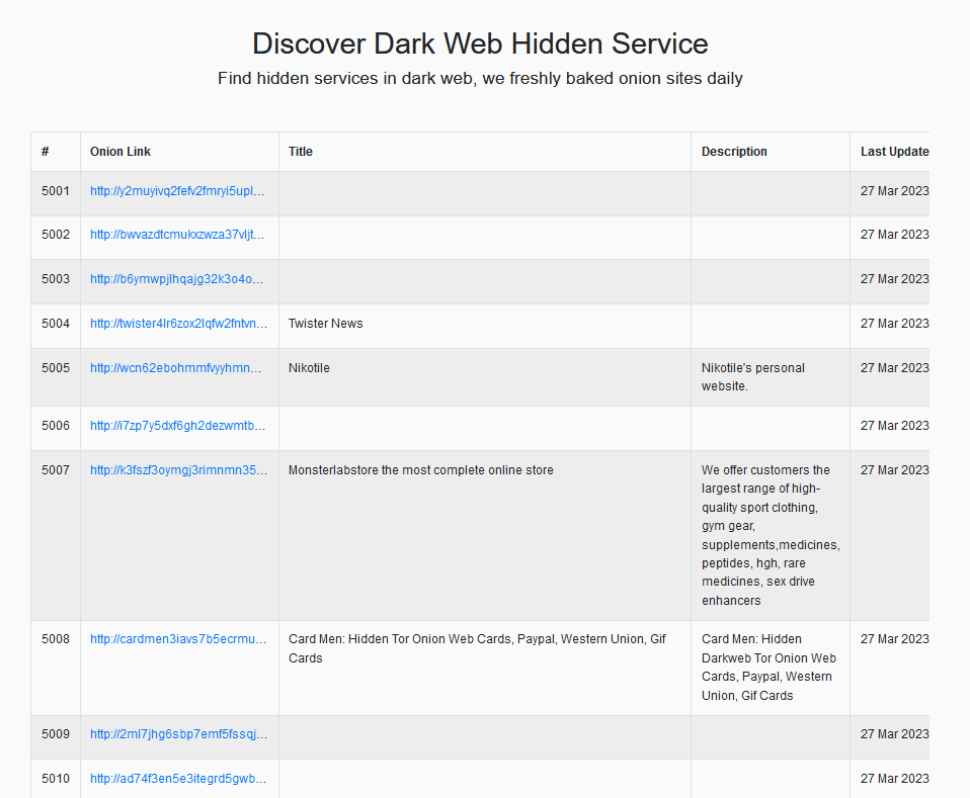
Imagen 107. Sitio Oficial de OnionLand

OnionLand ofrece los siguientes recursos dentro de su sitio web:

- Dispone de un inventario de los últimos dominios .onion junto con una descripción, título de la web (en algunos casos) y fecha de actualización. En la Imagen 108 puede verse un ejemplo de lo mencionado. El acceso está disponible en el siguiente enlace: https://onionlandsearchengine.com/discover.

- Dispone de un inventario de términos de búsqueda más demandados, ordenados alfabéticamente. En la Imagen 109 puede verse un ejemplo de lo mencionado. El acceso está disponible en el siguiente enlace: https://onionlandsearchengine.com/most-popular.

Con este buscador hay que tener bastante cuidado (tal como se puede llegar a comprobar en la Imagen 109) porque no realiza ningún tipo de filtrado con los términos de búsqueda detectados e indexados, lo que implica que podamos encontrarnos con enlaces hacia contenido muy delicado como el abuso y explotación infantil.

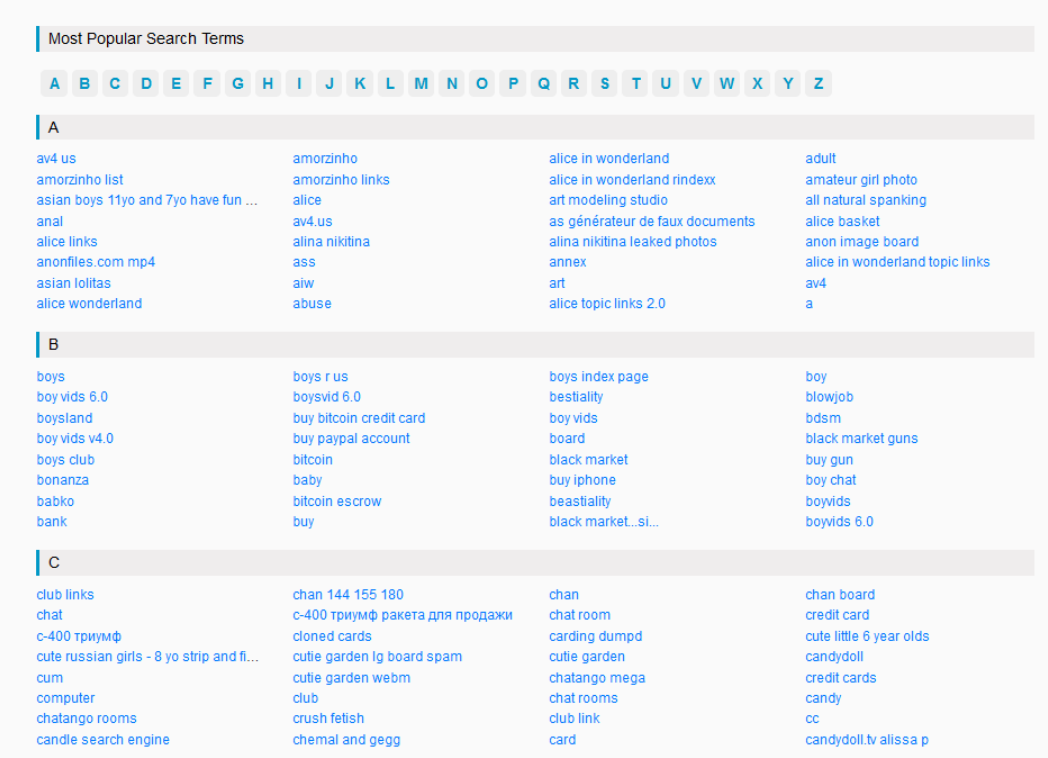


Discover Dark Web Hidden Service

Find hidden services in dark web, we freshly baked onion sites daily

#	Onion Link	Title	Description	Last Update
5001	http://y2muyivq2fefv2fmryi5upl...			27 Mar 2023
5002	http://bwvazdtcmuloxzwza37vljt...			27 Mar 2023
5003	http://b6ymwpjlhqajg32k3o4o...			27 Mar 2023
5004	http://twister4lr6zox2lqfw2fntvn...	Twister News		27 Mar 2023
5005	http://wcn62ebohmmfvyyhmn...	Nikotile	Nikotile's personal website.	27 Mar 2023
5006	http://i7zp7y5dxf6gh2dezwmtb...			27 Mar 2023
5007	http://k3fszf3oymgj3rimnmn35...	Monsterlabstore the most complete online store	We offer customers the largest range of high-quality sport clothing, gym gear, supplements,medicines, peptides, hgh, rare medicines, sex drive enhancers	27 Mar 2023
5008	http://cardmen3iavs7b5ecrmu...	Card Men: Hidden Tor Onion Web Cards, Paypal, Western Union, Gif Cards	Card Men: Hidden Darkweb Tor Onion Web Cards, Paypal, Western Union, Gif Cards	27 Mar 2023
5009	http://2ml7jhg6sbp7emf5fssqj...			27 Mar 2023
5010	http://ad74f3en5e3itegrd5gwb...			27 Mar 2023

Imagen 108. Discover de Hidden Services de OnionLand


Most Popular Search Terms

A B C D E F G H I J K L M N O P Q R S T U V W X Y Z

A

av4 us
amorzinho list
asian boys 11yo and 7yo have fun ...
anal
alice links
anonfiles.com mp4
asian lolitas
alice wonderland
amorzinho
amorzinho links
alice
av4.us
alina nikitina
ass
aiw
abuse
alice in wonderland
alice in wonderland rindexx
art modeling studio
as générateur de faux documents
alina nikitina leaked photos
annex
art
alice topic links 2.0
adult
amateur girl photo
all natural spanking
alice basket
anon image board
alice in wonderland topic links
av4
a

B

boys
boy vids 6.0
boysland
boy vids v4.0
boys club
bonanza
babko
bank
boys r us
boysvid 6.0
buy bitcoin credit card
buy paypal account
bitcoin
baby
bitcoin escrow
buy
boys index page
bestiality
boy vids
board
black market
buy iphone
beastiality
black market...si...
boy
blowjob
bdsm
black market guns
buy gun
boy chat
boyvids
boyvids 6.0

C

club links
chat
c-400 триумф
cute russian girls - 8 yo strip and fi...
cum
computer
chatango rooms
candle search engine
chan 144 155 180
c-400 триумф ракета для продажи
cloned cards
cutie garden lg board spam
cutie garden webm
club
crush fetish
chemal and gegg
chan
chat room
carding dumpd
cutie garden
chatango mega
chat rooms
club link
card
chan board
credit card
cute little 6 year olds
candydoll
credit cards
candy
cc
candydoll.tv alissa p

Imagen 109. Términos más buscados en OnionLand ordenados alfabéticamente

2.1.4. DARKFEED

DarkFeed es un servicio online que ofrece información sobre incidentes de ransomware, permitiendo realizar un seguimiento de estos en cuanto a volumetría. Recientemente, DarkFeed ha creado diferentes tipos de suscripciones, una gratuita y dos de pago. El acceso está disponible en el siguiente enlace: https://darkfeed.io.

En la Imagen 110 se puede ver el sitio web oficial de DarkFeed, el cual recoge información sobre los últimos ataques por ransomware, el top 8 de los grupos asociados que están activos en la actualidad, top 10 del total de grupos según la victimología y el top 10 de ataques dirigidos hacia países concretos.

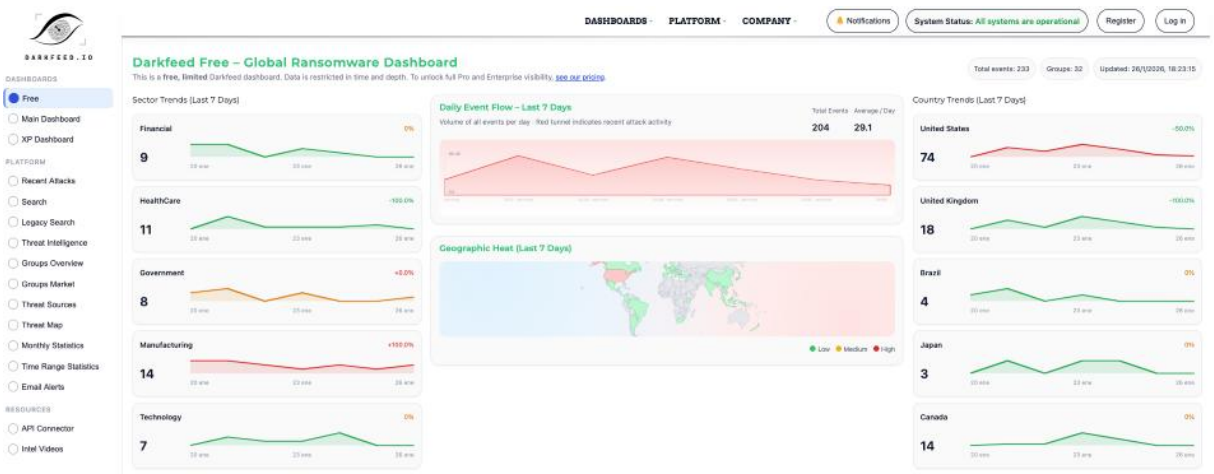


Imagen 110. Volumetrías sobre incidentes de ransomware ofrecidos por DarkFeed

DarkFeed ofrece también de manera gratuita un inventario con información relacionada con los grupos de ransomware, donde se puede ver un listado con los grupos que están activos, el total de víctimas de cada grupo, la última víctima, lugar de alojamiento del sitio web oficial de cada grupo (Tor, Surface Web o Telegram) y estado del grupo (activo o inactivo). En la Imagen 111 puede visualizarse lo comentado. El acceso al recurso está disponible en el siguiente enlace: https://darkfeed.io/groups-overview/.

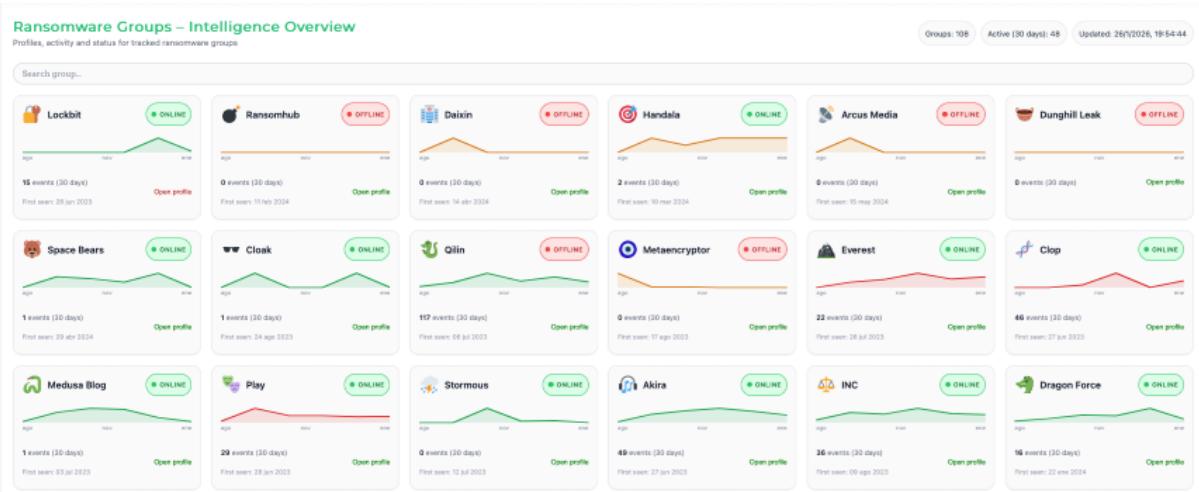


Imagen 111. Listado de grupos de ransomware en DarkFeed

2.1.5. STEALTHmole

StealthMole es un servicio online de pago que está formado por un conjunto de módulos que ofrece información de diversa índole, tales como fugas de información, monitorización de ataques de ransomware, credenciales expuestas, tracking de transacciones con criptomonedas, análisis de dominios de la Dark Web, etc. El acceso está disponible en el siguiente enlace: https://www.stealthmole.com/.

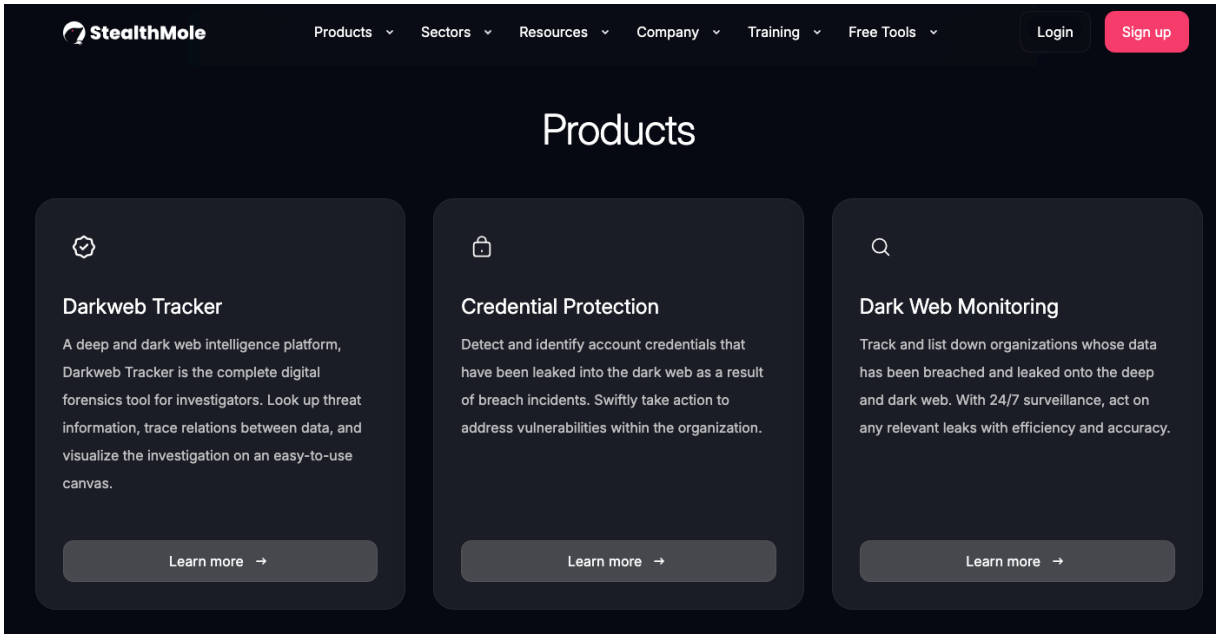


Imagen 112. Servicios ofrecidos por StealthMole

En la actualidad dispone de un total de 214 billones de datos almacenados en sus propias bases de datos internas, 1,2 millones de direcciones .onions, monitorización de 58.889 dominios .onion en tiempo real y un total de 5.989 direcciones IP. En la Imagen 113 puede comprobarse lo mencionado.

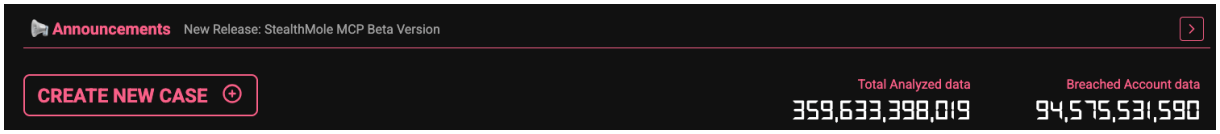


Imagen 113. Volumetría de contenido de datos de StealthMole

StealthMole permite crear una cuenta gratuita por medio de un correo corporativo, donde se dispone de un módulo totalmente gratuito de monitorización de víctimas de ransomware, ofreciendo un pequeño inventario sobre cada ataque. Para ello es necesario

acceder al "Extension Packs" para seleccionar y añadir el módulo de "Ransomware Monitoring" tal como se puede ver en la Imagen 114.

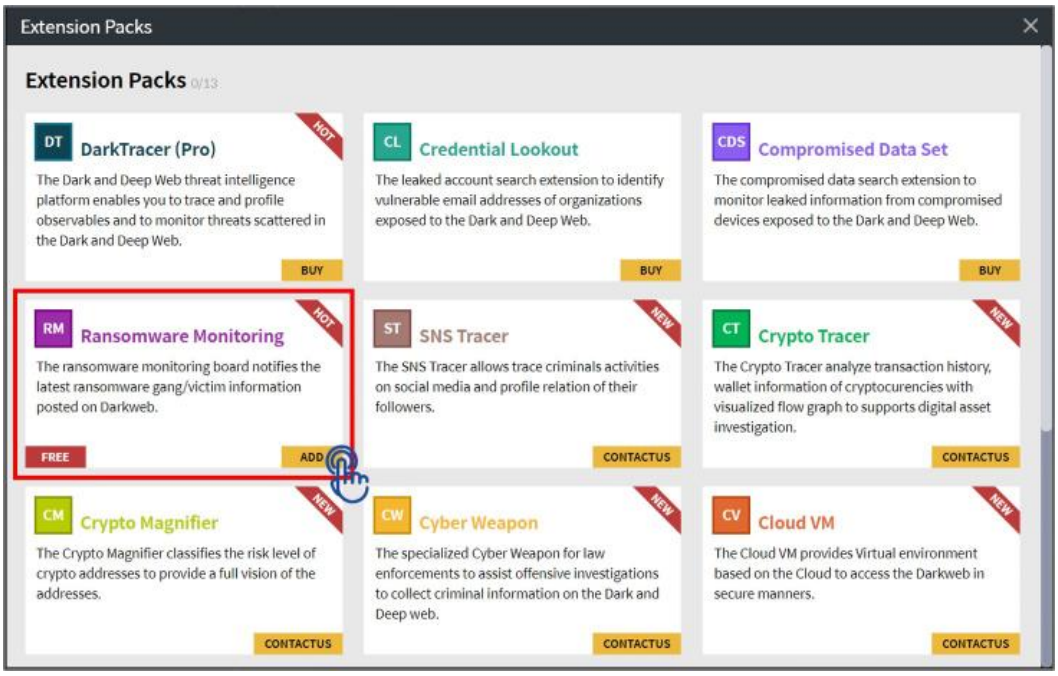


Imagen 114. Añadir modulo gratuito de StealthMole sobre ransomware

En el momento que tengamos añadido dicho módulo se podrá acceder al portal Ransomware Monitoring (RM) para realizar un seguimiento e investigar víctimas de ransomware. En la Imagen 115 puede verse lo mencionado, donde se puede recolectar información de cada ataque de ransomware conocido de manera pública (por medio de las difusiones de los distintos grupos de ransomware en su correspondiente sitio web) como por ejemplo el nombre de la víctima, su sitio web, país de origen, sector, la fecha de detección, junto con el grupo de ransomware relacionado. Además, es posible representar cada tipo de dato en un grafo con relaciones. StealthMole nos permite realizar un total de 30 peticiones de manera gratuita al mes, por lo que se deberá tener cuidado de no abusar de ellas con facilidad.

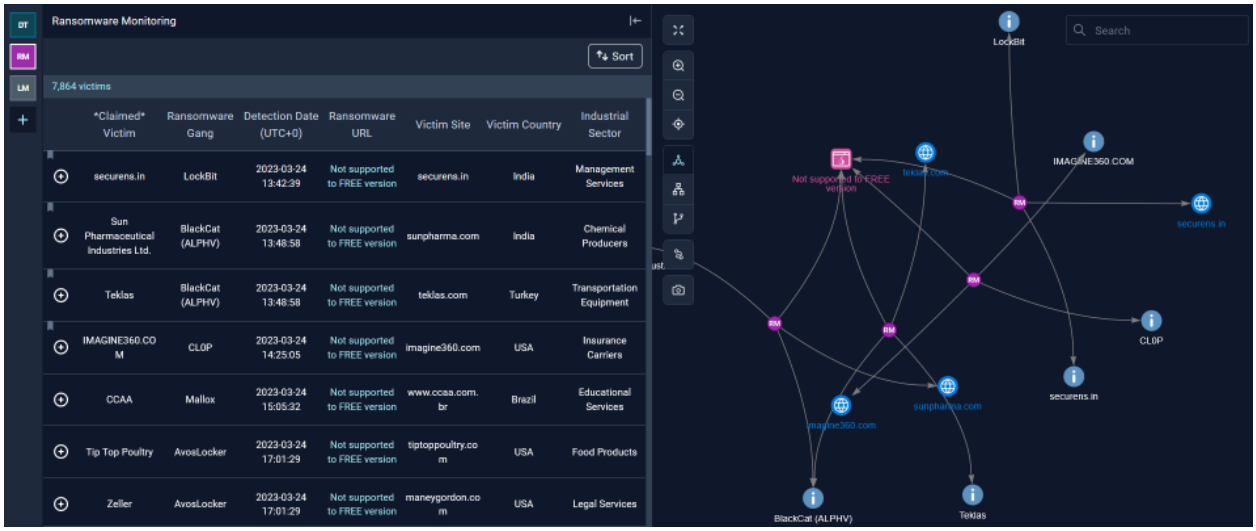


Imagen 115. Portal del módulo de Ransomware Monitoring de StealthMole

Por otro lado, StealthMole permite realizar un total de 100 consultas gratuitas al mes dentro de su módulo StealthMole (DT), para realizar cualquier tipo de investigación, pero con ciertas limitaciones al tener la cuenta gratuita.

Ahora, procedemos a realizar una consulta de la palabra clave “ransomware” dentro de StealthMole, el cual representa dicha palabra clave dentro del grafo y devuelve una serie de dominios y URLs de Tor y de I2P (visible en la cuenta gratuita) y otros tipos de datos (no visibles con la cuenta gratuita). Lo mencionado puede verse en la Imagen 116.

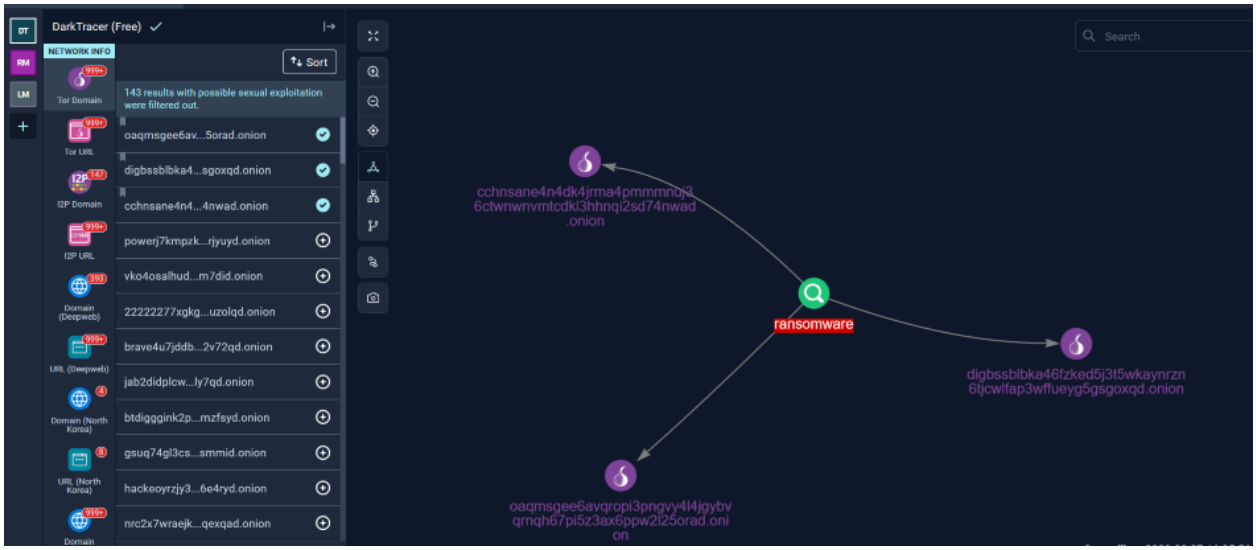


Imagen 116. Búsqueda de la palabra clave "ransomware" en StealthMole

Todos los enlaces que se detecten pueden ser añadidos en el grafo para su investigación. Si se intenta obtener más detalle de cada nodo del grafo, se comprobará que no nos lo permitirá ya que se necesitará una cuenta de pago, tal como se puede apreciar en la Imagen 117.

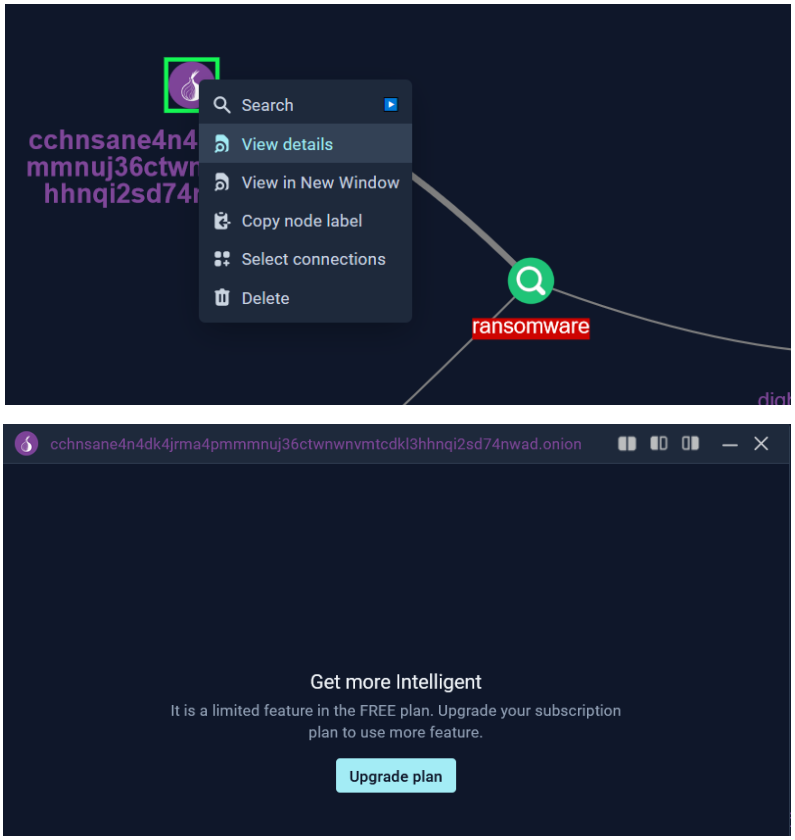


Imagen 117. Intento de ver detalle de un dominio añadido al grafo

En el caso de las URLs que se detectan de Tor, la herramienta sí que permite acceder al detalle de su contenido de manera gratuita, tal como se puede ver en la Imagen 118. Entre los datos que se detectan de la URL, se puede encontrar un screenshot del sitio web, la URL, fecha de escaneo, tamaño del contenido, hash, visualización del texto del sitio web y de su código fuente.

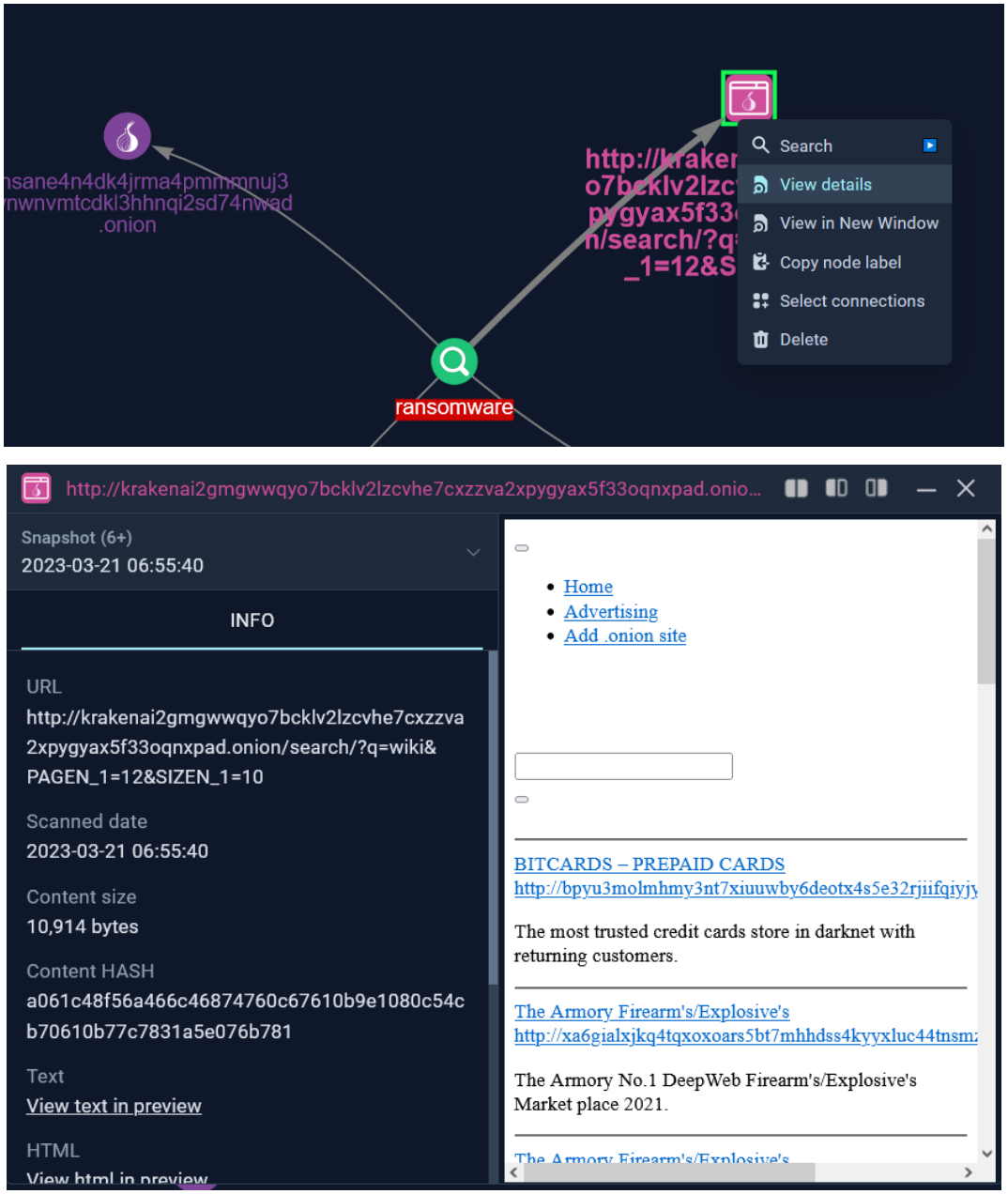


Imagen 118. Contenido de una URL de un dominio de Tor ofrecida pro StealthMole

En el caso de los dominios y URLs de I2P ocurriría exactamente lo mismo que se ha visto con los dominios de Tor.

2.2. BUSCADORES DE HIDDEN SERVICES DENTRO DE TOR

Hasta ahora hemos visto diferentes técnicas empleadas dentro de la Surface Web como punto de partida y saltar a la red Tor en un segundo paso. En este caso se va a acceder directamente a la red Tor, saliendo de lo que son las fuentes abiertas, pero es interesante conocer ciertas fuentes para consultar Hidden Services concretos a lo largo de una investigación.

2.2.1. THE HIDDEN WIKI

The Hidden Wiki es un servicio muy similar a la Wikipedia pero en este caso centrado en la red Tor, permitiendo el acceso a diferentes dominios .onion categorizados por tipos. El acceso al enlace es el siguiente: http://zqktlwiuavvvqqt4ybvgvi7tyo4hjl5xgfuvpdf6otjiycgwqbym2qad.onion/wiki/index.php/Main_Page

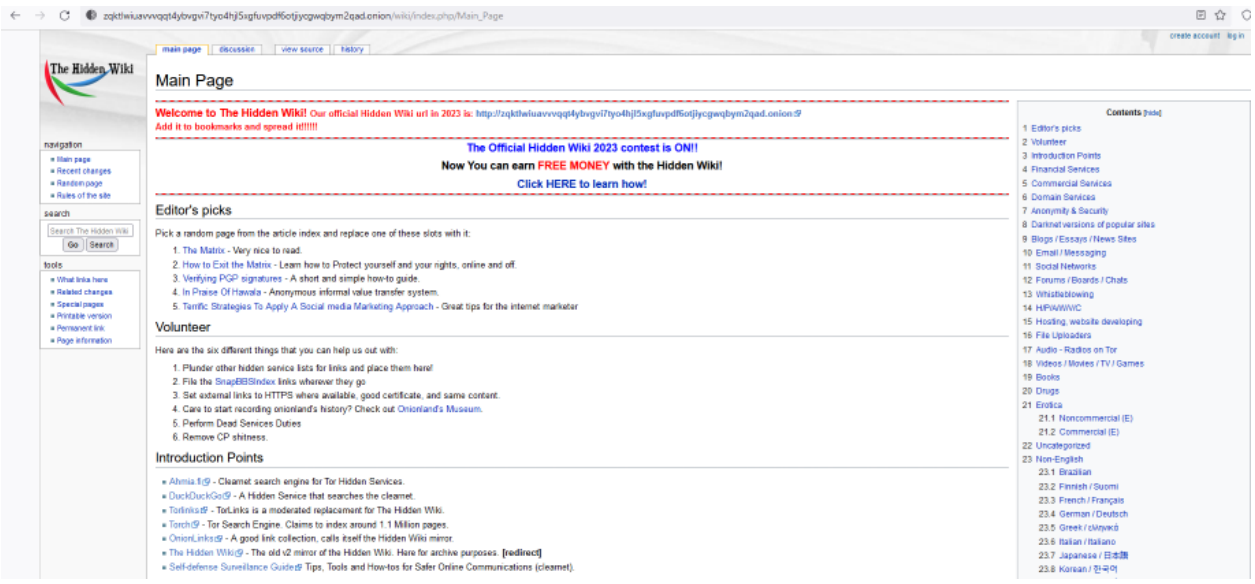


Imagen 119. Sitio web principal de The Hidden Wiki

2.2.2. TORCH

TORCH es un buscador que permite realizar consultas dentro de la red Tor para descubrir contenido en dicha Darknet. En la actualidad tiene indexado un total de 1,7 millones de documentos, tal como se puede observar en la Imagen 120.

El acceso al enlace es el siguiente: http://xmh57jrknzkhv6y3ls3ubitzfqnkrwxhopf5aygthi7d6rplyvk3noyd.onion.



Imagen 120. Sitio web de TORCH

Ahora, procedemos a realizar una consulta de la palabra clave "ransomware" dentro del buscador, el cual nos devuelve *3.235 resultados*. En la Imagen 121 se puede observar que obtenemos el título y una breve descripción de cada enlace .onion, junto con la URL y la palabra clave coincidente en la búsqueda.

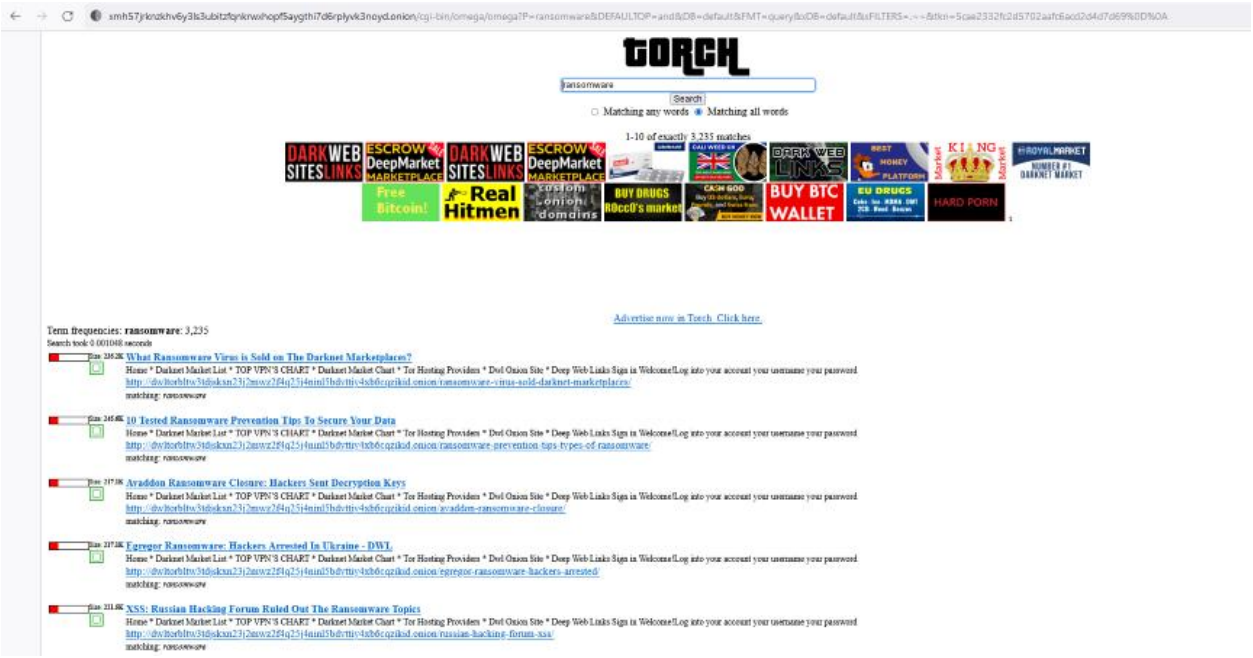


Imagen 121. Resultados de la palabra clave "ransomware" en TORCH

Si se accede al quinto enlace de la Imagen 121 se puede acceder al propio contenido de la URL .onion detectada, siendo un repositorio a modo inventario sobre black markets, foros relacionados con el cibercrimen, etc. En la Imagen 122 puede verse lo mencionado. Además, navegando por el sitio web se puede descubrir una sección sobre canales de Telegram relacionado con la misma temática anterior (ver Imagen 123)

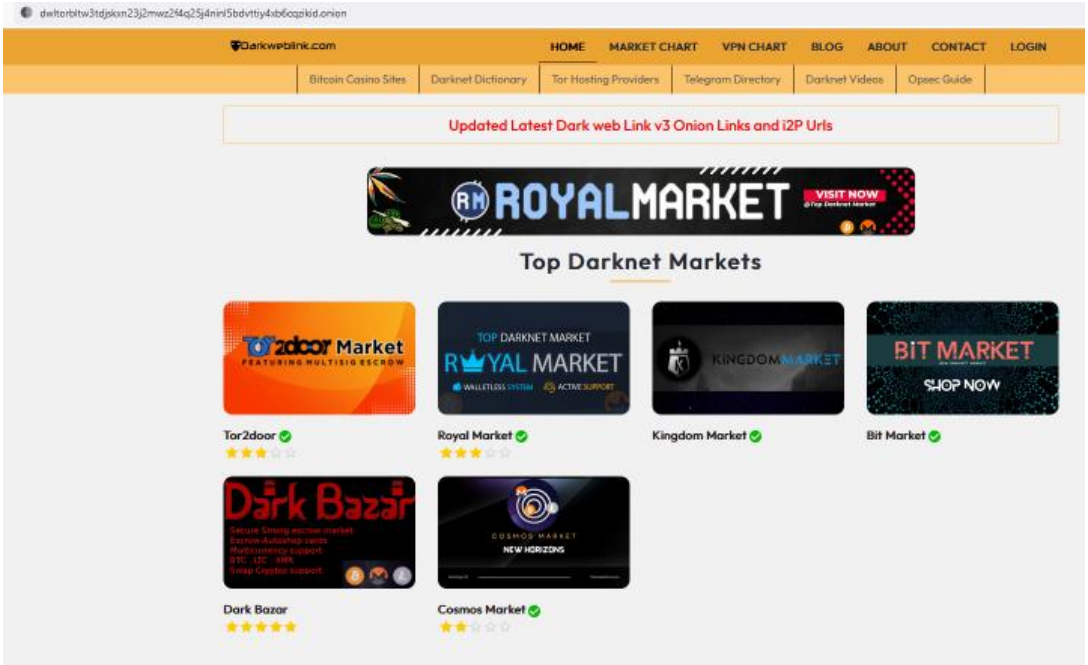


Imagen 122. Sitio web en Tor descubierto con TORCH

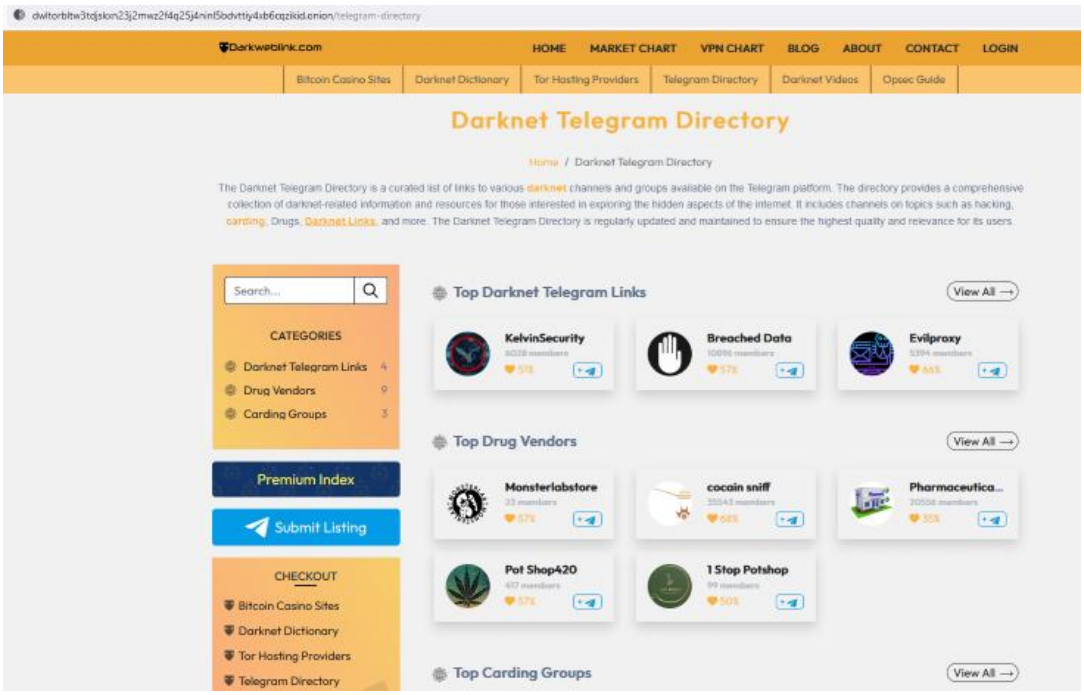


Imagen 123. Directorio de canales de Telegram detectados con TORCH

2.2.3. DEEP SEARCH

Deep Search es un buscador que permite realizar consultas dentro de la red Tor para descubrir contenido en dicha Darknet. En la Imagen 124 pueden verse que Deep Search tiene indexado un total de 315.135 sitios webs y ofrece una serie de estadísticas sobre el

top 10 de búsquedas en el propio Deep Search, yendo todo a la misma dinámica de búsquedas relacionadas con temas pornográficos.

El enlace es el siguiente: http://search7tdrcvri22rieiwgi5g46qnwsesvnubqav2xakhezv4hjzkkad.onion/

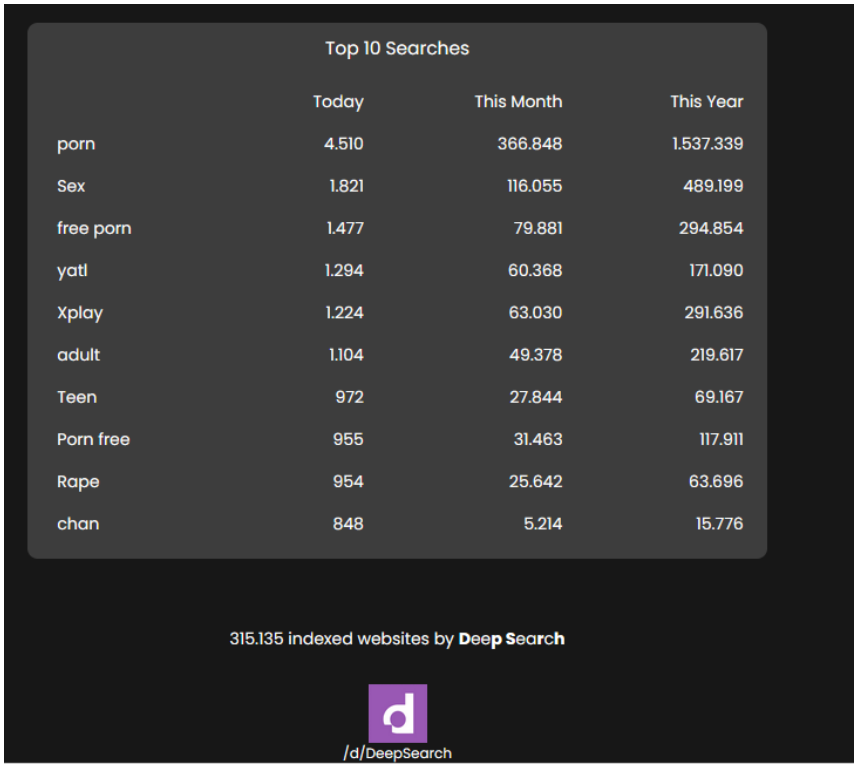


Imagen 124. Top 10 de búsquedas realizadas con Deep Search

Ahora, procedemos a realizar una consulta de la palabra clave "ransomware" dentro del buscador, el cual nos devuelve *15 resultados*. En la Imagen 125 se puede observar que obtenemos el título y una breve descripción de cada enlace .onion, junto con la URL asociada. Ahora se podría ir accediendo a cada enlace recolectado y descubrir si su contenido es interesante para la investigación o no.

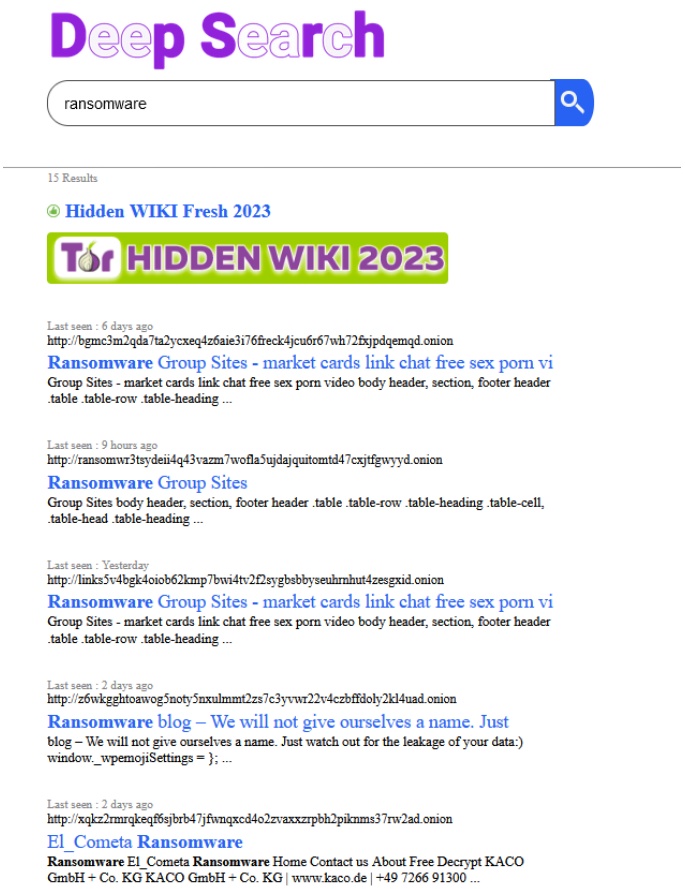


Imagen 125. Resultados de la palabra clave "ransomware" en Deep Search

2.2.4. THE DEEP SEARCHES

The Deep Searches es un buscador muy similar a los anteriores, el cual permite realizar consultas dentro de la red Tor para descubrir cualquier tipo de contenido. El enlace a The Deep Searches es el siguiente: http://searchgf7gdtauh7bhnbyed4ivxqmuoat3nm6zfrg3ymkq6mtnpye3ad.onion/.

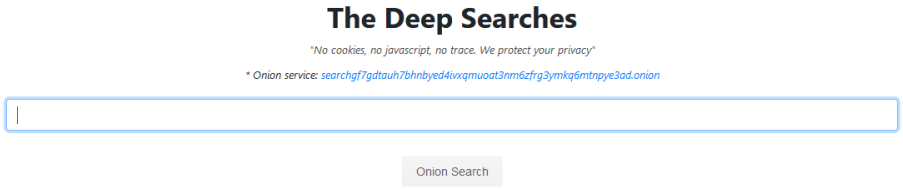


Imagen 126. Sitio web de The Deep Searches

En la Imagen 127 puede visualizarse los términos más utilizados como búsquedas dentro del buscador de The Deep Searches. El acceso al enlace hacia lo mencionado se puede encontrar a continuación: http://searchgf7gdtauh7bhnbyed4ivxqmuoat3nm6zfrg3ymkq6mtnpye3ad.onion/most-popular

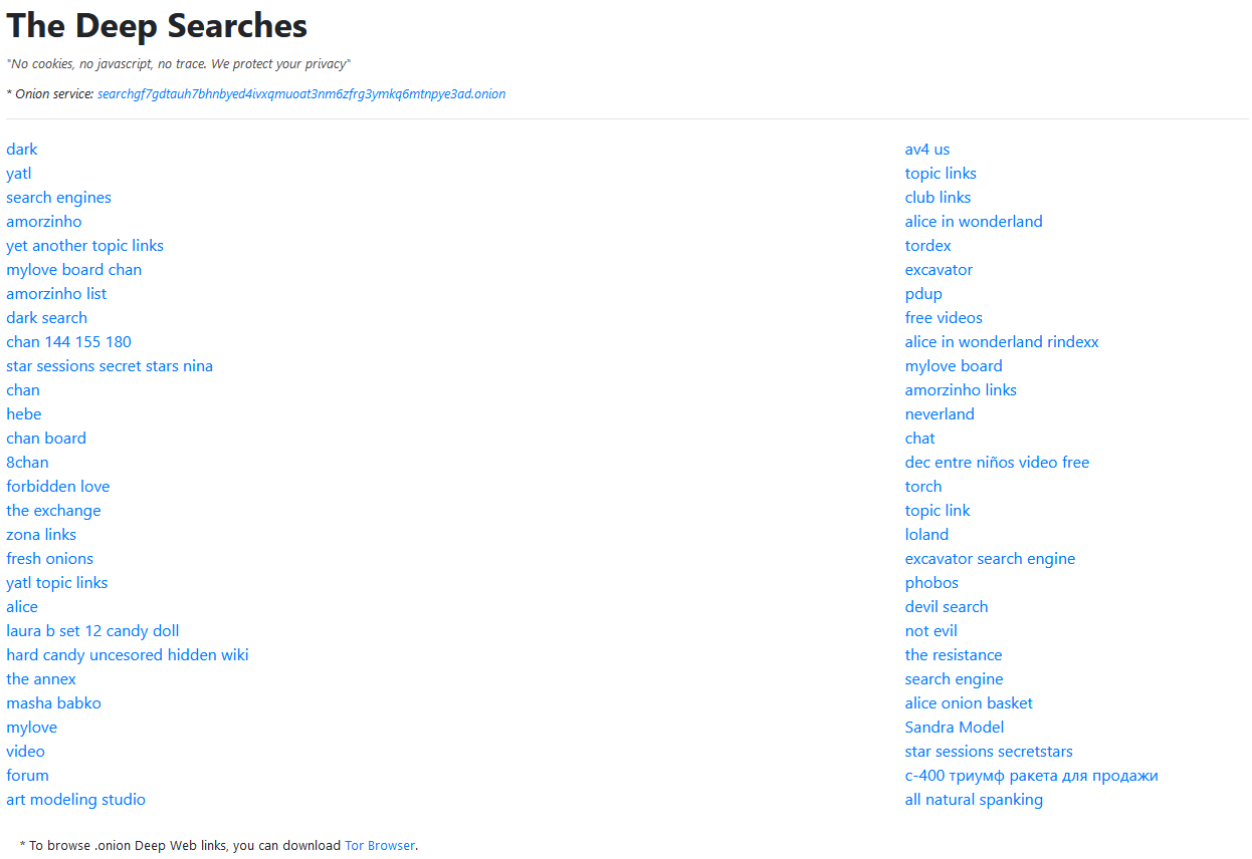


Imagen 127. Términos más utilizados como búsqueda dentro de The Deep Searches

Procedemos a realizar una consulta de la palabra clave "ransomware" dentro del buscador en conjunto con tres palabras clave a excluir (sex, xxx y porn). En la Imagen 128 pueden verse los resultados, obteniéndose un total de 133, donde cada uno de ellos aparece con su correspondiente enlace, título y descripción del sitio web.

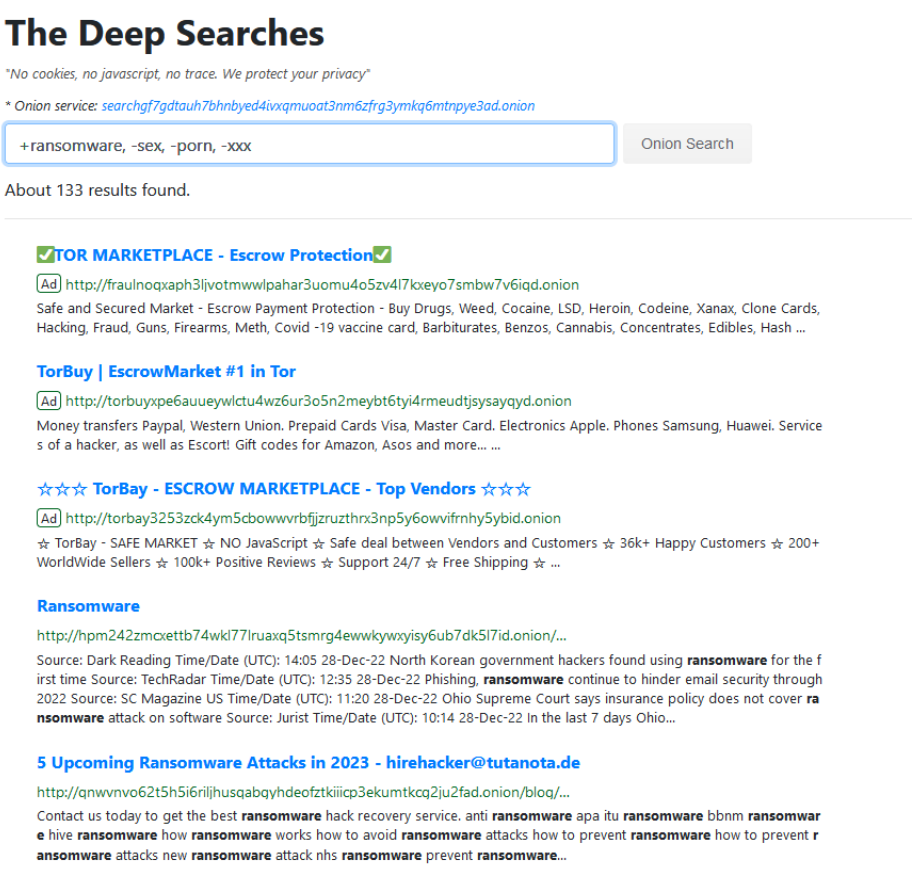


Imagen 128. Búsqueda de una dork con The Deep Searches

3. Introducción al Cyber Threat Intelligence (CTI)

Desde hace algún tiempo estamos viviendo en primera persona la evolución que está teniendo la tecnología a todos los niveles. Esta situación es algo bueno para la sociedad, ya que nos brinda de una serie de posibilidades que hace unos años serian impensables, desde el punto de vista del uso de ciertos recursos. La tecnología puede ayudarnos a ser más eficientes y dar mejores resultados en nuestro día a día, siempre y cuando la utilicemos de la manera adecuada.

Los criminales también están aprovechando el uso de la tecnología a su favor para de alguna manera sacar provecho de este avance. Por este mismo hecho, muchas de las operaciones de los criminales son perpetradas utilizando recursos cibernéticos en vez de realizar actos delictivos de manera física. Esto les permite añadir más capas de anonimato para ocultar sus huellas e identidad, además de poder ejecutar dichas operaciones desde cualquier punto del mundo.

Las amenazas ejecutadas por los criminales están avanzando a pasos agigantados, lo que conlleva a que las propias defensas de una empresa u organización se vean afectadas si utilizan medidas de seguridad tradicionales o si los enfoques operativos no están adecuados a las nuevas amenazas.

Para hacer frente a la gran variedad de amenazas que llevan años produciéndose, apareció en Europa el concepto de Cyber Threat Intelligence por medio del CERT de Reino Unido (CERT-UK). Este concepto también es conocido como CTI o Threat Intelligence, el cual es definido de la siguiente manera:

> Conocimiento resultante sobre las amenazas basándose en evidencias concretas incluyendo capacidades, infraestructura, motivación, objetivos y recursos del atacante. Por lo tanto, CTI permite detectar indicadores relacionados a ciberamenazas, extraer información referente a métodos de ataque, identificar amenazas de seguridad y tomar decisiones con antelación, con el fin de responder a posibles ataques de manera precisa y contundente.

Al final el **Cyber Threat Intelligence** no deja de ser una disciplina que permite generar un producto de Inteligencia que ayude en la toma de decisiones para protegerse y hacer frente a las ciberamenazas. A través del conocimiento que aporta CTI podemos llegar a ser capaces de recolectar información sobre un adversario con el fin de detectar cuál es su actividad maliciosa relacionada, que patrones suele utilizar y entender cuál es el comportamiento empleado detrás de sus ataques.

El fin del CTI no es recolectar únicamente indicadores de compromiso sobre amenazas, sino generar ese conocimiento mencionado alrededor del adversario con el objetivo de reducir el posible riesgo que pudiera ocasionar a la empresa u organización, además de anteponerse a sus ataques y contrarrestarlos. Para analizar una amenaza en su conjunto es vital detectar una serie de datos que ayuden a identificar el actor o grupo criminal detrás de un ataque. Por este hecho es bastante importante aplicar técnicas de análisis basados en hipótesis y evidencias a través de un proceso analítico de todos los datos recolectados.

Las preguntas claves a hacerse sobre una amenaza son las siguientes:

- **Quiénes** son los adversarios, incluyendo a los actores, patrocinadores y empleados.
- **Qué** usan los adversarios, incluyendo sus capacidades e infraestructura utilizadas.
- **Donde** suelen atacar los adversarios, detallando industrias, tipo de empresas y regiones geográficas.
- **Cuando** actúan los adversarios, identificando líneas de tiempo.
- **Por qué** atacan los adversarios, incluyendo sus motivos e intenciones.
- **Cómo** operan los adversarios, enfocados en sus comportamientos y patrones.

Un producto de Inteligencia basado en Cyber Threat Intelligence debe tener siempre dos elementos finales que son el **contexto** y la **acción**, sin ambos, **la Inteligencia sobre la amenaza no sería ni entendible ni procesable por parte del consumidor**.

Por medio del contexto podemos llegar a identificar el por qué, por quién y el cómo es efectuada la amenaza. Además, dicho contexto también puede facilitar información sobre qué tipo de empresas son objetivos y pueden llegar a verse afectadas frente a una amenaza concreta. Muchas de estas están dirigidas a un sector profesional específico, una tecnología vulnerable o incluso a un país en particular. Conociendo el contexto de una amenaza, muchas empresas pueden llegar a identificar si dicho incidente puede llegar a afectarles, priorizar de una manera más eficiente o bien saber cómo mitigar la amenaza.

Generalmente un contexto suele incluir lo siguiente:

- Descripción del comportamiento del actor o grupo criminal detrás de la amenaza teniendo en cuenta el KillChain
- Descripciones técnicas a alto nivel como por ejemplo indicadores de compromisos claves usados, breve análisis de la amenaza, actividades maliciosas detectadas, artefactos de red principales, etc
- Industria/s y país/es afectados
- Evaluación del impacto y análisis de riesgos

Un ejemplo de dicho contexto sería el siguiente:

Amenaza: APT Vicious Panda
Sector: Gubernamental
Países objetivo: Mongolia
Impacto: **HIGH**

Campaña dirigida hacia el sector público de Mongolia, en concreto a su gobierno. Los adversarios utilizan el miedo generalizado del Coronavirus con el fin de usarlo como anzuelo y engañar a las víctimas a través de correos electrónicos bajo el pretexto de nuevos datos sobre la prevalencia de nuevas infecciones por coronavirus.

Investigadores detectaron dos documentos maliciosos en formato RTF adjuntados en dichos correos electrónicos, los cuales fueron enviados al sector público de Mongolia, supuestamente desde el Ministerio de Relaciones Exteriores de Mongolia. Los documentos mencionados fueron recibidos en idioma mongol aprovechando el miedo generalizado del COVID-19 ocasionado en el mundo entero para engañar a las víctimas.

El proceso de infección parte del envío del correo electrónico con el documento en formato RTF adjunto bajo el nombre de "**About the prevalence of New coronavirus infections.rtf**". Dicho documento explota la vulnerabilidad del editor de ecuaciones de Microsoft Word (**CVE-2017-11882** y **CVE-2018-0798**). En el propio documento RTF (aparentemente creado con la herramienta **RoyalRoad**) es insertado un objeto malicioso embebido que explota la vulnerabilidad anteriormente mencionada. La ejecución del payload presente en el documento copia el fichero **intel.ws** dentro del directorio de arranque de Microsoft Word (**%APPDATA%\Microsoft\Word\STARTUP**) con el fin de ganar persistencia en cada inicio del software indicado.

El fichero **intel.ws** se comunica con el servidor malicioso **95.179.242[.]6,** desde donde se descarga el loader **minisdllpub.dll**. Dicha librería mencionada será ejecutada por medio de **Rundll32**, el cual se comunicará con un **servidor C&C** (**95.179.242[.]27**) para recibir funcionalidades extra.

El propio loader descargará y descifrará un **módulo RAT (Troyano de Acceso Remoto)** a través de un plugin que funciona como backdoor (**mdll.dll**), el cual lo carga en memoria, permitiendo la ejecución de una serie de operaciones directamente en la víctima. Entre estas son descubiertas capacidades básicas bastante comunes, tales como realizar capturas de pantalla, listar archivos y directorios, crear y eliminar archivos, mover y eliminar archivos, descargar un archivo, ejecutar un nuevo proceso y obtener una lista de todos los servicios en ejecución.

Por medio de diversas fuentes se contrasta que parte de la carga maliciosa de Vicious Panda es utilizada en otros ataques registrados por medio de diferentes actores, en concreto en el bucle de descifrado utilizado por cada muestra de las cuatro amenazas.
Los actores detectados son **Microcin** (**Objetivo Rusia**), **BYEBY** (**Objetivo Bielorrusia**) y **Mikroceen** (**Objetivo Asia Central**).

Analizando todos los Indicadores de Compromiso (IoC) de las cuatro amenazas detectamos que los dominios y direcciones IP utilizados en los ataques de **BYEBY** y **Vicious Panda** comparten la misma infraestructura a través de los servicios de **Vultr** y **GODADDY**.

En el caso de que no fuera identificado el contexto, únicamente dispondríamos de indicadores sin sentido y sin un propósito conocido. Al carecer de elementos claves para identificar correctamente el porqué de la amenaza, no sería posible obtener un producto de Inteligencia que ayudara a tomar una decisión determinada sobre la amenaza en cuestión.

El otro elemento final mencionado anteriormente, la acción, proporciona recomendaciones técnicas y posibles soluciones para resolver una incidencia concreta. Además, debe informar también del comportamiento que utiliza la amenaza y el impacto asociado. La información recogida dentro de la acción tiene que resultar interesante para cualquier tipo de profesional relacionado con el Cyber Threat Intelligence, desde indicadores de compromiso o cualquier detalle técnico que ayude a un perfil técnico (por ejemplo, analistas de malware y forenses) hasta el riesgo y el impacto que puede repercutir económicamente a una empresa proporcionando información útil a un perfil estratégico como pudiera ser el CEO de una compañía, o bien, quien está detrás de la amenaza y que TTPs utilizan para ayudar de esta manera a un perfil táctico (director de seguridad de una empresa - CISO).

Una acción debería incluir lo siguiente:

- Procedimientos y políticas que permitan prevenir y proteger la empresa u organización de cualquier tipo de amenaza
- Adjuntar Técnicas, Tácticas y Procedimientos (TTP) utilizadas por la amenaza para poder buscar similitudes con otras amenazas y protegerse de ellas
- Recomendaciones recolectando información de valor referentes a diferentes TTP de diversas fuentes para una detección de amenazas más efectiva y proactiva
- Planes de mitigación de la amenaza

Un ejemplo de la acción sería el siguiente:

Amenaza: APT Vicious Panda

Impacto: **HIGH**

Campaña dirigida hacia el sector público de Mongolia explotando el miedo generalizado del Coronavirus con el fin de usarlo como anzuelo y engañar a las víctimas a través de correos electrónicos bajo el pretexto de la prevalencia de nuevas infecciones por el coronavirus. Según lo mencionado en el contexto, existen similitudes con campañas anteriores que indican que el grupo malicioso lleva ejecutando operaciones desde el 2016.

Analizando las Tácticas, Técnicas y Procedimientos asociadas a las muestras de malware detectadas, descubrimos la presencia de **10 tácticas** y **30 técnicas**. Entre estas podemos encontrarnos con las tácticas de **acceso inicial** (*mediante Phishing*), **ejecución** (*el usuario ejecuta un fichero malicioso*), **persistencia** (*carga de una librería DLL y persistencia con esta en el inicio de la aplicación Microsoft Word*), **elevación de privilegios** (*bypass del control de cuentas de usuario de Windows*), **evasión defensiva** (*desofuscación/ofuscación de archivos o información, modificación de registros, ejecución de binarios firmados como Regsvr32 o Rundll32),* **acceso a credenciales** (*captura de credenciales a través de API Hooking*), **descubrimiento** *(enumeración de archivos y directorios y descubrimiento de llaves de registro*), **movimiento lateral** (*transferencia lateral de herramientas en los sistemas internos de la víctima*), **colección** (*pantallazo del escritorio, datos desde unidades de red compartidas, el sistema local o repositorios de información, colección automatizada para recolectar información*) y **comando y control** (*codificación de datos, uso de canales cifrados, utilización de canales de comunicación alternativos o de puertos no comunes*).

Alguna de las herramientas utilizadas por Vicious Panda en las operaciones son las siguientes: **Enfal / Lurid** (*Downloader*), **Pylot / Travle** (*Backdoor*), **Cmstar** (*Downloader*), **Byeby** (*Backdoor*), **BBSRAT** (*Backdoor*) y **8.t Dropper / RoyalRoad** (*Dropper*).

Mitigación de la amenaza:

- Aislar de la red las máquinas infectadas por la amenaza.
- Generar reglas para bloquear tráfico entrante y saliente hacia cualquier IoC relacionado con la amenaza en cortafuegos, IDS, IPS, proxies y resto de dispositivos defensivos perimetrales
- Añadir todas las direcciones IP y dominios relacionados con la amenaza en blacklists

- Analizar mediante un sandbox todos los archivos adjuntos en correos electrónicos para verificar su legitimidad

- Bloquear por defecto los archivos adjuntos desconocidos o no utilizados habitualmente y que no deban transmitirse por correo electrónico como los siguientes formatos entre otros: .exe, .scr, .pif, .cpl, etc

- Inspeccionar manualmente las configuraciones establecidas en los archivos manifest para comprobar que no existan vulnerabilidades relacionadas con la carga o subida de cualquier tipo de fichero o software

- Desactivar la ejecución de macros y complementos de Microsoft Office. En el caso de ser necesarias, deben ir firmadas

- Instalar el software necesario en ubicaciones que estén protegidas contra la escritura

- Eliminar usuarios del grupo de administradores locales en los sistemas

- Añadir permisos para evitar que los usuarios modifiquen claves de registro de cualquier componente del sistema

- Tener activado el UAC (control de cuentas de usuario de Windows) al nivel más alto, siempre que sea posible

- Identificar y bloquear la ejecución de funcionalidades a través de regsvr32 y rundll32 que estén categorizadas como software potencialmente malicioso

- Desactivar servicios relacionados con el protocolo SMB sino son utilizados, en el caso de que sean necesarios, mantener actualizados estos con los últimos parches de seguridad.

Recomendaciones:

- Disponer de las últimas actualizaciones de aplicaciones y sistema operativo instaladas (siempre que sea posible)

- Revisar periódicamente las cuentas y los privilegios de los repositorios críticos y sensibles

- Software antivirus y antimalware actualizados para disponer de los últimos parches de seguridad sobre vulnerabilidades conocidas

- Detectar nuevos IoC asociados a la amenaza realizando un triaje en el SIEM para la monitorización de reglas a partir de patrones, reglas YARA y expresiones regulares como medida proactiva para evitar nuevos incidentes

- Emplear la detección de malware basada en la heurística

- Verificar logs de dispositivos perimetrales de seguridad en busca de patrones de comportamiento de la amenaza

- Evitar instalar software no oficial

- Formación de concienciación sobre amenazas de ciberseguridad a los empleados como por ejemplo el Phishing

- Cifrar todo el almacenamiento con información sensible tanto en la red interna como externa. Con esto conseguimos proteger los activos más valiosos de la organización en el caso de que el adversario consiga adquirir la información por medio de alguna técnica de colección.

Enlaces de interés:

- https://research.checkpoint.com/2020/vicious-panda-the-covid-campaign/
- https://www.welivesecurity.com/2020/05/14/mikroceen-spying-backdoor-high-profile-networks-central-asia/

3.1. INDICADORES DE COMPROMISO

NIST define el indicador de compromiso (dentro de la guía para compartir información sobre ciberamenazas) como "**un artefacto técnico u observable que sugiere que un ataque es inminente, está en curso o que ha podido ocurrir ya**". Algunos ejemplos de indicadores son: URL, Dirección IP, Rango IP, Hash, Dominio, Registro DNS como MX,NS,SOA,CNAME y TTP.

La idea fundamental de los indicadores de compromiso (IoC) es detectar tanto de manera reactiva como proactiva patrones que permitan identificar indicadores relacionados con algún tipo de amenaza que pudiera afectar a la organización, ya sea porque estén presentes en algún registro de log de sistemas internos o bien para defenderse de dichas amenazas en el futuro añadiendo en listas negras direcciones IPs asociadas a botnets, por ejemplo.

Los IoCs son importantes por dos grandes motivos. En primer lugar, permiten documentar una amenaza con datos concretos y específicos siguiendo una terminología común. Esto último ayuda a compartir los diversos indicadores con el mismo equipo o incluso con otras organizaciones hablando el mismo idioma. En segundo lugar, proporciona a los equipos técnicos una manera eficiente de tratar los datos mediante automatizaciones con el fin de detectar si los indicadores obtenidos de fuentes externas están presentes en los sistemas internos de la organización.

Un IoC es cualquier observable que tenga relación con una amenaza. A través de dicho observable es posible detectar los mismos patrones de una amenaza en otras. Existen una gran variedad de IoC dependiendo de la amenaza en cuestión, pero los más utilizados y conocidos son los siguientes:

- URL
- Dirección IP Origen
- Dirección IP Destino

- Dirección MAC Origen
- Dirección MAC destino
- Puerto
- Nombre servicio
- Protocolo
- Rango IP
- Dominio
- Registro DNS como MX,NS,SOA,CNAME
- Hostname
- Hash (MD5, SHA1, SHA224, SHA256, SHA512)
- Fecha del incidente
- Correo electrónico
- Nombre de procesos y archivos afectados
- Muestra de fichero malicioso
- Funciones utilizadas por el archivo malicioso
- Clave de registro
- Cookie. Son archivos generados por los navegadores webs. Incluye información relativa a la autenticación o sesión del usuario pudiendo incluso suplantar la identidad del propio usuario en el caso de que este logueado en algún servicio de terceros.
- CVE (Common Vulnerabilities and Exposures), CPE (Common Platform Enumeration)
- IBAN, BIN (Número de identificación bancario), BIC (Código de identificación bancario).
- BTC, ETH (Direcciones de criptomonedas: Bitcoin y Ethereum).
- TTP
- Actor o grupo criminal

Existen una infinidad de fuentes donde consultar y recolectar información relativa a IoCs, como por ejemplo threatfeeds (ver Imagen 129), el cual permite descargar diferentes

feeds, indicando en cada uno de ellos el número de IoCs que contiene en su interior, la fecha de publicación, última fecha de modificación, tamaño del feed, número total de líneas y un código de estado HTTP para comprobar si el feed es accesible actualmente.

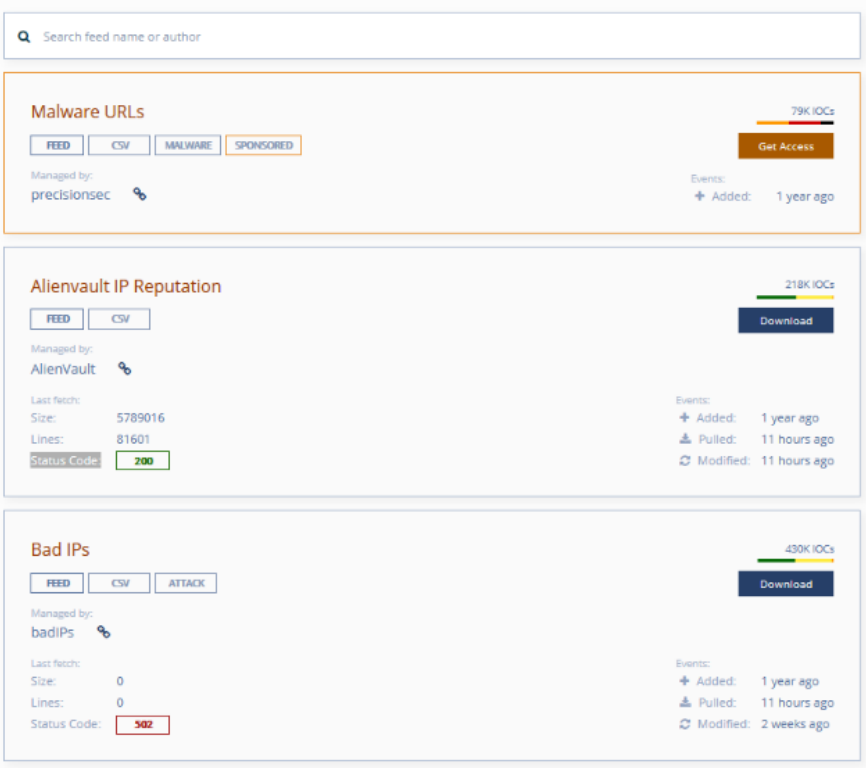


Imagen 129.Listado de feeds de Threatfeeds.io

3.2. ACTORES DE AMENAZA

Los actores maliciosos también son conocidos como los adversarios y pueden ser un individuo o grupo relacionados con un determinado ataque. La información que puede ser recopilada asociada a un actor es la siguiente:

- Afiliación a un colectivo concreto como puede ser el servicio secreto de un estado-nación o grupos hacktivistas, entre otros.
- Identidad del atacante
- Motivación del ataque
- Sector en los que opera
- Relación con otros actores de amenazas
- TTPs relacionados

Según UNIT42 las principales motivaciones de los actores son las siguientes:

- **Ciberespionaje**. El espionaje cibernético está centrado en la explotación de los sistemas y redes de manera paciente, persistente y creativa con el fin de obtener ventajas estratégicas económicas, políticas y/o militares. Una de las principales amenazas utilizadas en el ciberespionaje son los APT. Los actores que operan bajo esta motivación son:

    - Estado-Nación. Son aquellas actividades de recolección de Inteligencia patrocinadas por el gobierno y/o fuerzas militares de un país para cumplir con los objetivos fijados.

    - Corporativo o empresarial. Son aquellas actividades centradas en la ventaja competitiva desleal dentro de una industria. Aquí entra mucho en juego los Insiders.

- **Cibercrimen**. Es una extensión de la actividad delictiva tradicional pero trasladado al ciberespacio. Está centrado en el robo de información personal y de cuentas, además de establecer campañas de influencia para lograr objetivos monetarios. Existen varios subtipos de actores, los cuales realizan actividades relacionadas con el fraude online, brechas de seguridad y robo de información. La gran mayoría de ataques están enfocados en la Ingeniería Social para engañar a las víctimas para que compartan información confidencial o ejecuten código malicioso en su dispositivo.

- **Hacktivismo**. Son actividades de activistas que buscan influir en la opinión y/o reputación de organizaciones, afiliaciones o causas específicas en base a unas creencias. Un colectivo dentro del Hacktivismo es Anonymous, que funcionan como grupos independientes en función de sus ideales, objetivos y sobre todo país o región de origen. Este colectivo muchas veces carece de una jerarquía formal de liderazgo debido en gran parte a que están repartidos por zona geográficas diferentes, además de que suelen poseer intereses diferentes. Los grupos de actores maliciosos englobados con esta motivación, pero con un liderazgo más cohesionado y estructurado, generalmente muestran apoyo político hacia algún partido o gobierno concreto operando bajo sus órdenes. Entre los ataques más utilizados siguiendo esta motivación tenemos: denegaciones de servicio, filtración de información confidencial y manipulación del contenido de perfiles sociales y páginas web reivindicando algo concreto.

- **Guerra cibernética**. Son operaciones que ayudan a eliminar o degradar las capacidades de un objetivo orientado a un estado-nación concreto, ya sea como complemento a actividades militares o por motivaciones propias. Entre los objetivos de las actividades ejecutadas por los actores tenemos: la interrupción de las operaciones de los estado-nación enemigas, degradación y manipulación de las capacidades subyacentes de los estado-nación y la destrucción de objetivos físicos de los estado-nación enemigos.

- **Ciberterrorismo**. Actividades y operaciones de terrorismo tradicionales trasladado al ciberespacio, el cual, se diferencia en que no hay pérdidas humanas (generalmente), ocasionan grandes pérdidas económicas y perturban y dañan la infraestructura básica. Entre los actores maliciosos tenemos a los grupos terroristas oficialmente reconocidos y grupos o individuos categorizados como “Black Hat”. Entre las motivaciones que tienen dichos actores destacan la

interrupción de bienes o servicios de las victimas e intimidación de una población para generar una influencia concreta en ella.

- **Diversión**. Son actividades y operaciones que generalmente son ejecutadas por personas sin ningún tipo de motivación concreta, solo les interesa hacer ruido o atacar sistemas por diversión sin patrón alguno. La mayoría de las veces son "hackers novatos" que están aprendiendo a realizar determinados ataques, pero sin albergar intenciones maliciosas. Se les conoce también como los "Script Kiddies", que son aquellas personas que carecen de nivel técnico y únicamente ejecutan herramientas de hacking, pero sin el conocimiento adecuado para ello.

Esta información es utilizada para comprender mejor al adversario y poder defenderse, aplicando contramedidas más eficaces para proteger los propios sistemas de la organización a través de un análisis a fondo de cada Táctica, Técnica y Procedimiento (TTP). Los niveles de atribución son muy valiosos para identificar quien está detrás de un determinado ataque para relacionar TTPs que no sean atribuidas a ningún actor conocido pero que por las técnicas o tácticas utilizadas puedan relacionarse a actores concretos por la similitud del propio ataque. Disponer de un repositorio donde almacenar las principales capacidades de los actores es vital para poder atribuir ciertos ataques no identificados a priori. En la Imagen 130 pueden verse los diferentes niveles de atribución para categorizar a cada adversario.



Imagen 130. Niveles de atribución

La definición de cada uno de los niveles son los siguientes:

- **High-Level Motivation**. Son las motivaciones de alto nivel. Las amenazas son más fáciles de atribuir porque generalmente están agrupados en alguno de las 5 motivaciones descritas anteriormente.

- **Qualifiers**. La amenaza es clasificada en función de ciertos aspectos como pueden ser el objetivo preferido (sector, afiliación, tipo de información, etc), actividades patrocinadas (financiación) y la detección de la posible relación con otros grupos criminales o actores a través de operaciones similares, la misma ideología política o intereses comunes.

- **Group**. Incluye la identificación mediante TTPs, categorización por herramientas y malware utilizado, infraestructura usada para el ataque y el grado de cohesión del grupo.

- **Individual**. Es el nivel más difícil de identificar, principalmente porque los adversarios tienen un nivel muy avanzado, en el cual, utilizan técnicas muy sofisticadas e innovadoras. Suelen utilizar ataques muy dirigidos.

Un recurso donde ver operaciones de APTs asociados a actores y grupos criminales es el que puede verse en la Imagen 131. Puede consultarse a través del siguiente enlace: http://apt.threattracking.com.

README | China | Russia | North Korea | Iran | Israel | NATO | Middle East | Others | Unknown | _Download | _Schemes | _Malware | _Sources

Russia

Common Name	Other Name 1	Other Name 2	Other Name 3	Other Name 4	Other Name 5	Other Name 6	Other Name 7	Other Name 8	Other Name 9	Other Name 10	Other Name 11	Other Name 12	Secureworks	Operation 1	Operation 2
Sofacy	APT28	Sednit	Pawn Storm	Group 74	Tsar Team	Fancy Bear	Strontium	Swallowtail	SIG40	Grizzly Steppe			IRON TWILIGH	Russian Doll	Bundestag
APT29	Dukes	Group 100	Cozy Duke	EuroAPT	Cozy Bear	CozyCar	Cozer	Office Monkeys / TEMP.Monkeys	Minidionis	SeaDuke	Hammer Toss	Fritillary	IRON HEMLOCK		
Turla Group	Snake	Venomous Bea	Group 88	Waterbug	Turla Team	Krypton	Uroburos	SIG23	MAKERSMAR				IRON HUNTER	Satellite Turla	Epic Turla
Energetic Bear	Dragonfly	Crouching Yeti	Group 24	Koala Team	Berserk Bear	Anger Bear	Dymalloy	Havex	PEACEPIPE	Ferfger			IRON LIBERTY		
Sandworm	Sandworm Tea	TEMP.Noble	Electrum	TeleBots	Quedagh Grou	BE2 APT	Black Energy	Iridium					IRON VIKING	Black Energy	Ukrenergo

Imagen 131. Grupos criminales y actores relacionados a APT

Otro recurso donde consultar información relacionada a actores y grupos criminales es MITRE ATT&CK (Imagen 132). Puede consultarse a través del siguiente enlace: https://attack.mitre.org/groups/.

Groups

Groups are sets of related intrusion activity that are tracked by a common name in the security community. Analysts track clusters of activities using various analytic methodologies and terms such as threat groups, activity groups, threat actors, intrusion sets, and campaigns. Some groups have multiple names associated with similar activities due to various organizations tracking similar activities by different names. Organizations' group definitions may partially overlap with groups designated by other organizations and may disagree on specific activity.

For the purposes of the Group pages, the MITRE ATT&CK team uses the term Group to refer to any of the above designations for a cluster of adversary activity. The team makes a best effort to track overlaps between names based on publicly reported associations, which are designated as "Associated Groups" on each page (formerly labeled "Aliases"), because we believe these overlaps are useful for analyst awareness. We do not represent these names as exact overlaps and encourage analysts to do additional research.

Groups are mapped to publicly reported technique use and original references are included. The information provided does not represent all possible technique use by Groups, but rather a subset that is available solely through open source reporting. Groups are also mapped to reported Software used, and technique use for that Software is tracked separately on each Software page.

Groups: 91

Name	Associated Groups	Description
admin@338		admin@338 is a China-based cyber threat group. It has previously used newsworthy events as lures to deliver malware and has primarily targeted organizations involved in financial, economic, and trade policy, typically using publicly available RATs such as Poisonivy, as well as some non-public backdoors.
APT1	Comment Crew, Comment Group, Comment Panda	APT1 is a Chinese threat group that has been attributed to the 2nd Bureau of the People's Liberation Army (PLA) General Staff Department's (GSD) 3rd Department, commonly known by its Military Unit Cover Designator (MUCD) as Unit 61398.
APT12	IXESHE, DynCalc, Numbered Panda, DNSCALC	APT12 is a threat group that has been attributed to China. The group has targeted a variety of victims including but not limited to media outlets, high tech companies, and multiple governments.
APT16		APT16 is a China-based threat group that has launched spearphishing campaigns targeting Japanese and Taiwanese organizations.
APT17	Deputy Dog	APT17 is a China-based threat group that has conducted network intrusions against U.S. government entities, the defense industry, law firms, information technology companies, mining companies, and non-government organizations.
APT18	TG-0416, Dynamite Panda, Threat Group-0416	APT18 is a threat group that has operated since at least 2009 and has targeted a range of industries, including technology, manufacturing, human rights groups, government, and medical.
APT19	Codoso, C0d0so0, Codoso Team, Sunshop Group	APT19 is a Chinese-based threat group that has targeted a variety of industries, including defense, finance, energy, pharmaceutical, telecommunications, high tech, education, manufacturing, and legal services. In 2017, a phishing campaign was used to target seven law and investment firms. Some analysts track APT19 and Deep Panda as the same group, but it is unclear from open source information if the groups are the same.
APT28	SNAKEMACKEREL, Swallowtail, Group 74, Sednit, Sofacy, Pawn Storm, Fancy Bear, STRONTIUM, Tsar Team, Threat Group-4127, TG-4127	APT28 is a threat group that has been attributed to Russia's Main Intelligence Directorate of the Russian General Staff by a July 2018 U.S. Department of Justice indictment. This group reportedly compromised the Hillary Clinton campaign, the Democratic National Committee, and the Democratic Congressional Campaign Committee in 2016 in an attempt to interfere with the U.S. presidential election. APT28 has been active since at least 2004.

Imagen 132. Listado de grupos criminales presentes en MITRE ATT&CK

3.3. TÁCTICAS, TÉCNICAS Y PROCEDIMIENTOS

Las Tácticas, Técnicas y Procedimientos (TTP) describen el comportamiento que tiene un actor malicioso. Los TTPs son utilizados para entender las operaciones ejecutadas de los adversarios (objetivo, cómo y porqué lo usan) y simular escenarios de ataque de manera

controlada, principalmente en proyectos de Threat Hunting y Red Team. A continuación, describimos cada uno de los términos que forman un TTP:

- Táctica: Este primer término indica la descripción del comportamiento a alto nivel. Una definición más exacta podría ser la siguiente: "Proceso que sigue un adversario para cumplir un objetivo marcado, el cual, puede apoyarse por diversas técnicas para alcanzar dicho fin". Esto indica que la táctica analiza las acciones realizadas por un adversario para contestar a las preguntas de quien, qué, dónde, cuándo, por qué, cómo y sobre todo entender cuál es su objetivo.

- Técnica: El segundo término ofrece una descripción más detallada dentro del contexto de la misma táctica. La técnica podemos definirlo de la siguiente forma: "Actividad que utiliza un patrón conocido con el que permite ejecutar los movimientos marcados en la táctica y cumplir así con el objetivo fijado".

- Procedimiento: El último término dispone de una descripción aún más detallada pero dentro del contexto de la técnica y a bajo nivel. El procedimiento es una guía paso a paso con todas las pautas o acciones a realizar de manera oficial y que deben cumplir el objetivo de obtener el resultado deseado en la parte técnica.

En definitiva, las técnicas son las herramientas para ejecutar la actividad, la táctica es la combinación de las técnicas que permiten cumplir con un trabajo concreto y el procedimiento es el estándar definido que ayuda a hacer el trabajo.

Los TTPs pueden ser de gran ayuda a la hora de detectar nuevas amenazas, ya que, analizando las técnicas utilizadas en el propio ataque puede ser identificada la táctica asociada a este y por consiguiente descubrir que actor o grupo criminal está detrás de la amenaza. El framework ATT&CK de MITRE es una de las referencias mundiales sobre TTPs. ATT&CK fue creado en el año 2010 por la necesidad de categorizar el comportamiento del adversario como parte de la realización de ejercicios estructurados de emulación del adversario dentro de una investigación interna llamada Fort Meade

Experiment (FMX). ATT&CK dispone de una base de conocimiento con un modelo donde es categorizado el comportamiento de los adversarios. El proyecto ATT&CK ha crecido hasta tal punto, que hoy en día cubre las tácticas, técnicas y procedimientos previos al ataque y bajo los dominios centrados en la tecnología, otros sistemas como Linux y MacOS, además de dispositivos móviles.



Imagen 133. Extracto de TTPs de MITRE ATT&CK

Tal como puede verse en la Imagen 133, ATT&CK ofrece un modelo de comportamiento de adversarios con los siguientes componentes:

- **Tácticas asociadas a los adversarios, pero con objetivos de ataque a corto plazo**. Las tácticas en el propio Framework de ATT&CK son divididos por columnas siendo las siguientes opciones: Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, Command and Control, Exfiltration, Impact. En la Imagen 146 puede verse un ejemplo con un extracto de la táctica de "Initial Access".

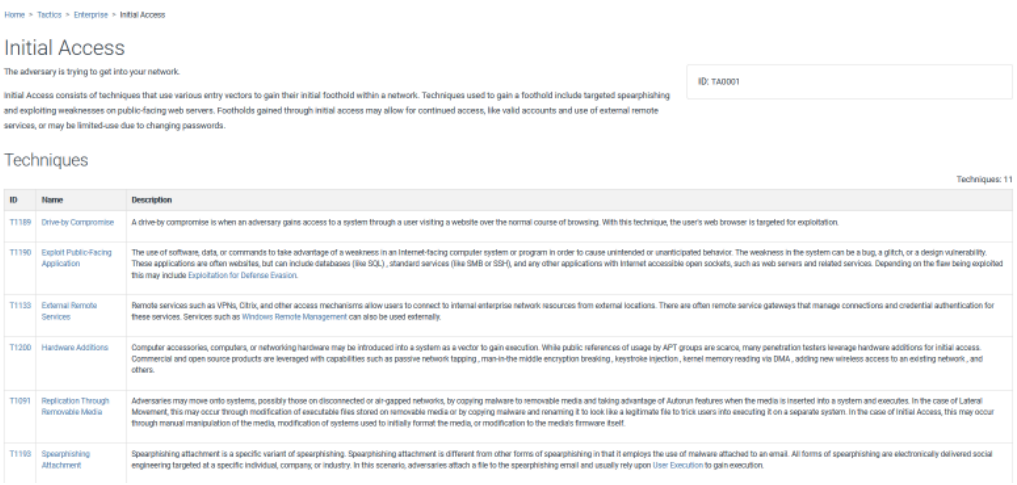


Imagen 134. Extracto de táctica de Initial Access de MITRE ATT&CK

- **Técnicas que permiten ejecutar ejercicios reales en base a cada táctica**. Dentro del Framework de ATT&CK corresponden a las celdas dividas por filas y englobadas en cada columna de la táctica asociada. En la Imagen 135 puede verse un ejemplo con un extracto de la técnica de "AppleScript".

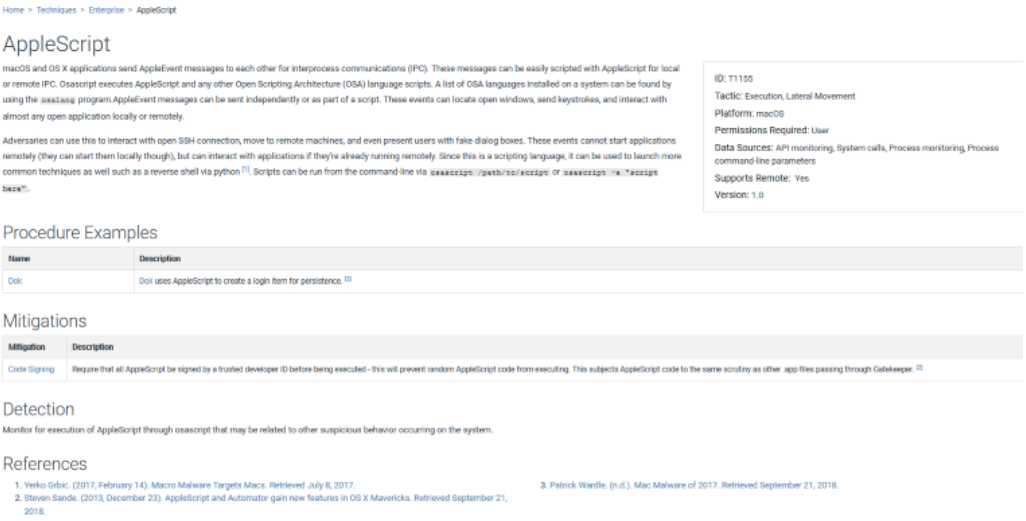
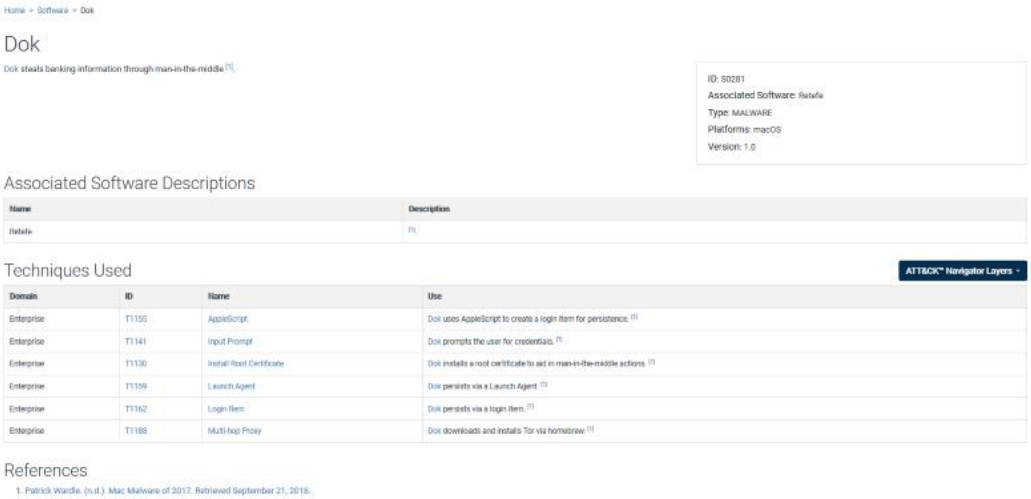


Imagen 135. Extracto de técnica de AppleScript de MITRE ATT&CK

- **Procedimientos en forma de documentos que recogen las técnicas individuales** utilizadas por cada adversario. En la Imagen 136 puede verse un ejemplo con un extracto del procedimiento de "Dok".


Home > Software > Dok

Dok

Dok steals banking information through man-in-the-middle [1].

ID: S0281
Associated Software: Retefe
Type: MALWARE
Platforms: macOS
Version: 1.0

Associated Software Descriptions

Name	Description
Retefe	[1]

Techniques Used

ATT&CK™ Navigator Layers

Domain	ID	Name	Use
Enterprise	T1155	AppleScript	Dok uses AppleScript to create a login item for persistence. [1]
Enterprise	T1141	Input Prompt	Dok prompts the user for credentials. [1]
Enterprise	T1130	Install Root Certificate	Dok installs a root certificate to aid in man-in-the-middle actions. [1]
Enterprise	T1159	Launch Agent	Dok persists via a Launch Agent. [1]
Enterprise	T1162	Login Item	Dok persists via a login item. [1]
Enterprise	T1188	Multi-hop Proxy	Dok downloads and installs Tor via homebrew. [1]

References

1. Patrick Wardle. (n.d.). Mac Malware of 2017. Retrieved September 21, 2018.

Imagen 136. Extracto del procedimiento de Dok de MITRE ATT&CK

MITRE público en julio de 2018 un documento que explica el diseño y la filosofía desarrollada por MITRE ATT&CK. En su interior es descrito el comportamiento en forma de TTPs utilizados por los adversarios, además de proporcionar una taxonomía seguida tanto para el ataque como para la defensa. Marco muy utilizado por los analistas para analizar información sobre amenazas, ya sea para defenderse de estas o simular ejercicios de Red Team aprovechando algún TTP de algún actor conocido. En el siguiente enlace se puede visualizar dicho documento: https://attack.mitre.org/docs/ATTACK_Design_and_Philosophy_March_2020.pdf

3.4. LA PIRÁMIDE DEL DOLOR

El objetivo principal de los IoCs es poder responder a ellos con la suficiente rapidez como para bloquear el uso de ese indicador al adversario cuando está atacando a la organización. Este concepto fue expuesto en 2013 por David Bianco en su artículo "The Pyramid of Pain", en el que afirmaba la necesidad de responder a los indicadores de compromiso sin centrarse únicamente en recolectarlos y detectarlos.

Como todos los indicadores no son iguales, David Bianco diseño una pirámide (Ver Imagen 137) que en función de lo valioso que fuera un IoC para un adversario, el analista de seguridad fuera poniéndole barreras con el fin de proteger el activo y frustrar al atacante. Es una manera proactiva de analizar los diferentes IoC, ver relaciones con otros y definir una estrategia que permita defender cada uno de los indicadores frente a TTP asociados a una amenaza o actor malicioso concreto.

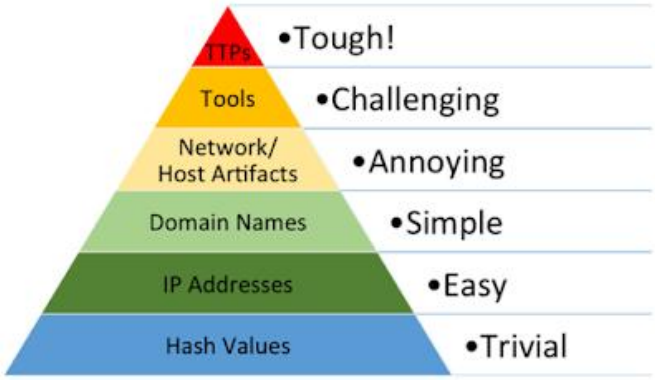


Imagen 137. Pirámide del dolor

En el año 2014, el propio David Bianco dio una ponencia en RVAsec donde expuso como la Inteligencia de amenazas puede ser utilizada para algo más que detectar y responder ante incidentes (ver Video 1). La idea que propuso era dificultar cada acción de un adversario con el fin de que cada operación que ejecutará fuera cada vez más costosa hasta que se dieran por vencidos debido a la frustración de no conseguir su objetivo. La presentación de dicha ponencia puede descargarse a través del siguiente enlace: https://rvasec.com/slides/2014/Bianco_Pyramid%20of%20Pain.pdf



Video 1. Ponencia de David Bianco en RVAsec sobre la pirámide del dolor

La pirámide del dolor dispone de 6 niveles organizados por el grado de dificultad que puede permitir a un adversario anteponerse ante cualquier tipo de problema para cumplir su objetivo de ataque. Si prestamos atención a la pirámide podemos darnos cuenta de que son utilizados diferentes colores en cada uno de los niveles, los cuales, no están fijados al azar sino todo lo contrario. La base de la pirámide es representada con color azul debido a que es el nivel que menor grado de dificultad supone para un atacante y el último nivel es representado con un color rojo debido a que el grado de dificultad es muchísimo mayor para un adversario. En este sentido cuanto más cercano este el IoC a la base más fácil será el ataque. A continuación, serán explicados cada uno de los niveles que componen la pirámide del dolor:

- Valores Hash. El primer nivel es el encargado de detectar los hashes (MD5, SHA1, SHA256, etc) relacionados con ficheros sospechosos o maliciosos. Los hashes suelen ser utilizados en CTI como referencia única para identificar si un determinado archivo dispone de malware en su interior. Utilizando diferentes algoritmos de cifrado sobre un mismo archivo o muestra es posible generar

distintas huellas digitales sobre este, tal como ocurre con los hashes de la tabla inferior. El valor hash está situado en la base de la pirámide porque la modificación de este es muy trivial para el adversario. El atacante con cualquier leve cambio que realice dentro del archivo malicioso generará un valor hash diferente, por lo tanto, para el adversario es relativamente sencillo anteponerse ante un bloqueo de un hash. Ante esta situación, un analista de seguridad no puede realizar prácticamente nada y únicamente podrá ir bloqueando los hashes en el momento de ser detectado por las medidas de seguridad o bien este relacionado con alguna amenaza.

MD5 70432e23f52d29306c1ff7b437c07fc0

SHA1 39a7525069d6070c2ab521f1b0c5f0571e206948

SHA256

ac27e0944ce794ebbb7e5fb8a851b9b0586b3b674dfa39e196a8cd47e9ee72b2

- Direcciones IP. El segundo nivel es el encargado de detectar las direcciones IP, que al igual que ocurre con los hashes es un indicador muy trivial para los adversarios. En el caso de que los sistemas detecten una dirección IP relacionada con cualquier tipo de amenaza, para el atacante es muy sencillo cambiar esa dirección IP por otra a través de proxies, VPN o Tor, por citar algunos ejemplos.

- Dominios. El tercer nivel es el encargado de detectar los dominios que tal como ocurre con el nivel anterior, todavía es fácil cambiar un dominio. Cada dominio nuevo tiene que ser registrado, pagado y alojado en algún lugar. En este sentido, los nuevos dominios registrados pueden tardar hasta 2 días en ser visibles en Internet, por lo tanto, sube un grado de dificultad para el adversario

ya que no puede cambiar en el momento del ataque el dominio tal como si ocurre con las direcciones IP. En la práctica no es relativamente difícil cambiar el dominio a través de servicios de DNS dinámicos que permiten automatizar el proceso de creación de dominios o proveedores DNS poco estrictos a la hora de generar un dominio nuevo. En este caso los adversarios suelen utilizar ataques IDN Homograph para simular ser otro dominio parecido al dominio legítimo, tal como puede verse en la tabla inferior.

En este ejemplo es utilizado el alfabeto griego para simular ser el dominio apple.com. Esto puede detectarse a través de las traducciones a punnycode[3].

Dominio legitimo: apple.com

IDN Homograph: αρρıє.com

Punnycode: xn--mxail5aa.com

- Artefactos de host y red. El cuarto nivel tal como indica su nombre está enfocado en los artefactos de host y de red, los cuales, ya genera un impacto negativo y molesto para el adversario. En este punto es muy difícil realizar cualquier acción sin dejar huellas en los logs de los sistemas de una organización. Desde el lado defensivo pueden analizarse los artefactos de host en busca de actividades maliciosas en archivos, entradas de registro, strings y procesos cargados en memoria que permitan obtener los patrones utilizados por los adversarios. Si son analizados los artefactos de red pueden centrarse en el análisis de patrones URI repetitivos, User-Agent[4] utilizados, errores de protocolo, peticiones y respuestas a un servicio web o comunicaciones con otros servicios de red. Aunque en este nivel se haya aumentado el grado de

[3] Punnycode: Es una codificación utilizada para convertir caracteres Unicode a ASCII. Es usado en los nombres de dominios internacionalizados (IDN).
[4] User-Agent: Son una serie de parámetros enviados por el navegador web del usuario a las páginas web que consulta este en Internet.

dificultad, el adversario todavía puede modificar los parámetros utilizados pero cada vez es más difícil ocultar su propia huella en los sistemas víctima. Un ejemplo de estos parámetros detectados son los que pueden verse en la tabla inferior.

> **Patrones URI repetitivos**: /^[A-F0-9]{16}\/\d{3,5}\.{php|aspx}$/
> **User-Agent**: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/535.7
> (KHTML, like Gecko) Chrome/16.0.912.75 Safari/535.7

- Herramientas. El nivel 5 está enfocado en el análisis de los artefactos generados por las herramientas utilizadas por el adversario. En este nivel el grado de dificultad ya es más elevado debido a la detección de los artefactos que identifiquen las herramientas del atacante y bloqueen cualquiera de sus acciones con estas. Este hecho puede provocar un nivel de frustración en el adversario bastante alto, ya que sería necesario investigar otras herramientas con las mismas capacidades o crear unas nuevas, lo que conlleva un tiempo de estudio bastante elevado para el criminal.

  Algunos ejemplos de los indicadores generados por dichas herramientas pueden ser firmas de antivirus o reglas YARA. El análisis de dichos artefactos incluso con pequeñas variaciones en los archivos asociados, puede ser clave para bloquear constantemente los ataques de un adversario.

- TTPs. El último nivel es el encargado de analizar las Tácticas, Técnicas y Procedimientos utilizados por los adversarios para contrarrestarlos. En este nivel está haciéndose frente al comportamiento del adversario y no a las herramientas utilizadas por este, esto significa que es bloqueada automáticamente la técnica asociada al TTP en cuestión sin centrarse en la herramienta que lo ha generado. En este caso, si somos capaces de responder

a los TTPs de los adversarios de manera eficiente y eficaz, podremos obligar al atacante o bien a renunciar o a aprender nuevos comportamientos desde 0. En la tabla inferior puede verse un ejemplo de los TTPs que pueden ser detectados y contrarrestados.

Táctica del adversario: Creación de un fichero RAR cifrado y exfiltración de datos.

Técnica del adversario: Cifrado AES, archivos con una exactitud de 650.000 bytes

y copiar los ficheros vía SMB.

Procedimiento del adversario: winrar a -hpqwerty -r photos.rar staging_dir

net use \\exfil_server\photos

3.5. MODELANDO LA AMENAZA MEDIANTE STIX

Structured Threat Information Expression (STIX) es un lenguaje estandarizado para la representación estructurada de la información sobre amenazas. STIX tiene como objetivo proporcionar e intercambiar información sobre CTI entre organizaciones con el fin de facilitar a la comunidad un conocimiento compartido sobre amenazas, para detectar y responder de manera más rápida y eficiente ante dichas amenazas.

STIX está diseñado para mejorar diversas capacidades como pueden ser el análisis de amenazas colaborativas, el intercambio automatizado de amenazas, la detección y respuesta automática. La arquitectura de STIX está formada por un conjunto de clases de información sobre amenazas denominados objetos que categorizan cada pieza de información con atributos específicos. La versión 2 de STIX define actualmente doce **STIX Domain Object** (**SDOs**) (ver Imagen 138). A continuación, puede verse un resumen de cada uno de ellos:

1. Attack Pattern. Tipo de TTP que describe como los actores intentan comprometer los objetivos.

2. Campaign. Comportamiento de adversarios que describen un conjunto de actividades maliciosas o ataques dirigidos a un conjunto de objetivos durante un periodo de tiempo determinado.

3. Course of Action. Acción tomada para prevenir un ataque o responder a este.

4. Identity. Individuos, organizaciones o grupos.

5. Indicator. Contiene un patrón que sirve para detectar actividades maliciosas. La especificación de dichos patrones pueden consultarse en el siguiente enlace: https://docs.oasis-open.org/cti/stix/v2.0/stix-v2.0-part5-stix-patterning.html.

6. Intrusion Set. Conjunto de conductas de adversarios y recursos con propiedades comunes relacionadas a un único actor.

7. Malware. Tipo de amenaza también conocido como código o software malicioso, utilizado para comprometer la confidencialidad, integridad o disponibilidad de datos o sistemas objetivos.

8. Observed Data. Transmite información observada en un sistema o red. En el siguiente enlace pueden ser consultados los diferentes observables y sus propiedades: https://docs.oasis-open.org/cti/stix/v2.0/stix-v2.0-part4-cyber-observable-objects.html.

9. Report. Colecciones de información sobre amenazas centradas en uno o varios temas, incluyendo los detalles contextuales. Algunos ejemplos son la descripción de un actor, el malware utilizado en una amenaza o la propia técnica del ataque.

10. Threat Actor. Individuos, grupos u organizaciones que operan detrás de una amenaza.

11. Tool. Programas utilizados por los actores para realizar los ataques.

12. Vulnerability. Vulnerabilidades de cualquier índole relacionados a sistemas utilizadas por los atacantes para acceder a estos.



Imagen 138. Clases de información sobre amenazas con STIX

En el siguiente enlace puede verse más a fondo las propiedades que pueden especificarse con cada uno de los objetos: https://docs.oasis-open.org/cti/stix/v2.0/stix-v2.0-part2-stix-objects.html. Además de los SDOs, STIX dispone de dos **STIX Relationship Objects** (**SROs**) que permiten relacionar los diferentes SDOs entre sí, dando una visión más completa sobre una amenaza. Estos objetos de relación son los siguientes:

1. Relationship. Se utiliza para enlazar dos SDO y para describir cómo se relacionan entre sí.

2. Sighting. Informa sobre la creencia de haber visto un elemento CTI, como por ejemplo un indicador, malware, etc.

En la Imagen 139 puede verse un diagrama de como interactúan los diferentes objetos y las relaciones objetos entre sí.

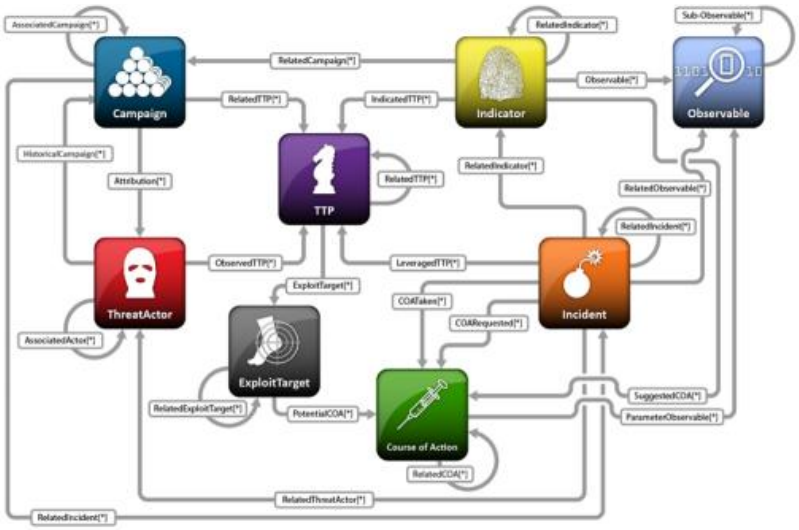


Imagen 139. Diagrama de SDOs y SROs

En la Imagen 140 pueden verse algunos casos de uso utilizando diferentes objetos y relaciones entre estos. Toda la documentación puede ser consultada a través del siguiente enlace: https://oasis-open.github.io/cti-documentation/stix/examples.

Example	STIX Types	Description
Identifying a Threat Actor Profile		Threat Actors often have several discernible characteristics such as aliases, goals and motivations which can be captured within a STIX Threat Actor object. In this example, the threat actor can also be attributed to an Identity object which models more basic identifiable information.
Defining Campaigns vs. Intrusion Sets vs. Threat Actors		Intrusion Sets in STIX are represented as an attack package consisting of potentially several campaigns, threat actors and attack patterns. This example helps explain the differences between the Campaign, Intrusion Set, and Threat Actor objects and demonstrates a scenario where all three are used together.
Indicator for Malicious URL		This example models a STIX Indicator object that represents a malicious URL using STIX patterning language. The Indicator indicates that it's a delivery mechanism for a piece of malware.
Malware Indicator for File Hash		File hashes for malware variants can be captured within an Indicator STIX Domain Object and then associated with a Malware object which provides more detail about the malware.
Sighting of an Indicator		Indicators on one organization's network are often spotted on other organizations' networks. When this is the case, a Sighting STIX Relationship Object(SRO) can be issued to relay that this specific indicator was seen. This example discusses how a company can use a Sighting for a STIX Indicator object.
Sighting of Observed-data		Observed data represent machine-generated raw information and are different from Indicators which dictate more of an intelligence assertion. These Observed-data SDO's can still be shared and referenced within a Sighting SRO. This example demonstrates the usage of Observed-data and their relation to other STIX objects.
Threat Actor Leveraging Attack Patterns and Malware		Threat actors can often be characterized by the attack patterns they leverage and the malware varieties they use. This example describes how to represent a threat actor who uses a phishing attack pattern to deliver a form of malware.
Using Marking Definitions		Sometimes when creating STIX objects it may be useful to provide guidance or permissions on how those objects may be used. In this example, Marking Definition objects are created and applied to an Indicator object to specify restrictions and copyright information.

Imagen 140. Diferentes casos de uso usando STIX

A continuación, vamos a ver dos tipos de casos de uso con los dos tipos de SDOs existentes. Comenzamos con el caso de uso de "Malware Indicator for File Hash". En la Imagen 141 podemos ver los SDOs y el SRO utilizados.

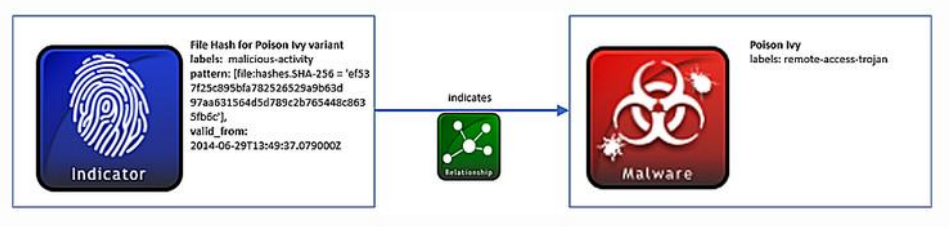


Imagen 141. Caso de uso STIX 1

Este caso de uso hace referencia a un objeto "Indicator" del tipo "hash" con una relación objeto con otro objeto "Malware". En la Imagen 142 puede verse el fichero JSON creado para dicho caso de uso.


```
{
  "type": "bundle",
  "id": "bundle--44af6c39-c09b-49c5-9de2-394224b04982",
  "spec_version": "2.0",
  "objects": [
    {
      "type": "indicator",
      "id": "indicator--a932fcc6-e032-476c-826f-cb970a5a1ade",
      "created": "2014-02-20T09:16:08.989Z",
      "modified": "2014-02-20T09:16:08.989Z",
      "name": "File hash for Poison Ivy variant",
      "description": "This file hash indicates that a sample of Poison Ivy is present.",
      "labels": [
        "malicious-activity"
      ],
      "pattern": "[file:hashes.'SHA-256' = 'ef537f25c895bfa782526529a9b63d97aa631564d5d789c2b765448c8635fb6c']",
      "valid_from": "2014-02-20T09:00:00.000000Z"
    },
    {
      "type": "malware",
      "id": "malware--fdd60b30-b67c-41e3-b0b9-f01faf20d111",
      "created": "2014-02-20T09:16:08.989Z",
      "modified": "2014-02-20T09:16:08.989Z",
      "name": "Poison Ivy",
      "labels": [
        "remote-access-trojan"
      ]
    },
    {
      "type": "relationship",
      "id": "relationship--f191e70e-1736-47c3-b0f9-fdfe01387eb1",
      "created": "2014-02-20T09:16:08.989Z",
      "modified": "2014-02-20T09:16:08.989Z",
      "relationship_type": "indicates",
      "source_ref": "indicator--a932fcc6-e032-476c-826f-cb970a5a1ade",
      "target_ref": "malware--fdd60b30-b67c-41e3-b0b9-f01faf20d111"
    }
  ]
}
```


Imagen 142. JSON del caso de uso STIX 1

En la Imagen 143 puede verse como se crea el caso de uso 1 mediante Python, utilizando la librería STIX2 que puede descargarse desde el GitHub oficial de OASIS desde el siguiente enlace: https://github.com/oasis-open/cti-python-stix2.

```python
import stix2

#Definición del objeto Indicator
indicator = stix2.Indicator(
    #Definición de propiedades
    id="indicator--a932fcc6-e032-476c-826f-cb970a5alade", #identificador aleatorio
    created="2014-02-20T09:16:08.989Z",
    modified="2014-02-20T09:16:08.989Z",
    name="File hash for Poison Ivy variant",
    description="This file hash indicates that a sample of Poison Ivy is present.",
    labels=["malicious-activity"],
    #define el tipo de indicador en este caso un hash
    pattern="[file:hashes.'SHA-256' = 'ef537f25c895bfa782526529a9b63d97aa631564d5d789c2b765448c8635fb6c']",
    valid_from="2014-02-20T09:00:00.000000Z"
)

#Definición del objeto Malware
malware = stix2.Malware(
    #Definición de propiedades
    id="malware--fdd60b30-b67c-41e3-b0b9-f01faf20d111",
    created="2014-02-20T09:16:08.989Z",
    modified="2014-02-20T09:16:08.989Z",
    name="Poison Ivy",
    labels=["remote-access-trojan"]
)

#Crea el ojeto relacion "indicates" entre el objeto Indicator y Malware
relationship = stix2.Relationship(indicator, 'indicates', malware)

#Crea el formato STIX 2 con todos los objetos del caso de uso
bundle = stix2.Bundle(objects=[indicator, malware, relationship])
```

Imagen 143. Creación del STIX del caso de uso 1

En la Imagen 144 puede verse como se programa la visualización del fichero STIX en Python del caso de uso 1.

```python
import stix2

#Bucle para leer los objetos
for obj in bundle.objects:
    #Comprueba si el objeto es igual a malware
    if obj == malware:
        #Lee todas las propiedades del objeto malware
        print("------------------")
        print("== MALWARE ==")
        print("------------------")
        print("ID: " + obj.id)
        print("Created: " + str(obj.created))
        print("Modified: " + str(obj.modified))
        print("Name: " + obj.name)
        print("Labels: " + obj.labels[0])

    #Comprueba si el objeto es igual a indicator
    elif obj == indicator:
        #Lee todas las propiedades del objeto indicator
        print("------------------")
        print("== INDICATOR ==")
        print("------------------")
        print("ID: " + obj.id)
        print("Created: " + str(obj.created))
        print("Modified: " + str(obj.modified))
        print("Name: " + obj.name)
        print("Description: " + obj.description)
        print("Labels: " + obj.labels[0])
        print("Pattern: " + obj.pattern)
        print("Valid From: " + str(obj.valid_from))

    #Comprueba si el objeto es igual a relationship
    elif obj == relationship:
        #Lee todas las propiedades del objeto relacion
        print("------------------")
        print("== RELATIONSHIP ==")
        print("------------------")
        print("ID: " + obj.id)
        print("Created: " + str(obj.created))
        print("Modified: " + str(obj.modified))
        print("Relationship Type: " + obj.relationship_type)
        print("Source Ref: " + obj.source_ref)
        print("Target Ref: " + obj.target_ref)
```

Imagen 144. Visualizar contenido del caso de uso 1

El siguiente caso de uso es “Sighting of Observed-data”. En la Imagen 145 podemos ver los SDOs y el SRO utilizados.

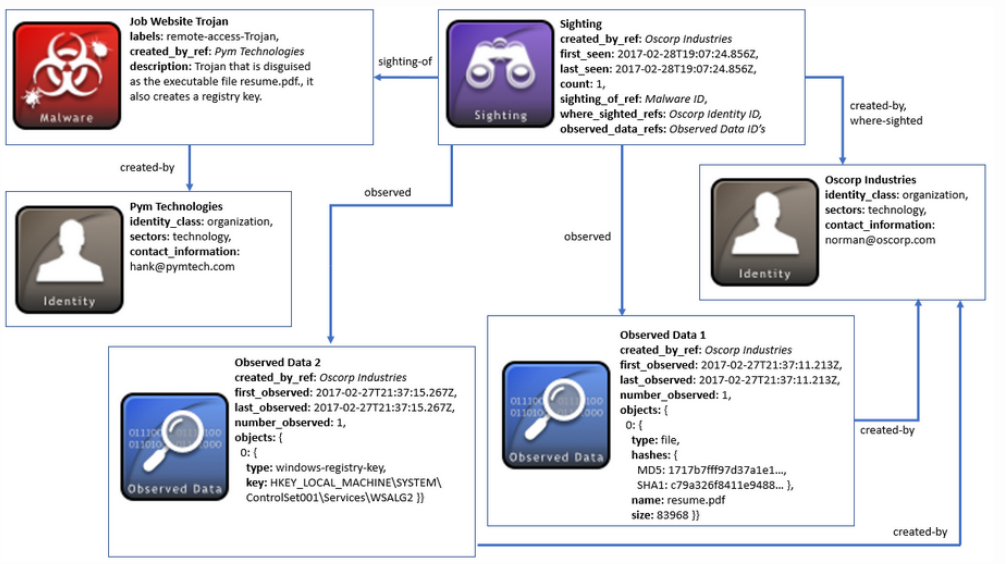


Imagen 145. Caso de uso 2 con STIX

Este caso de uso dispone de dos objetos “Identity” del tipo “organization”, un objeto “Malware”, dos objetos “Observed Data” y cuatro objetos sighting. En la Imagen 146 puede verse un extracto del fichero JSON creado para dicho caso de uso.



```
{
  "type": "bundle",
  "id": "bundle--a836f05a-f235-4b4b-b523-bd87e40478a1",
  "spec_version": "2.0",
  "objects": [
    {
      "type": "identity",
      "id": "identity--987eeee1-413a-44ac-96cc-0a8acdcc2f2c",
      "created": "2017-04-14T13:07:49.812Z",
      "modified": "2017-04-14T13:07:49.812Z",
      "name": "Oscorp Industries",
      "identity_class": "organization",
      "contact_information": "norman@oscorp.com",
      "sectors": [
        "technology"
      ]
    },
    {
      "type": "identity",
      "id": "identity--7865b6d2-a4af-45c5-b582-afe5ec376c33",
      "created": "2017-04-14T13:07:49.812Z",
      "modified": "2017-04-14T13:07:49.812Z",
      "name": "Pym Technologies",
      "identity_class": "organization",
      "contact_information": "hank@pymtech.com",
      "sectors": [
        "technology"
      ]
    },
    {
      "type": "malware",
      "id": "malware--ae560258-a5cb-4be8-8f05-013d6712295f",
      "created_by_ref": "identity--7865b6d2-a4af-45c5-b582-afe5ec376c33",
      "created": "2014-02-20T09:16:08.989Z",
      "modified": "2014-02-20T09:16:08.989Z",
      "name": "Online Job Site Trojan",
      "description": "Trojan that is disguised as the executable file resume.pdf., it also creates a registry key.",
      "labels": [
        "remote-access-trojan"
      ]
    },
    {
      "type": "sighting",
      "id": "sighting--779c4ae8-e134-4180-baad-03141095d971",
      "created_by_ref": "identity--987eeee1-413a-44ac-96cc-0a8acdcc2f2c",
      "created": "2017-02-28T19:37:11.213Z",
      "modified": "2017-02-28T19:37:11.213Z",
      "first_seen": "2017-02-28T19:07:24.856Z",
      "last_seen": "2017-02-28T19:07:24.856Z",
      "count": 1,
      "sighting_of_ref": "malware--ae560258-a5cb-4be8-8f05-013d6712295f",
      "where_sighted_refs": [
        "identity--987eeee1-413a-44ac-96cc-0a8acdcc2f2c"
      ],
      "observed_data_refs": [
        "observed-data--cf8eaa41-6f4c-482e-89b9-9cd2d6a83cb1",
        "observed-data--a0d34360-66ad-4977-b255-d9e1080421c4"
      ]
    },
```


Imagen 146. JSON del caso de uso STIX 2

En la Imagen 147 puede verse como se crea el caso de uso 2 mediante Python, utilizando la librería STIX2 de nuevo.

```python
import stix2

#Definición del objeto Identity
identityOscorp = stix2.Identity(
    id="identity--987eeee1-413a-44ac-96cc-0a8acdcc2f2c",
    created="2017-04-14T13:07:49.812Z",
    modified="2017-04-14T13:07:49.812Z",
    name="Oscorp Industries",
    identity_class="organization",
    contact_information="norman@oscorp.com",
    sectors=["technology"]
)

#Definición del objeto Identity
identityPym = stix2.Identity(
    id="identity--7865b6d2-a4af-45c5-b582-afe5ec376c33",
    created="2017-04-14T13:07:49.812Z",
    modified="2017-04-14T13:07:49.812Z",
    name="Pym Technologies",
    identity_class="organization",
    contact_information="hank@pymtech.com",
    sectors=["technology"]
)

#Definición del objeto Malware
malware = stix2.Malware(
    id="malware--ae560258-a5cb-4be8-8f05-013d6712295f",
    created="2014-02-20T09:16:08.989Z",
    modified="2014-02-20T09:16:08.989Z",
    #crea una relacion con la referencia del objeto Identity de linea 16
    created_by_ref="identity--7865b6d2-a4af-45c5-b582-afe5ec376c33",
    name="Online Job Site Trojan",
    description="Trojan that is disguised as the executable file resume.pdf., it also creates a registry key.",
    labels=["remote-access-trojan"]
)

#Definición del objeto Observed Data
observedDataFile = stix2.ObservedData(
    id="observed-data--cf8eaa41-6f4c-482e-89b9-9cd2d6a83cb1",
    created="2017-02-28T19:37:11.213Z",
    modified="2017-02-28T19:37:11.213Z",
    first_observed="2017-02-27T21:37:11.213Z",
    last_observed="2017-02-27T21:37:11.213Z",
    number_observed=1,
    #crea una relacion con la referencia del objeto Identity de linea 16
    created_by_ref="identity--7865b6d2-a4af-45c5-b582-afe5ec376c33",
    #Crea los objetos, en este caso del tipo file con dos hashes
    objects={
        "0": {
            "type": "file",
            "hashes": {
                "MD5": "1717b7fff97d37a1e1a0029d83492de1",
                "SHA-1": "c79a326f841le9488bdc3779753ele3489aaedea"
            },
            "name": "resume.pdf",
            "size": 83968
        }
    }
)

#Definición del objeto Observed Data
observedDataRegKey = stix2.ObservedData(
    id="observed-data--a0d34360-66ad-4977-b255-d9e1080421c4",
    created="2017-02-28T19:37:11.213Z",
    modified="2017-02-28T19:37:11.213Z",
    first_observed="2017-02-27T21:37:11.213Z",
    last_observed="2017-02-27T21:37:11.213Z",
    number_observed=1,
    #crea una relacion con la referencia del objeto Identity de linea 16
    created_by_ref="identity--7865b6d2-a4af-45c5-b582-afe5ec376c33",
    #Crea los objetos, en este caso del tipo windows-registry-key con un registro de windows
    objects={
        "0": {
            "type": "windows-registry-key",
            "key": "HKEY_LOCAL_MACHINE\\SYSTEM\\ControlSet001\\Services\\WSALG2"
        }
    }
)

#Crea los objetos Sighting "sighting_of_ref", "where_sighted_refs" y "observed_data_refs"
sighting = stix2.Sighting(
    id="sighting--779c4ae8-e134-4180-baa4-03141095d971",
    created_by_ref="identity--987eeee1-413a-44ac-96cc-0a8acdcc2f2c",
    created="2017-02-28T19:37:11.213Z",
    modified="2017-02-28T19:37:11.213Z",
    first_seen="2017-02-28T19:07:24.856Z",
    last_seen="2017-02-28T19:07:24.856Z",
    count=1,
    sighting_of_ref="malware--ae560258-a5cb-4be8-8f05-013d6712295f",
    where_sighted_refs=["identity--987eeee1-413a-44ac-96cc-0a8acdcc2f2c"],
    observed_data_refs=["observed-data--cf8eaa41-6f4c-482e-89b9-9cd2d6a83cb1", "observed-data--a0d34360-66ad-4977-b255-d9e1080421c4"]
)

#Crea el formato STIX 2 con todos los objetos del caso de uso
bundle = stix2.Bundle(objects=[identityPym, identityOscorp, malware, observedDataFile, observedDataRegKey, sighting])
```

Imagen 147. Creación del STIX del caso de uso 2

3.6. PLATAFORMAS DE THREAT INTELLIGENCE

Transformar y contextualizar los datos obtenidos de las múltiples fuentes y herramientas en un repositorio común donde consultar determinada información sobre una amenaza es vital para una organización. Esta información es muy útil para realizar investigaciones proactivas sobre cualquier tipo de amenaza; esto ayuda a tener todos los datos sobre actores y grupos criminales relacionados con los IoC que estén asociados, con el fin de detectar patrones utilizados por estos para defenderse en posibles amenazas futuras.

Una Plataforma de Threat Intelligence es un recurso tecnológico que ayuda a las organizaciones a agregar, correlacionar y analizar todos los datos sobre amenazas a través de diversas fuentes (externas e internas) en tiempo real, para ayudar a defenderse de las actividades maliciosas. Todo este enriquecimiento de datos es recopilado en un repositorio centralizado, el cual puede comunicarse con el SIEM u otros dispositivos perimetrales de seguridad para detectar patrones maliciosos en sus conexiones con el fin de bloquearlos y neutralizarlos. Según comenta ENISA en su publicación de "Exploring the opportunities and limitations of current Threat Intelligence Platforms", un TIP es una disciplina tecnológica emergente que apoya a los Programas de Threat Intelligence de las organizaciones para mejorar su madurez para hacer frente a las amenazas. Los TIP ayudan a resolver los siguientes desafíos:

- Recopilación de un volumen considerable de datos que ayuda a comprender mejor el entorno que rodea a una amenaza.
- Filtrado de falsos positivos o datos no procesables de manera automática sin la iteración humana, lo que beneficia a no tener un esfuerzo humano.
- Contextualizar la información para comprender su importancia.
- Clasificar y priorizar las acciones para defenderse contra las amenazas y reducir el riesgo asociado.

- Correlacionar datos para detectar patrones y conexiones entre amenazas activas y posibles vulnerabilidades.

En la Imagen 148 puede verse un resumen de lo mencionado. Al final se dispone de fuentes internas (SOC, SIEM, EDR, información de incidentes pasados, conocimiento de profesionales de la empresa) y fuentes externas (datos de herramientas OSINT, feeds de datos sobre IoC externos, Dark Web, etc) que serán recolectadas y correlacionadas en el nivel 1 mediante ficheros JSON, STIX o reglas YARA. Los analistas analizarán y normalizarán todos los datos para detectar patrones de amenazas en el nivel 2, donde finalmente en el nivel 3 será contextualizada toda la información generada en el nivel 2 y se generará un informe sobre la amenaza para difundirlo por el canal adecuado a su decisor posteriormente para que pueda tomar una decisión sobre esta.

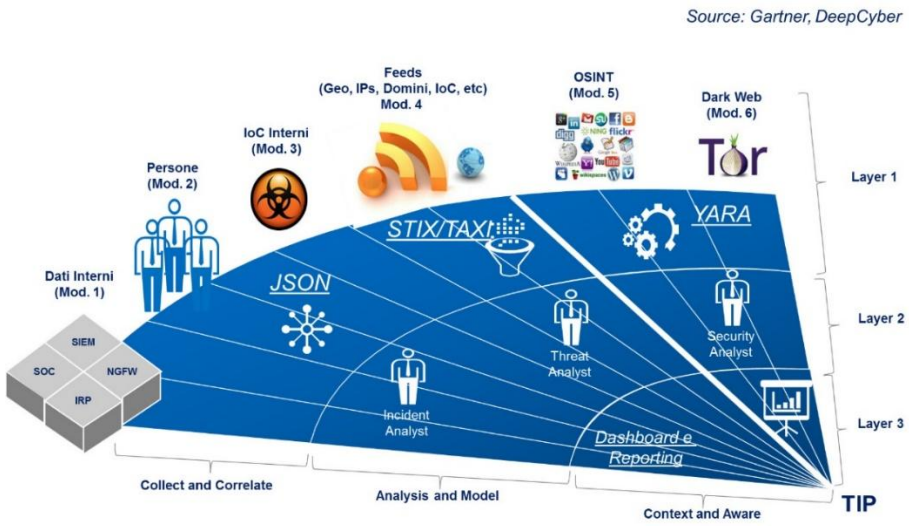


Imagen 148. Fuentes y procesos de un TIP

3.6.1. MISP

MISP es una plataforma que está desarrollada para la recopilación, compartición y correlación de IoC sobre ataques dirigidos, amenazas inteligentes, información de fraude financiero, vulnerabilidades o antiterrorismo, entre otras amenazas. Esta plataforma puede ayudar a analizar un indicador concreto y descubrir cómo se relaciona con otros, lo que puede permitir tener una visión global de un ataque al relacionar IoC entre sí.

Además, permite también analizar sucesos y amenazas como por ejemplo que actores pueden estar relacionados con un ataque concreto o que TTPs puede estar usando un grupo criminal. Las principales características básicas son las siguientes:

- Dispone de una base de datos de indicadores que permite almacenar información técnica y no técnica sobre muestras de malware, incidentes, atacantes e Inteligencia.
- Correlación automática entre atributos e indicadores de malware, campañas de ataques o análisis.
- Dispone de un modelo de datos flexible en el que se pueden enlazar objetos complejos para expresar información sobre amenazas, incidentes o elementos conectados.
- Dispone de una funcionalidad que permite la compartición de datos utilizando diferentes modelos de distribución. MISP puede sincronizar automáticamente eventos y atributos entre diferentes instancias.
- Tiene una interfaz de usuario intuitiva para que los usuarios finales creen, actualicen y colaboren en eventos y atributos/indicadores. Dispone de una interfaz gráfica para navegar sin problemas entre los eventos y sus correlaciones.
- Almacenamiento de datos en un formato estructurado con un amplio soporte de indicadores de seguridad.
- Permite múltiples formatos de exportación de resultados y/o detecciones de IoC como OpenIOC, texto plano, CSV, XML, JSON, integración con IDS (Snort, Suricata, Bro) u otros sistemas.
- MISP permite importaciones mediante bulk-import, batch- import, texto plano, OpenIOC, GFI Sandbox, CSV de ThreatConnect o formato MISP.

- Intercambio y sincronización automática con otros grupos de confianza mediante MISP.
- Herramienta flexible para integrar fuentes de cualquier amenaza o mediante OSINT.
- Permite un mecanismo seudo-anónimo para delegar la publicación de eventos/indicadores a otra organización.
- API flexible para integrar MISP con otras soluciones. A través de la librería de Python, PyMISP, puedes recuperar, añadir o actualizar atributos de eventos, manejar muestras de malware o buscar atributos.
- Taxonomía adaptable para clasificar y etiquetar eventos siguiendo esquemas de clasificación propios o taxonomías existentes. La taxonomía puede ser local para su MISP, pero también puede ser compartida entre otras instancias. La herramienta dispone de un conjunto predeterminado de taxonomías y esquemas de clasificación bien conocidos para apoyar la clasificación estándar utilizada por ENISA, Europol, DHS, CSIRTs u otras organizaciones.
- Utiliza un diccionario con palabras relacionadas con la inteligencia llamada galaxias. Con esto se consigue agrupar y relacionar sucesos o eventos con actores de amenazas existentes, malware, RAT, ransomware o MITRE ATT&CK.
- Permite integrar módulos desarrollados en Python a través de misp-modules.
- Dispone de soporte STIX mediante la importación y exportación de datos en formato STIX (XML y JSON).
- Cifrado integrado y firma de las notificaciones vía PGP o S/MIME dependiendo de las preferencias del usuario.
- Canal de publicación en tiempo real para obtener automáticamente todos los cambios sobre nuevos eventos, indicadores o etiquetados mediante ZMQ o Kafka.

A continuación, se facilitan enlaces relacionados con MISP:

- Sitio Oficial de MISP: https://www.misp-project.org.
- Documentación Oficial: https://github.com/MISP/misp-book.
- Repositorio API: https://github.com/MISP/PyMISP.
- Documentación API: https://buildmedia.readthedocs.org/media/pdf/pymisp/latest/pymisp.pdf.
- Repositorio módulos MISP. Listado de módulos de diversas fuentes que pueden ser instalados y utilizadas en MISP mediante uso de API.
    - Enlace: https://github.com/MISP/misp-modules.
- Repositorio Taxonomías MISP. Bibliotecas de clasificación actualizadas sobre inteligencia para etiquetar, clasificar y organizar la información dentro de MISP.
    - Enlace: https://github.com/MISP/misp-taxonomies
- Repositorio Galaxias MISP. Listado de objetos de vocabularios para ser utilizados en MISP.
    - Enlace: https://github.com/MISP/misp-galaxy
- Repositorio Warninglist MISP. Listas de indicadores bien conocidos que pueden asociarse a posibles falsos positivos, errores o equivocaciones.
    - Enlace: https://github.com/MISP/misp-warninglists
- Training MISP: http://circl.lu/services/misp-training-materials/

3.6.2. INSTALACIÓN DE MISP

Para instalar MISP hay varias opciones (OVA, Ansible, BASH, Docker, Cloud), por rapidez y facilidad de uso utilizaremos la instalación mediante OVA. CIRCL cada poco tiempo suele ir actualizando el repositorio de imágenes con versiones nuevas de MISP. En la Imagen 149 puede verse la última actualización y publicación de MISP en el repositorio de CIRCL. El fichero que hay que descargar es "**MISP_v2.4.158@3aad442.ova**" (ira actualizándose el nombre en función de la versión). El repositorio podéis encontrarlo en el siguiente enlace: https://www.circl.lu/misp-images/_latest/.



Imagen 149. Repositorio de CIRCL sobre MISP

Las diferentes credenciales de acceso a MISP son las siguientes:

- Acceso mediante Shell o SSH
  - Usuario / Contraseña: misp / Password1234
  - Descubrir dirección IP: Una vez que hayáis accedido al sistema, ejecutar **ifconfig** para detectar cual es la dirección IP de la máquina.
- Acceso para la plataforma web
  - Acceso: Introducir dirección IP de la máquina en el navegador de vuestra maquina anfitriona.
  - Usuario / Contraseña: admin@admin.test / admin. Ver Imagen 150.

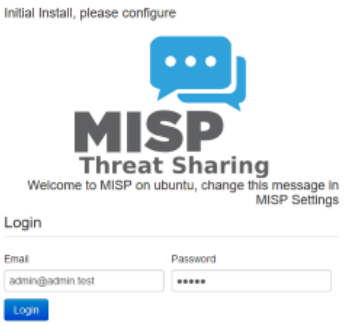
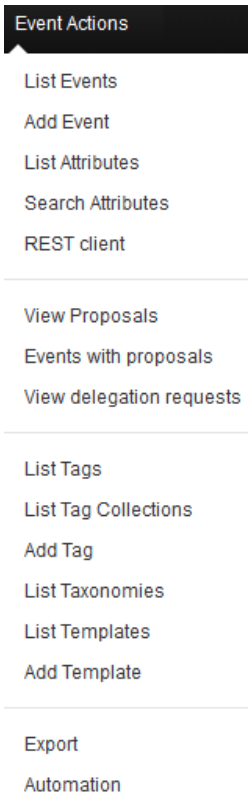


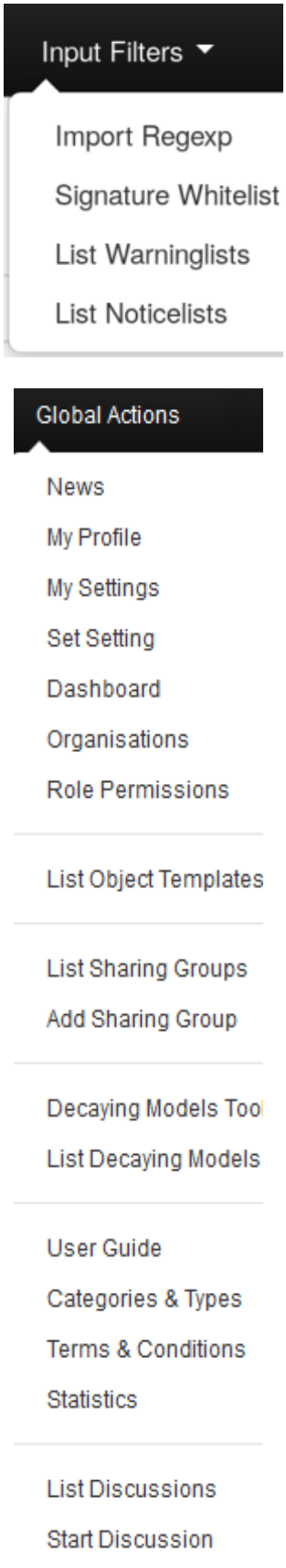
Imagen 150. Página de login de MISP

3.6.3. CONFIGURACIÓN MISP



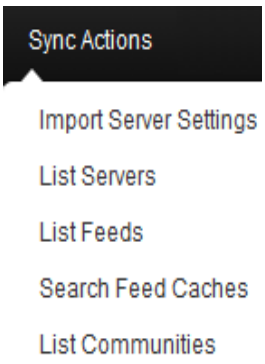
- List Events: Enumera todos los eventos del sistema que no son privados o que pertenecen a su organización. Puede añadir, modificar, borrar, publicar o ver eventos individuales desde esta vista.
- Add Events: Le permite rellenar un formulario de creación de eventos y crear el objeto de evento, donde puede empezar a añadir atributos.
- List Attributes: Enumera todos los atributos del sistema que no son privados o que pertenecen a su organización. Puede modificar, borrar o visualizar cada atributo individual desde esta vista.
- Search Attributes: Aquí puede definir los términos de búsqueda para una vista de índice de atributos filtrados.
- REST client: Cliente REST donde puede realizar llamadas directamente a la API a través de una interfaz de usuario web.
- View Proposals: Muestra una lista de todas las propuestas que puede ver.
- Events with proposals: Muestra todos los eventos creados por su organización que tienen propuestas pendientes.
- List Tags: Enumera todas las etiquetas que han sido creadas por usuarios con derechos de creación de etiquetas en esta instancia.
- Add Tag: Crear una nueva etiqueta.
- List Taxonomies: Enumera todas las taxonomías instaladas en la instancia del MISP. Este es también el lugar para activar las taxonomías como Org Admin/Site Admin.
- List Templates: Enumera todas las plantillas creadas por los usuarios con derechos de creación de plantillas en esta instancia.
- Add Templates: Cree una nueva plantilla.

- Export: Exporte los datos accesibles en varios formatos.
- Automation: Si tiene acceso a la clave de autenticación, aquí puede ver cómo utilizar su clave para utilizar la interfaz REST para la automatización.



- Import Regexp: Permite ver, editar y añadir reglas de expresiones regulares
- Signature Whitelist: Puede ver y editar las reglas de la lista blanca que contiene los valores que están bloqueados para ser utilizados en las exportaciones y la automatización en esta instancia.
- List Warninglists: Listas integradas en MISP para mostrar un cuadro de información/aviso a nivel de evento y atributo.
- Dashboard: Permite ver sus notificaciones de propuestas, eventos con propuestas y solicitud de delegación. Puede ver los últimos cambios desde su última visita, como actualizaciones de eventos y publicaciones de eventos.
- Organizations: Vea las organizaciones que tienen presencia en esta instancia con algunas informaciones útiles como el nombre del contacto.
- Role Permissions: Puede ver los permisos de los roles aquí.
- List Sharing Groups: Puede ver la lista de Grupos de compartición existentes a los que usted o su organización tienen acceso.
- Add Sharing Group: Puede crear un grupo de compartición.

- Categories & Types: Rápida visión general de las categorías y tipos de atributos.
- Terms & Conditions: Términos y condiciones generales que se pueden configurar en Administration -> Server Settings -> MISP Settings: Archivo_de_términos MISP. De la UI: "El nombre del archivo de términos y condiciones. Asegúrese de que el archivo se encuentra en su directorio MISP/app/files/terms".
- Stadistics: Ver una serie de estadísticas sobre los usuarios y los datos de esta instancia.
- List Discussion: Enumerar los hilos de discusión creados en la instancia MISP por las organizaciones conectadas a esta comunidad local.
- Start Discussion: Cree un nuevo hilo de discusión.



- List Servers: Conecte la instancia MISP a otras instancias, o vea y modifique las conexiones actualmente establecidas.
- List Feeds: Siga los canales RSS de otras organizaciones o CERTs de todo el mundo.
- Search Feed Caches: Listado de los feeds que hayan sido marcados como cache.
- List Communities: Listado de comunidades integrados en MISP.

En la Imagen 151 puede verse el listado de feeds que pueden ser integrados en MISP, en este momento únicamente esta activado el feed de CIRCL OSINT. Es posible activar aquellos que interesen. La ruta para acceder es “Sync Actions/List Feeds”.

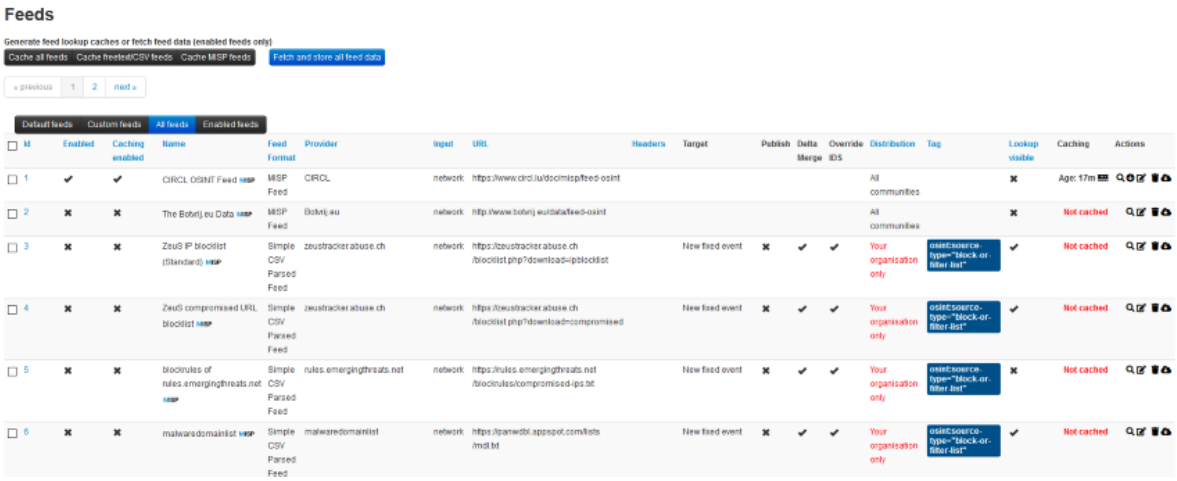


Imagen 151. Listado de feeds en MISP

En la Imagen 152 puede verse el listado de taxonomías que pueden ser utilizados en MISP. Cada una de estas taxonomías tienen asociadas una serie de tags. Un ejemplo de esto puede verse en la Imagen 153 con los tags relacionados a la taxonomía TLP. Es posible activar aquellos que interesen. La ruta para acceder a las taxonomías es "Event Actions/List Taxonomies" y al listado total de tags en "Event Actions/List Tags".

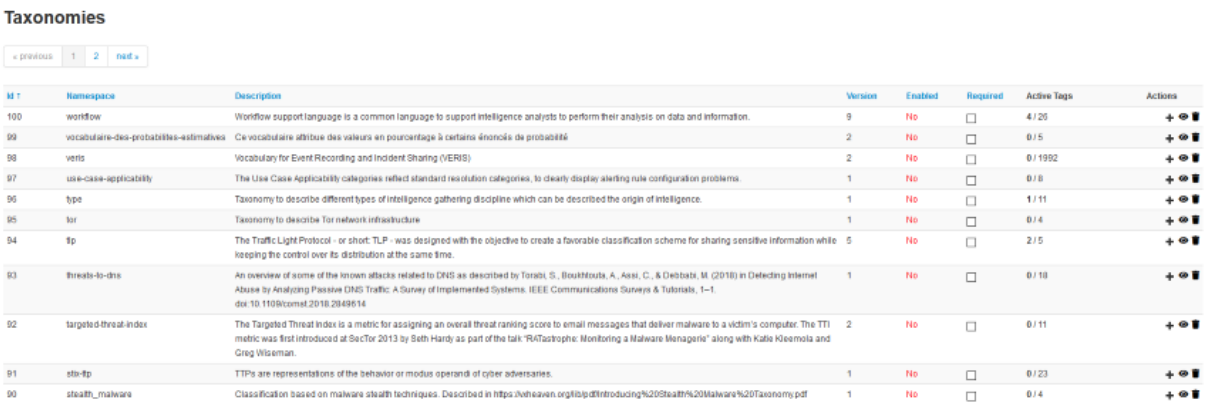


Imagen 152. Listado de taxonomías

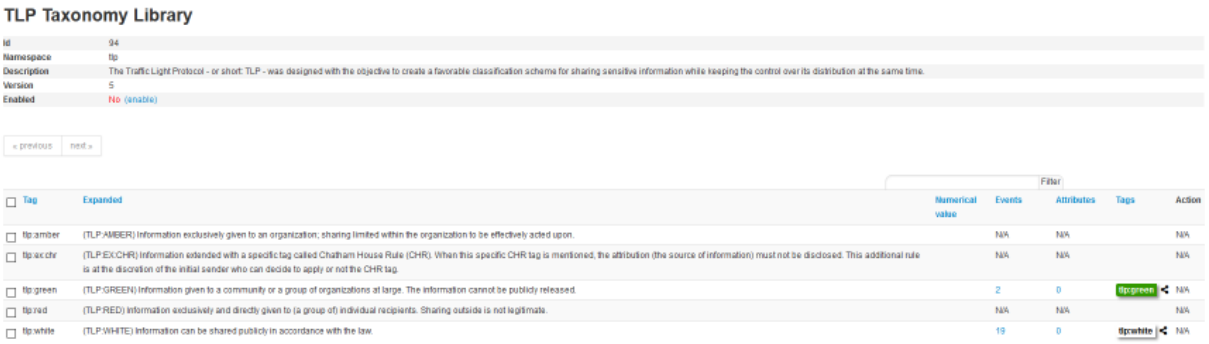


Imagen 153. Tags de Taxonomía TLP

En la Imagen 154 puede verse el listado de galaxias que pueden ser utilizados en MISP, para asociarlas a amenazas concretas. Esto es muy útil, ya que permite crear un clúster de objetos conectados a diversos eventos o atributos de MISP. Un clúster puede estar compuesto de uno o más elementos. Los elementos se expresan como valores clave.

Hay vocabularios por defecto disponibles en la galaxia MISP pero estos pueden ser sobreescritos, reemplazados o actualizados. Los vocabularios son de estándares existentes (como STIX, Veris, ATT&CK, MISP, etc.) o personalizados para la propia organización.

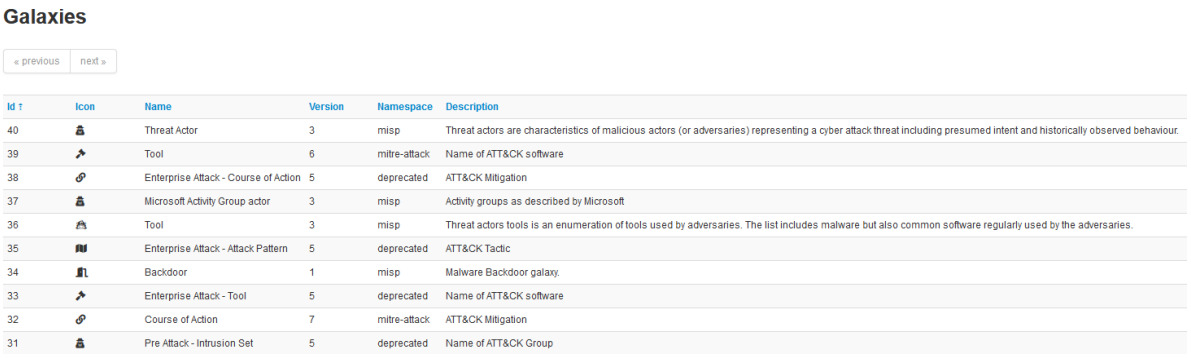


Imagen 154. Listado de galaxias

Para crear un evento hay que tener en cuenta lo siguiente:

- **Distribución del evento**
  - Your organization only: Solo visible para los miembros de tu organización.
  - This Community-only: Organizaciones existentes en el servidor MISP y otras organizaciones en servidores MISP sincronizadas.
  - Connected communities: Organizaciones del propio servidor MISP y otras organizaciones conectadas directamente.
  - All communities: Todas las comunidades.
  - Sharing group: Compartir evento con las organizaciones de grupos definidos previamente.
- **Threat Level**
  - Low
  - Medium
  - High

En la Imagen 155 puede verse un ejemplo de creación de un evento.

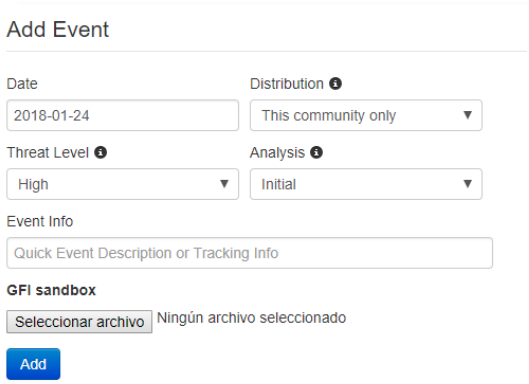


Imagen 155. Creación de un evento

En la Imagen 156 puede verse un ejemplo de evento creado con elementos ya parametrizados en relación con TrickBot.

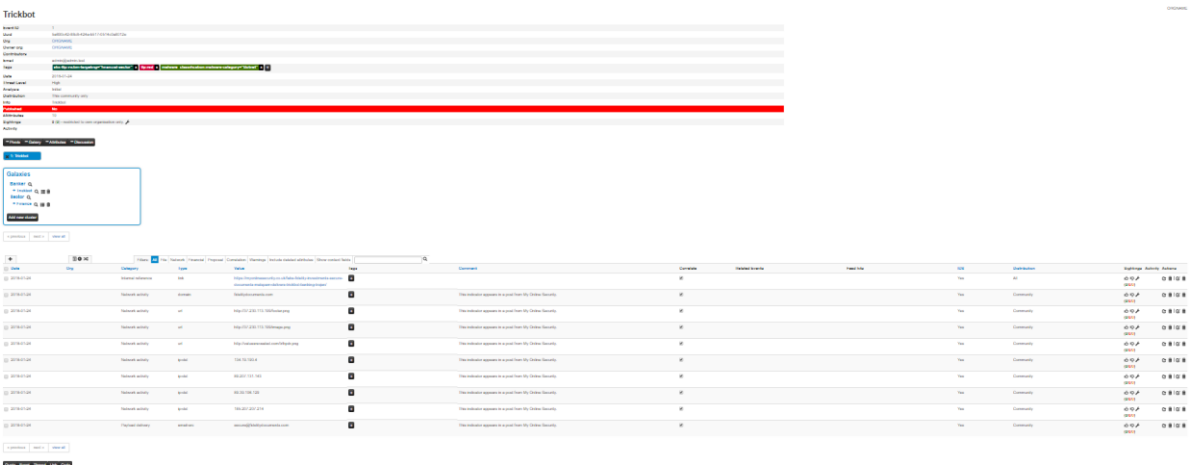


Imagen 156. Ejemplo de un evento creado y parametrizado de TrickBot

4. CASO PRÁCTICO DE INVESTIGACIÓN DE UNA AMENAZA

4.1. INVESTIGACIÓN DEL GRUPO CRIMINAL SILVERTERRIER

Durante la pandemia del COVID-19 aparecieron multitud de amenazas queriendo aprovecharse de la situación de aquel momento, como por ejemplo las campañas Business Email Compromise (BEC) distribuidas por medio del grupo criminal SilverTerrier.

SilverTerrier es un grupo nigeriano que lleva activo desde 2014. Según UNIT42 de Palo Alto han sido identificadas 10 campañas de malware bajo la temática COVID-19, detectándose un total de 170 correos electrónicos de phishing y directamente relacionados hacia este grupo criminal. El artículo de UNIT42 referente a este tema puede encontrarse en el siguiente artículo: "SilverTerrier: New COVID-19 Themed Business Email Compromise Schemes"

Entre los sectores objetivos de SilverTerrier se encuentran:

- Agencias gubernamentales de salud
- Gobiernos locales y regionales
- Grandes universidades con programas o centros médicos
- Empresas de servicios públicos regionales
- Editoriales médicas
- Compañías de seguros

Algunos de los países afectados por esta amenaza son los siguientes:

- Estados Unidos
- Australia
- Canadá
- Italia
- Reino Unido

4.1.1. OPERACIONES DE SILVERTERRIER

Entre las operaciones han sido detectadas 10 campañas BEC, tal como comentamos anteriormente. Según UNIT42 dentro de estas campañas son identificados tres actores diferentes pertenecientes al mismo grupo de SilverTerrier.

Al primer actor se le atribuyen ocho campañas:

- Campaña 1. Correo electrónico con una muestra de **LokiBot** camuflada como archivo adjunto y simulando ser el **departamento de salud de indonesia.**

Date:	1/30/2020
Subjects:	Coronavirus in Indonesia: KNOW HOW TO PROTECT AND PREVENT YOURSELF. DONT GET INFECTED Coronavirus di Indonesia: TAHU CARA MELINDUNGI DAN MENCEGAH DIRI. JANGAN MENDAPAT INFEKSI
Attachment:	INDONESIAN HEALTH DEPARTMENT_PDF.gz [3335ebffd8…]

Imagen 157. Indicadores de la primera campaña (Fuente: UNIT42)

- Campaña 2. Correo electrónico con un documento Excel que explotaba la vulnerabilidad **CVE-2017-11882**, simulando un envío de la **ONU** y cuyo objetivo era un **proveedor de Estados Unidos.**

Original Content	Translated
MBC	MBC
BESONDERHEDE BESONDERHEDE VIR HIERDIE MAAND	DETAILS DETAILS FOR THIS MONTH
DRAENDE NR. HOEV	BEARING NO. HOW
30208 NBC DRAAG 30 STK	30208 NBC DRESS 30 PCS
30308 NBC DRAAG 6 STK	30308 NBC DRESS 6 PCS
32007X NBC DRAAG 74 STK	32007X NBC BEAR 74 pcs
33005 NBC wat 5 stelle dra	33005 NBC carrying 5 sets
52799 / 800U (25877/21) NBC wat 30 PCS dra	52799 / 800U (25877/21) NBC carrying 30 PCS

Imagen 158. Contenido traducido del documento Excel adjunto (Fuente: UNIT42)

Date:	3/10/2020
Sender:	d.william@accountant[.]com
Subject:	Fw:UN, Coronavirus Update attached
Attachment:	UPDATE!!!.xlsx [e365100468…]

Imagen 159. Indicadores de la segunda campaña

- Campaña 3. Varios correos electrónicos de Phishing enviados a un **proveedor de seguros de salud australiano**. Esta campaña vuelve a aprovechar la

vulnerabilidad **CVE-2017-11882** con un documento RTF adjunto en el correo. Se detecta **Agent Tesla** como malware utilizado.

Date:	3/23/2020
Sender:	handie@indo.net[.]id
Subject:	COVID:19 - FACIAL MASKS NEW ORDER
Attachment:	COVID 19 NEW ORDER FACE MASKS.doc [27d601ef1a…]

Imagen 160. Indicadores de la tercera campaña (Fuente: UNIT42)

- Campaña 4. Varios correos electrónicos de Phishing que simulaban estar relacionados con **suministros de COVID-19**. Dentro de esta campaña fueron detectados tres objetivos diferentes enviados desde tres correos distintos siendo los siguientes:

    - Entre el primer objetivo se encontraba una **universidad de los Estados Unidos con un reconocido programa médico**. El adjunto utilizado vuelve a aprovechar la vulnerabilidad **CVE-2017-11882.**

    - El segundo objetivo fue una **agencia de salud canadiense**. En esta ocasión utilizan una muestra de malware de **Agent Tesla** empaquetado como archivo adjunto.

    - Entre el tercer objetivo fue detectada una **compañía de energía australiana**. Como archivo adjunto vuelven a utilizar una muestra del malware **Agent Tesla**

Date:	3/24/2020-3/25/2020
Sender:	april@jetfacilities[.]com
Subject:	COVID-19 Supplies (Masks, Gloves, & other products)
Attachment:	Sample Products.xlsx [563b1c6252…]
Date:	3/29/2020
Sender:	rohan.jayawardena@multywaychem[.]com
Subject:	COVID-19 Supplies (Masks, Gloves, & other products)
Attachment	Product_Sample_List.r09 [0ae2aaeb29…]
File:	Product_Sample_List.exe [4b8b49bdfa…]
Date:	4/7/2020
Sender:	sales@mailgoesbulkworld[.]live
Subject:	COVID-19 Supplies (Masks, Gloves, & other products)
Attachment	Sample Product.r15 [589a1900b2…]
File:	Sample Product.exe [7f661c6f5e…]

Imagen 161. Indicadores de la cuarta campaña (Fuente: UNIT42)

- Campaña 5. Se detectan varios correos electrónicos con múltiples muestras de malware simulando ser una organización de investigación clínica de los Estados Unidos. Tal como ocurre con la campaña anterior son detectados tres objetivos diferentes:

    - En uno de los correos de phishing detectados es identificado un adjunto con el nombre de "Galaxy International Trading Limited" que vuelve a aprovechar la vulnerabilidad **CVE-2017-11882**

    - En una segunda operación dentro de esta campaña se identifica como objetivo una **agencia del gobierno de los Estados Unidos** utilizando el mismo asunto y nombre del fichero adjunto de la oleada de phishing mencionada anteriormente. La única diferencia es que esta vez es utilizada una muestra de **Agent Tesla** camuflada como fichero adjunto

    - La tercera operación tenía como objetivo a una **editorial médica en Europa** y una agencia del **gobierno de los Estados Unidos**. Como documento adjunto vuelve a utilizarse una muestra de **Agent Tesla**

Date:	3/26/2020
Sender:	info.mmd@medpace[.]com
Subject:	Purchase Order (PO For-COVID-19 Products)
Attachment:	PO For-COVID-19 ProductS.xlsx [f7183d3a99…]
Date:	3/29/2020
Sender:	roseline@reynoldsgh[.]com
Subject:	Purchase Order (PO For-COVID-19 Products)
Attachment	PO For-COVID-19 Products.exe [83457e2b8f…]
Date:	4/6/2020
Sender:	info.mmd@medpace[.]com
Subject:	Purchase Order (PO For-COVID-19 Products)
Attachment	PO For-COVID-19 Products.exe [b58e386928…]

Imagen 162. Indicadores de la quinta campaña (Fuente: UNIT42)

- Campaña 6. Correo electrónico de phishing simulando ser una carta de retraso de un barco perteneciente a una **compañía naviera de Singapur**. En dicho correo fue utilizado un documento **Word** adjunto que explotaba la vulnerabilidad **CVE 2017-11882** utilizando los **servicios de DNS dinámicos** ofrecidos por **DuckDNS**

Date:	3/30/2020
Sender:	tanc@richfield[.]com[.]sg
Subject:	VESSEL DELAY LETTER-COVID-19
Attachment	VESSEL DELAY LETTER.docx [c5c43b3409…]

Imagen 163. Indicadores de la sexta campaña (Fuente: UNIT42)

- Campaña 7. Simularon un correo electrónico relacionado con una **vacuna de COVID-19** utilizando dos muestras del **RAT NanoCore**. Los objetivos de esta campaña fueron una **agencia de salud del gobierno de los Estados Unidos**, dos **universidades con programas médicos** del mismo país y una **aseguradora de salud canadiense.**

Date:	4/7/2020
Sender:	berge@ladbible[.]com
Subject:	Latest vaccine release for Corona-virus(COVID-19)
Attachment	COVID-19 Vaccine Sample.rar [f7b9219f81…]
File	COVID-19 Vaccine Sample.exe [241f09feda…]
Date:	4/7/2020 – 4/8/2020
Sender:	berge@ladbible[.]com
Subject:	Latest vaccine release for Corona-virus(COVID-19)
Attachment	RFQ-0043232QQ.rar [31d2ef10ca…]
File	MS-RFQ.exe [7b2512d067…]

Imagen 164. Indicadores de la séptima campaña (Fuente: UNIT42)

- Campaña 8. Simularon un correo electrónico con el asunto de **materiales de ayuda de COVID-19** procedentes del **departamento médico de Tailandia** utilizando una muestra de **Lokibot** adjunta. Los objetivos de esta campaña fueron una **agencia de salud del gobierno de los Estados Unidos**, **una infraestructura del estado, una aseguradora de salud del mismo país, una universidad italiana, un gobierno regional italiano y varias instituciones gubernamentales australianas.**

Date:	4/8/2020
Sender:	enquiry@herrnessolar[.]com
Subject:	NEW ORDER 300879 - COVID-19 RELIEF MATERIALS
Attachment:	NEW ORDER 300879.exe [aff38fe42c…]
Attachment:	NEW ORDER 300879.exe [8f56fb41ee…]

Imagen 165. Indicadores de la octava campaña (Fuente: UNIT42)

Al **segundo actor** se le atribuye una campaña dirigida hacia una **agencia de salud del gobierno** de los **Estados Unidos** descubriéndose dos muestras de malware de LokiBot entre los adjuntos de los correos electrónicos enviados.

Date:	3/17/2020 – 3/18/2020
Sender:	sofian@cahayapack[.]com[.]my
Subject:	COVID-19 UPDATE // BUSINESS CONTINUITY PLAN ANNOUNCEMENT STARTING MARCH 2020.
Attachment:	AWARENESS NOTICE ON CORONAVIRUS COVID-19 DOCUMENT_pdf.exe [da26ba1e13…]
Date:	3/18/2020
Sender:	sofian@cahayapack[.]com[.]my
Subject:	CORONAVIRUS (COVID-19) UPDATE // BUSINESS CONTINUITY PLAN ANNOUNCEMENT STARTING MARCH 2020.
Attachment:	AWARENESS NOTICE ON CORONAVIRUS COVID-19 DOCUMENT_pdf.exe [1ee6646e0e…]

Imagen 166. Indicadores asociados a la campaña del segundo actor (Fuente: UNIT42)

Al **tercer actor** se le atribuye una campaña en la que camufla muestras de malware como adjuntos, los cuales, utilizan PowerShell para descargar archivos ejecutables maliciosos. Esta vez simulan ser correos electrónicos relacionados con información sobre COVID-19.

Date:	3/23/2020 - 3/24/2020
Sender:	info@welheadcontrol[.]com
Subject:	Information about Covid- 19 Actions
Attachment:	information.rtf [d80a440755…]
Attachment:	covid 19.rtf [d731fb3fcc…]
Attachment:	WxByN.xlsm [8037a8e12e…]

Imagen 167. Indicadores asociados a la campaña del tercer actor (Fuente: UNIT42)

4.1.2. INDICADORES DE COMPROMISO ASOCIADOS

En la propia investigación que se podrá ver en su sección correspondiente, nos centraremos en **SilverTerrier** y el malware **Agent Tesla**. A modo resumen han sido detectados un total de 90 IoCs divididos en los siguientes tipos:

- **2 direcciones IP**
- **17 dominios**
- **69 hashes (MD5, SHA1, SHA256)**
- **1 URL**
- **1 CVE**

4.1.3. MALWARE ASOCIADO

A este grupo criminal se le atribuye la utilización de los siguientes malware en sus campañas:

- Agent Tesla. Se trata de un troyano espía cuyo objetivo de ataque son las plataformas de Microsoft Windows. Sus primeras apariciones datan del 29 de enero de 2019 teniendo sus últimas apariciones este mismo mes de mayo
- NanoCore. Remote Access Tool (RAT) desarrollado en .NET y utilizado para espiar y robar información a las víctimas. Amenaza activa desde el año 2013
- DarkComet. Remote Access Tool (RAT) y backdoor utilizado de nuevo para espiar y robar información a sus víctimas utilizando múltiples técnicas para ello.
- NETWIRE. Remote Access Tool (RAT) de acceso público utilizada por diferentes grupos criminales y APT desde el año 2012 para espiar y robar información a sus víctimas

4.1.4. TTPs ASOCIADOS

La única técnica atribuida a SilverTerrier es la denominada como "*Standard Application Layer Protocol*". Esta técnica permite la comunicación de los adversarios a sus C2 a través de un protocolo de capa de aplicación común como pueden ser HTTP, HTTPS, SMTP o DNS.

La táctica asociada a la técnica mencionada es "*Command and Control*". Dicha táctica hace referencia al intento de conexión del adversario a los sistemas comprometidos de las víctimas y su control por medio de un panel de control conformando una botnet compuesto de múltiples servidores víctima infectados.

4.1.5. INVESTIGACIÓN DE LAS DIRECCIONES IP DETECTADAS

Comenzamos la investigación con las 2 direcciones IP detectadas en la información de partida y que tienen algún tipo de relación con el actor. Un primer vistazo de los datos recolectados puede ser visualizados en la Imagen 168, en el cual son representadas las relaciones existentes entre los nodos detectados a alto nivel. Cada uno de los nodos simbolizan un tipo de dato concreto tal como puede verse en



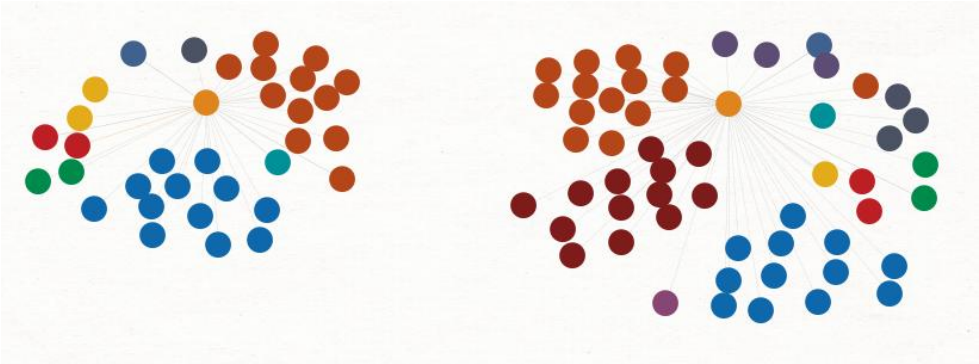


Imagen 168. Relación entre los diferentes IoCs asociados a SilverTerrier

Si prestamos atención en la Imagen 170 y 171 podemos observar el grafo desde la perspectiva del tipo de dato detectado, descubriendo que no existen relaciones entre ambas direcciones IP de manera directa.

Si hacemos foco ahora en la dirección IP 185.126.202[.]111 (Imagen 169) sacamos en claro lo siguiente:

- La dirección IP apunta a **Irán** en concreto a **Tehran.**
- Se detecta **un dominio** (dn-server.com) que apuntan a la propia dirección IP.
- Se detectan **9 subdominios** (tb.64-b.it, tbillboard.64-b.it, px834095.64-b.it, live.samanedu.ir, tbb.16-b.it, ll.n4t.co, test.msisoft.ir, git.msisoft.ir y parsonline.dn-server.com) que apuntan a la propia dirección IP.
- Se detectan **2 registros NS** (ns1.surfoption.com y ns2.surfoption.com) que apuntan a la misma dirección IP.
- La dirección IP está asociada al **rango IP** 185.126.202.0-185.126.202.255.

- Son detectadas **dos compañías relacionadas** (XZN Hosting y Network Coordination Centre).
- Son detectados **dos números de teléfono** (+98 2172308 y +31 20 535 4444).
- Son detectadas **12 URLs** que han dado positivo en algún motor antivirus por estar relacionada con actividad maliciosa.

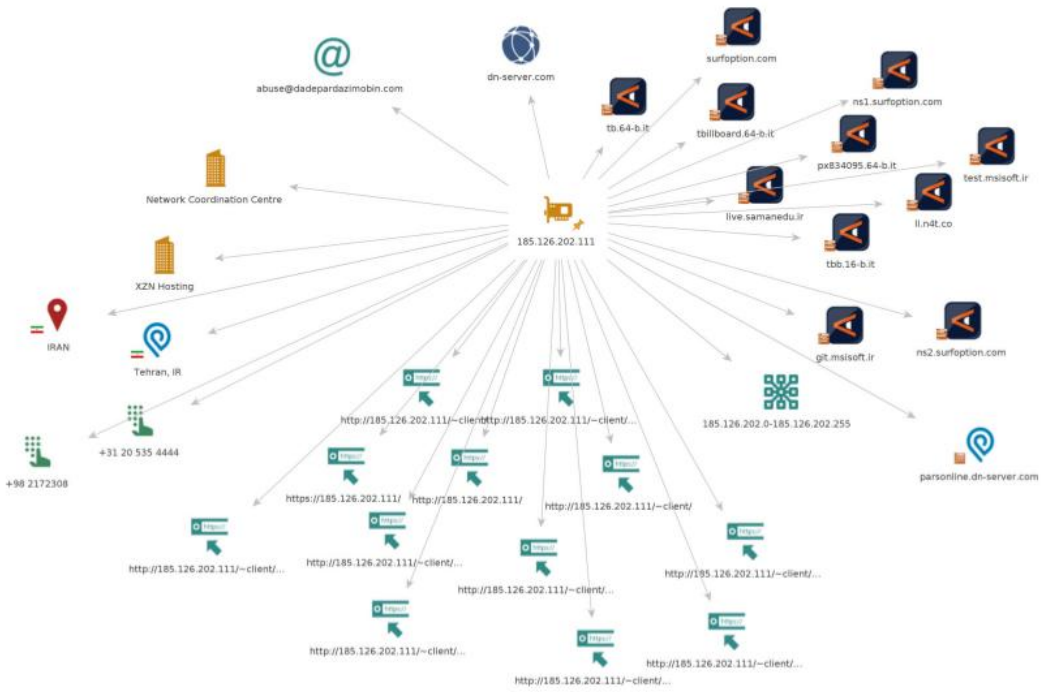


Imagen 169. Recolección de información del IoC 185.126.202[.]111

Ahora nos centramos en la dirección IP 23.95.132[.]48 (Imagen 170) sacando en claro lo siguiente:

- La dirección IP apunta a **Estados Unidos** en concreto a **Buffalo.**
- Se detectan **4 dominios** (slotsipedia.com, andyhindmarsh.com, colocrossing.com y ilivethedream2.com) que apuntan a la propia dirección IP.
- Se detectan **3 subdominios** (test.slotsipedia.com, 23-95-132-48-host.colocrossing.com y www.slotsipedia.com) que apuntan a la propia dirección IP.
- Se detectan **8 registros NS** (ns1.mbir.ir, ns2.mbir.ir, ns2.azarwebsite.com, ns1.andyhindmarsh.com, ns2.andyhindmarsh.com, ns2.ilivethedream2.com,

ns1.azarwebsite.com y ns1.ilivethedream2.com) que apuntan a la propia dirección IP.

- Se detectan **2 servidores de correo** (mail.andyhindmarsh.com y mail.slotsipedia.com) que apuntan a la propia dirección IP.
- La dirección IP está asociada al **rango IP** 23.95.128.0-23.95.159.255.
- Es detectada **una compañía relacionada** (Colocrossing).
- Son detectados **dos números de teléfono** (+1 800 518 9716 y 1-800-518-9716).
- Son detectadas **12 URLs** que han dado positivo en algún motor antivirus debido a actividad maliciosa.
- Son detectadas **13 muestras de malware.**
- Es detectado **un correo electrónico** (abuse@colocrossing.com).
- Son detectados perfiles creados en las siguientes redes sociales: LinkedIn, Facebook y Twitter
- Es detectado un **certificado SSL** asociado a la dirección IP con el hash 080a59a1609de3f55e23d9cb075d507f8c3694ecfc4802e9a5e0c7b5ab439043. Analizando el propio hash descubrimos que el certificado ha sido creado con un algoritmo de cifrado SHA256, el Common Name (CN) asociado al certificado es 23.95.132.48, la organización asociada es AliReza y dicho certificado es válido hasta el 19 de mayo de 2028. En la Imagen 171 puede visualizarse la información del certificado extraído.

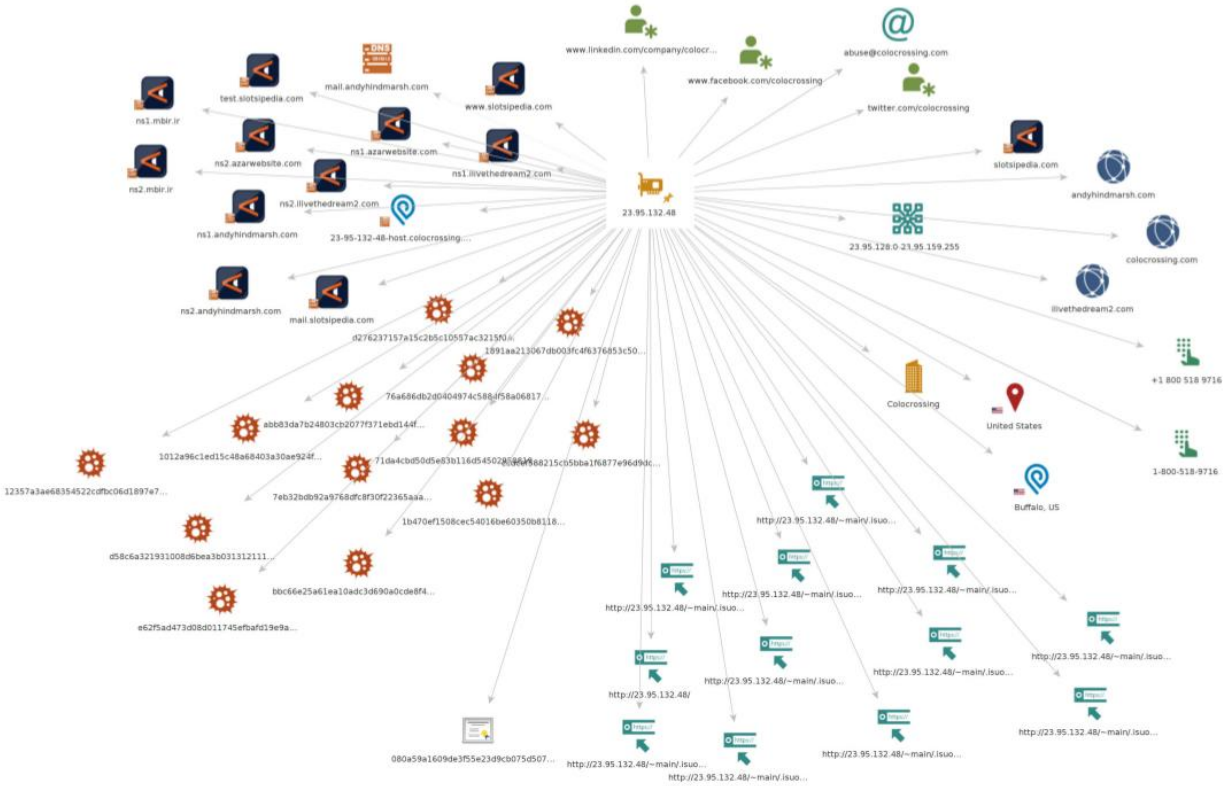


Imagen 170. Recolección de información del IoC 23-95-132[.]48



Imagen 171. Información del certificado SSL asociado al IoC 23.95.132[.]78

Podemos concluir que ambas direcciones IP no comparten ningún tipo de dato entre sí.

4.1.6. INVESTIGACIÓN DE LOS DOMINIOS DETECTADOS

Comenzamos ahora la investigación sobre los dominios detectados en la información de partida y que tienen algún tipo de relación con el actor. Un primer vistazo de los datos recolectados puede ser visualizados en la Imagen 172 a través de las relaciones existentes entre dichos dominios.

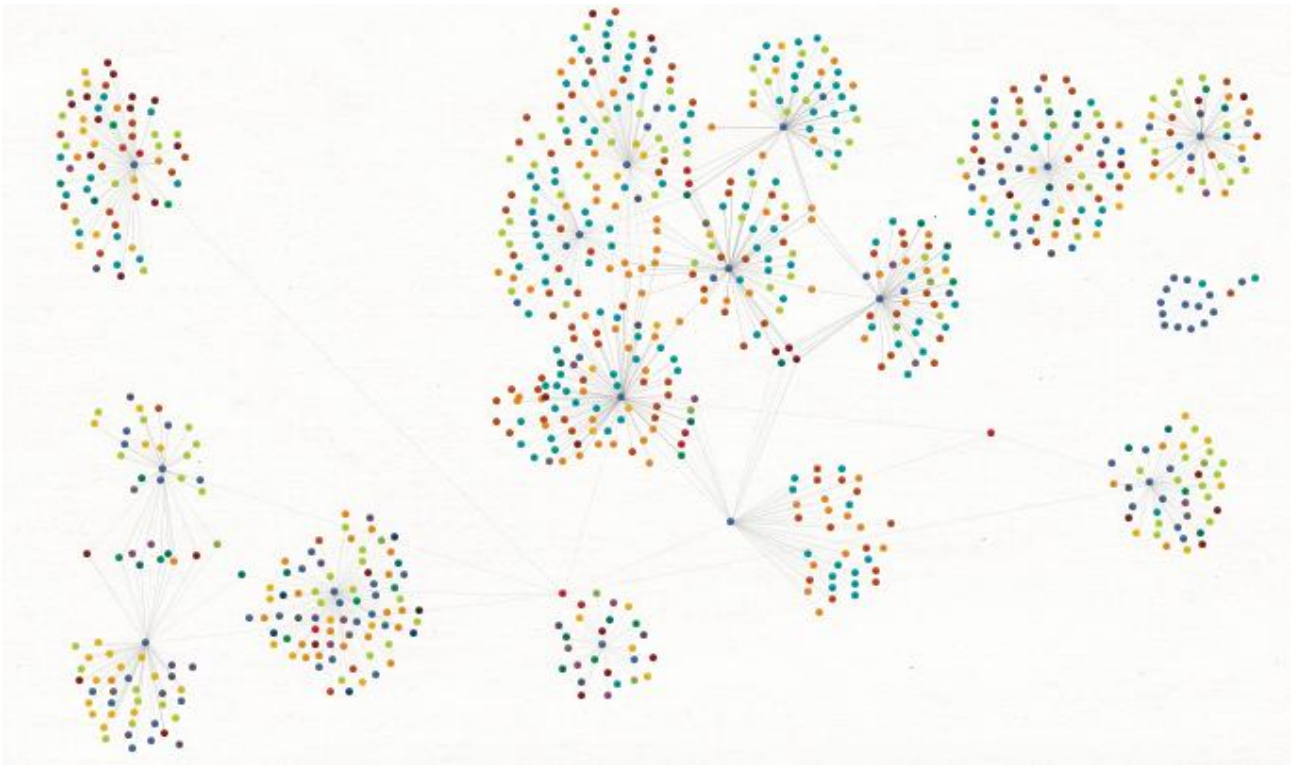


Imagen 172. Relaciones globales existentes entre los diferentes dominios asociados con SilverTerrier

Debido a la gran volumetría de datos obtenidos de los 17 dominios, tal como puede visualizarse en la imagen superior, vamos a centrarnos en las relaciones directas entre los diferentes dominios. El grafo resultante puede ser visualizado en la Imagen 173.

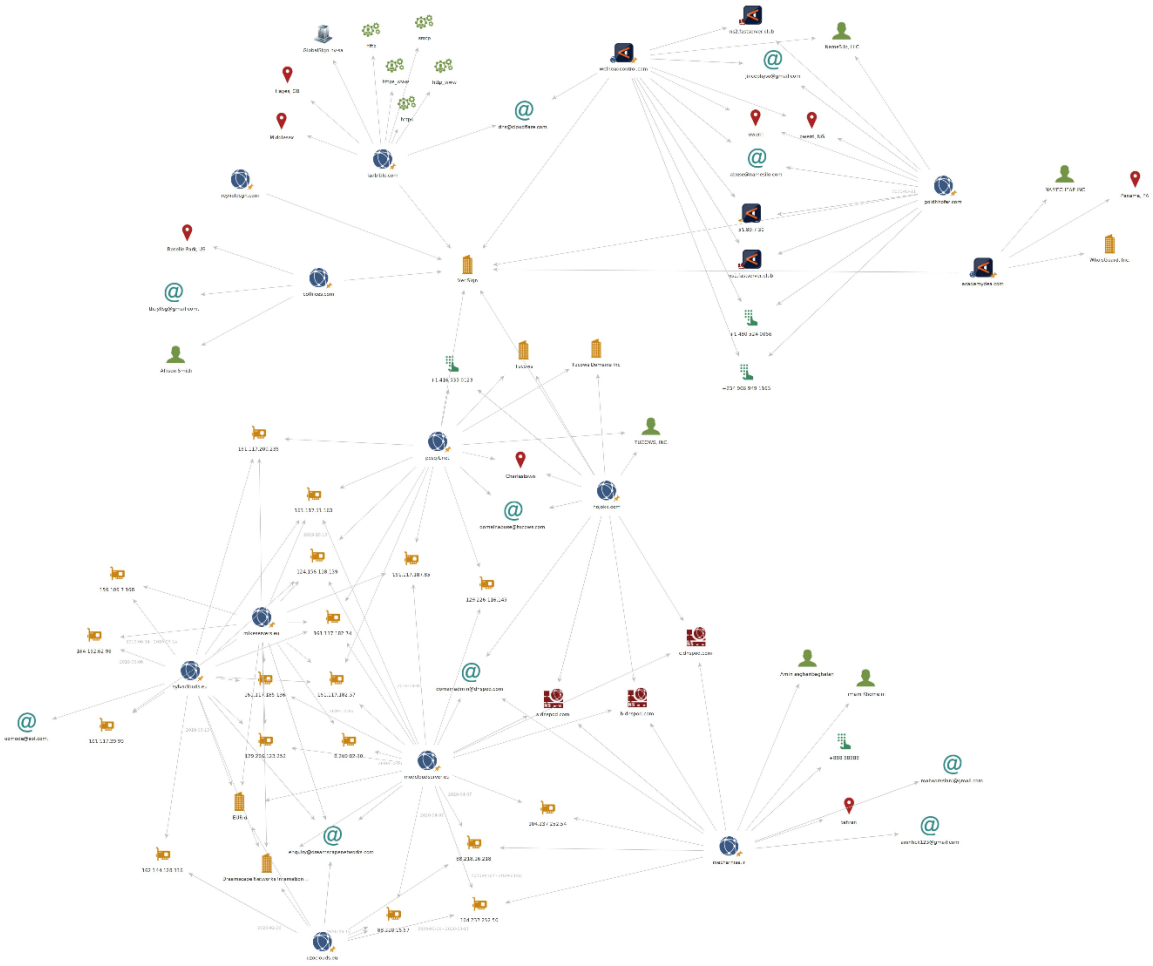
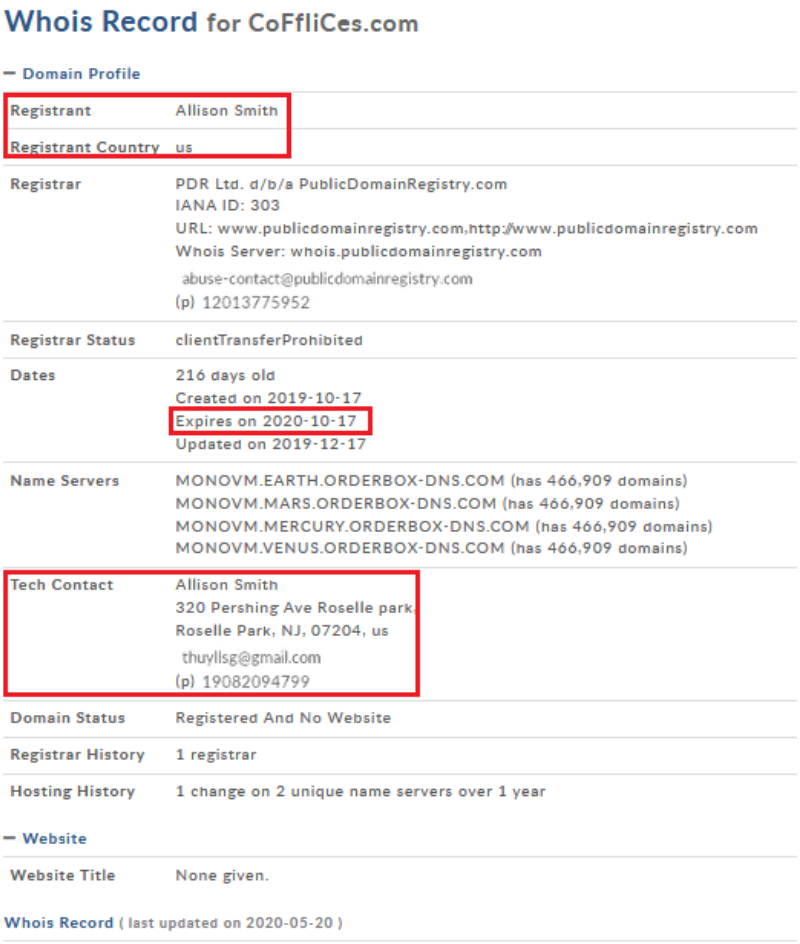


Imagen 173. Relaciones directas entre los dominios

Si analizamos en conjunto todo el grafo podemos sacar en claro las siguientes relaciones por cada uno de los dominios:

- coffiices.com:
    - El dominio comparte el proveedor de dominios **VeriSign** junto a otros **7 dominios** (reynoldsgh.com, ladbible.com, goldhhofer.com, academydea.com, hojokk.com, welheadcontrol.com y posqit.net).
    - A través de otra herramienta (DomainTools) se corrobora que el propio dominio está registrado en **Estados Unidos** por medio de Allison Smith,

además su **registro expira el 20 de octubre de 2020**. Lo mencionado puede visualizarse en la Imagen 174.



Whois Record for CoFfliCes.com

– Domain Profile

Registrant	Allison Smith
Registrant Country	us
Registrar	PDR Ltd. d/b/a PublicDomainRegistry.com IANA ID: 303 URL: www.publicdomainregistry.com,http://www.publicdomainregistry.com Whois Server: whois.publicdomainregistry.com abuse-contact@publicdomainregistry.com (p) 12013775952
Registrar Status	clientTransferProhibited
Dates	216 days old Created on 2019-10-17 Expires on 2020-10-17 Updated on 2019-12-17
Name Servers	MONOVM.EARTH.ORDERBOX-DNS.COM (has 466,909 domains) MONOVM.MARS.ORDERBOX-DNS.COM (has 466,909 domains) MONOVM.MERCURY.ORDERBOX-DNS.COM (has 466,909 domains) MONOVM.VENUS.ORDERBOX-DNS.COM (has 466,909 domains)
Tech Contact	Allison Smith 320 Pershing Ave Roselle park Roselle Park, NJ, 07204, us thuyllsg@gmail.com (p) 19082094799
Domain Status	Registered And No Website
Registrar History	1 registrar
Hosting History	1 change on 2 unique name servers over 1 year

– Website

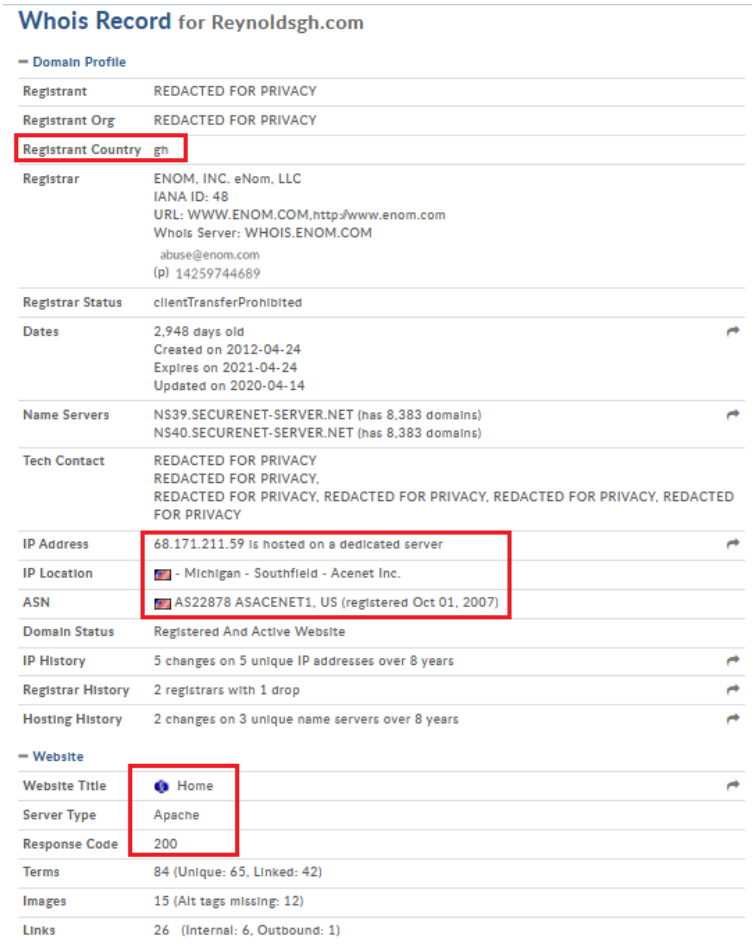
Website Title	None given.

Whois Record (last updated on 2020-05-20)

Imagen 174. Whois del dominio coffiices.com

- reynoldsgh.com
  - El dominio comparte el proveedor de dominios **VeriSign** junto a otros **7 dominios** analizados de partida (coffiices.com, ladbible.com, goldhhofer.com, academydea.com, hojokk.com, welheadcontrol.com y posqit.net).
  - A través de otra herramienta (DomainTools) es detectada la **dirección IP** a la que apunta el dominio actualmente (68.171.211.59), su **ASN asociado** (AS22878), **el país del registrante** (gh - Ghana), s**u geolocalización**

(Michigan – Southfield, Estados Unidos) y que su **registro expira el 24 de abril de 2021**. Lo mencionado puede visualizarse en la Imagen 175.



Whois Record for Reynoldsgh.com

– Domain Profile

Registrant	REDACTED FOR PRIVACY
Registrant Org	REDACTED FOR PRIVACY
Registrant Country	gh
Registrar	ENOM, INC. eNom, LLC IANA ID: 48 URL: WWW.ENOM.COM,http://www.enom.com Whois Server: WHOIS.ENOM.COM abuse@enom.com (p) 14259744689
Registrar Status	clientTransferProhibited
Dates	2,948 days old Created on 2012-04-24 Expires on 2021-04-24 Updated on 2020-04-14
Name Servers	NS39.SECURENET-SERVER.NET (has 8,383 domains) NS40.SECURENET-SERVER.NET (has 8,383 domains)
Tech Contact	REDACTED FOR PRIVACY REDACTED FOR PRIVACY, REDACTED FOR PRIVACY, REDACTED FOR PRIVACY, REDACTED FOR PRIVACY, REDACTED FOR PRIVACY
IP Address	68.171.211.59 is hosted on a dedicated server
IP Location	- Michigan - Southfield - Acenet Inc.
ASN	AS22878 ASACENET1, US (registered Oct 01, 2007)
Domain Status	Registered And Active Website
IP History	5 changes on 5 unique IP addresses over 8 years
Registrar History	2 registrars with 1 drop
Hosting History	2 changes on 3 unique name servers over 8 years

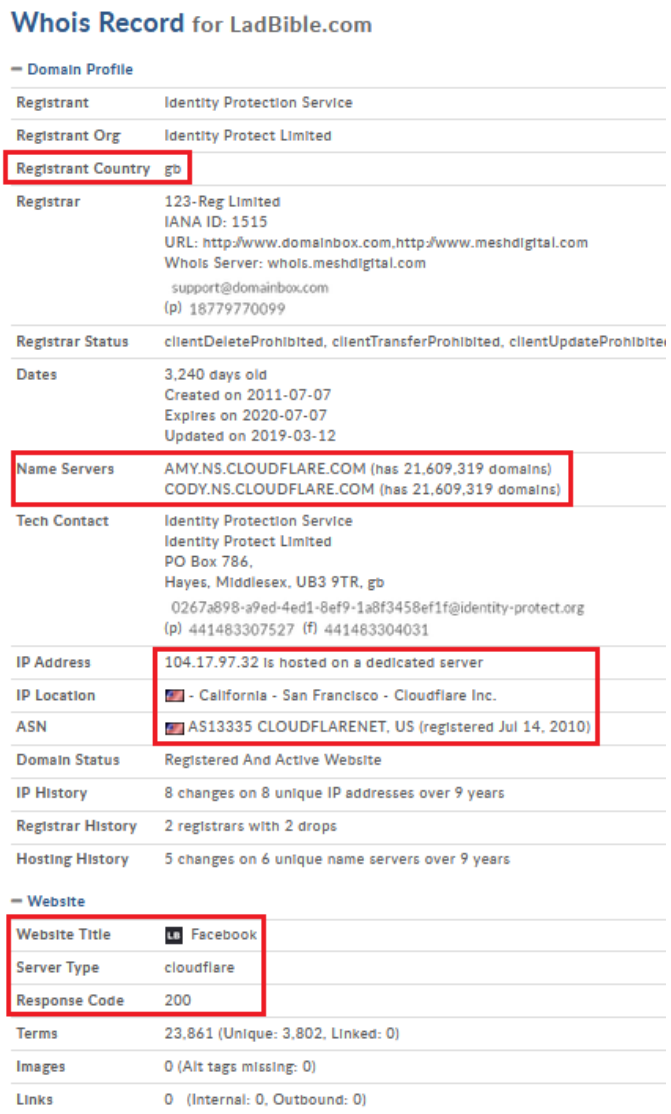
– Website

Website Title	Home
Server Type	Apache
Response Code	200
Terms	84 (Unique: 65, Linked: 42)
Images	15 (Alt tags missing: 12)
Links	26 (Internal: 6, Outbound: 1)

Imagen 175. Whois del dominio reynoldsgh.com

- ladbible.com
    - El dominio comparte el proveedor de dominios **VeriSign** junto a otros **7 dominios** analizados de partida (coffiices.com, reynoldsgh.com, goldhhofer.com, academydea.com, hojokk.com, welheadcontrol.com y posqit.net).

- El dominio tiene asociado un **correo electrónico** (dns@cloudflare.com) que comparte con **welheadcontrol.com**. Esto indica que existe alguna vinculación con el proveedor de Cloudflare por parte de ambos dominios.
- Son detectados 3 servicios expuestos a Internet (HTTP, HTTPS y SMTP).
- A través de otra herramienta (DomainTools) es detectada la **dirección IP** a la que apunta el dominio actualmente (104.17.97.32), su **ASN asociado** (AS13335), un **CDN** (Cloudflare), **el país del registrante** (gb – Reino Unido), **su geolocalización** (California, Estados Unidos) y la **expiración del registro el 07 de julio de 2020**. Lo mencionado puede visualizarse en la Imagen 176.



Whois Record for LadBible.com

Domain Profile

Registrant	Identity Protection Service
Registrant Org	Identity Protect Limited
Registrant Country	gb
Registrar	123-Reg Limited IANA ID: 1515 URL: http://www.domainbox.com,http://www.meshdigital.com Whois Server: whois.meshdigital.com support@domainbox.com (p) 18779770099
Registrar Status	clientDeleteProhibited, clientTransferProhibited, clientUpdateProhibite
Dates	3,240 days old Created on 2011-07-07 Expires on 2020-07-07 Updated on 2019-03-12
Name Servers	AMY.NS.CLOUDFLARE.COM (has 21,609,319 domains) CODY.NS.CLOUDFLARE.COM (has 21,609,319 domains)
Tech Contact	Identity Protection Service Identity Protect Limited PO Box 786, Hayes, Middlesex, UB3 9TR, gb 0267a898-a9ed-4ed1-8ef9-1a8f3458ef1f@identity-protect.org (p) 441483307527 (f) 441483304031
IP Address	104.17.97.32 is hosted on a dedicated server
IP Location	- California - San Francisco - Cloudflare Inc.
ASN	AS13335 CLOUDFLARENET, US (registered Jul 14, 2010)
Domain Status	Registered And Active Website
IP History	8 changes on 8 unique IP addresses over 9 years
Registrar History	2 registrars with 2 drops
Hosting History	5 changes on 6 unique name servers over 9 years

Website

Website Title	Facebook
Server Type	cloudflare
Response Code	200
Terms	23,861 (Unique: 3,802, Linked: 0)
Images	0 (Alt tags missing: 0)
Links	0 (Internal: 0, Outbound: 0)

Imagen 176. Whois del dominio ladbible.com

- welheadcontrol.com
    - El dominio comparte el proveedor de dominios VeriSign junto a otros **7 dominios** analizados de partida (coffiices.com, reynoldsgh.com, goldhhofer.com, academydea.com, hojokk.com, ladbible.com y posqit.net). Además, este dominio comparte **proveedor de dominios** (NameSilo) con el dominio **goldhhofer.com**, junto a otro **correo electrónico relacionado con dicho proveedor** (abuse@namesilo.com).

- El dominio tiene asociado **un correo electrónico** (dns@cloudflare.com) que comparte con **ladbible.com**. Esto indica que existe alguna vinculación con un CDN (Cloudflare) por parte de ambos dominios. Este dominio dispone de otra relación por medio de un **correo electrónico** (jincephyso@gmail.com) con el dominio **goldhhofer.com.**

- Comparte **dos números de teléfono** con el dominio **goldhhofer.com**, uno asociado al proveedor de dominios NameSilo y otro al contacto técnico, en este caso Black Emeka.

- Es detectada una **relación con el dominio goldhhofer.com** por medio de dos **servidores NS** y una **dirección IP**. Analizando el histórico de las direcciones IP asociadas al dominio podemos ver que en un instante de tiempo en el pasado apuntó a la **dirección IP** (51.89.7.30) detectada en Maltego. En la Imagen 177 puede verse lo mencionado.

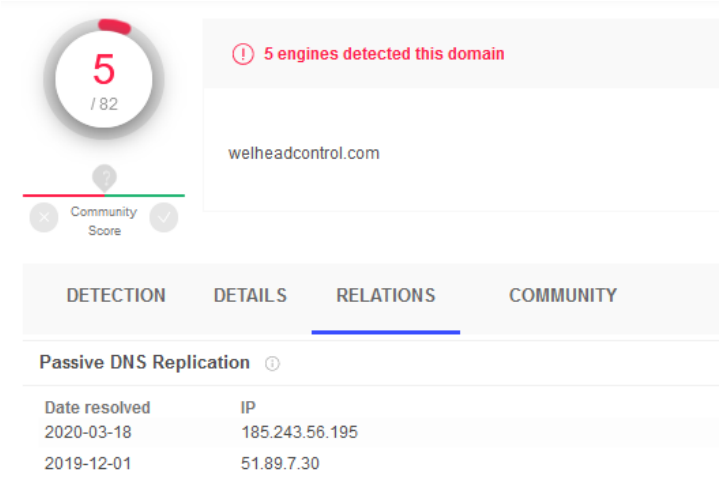
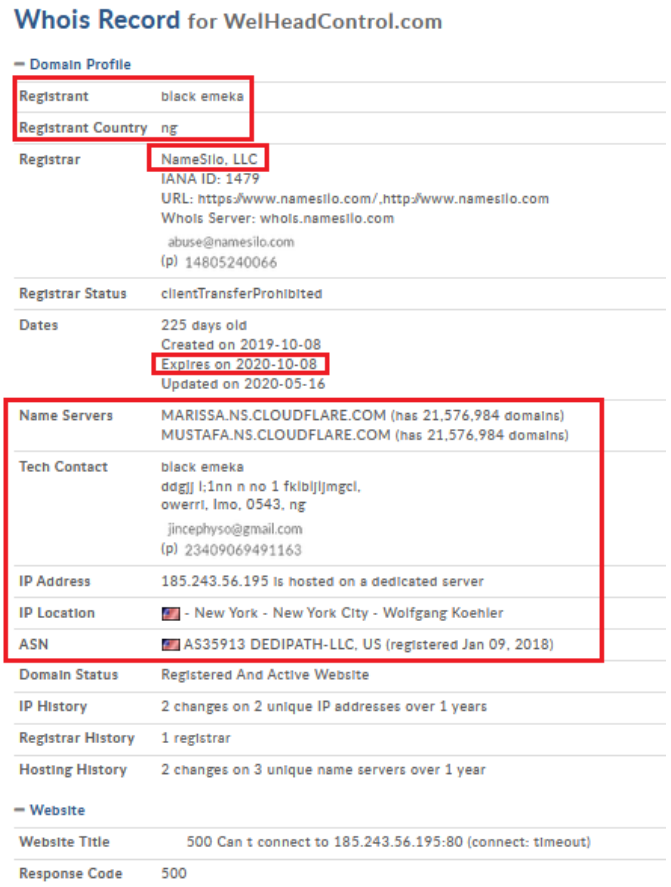


Imagen 177. Dirección IP obtenida mediante el histórico del dominio con VirusTotal

- A través de otra herramienta (DomainTools) es detectada la **dirección IP a la que apunta el dominio actualmente** (185.243.56.195), su **ASN asociado** (AS35913), el **CDN utilizado** (Cloudflare), **su registrante** (Black

Emeka), **el país del registrante** (ng – Nigeria), **su geolocalización** (Nueva York, Estados Unidos) y **la expiración del registro el 08 de octubre de 2020**. Lo mencionado puede visualizarse en la Imagen 178.



Whois Record for WelHeadControl.com

– Domain Profile

Registrant	black emeka
Registrant Country	ng
Registrar	NameSilo, LLC IANA ID: 1479 URL: https://www.namesilo.com/,http://www.namesilo.com Whois Server: whois.namesilo.com abuse@namesilo.com (p) 14805240066
Registrar Status	clientTransferProhibited
Dates	225 days old Created on 2019-10-08 Expires on 2020-10-08 Updated on 2020-05-16
Name Servers	MARISSA.NS.CLOUDFLARE.COM (has 21,576,984 domains) MUSTAFA.NS.CLOUDFLARE.COM (has 21,576,984 domains)
Tech Contact	black emeka ddgjj l;1nn n no 1 fkibijjmgcl, owerri, imo, 0543, ng jincephyso@gmail.com (p) 23409069491163
IP Address	185.243.56.195 is hosted on a dedicated server
IP Location	- New York - New York City - Wolfgang Koehler
ASN	AS35913 DEDIPATH-LLC, US (registered Jan 09, 2018)
Domain Status	Registered And Active Website
IP History	2 changes on 2 unique IP addresses over 1 years
Registrar History	1 registrar
Hosting History	2 changes on 3 unique name servers over 1 year

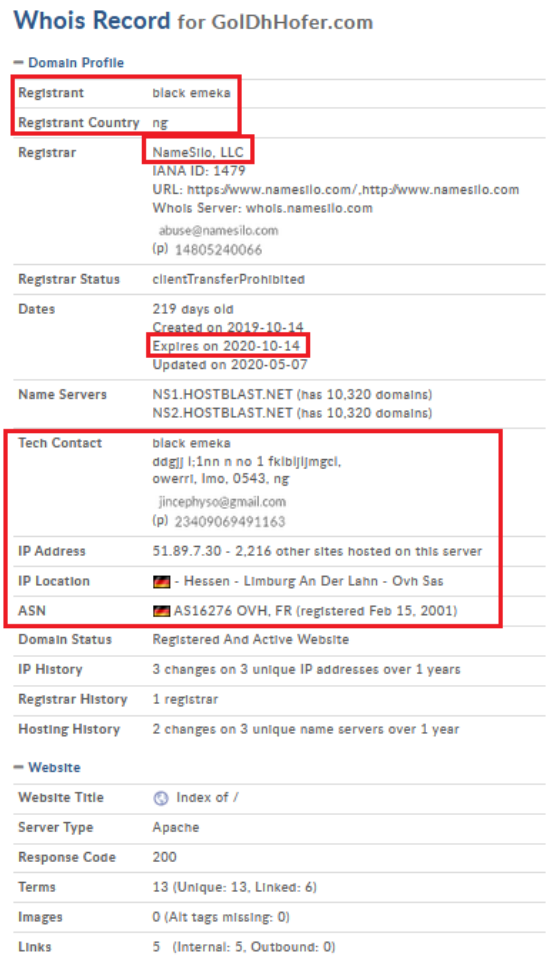
– Website

Website Title	500 Can t connect to 185.243.56.195:80 (connect: timeout)
Response Code	500

Imagen 178. Whois del dominio welheadcontrol.com

- goldhhofer.com
  - El dominio comparte el proveedor de dominios **VeriSign** junto a otros **7 dominios** analizados de partida (coffiices.com, reynoldsgh.com, welheadcontrol.com, academydea.com, hojokk.com, ladbible.com y posqit.net). Además, este dominio comparte proveedor de dominios (NameSilo) con el dominio **welheadcontrol.com**, junto a otro **correo relacionado con dicho proveedor** (abuse@namesilo.com).

- El dominio tiene asociado **un correo electrónico** (jincephyso@gmail.com) que comparte con el dominio **welheadcontrol.com.**
- Comparte dos números de teléfono con el dominio welheadcontrol.com, uno asociado al proveedor de dominios NameSilo y otro al contacto técnico, en este caso Black Emeka.
- Es detectada una **relación con el dominio welheadcontrol.com** por medio de dos **servidores NS** y una **dirección IP.**
- A través de otra herramienta (DomainTools) es detectada la **dirección IP** a la que apunta el dominio actualmente (51.89.7.30), **su ASN asociado** (AS16276), **su registrante** (Black Emeka), **el país del registrante** (ng – Nigeria), **su geolocalización** (Hessen - Limburg An Der Lahn, Alemania) y que **su registro expira el 14 de octubre de 2020**. Lo mencionado puede visualizarse en la Imagen 179.



Whois Record for GolDhHofer.com

– Domain Profile

Registrant	black emeka
Registrant Country	ng
Registrar	NameSilo, LLC IANA ID: 1479 URL: https://www.namesilo.com/,http://www.namesilo.com Whois Server: whois.namesilo.com abuse@namesilo.com (p) 14805240066
Registrar Status	clientTransferProhibited
Dates	219 days old Created on 2019-10-14 Expires on 2020-10-14 Updated on 2020-05-07
Name Servers	NS1.HOSTBLAST.NET (has 10,320 domains) NS2.HOSTBLAST.NET (has 10,320 domains)
Tech Contact	black emeka ddgjj l;1nn n no 1 fkibijjmgcl, owerri, Imo, 0543, ng jincephyso@gmail.com (p) 23409069491163
IP Address	51.89.7.30 - 2,216 other sites hosted on this server
IP Location	- Hessen - Limburg An Der Lahn - Ovh Sas
ASN	AS16276 OVH, FR (registered Feb 15, 2001)
Domain Status	Registered And Active Website
IP History	3 changes on 3 unique IP addresses over 1 years
Registrar History	1 registrar
Hosting History	2 changes on 3 unique name servers over 1 year

– Website

Website Title	Index of /
Server Type	Apache
Response Code	200
Terms	13 (Unique: 13, Linked: 6)
Images	0 (Alt tags missing: 0)
Links	5 (Internal: 5, Outbound: 0)

Imagen 179. Whois del dominio goldhhofer.com

- academydea.com
    - El dominio comparte el proveedor de dominios **VeriSign** junto a otros **7 dominios** analizados de partida (coffiices.com, reynoldsgh.com, welheadcontrol.com, goldhhofer.com, hojokk.com, ladbible.com y posqit.net).

- A través de otra herramienta (DomainTools) es detectada la **dirección IP** a la que apunta el dominio actualmente (165.227.16.98), **su ASN asociado** (AS14061), **su registrante** (WhoisGuard Protected), **el país del registrante** (pa - Panama), **su geolocalización** (Nueva York, Estados Unidos) y **la expiración del registro el 25 de agosto de 2020**. Lo mencionado puede visualizarse en la Imagen 180.



Whois Record for AcademyDea.com

– Domain Profile

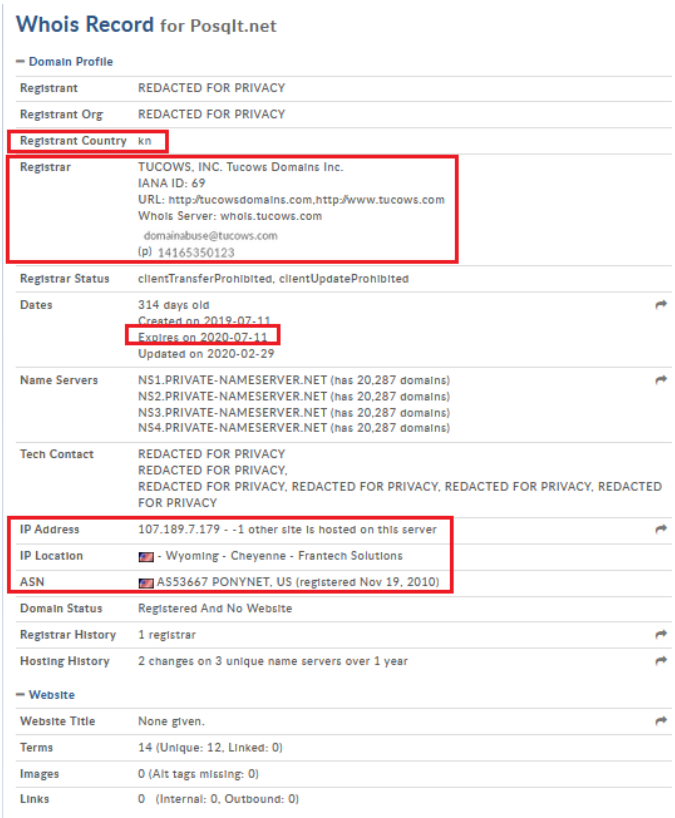
Registrant	WhoisGuard Protected
Registrant Org	WhoisGuard, Inc.
Registrant Country	pa
Registrar	NAMECHEAP INC NameCheap, Inc. IANA ID: 1068 URL: http://www.namecheap.com Whois Server: whois.namecheap.com abuse@namecheap.com (p) 16613102107
Registrar Status	clientTransferProhibited
Dates	269 days old Created on 2019-08-25 Expires on 2020-08-25 Updated on 0000-12-31
Name Servers	NS1.MOGULBOUND.IO (has 33 domains) NS2.MOGULBOUND.IO (has 33 domains) NS3.MOGULBOUND.IO (has 33 domains)
Tech Contact	WhoisGuard Protected WhoisGuard, Inc. P.O. Box 0823-03411, Panama, Panama, pa f749919287204eeab27693ae97780808.protect@whoisguard.com (p) 5078365503 (f) 5117057182
IP Address	165.227.16.98 - 25 other sites hosted on this server
IP Location	- New York - New York City - Digitalocean Llc
ASN	AS14061 DIGITALOCEAN-ASN, US (registered Sep 25, 2012)
Domain Status	Registered And Active Website
IP History	17 changes on 17 unique IP addresses over 12 years
Registrar History	5 registrars with 4 drops
Hosting History	13 changes on 9 unique name servers over 15 years

– Website

Website Title	500 SSL negotiation failed:
Response Code	500

Imagen 180. Whois del dominio academydea.com

- posqit.net
    - El dominio comparte el proveedor de dominios **VeriSign** junto a otros **7 dominios** analizados de partida (coffiices.com, reynoldsgh.com, welheadcontrol.com, goldhhofer.com, hojokk.com, ladbible.com y academydea.com).
    - El dominio tiene **diferentes tipos de relaciones con hojokk.com**, son los siguientes:
        - **Una empresa** (TUCOWS, INC) y **un correo electrónico** (domainabuse@tucows.com) asociado a dicha empresa
        - **Un número de teléfono**
        - **Una geolocalización** (Charlestown)
    - El dominio está relacionado con mikeservers.eu, sylvaclouds.eu y modcloudserver.eu por medio de **7 direcciones IP.**
    - A través de otra herramienta (DomainTools) es detectada la **dirección IP** a la que apunta el dominio actualmente (107.189.7.179), **su ASN asociado** (AS53667), **el país del registrante** (kn – Corea del Norte), **su geolocalización** (Wyoming - Cheyenne, Estados Unidos) y que **su registro expira el 11 de julio de 2020**. Lo mencionado puede visualizarse en la Imagen 181.

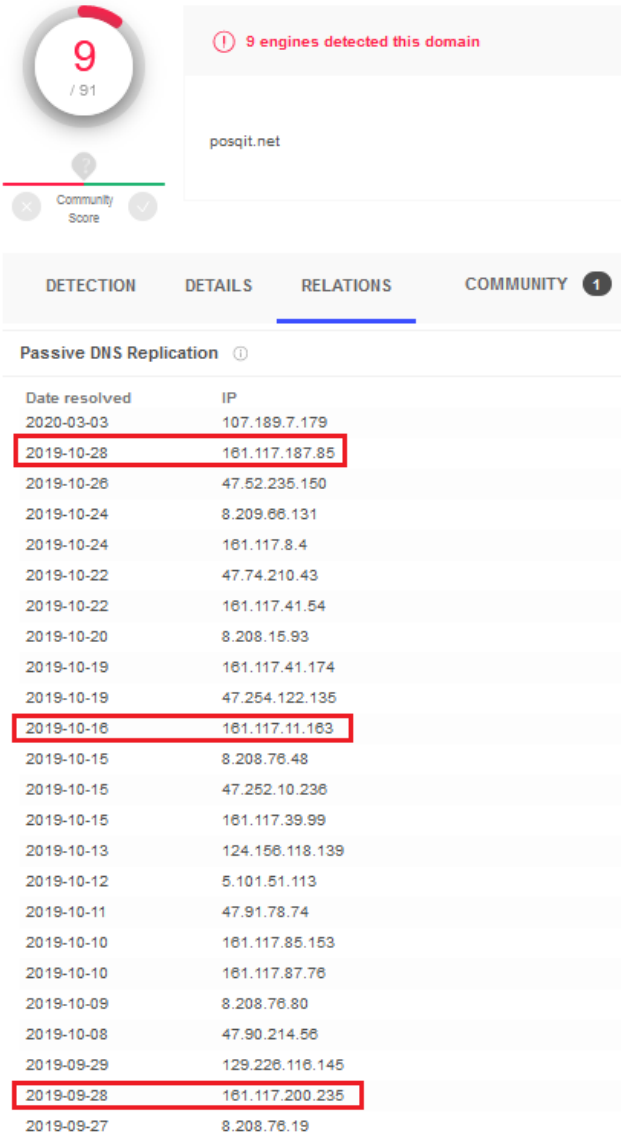


Whois Record for Posqlt.net

Domain Profile	
Registrant	REDACTED FOR PRIVACY
Registrant Org	REDACTED FOR PRIVACY
Registrant Country	kn
Registrar	TUCOWS, INC. Tucows Domains Inc. IANA ID: 69 URL: http://tucowsdomains.com,http://www.tucows.com Whois Server: whois.tucows.com domainabuse@tucows.com (p) 14165350123
Registrar Status	clientTransferProhibited, clientUpdateProhibited
Dates	314 days old Created on 2019-07-11 Expires on 2020-07-11 Updated on 2020-02-29
Name Servers	NS1.PRIVATE-NAMESERVER.NET (has 20,287 domains) NS2.PRIVATE-NAMESERVER.NET (has 20,287 domains) NS3.PRIVATE-NAMESERVER.NET (has 20,287 domains) NS4.PRIVATE-NAMESERVER.NET (has 20,287 domains)
Tech Contact	REDACTED FOR PRIVACY REDACTED FOR PRIVACY, REDACTED FOR PRIVACY, REDACTED FOR PRIVACY, REDACTED FOR PRIVACY, REDACTED FOR PRIVACY
IP Address	107.189.7.179 - -1 other site is hosted on this server
IP Location	- Wyoming - Cheyenne - Frantech Solutions
ASN	AS53667 PONYNET, US (registered Nov 19, 2010)
Domain Status	Registered And No Website
Registrar History	1 registrar
Hosting History	2 changes on 3 unique name servers over 1 year
Website	
Website Title	None given.
Terms	14 (Unique: 12, Linked: 0)
Images	0 (Alt tags missing: 0)
Links	0 (Internal: 0, Outbound: 0)

Imagen 181. Whois del dominio posqit.net

- Analizando el histórico de las direcciones IP asociadas al dominio podemos ver que en un instante de tiempo en el pasado apuntó a las **7 direcciones IP** detectadas en Maltego. En la Imagen 182 pueden visualizarse algunas de las coincidencias.



Date resolved	IP
2020-03-03	107.189.7.179
2019-10-28	161.117.187.85
2019-10-26	47.52.235.150
2019-10-24	8.209.66.131
2019-10-24	161.117.8.4
2019-10-22	47.74.210.43
2019-10-22	161.117.41.54
2019-10-20	8.208.15.93
2019-10-19	161.117.41.174
2019-10-19	47.254.122.135
2019-10-16	161.117.11.163
2019-10-15	8.208.76.48
2019-10-15	47.252.10.236
2019-10-15	161.117.39.99
2019-10-13	124.156.118.139
2019-10-12	5.101.51.113
2019-10-11	47.91.78.74
2019-10-10	161.117.85.153
2019-10-10	161.117.87.76
2019-10-09	8.208.76.80
2019-10-08	47.90.214.56
2019-09-29	129.226.116.145
2019-09-28	161.117.200.235
2019-09-27	8.208.76.19

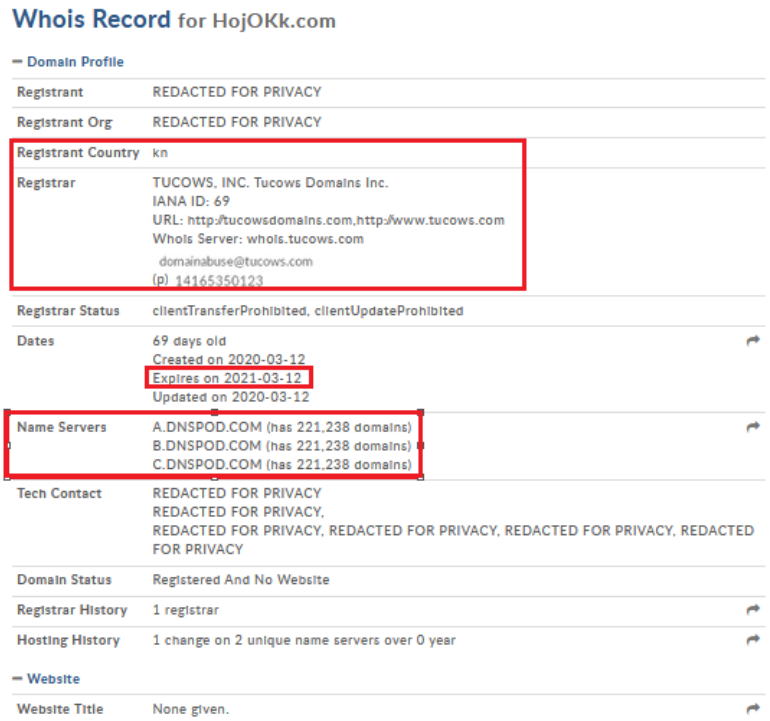
Imagen 182. Histórico de direcciones IP asociadas al dominio posqit.net

- hojokk.com
    - El dominio comparte el proveedor de dominios **VeriSign** junto a otros **7 dominios** analizados de partida (coffiices.com, reynoldsgh.com, welheadcontrol.com, goldhhofer.com, posqit.net, ladbible.com y academydea.com).
    - El dominio tiene **diferentes tipos de relaciones con posqit.net** siendo los siguientes:

- **Una empresa** (TUCOWS, INC) y **un correo electrónico** (domainabuse@tucows.com) asociado a dicha empresa.
- **Un número de teléfono.**
- **Una geolocalización** (Charlestown).

- Relacionado con los dominios modcloudserver.eu y mecharnise.ir por medio de un correo (domainadmin@dnspod.com) y tres registros NS (a.dnspod.com, b.dnspod.com y c.dnspod.com).

- A través de otra herramienta (DomainTools) es detectado el **país del registrante** (kn – Corea del Norte) y **la expiración del registro el 12 de marzo de 2021**. Lo mencionado puede visualizarse en la Imagen 183.



Whois Record for HojOKk.com

Domain Profile

Registrant	REDACTED FOR PRIVACY
Registrant Org	REDACTED FOR PRIVACY
Registrant Country	kn
Registrar	TUCOWS, INC. Tucows Domains Inc. IANA ID: 69 URL: http://tucowsdomains.com,http://www.tucows.com Whois Server: whois.tucows.com domainabuse@tucows.com (p) 14165350123
Registrar Status	clientTransferProhibited, clientUpdateProhibited
Dates	69 days old Created on 2020-03-12 Expires on 2021-03-12 Updated on 2020-03-12
Name Servers	A.DNSPOD.COM (has 221,238 domains) B.DNSPOD.COM (has 221,238 domains) C.DNSPOD.COM (has 221,238 domains)
Tech Contact	REDACTED FOR PRIVACY REDACTED FOR PRIVACY, REDACTED FOR PRIVACY, REDACTED FOR PRIVACY, REDACTED FOR PRIVACY, REDACTED FOR PRIVACY
Domain Status	Registered And No Website
Registrar History	1 registrar
Hosting History	1 change on 2 unique name servers over 0 year

Website

Website Title	None given.

Imagen 183. Whois del dominio hojokk.com

- mikeservers.eu
    - El dominio comparte relación con EURid y el proveedor Singapur Dreamscape Networks International Pte Ltd junto a otros tres dominios analizados de partida (sylvaclouds.eu, uzoclouds.eu y modcloudserver.eu).
    - El dominio está relacionado con posqit.net, sylvaclouds.eu y modcloudserver.eu por medio de 11 direcciones IP en total.
    - El dominio tiene asociado un correo electrónico (enquiry@dreamscapenetworks.com) que comparte con tres dominios (sylvaclouds.eu, modcloudserver.eu y uzoclouds.eu).
    - A través de otra herramienta (DomainTools) es detectado únicamente el registrante (Dreamscape Networks International Pte Ltd) y los registros NS. Lo mencionado puede visualizarse en la Imagen 184.

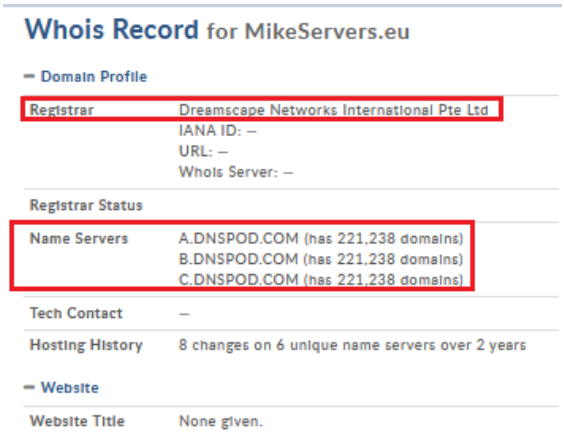


Imagen 184. Whois del dominio mikeservers.eu

- sylvaclouds.eu
    - El dominio comparte relación con EURid y el proveedor Singapur Dreamscape Networks International Pte Ltd junto a otros tres dominios analizados de partida (mikeservers.eu, uzoclouds.eu y modcloudserver.eu).

- El dominio está relacionado con posqit.net, mikeservers.eu y modcloudserver.eu por medio de 11 direcciones IP en total.
- El dominio tiene asociado un correo electrónico (enquiry@dreamscapenetworks.com) que comparte con tres dominios (mikeservers.eu, modcloudserver.eu y uzoclouds.eu).
- A través de otra herramienta (DomainTools) es detectada la dirección IP a la que apunta el dominio actualmente (162.214.75.129), su ASN asociado (AS46606) y su geolocalización (Utah, Estados Unidos). Lo mencionado puede visualizarse en la Imagen 185.

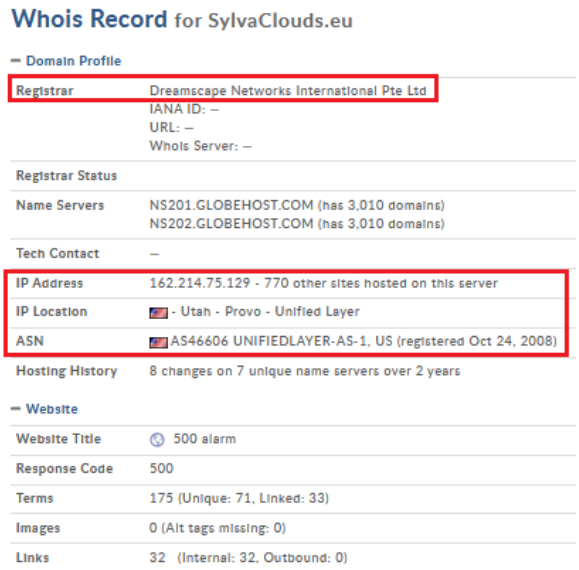
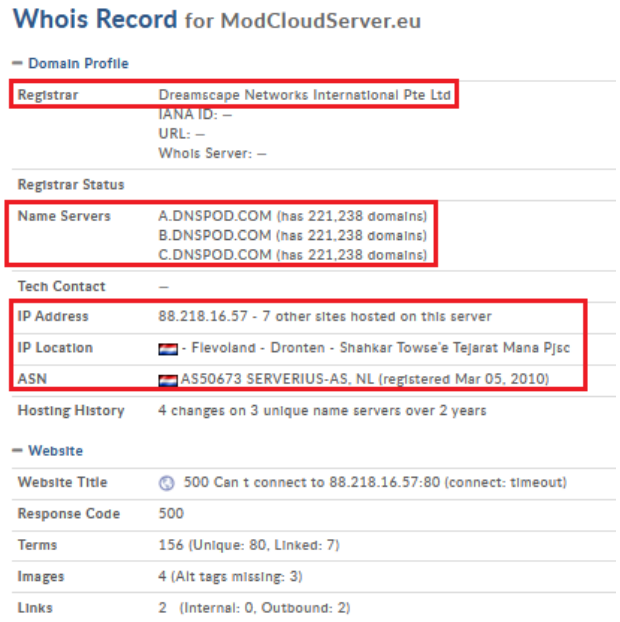


Imagen 185. Whois del dominio sylvaclouds.eu

- modcloudserver.eu
  - El dominio comparte relación con EURid y el proveedor Singapur Dreamscape Networks International Pte Ltd junto a otros tres dominios analizados de partida (mikeservers.eu, uzoclouds.eu y sylvaclouds.eu).

- Dispone de relación con los dominios posqit.net, sylvaclouds.eu, uzoclouds.eu, mikeservers.eu y mecharnise.ir por medio de 13 direcciones IP en total.
- El dominio tiene asociado un correo electrónico (enquiry@dreamscapenetworks.com) que comparte con tres dominios (sylvaclouds.eu, modcloudserver.eu y uzoclouds.eu).
- Relacionado con los dominios hojokk.com y mecharnise.ir por medio de un correo (domainadmin@dnspod.com) y tres registros NS (a.dnspod.com, b.dnspod.com y c.dnspod.com).
- A través de otra herramienta (DomainTools) es detectada la dirección IP a la que apunta el dominio actualmente (88.218.16.57), su ASN asociado (AS50673), su registrante (Dreamscape Networks International Pte Ltd) y su geolocalización (Flevoland – Dronten, Holanda). Lo mencionado puede visualizarse en la Imagen 186.



Whois Record for ModCloudServer.eu

Domain Profile

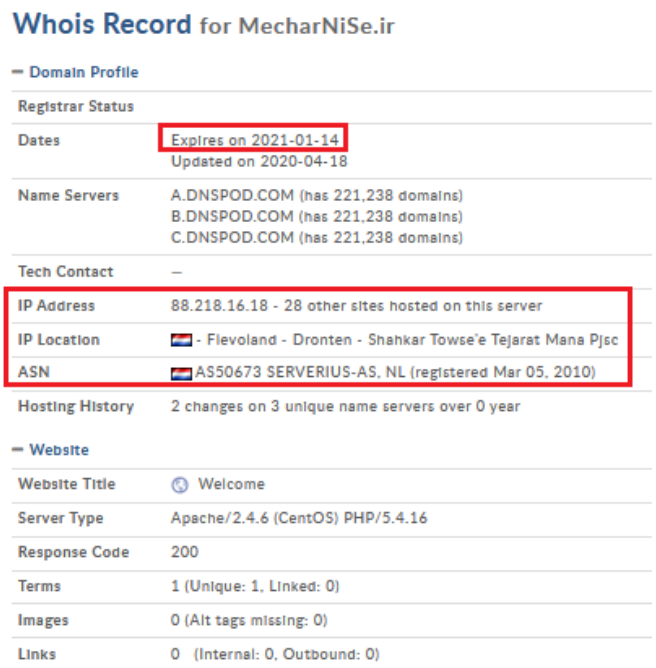
Registrar	Dreamscape Networks International Pte Ltd IANA ID: – URL: – Whois Server: –
Registrar Status	
Name Servers	A.DNSPOD.COM (has 221,238 domains) B.DNSPOD.COM (has 221,238 domains) C.DNSPOD.COM (has 221,238 domains)
Tech Contact	–
IP Address	88.218.16.57 - 7 other sites hosted on this server
IP Location	- Flevoland - Dronten - Shahkar Towse'e Tejarat Mana Pjsc
ASN	AS50673 SERVERIUS-AS, NL (registered Mar 05, 2010)
Hosting History	4 changes on 3 unique name servers over 2 years

Website

Website Title	500 Can t connect to 88.218.16.57:80 (connect: timeout)
Response Code	500
Terms	156 (Unique: 80, Linked: 7)
Images	4 (Alt tags missing: 3)
Links	2 (Internal: 0, Outbound: 2)

Imagen 186. Whois del dominio modcloudserver.eu

- mecharnise.ir
    - Dispone de relación con los dominios modcloudserver.eu y uzoclouds.eu por medio de cuatro direcciones IP en total.
    - Relacionado con los dominios hojokk.com y modcloudserver.eu por medio de un correo (domainadmin@dnspod.com) y tres registros NS (a.dnspod.com, b.dnspod.com y c.dnspod.com).
    - A través de otra herramienta (DomainTools) es detectada la dirección IP a la que apunta el dominio actualmente (88.218.16.18), su ASN asociado (AS50673), su geolocalización (Flevoland – Dronten, Holanda) y la expiración del registro el 14 de enero de 2021. Lo mencionado puede visualizarse en la Imagen 187.



Whois Record for MecharNiSe.ir

Domain Profile	
Registrar Status	
Dates	Expires on 2021-01-14 Updated on 2020-04-18
Name Servers	A.DNSPOD.COM (has 221,238 domains) B.DNSPOD.COM (has 221,238 domains) C.DNSPOD.COM (has 221,238 domains)
Tech Contact	–
IP Address	88.218.16.18 - 28 other sites hosted on this server
IP Location	- Flevoland - Dronten - Shahkar Towse'e Tejarat Mana Pjsc
ASN	AS50673 SERVERIUS-AS, NL (registered Mar 05, 2010)
Hosting History	2 changes on 3 unique name servers over 0 year
Website	
Website Title	Welcome
Server Type	Apache/2.4.6 (CentOS) PHP/5.4.16
Response Code	200
Terms	1 (Unique: 1, Linked: 0)
Images	0 (Alt tags missing: 0)
Links	0 (Internal: 0, Outbound: 0)

Imagen 187. Whois del dominio mecharnise.ir

- uzoclouds.eu
    - El dominio comparte relación con EURid y el proveedor Singapur Dreamscape Networks International Pte Ltd junto a otros tres dominios analizados de partida (mikeservers.eu, modcloudserver.eu y sylvaclouds.eu).
    - Dispone de relación con los dominios sylvaclouds.eu, modcloudserver.eu, mikeservers.eu y mecharnise.ir por medio de cuatro direcciones IP en total.
    - El dominio tiene asociado un correo electrónico (enquiry@dreamscapenetworks.com) que comparte con tres dominios (sylvaclouds.eu, modcloudserver.eu y modcloudserver.eu).
    - A través de otra herramienta (DomainTools) es detectada únicamente su registrante (Dreamscape Networks International Pte Ltd). Lo mencionado puede visualizarse en la Imagen 188.



Imagen 188. Whois del dominio uzoclouds.eu

Como conclusión del análisis podemos indicar lo siguiente:

- Los dominios mikeservers.eu, modcloudserver.eu y sylvaclouds.eu y uzoclouds.eu están relacionados por medio del mismo proveedor de servicios de Internet (Dreamscape Networks International Pte Ltd), el cual es originario de Singapur.

- Los dominios hojokk.com, modcloudserver.eu y mecharnise.ir comparten los mismos registros NS, lo que indica que están relacionados con la misma empresa proveedora de DNS.
- Los dominios hojokk.com y posqit.net a su vez comparten la misma empresa proveedora (TUCOWS, INC) relacionada con un portal de descarga de software. Además, el país registrante de ambos es Corea del Norte.
- Los dominios welheadcontrol.com y goldhhofer.com comparten el mismo proveedor de servicios (NameSilo), dos números de teléfono y el contacto Black Emeka que apunta a Nigeria.
- Los dominios ladbible.com y welheadcontrol.com comparten el mismo correo electrónico (dns@cloudflare.com), lo que indica que ambos disponen de CloudFlare como proveedor.
- Ocho dominios (hojokk.com, coffiices.com, reynoldsgh.com, welheadcontrol.com, goldhhofer.com, posqit.net, ladbible.com y academydea.com) comparten el mismo proveedor de servicios (VeriSign).
- En resumen, los países registrantes de los dominios detectados apuntan a Nigeria, Corea del Norte, Panamá, Ghana, Reino Unido y Estados Unidos.

5. BIBLIOGRAFÍA

A

ABUSE.ch - https://abuse.ch/.
AbuseIPDB - https://www.abuseipdb.com.
Actores - Recurso de APTs de grupos griminales y actores. http://apt.threattracking.com

B

Blacklists - MXToolbox - https://mxtoolbox.com/blacklists.aspx.
Buscadores de Hidden Service - DarkFeed - Surface Web - https://darkfeed.io.
Buscadores de Hidden Service - DarkTracer - Surface Web - https://darktracer.com.
Buscadores de Hidden Service - The Hidden Wiki - Tor - http://zqktlwiuavvvqqt4ybvgvi7tyo4hjl5xgfuvpdf6otjiycgwqbym2qad.onion/wiki/index.php/Main_Page.
Buscadores de Hidden Service - TORCH - Tor - http://xmh57jrknzkhv6y3ls3ubitzfqnkrwxhopf5aygthi7d6rplyvk3noyd.onion.
Buscadores de Hidden Services - AHMIA - Surface Web - https://ahmia.fi/. ,
Buscadores de Hidden Services - Daniel Hosting - Surface Web - https://danwin1210.de.
Buscadores de Hidden Services - Daniel Hosting - Tor - http://danielas3rtn54uwmofdo3x2bsdifr47huasnmbgqzfrec5ubupvtpid.onion/.
Buscadores de Hidden Services - OnionLand - Surface Web - https://onionlandsearchengine.com/.

D

Dehashed - https://dehashed.com.
DNS dinámicos. *https://maslinux.es/7-mejores-proveedores-de-dns-dinamicos-para-usar-gratis/.*
dores de Hidden Services - AHMIA - Tor - http://juhanurmihxlp77nkq76byazcldy2hlmovfu2epvl5ankdibsot4csyd.onion/.

E

Email Permutator - http://metricsparrow.com/toolkit/email-permutator.
ENISA - TIP - Exploring the opportunities and limitations of current Threat Intelligence Platforms. *https://www.enisa.europa.eu/publications/exploring-the-opportunities-and-limitations-of-current-threat-intelligence-platforms/*
Estándar - STIX - Documentación de los patrones. *https://docs.oasis-open.org/cti/stix/v2.0/stix-v2.0-part5-stix-patterning.html*
Éstandar - STIX - Documentación. *https://oasis-open.github.io/cti-documentation/stix/intro*
Estándar - STIX - Documentación de los objetos. https://docs.oasis-open.org/cti/stix/v2.0/stix-v2.0-part2-stix-objects.html
Estándar - STIX - Documentación de los observables. *https://docs.oasis-open.org/cti/stix/v2.0/stix-v2.0-part4-cyber-observable-objects.html*
Estándar - STIX - Ejemplos de casos de uso. *https://oasis-open.github.io/cti-documentation/stix/examples*
Estándar - STIX - Librería en Python. *https://github.com/oasis-open/cti-python-stix2*

F

Feodo Tracker - Blocklist - https://feodotracker.abuse.ch/blocklist/.
Feodo Tracker - Buscador - https://feodotracker.abuse.ch/browse/.

H

Hacker Target - DNS Lookup - https://hackertarget.com/dns-lookup/.

Hacker Target - Reverse IP Lookup - https://hackertarget.com/reverse-ip-lookup/..
Haveibeenpwned - https://haveibeenpwned.com.
HavelbeenPwned - Listado de Data Leaks - https://haveibeenpwned.com/PwnedWebsites.
Herramienta - ANY RUN - Aplicación. *https://app.any.run/*
Herramienta - ANY RUN - Últimas muestras públicas enviadas. *https://app.any.run/submissions*
Herramienta - ANY RUN - Web Oficial. *https://any.run*
Herramienta - APY RUN - Documentación API. *https://any.run/api-documentation/*
Herramienta - Hybrid Analysis - Búsquda por reglas YARA. *https://hybrid-analysis.com/yara-search*
Herramienta - Hybrid Analysis. *https://hybrid-analysis.com/*
Herramienta - Hybrid Analysis - Colección de últimas muestras analizadas. *https://hybrid-analysis.com/file-collections*
Herramienta - Hybrid Analysis - Documentación API. *https://hybrid-analysis.com/docs/api/v2*
Herramienta - Hybrid Analysis - Últimas URL enviadas al Sandbox. *https://hybrid-analysis.com/submissions/sandbox/urls*
Herramienta - Hybrid Analysis - Últimos ficheros enviados al Sandbox. *https://hybrid-analysis.com/submissions/sandbox/files*
Herramienta - Ipinfo. *https://ipinfo.io/*
Herramienta - Maltego. *https://www.paterva.com/*
Herramienta - Robtex. *https://www.robtex.com/*
Herramienta - ThreatMiner. *https://www.threatminer.org*
Herramienta - ThreatMiner - Queries. https://www.threatminer.org/features.php
Herramienta - ThreatMiner- Documentación API. *https://www.threatminer.org/api.php*
Herramienta - VirusShare. *https://virusshare.com/*
Hunter - Sitio web principal - https://hunter.io.

I

IntelligenceX - https://intelx.io/.
IP Blacklist Check - https://www.ipvoid.com/ip-blacklist-check/.

L

La pirámide del dolor de David Bianco. http://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html

M

MITRE - Framework ATT&CK. *https://attack.mitre.org/*
MITRE - Recurso de grupos crimianles. *https://attack.mitre.org/groups/*
MITRE - Web Oficial. *https://www.mitre.org/*

N

Namechk - https://namechk.com.
NIST - Guide to Cyber Threat Information Sharing. *https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-150.pdf*
NIST - Web Oficial. ***https://www.nist.gov/***

P

Pastebin - API - https://pastebin.com/api.
Pastebin - https://pastebin.com/search?q=keyword.
Piramide del dolor - Presentación de David Bianco en RVAsec. *https://rvasec.com/slides/2014/Bianco_Pyramid%20of%20Pain.pdf*

R

Ripe Database Query - https://apps.db.ripe.net/db-web-ui/query.

S

Silver Terrier - Artículo de UNIT42 - SilverTerrier: New COVID-19 Themed Business Email Compromise Schemes - https://unit42.paloaltonetworks.com/silverterrier-covid-19-themed-business-email-compromise/.
Social Bearing - https://socialbearing.com/.
Social Searcher - https://www.social-searcher.com/.

T

ThreatFox IOC de Abuse.ch - https://threatfox.abuse.ch/browse/.
TIP - MISP. *https://www.misp-project.org*
TIP - MISP - Documentación. *https://github.com/MISP/misp-book*
TIP - MISP - Documentación API. *https://buildmedia.readthedocs.org/media/pdf/pymisp/latest/pymisp.pdf*
TIP - MISP - Repositorio API. *https://github.com/MISP/PyMISP*
TIP - MISP - Repositorio de descarga OVA MISP. *https://www.circl.lu/misp-images/_latest/*
TIP - MISP - Repositorio Galaxias MISP. *https://github.com/MISP/misp-galaxy*
TIP - MISP - Repositorio Módulos MISP. *https://github.com/MISP/misp-modules*
TIP - MISP - Repositorio Taxonomías MISP. *https://github.com/MISP/misp-taxonomies*
TIP - MISP - Repositorio Warninglist MISP. *https://github.com/MISP/misp-warninglists*
TIP - MISP - Training MISP. *http://circl.lu/services/misp-training-materials/*
TIP - Threat Exchange - AlienVault OTX. *https://otx.alienvault.com*
TIP - Threat Exchange - AlienVault OTX - Conector Golang SDK. *https://github.com/AlienVault-OTX/OTX-Go-SDK*
TIP - Threat Exchange - AlienVault OTX - Conector Java SDK. https://github.com/AlienVault-OTX/OTX-Java-SDK
TIP - Threat Exchange - AlienVault OTX - Conector Python SDK. *https://github.com/AlienVault-OTX/OTX-Python-SDK*
TIP - Threat Exchange - AlienVault OTX - Documentación API. *https://otx.alienvault.com/api*
TIP - Threat Exchange - AlienVault OTX - Repositorio Bro. *https://github.com/AlienVault-OTX/OTX-Apps-Bro-IDS*
TIP - Threat Exchange - AlienVault OTX - Repositorio Suricata. *https://github.com/AlienVault-OTX/OTX-Suricata*
TIP - Threat Exchange - AlienVault OTX - Repositorio TAXII. *https://github.com/AlienVault-OTX/OTX-Apps-TAXII*

U

UNIT 42 - Investigadores de amenazas de Palo Alto. *https://unit42.paloaltonetworks.com*
UNIT 42 - Playbook de TTPs. *https://pan-unit42.github.io/playbook_viewer/*
UNIT42 - Adversarios y sus motivaciones. *https://unit42.paloaltonetworks.com/adversaries-and-their-motivations-part-1/*

V

VirusTotal - API - https://developers.virustotal.com/reference.
VirusTotal - https://www.virustotal.com/gui/home/search.
VirusTotal - Módulo Graph - https://www.virustotal.com/graph.
VirusTotal - Módulo Hunting - https://www.virustotal.com/gui/hunting.

W

Webmii - https://webmii.com.
Whois - DomainTools - https://whois.domaintools.com/.
Whois - who.is - https://who.is/.

6. VIDEOS SOBRE LA MATERIA

Video 1. Ponencia de David Bianco en RVAsec sobre la pirámide del dolor 138